

**ISIRI- ISO/IEC
15408-3**

1st. Edition

**Identical with
ISO/IEC15408-3:2008**



جمهوری اسلامی ایران
Islamic Republic of Iran

سازمان استاندارد و تحقیقات صنعتی ایران

Institute of Standards and Industrial Research of Iran



استاندارد ایران - ایزو -
آی ای سی ۱۵۴۰۸-۳

چاپ اول

فناوری اطلاعات - فنون امنیتی - معیار
ارزیابی امنیت فناوری اطلاعات -
قسمت ۳: مولفه‌های تضمین امنیتی

**Information technology — Security
techniques — Evaluation criteria for IT
security —Part 3:Security assurance
components**

ICS:35.040

به نام خدا

آشنایی با مؤسسه‌ی استاندارد و تحقیقات صنعتی ایران

مؤسسه‌ی استاندارد و تحقیقات صنعتی ایران به موجب بند یک ماده ۳ قانون اصلاح قوانین و مقررات مؤسسه‌ی استاندارد و تحقیقات صنعتی ایران، مصوب بهمن ماه ۱۳۷۱ تنها مرجع رسمی کشور است که وظیفه تعیین، تدوین و نشر استانداردهای ملی (رسمی) ایران را به عهده دارد.

تدوین استاندارد در حوزه‌های مختلف در کمیسیون‌های فنی مرکب از کارشناسان مؤسسه* صاحب نظران مراکز و مؤسسات علمی، پژوهشی، تولیدی و اقتصادی آگاه و مرتبط انجام می‌شود و کوششی همگام با مصالح ملی و با توجه به شرایط تولیدی، فناوری و تجاری است که از مشارکت آگاهانه و منصفانه‌ی صاحبان حق و نفع، شامل تولیدکنندگان، مصرف‌کنندگان، صادرکنندگان و واردکنندگان، مراکز علمی و تخصصی، نهادها، سازمان‌های دولتی و غیردولتی حاصل می‌شود. پیش‌نویس استانداردهای ملی ایران برای نظرخواهی به مراجع ذی‌نفع و اعضای کمیسیون‌های فنی مربوط ارسال می‌شود و پس از دریافت نظرها و پیشنهادات در کمیته ملی مرتبط با آن رشته طرح و در صورت تصویب به‌عنوان استاندارد ملی (رسمی) ایران چاپ و منتشر می‌شود.

پیش‌نویس استانداردهایی که مؤسسات و سازمان‌های علاقه‌مند و ذی‌صلاح نیز با رعایت ضوابط تعیین شده تهیه می‌کنند در کمیته ملی طرح و بررسی و در صورت تصویب، به‌عنوان استاندارد ملی ایران چاپ و منتشر می‌شود. بدین ترتیب، استانداردهایی ملی تلقی می‌شوند که بر اساس مفاد نوشته شده در استاندارد ملی ایران شماره ۵ تدوین و در کمیته ملی استاندارد مربوط که مؤسسه استاندارد تشکیل می‌دهد به تصویب رسیده باشد.

مؤسسه استاندارد و تحقیقات صنعتی ایران از اعضای اصلی سازمان بین‌المللی استاندارد (ISO)^۱ کمیسیون بین‌المللی الکتروتکنیک (IEC)^۲ و سازمان بین‌المللی اندازه‌شناسی قانونی (OIML)^۳ است و به‌عنوان تنها رابط^۴ کمیسیون کدکس غذایی (CAC)^۵ در کشور فعالیت می‌کند. در تدوین استانداردهای ملی ایران ضمن توجه به شرایط کلی و الزامات خاص کشور، از آخرین پیشرفت‌های علمی، فنی و صنعتی جهان و استانداردهای بین‌المللی بهره‌گیری می‌شود.

مؤسسه‌ی استاندارد و تحقیقات صنعتی ایران می‌تواند با رعایت موازین پیش‌بینی شده در قانون، برای حمایت از مصرف‌کنندگان، حفظ سلامت و ایمنی فردی و عمومی، حصول اطمینان از کیفیت محصولات و ملاحظات زیست محیطی و اقتصادی، اجرای بعضی از استانداردهای ملی ایران را برای محصولات تولیدی داخل کشور و یا اقلام وارداتی، با تصویب شورای عالی استاندارد، اجباری نماید. مؤسسه می‌تواند به‌منظور حفظ بازارهای بین‌المللی برای محصولات کشور، اجرای استانداردهای کالاهای صادراتی و درجه‌بندی آن را اجباری نماید. همچنین برای اطمینان قسمتیدن به استفاده کنندگان از خدمات سازمان‌ها و مؤسسات فعال در زمینه مشاوره، آموزش، بازرسی، ممیزی و صدور گواهی سامانه‌های مدیریت کیفیت و مدیریت زیست محیطی، آزمایشگاه‌ها و مراکز کالیبراسیون (واسنجی) وسایل سنجش، مؤسسه استاندارد این‌گونه سازمان‌ها و مؤسسات را براساس ضوابط نظام تأیید صلاحیت ایران ارزیابی می‌کند و در صورت احراز شرایط لازم، گواهینامه تأیید صلاحیت به آنها اعطا و بر عملکرد آنها نظارت می‌کند. ترویج دستگاه بین‌المللی یکاها، کالیبراسیون (واسنجی درجه‌بندی) وسایل سنجش، تعیین عیار فلزات گران‌بها و انجام تحقیقات کاربردی برای ارتقای سطح استانداردهای ملی ایران از دیگر وظایف این مؤسسه است.

* مؤسسه‌ی استاندارد و تحقیقات صنعتی ایران

1- International Organization for Standardization

2 - International Electrotechnical Commission

3- International Organization for Legal Metrology (Organization International de Metrology Legal)

4 - Contact point

5 - Codex Alimentarius Commission

کمیسیون فنی تدوین استاندارد
« فناوری اطلاعات- فنون امنیتی- معیار ارزشیابی امنیت فناوری اطلاعات- قسمت ۳: مولفه‌های تضمین »

رئیس:

سپیده صفایی
(کارشناس کامپیوتر)

کارشناس نرم‌افزار مرکز تحقیقات صنایع
انفورماتیک

دبیر:

منافی ، علیرضا
(کارشناس ارشد کامپیوتر)

سمت و/ یا نمایندگی

معاون سیستم‌های فناوری اطلاعات مرکز
تحقیقات صنایع انفورماتیک

اعضاء: (اسامی به ترتیب حروف الفبا)

اخوان نیایی، سید انوشیروان
(کارشناس ارشد مدیریت IT)

معاون طرح و برنامه و توسعه شرکت ایزایران

لیلازی، امیررضا
(کارشناس ارشد نرم‌افزار)

مدیر کل نرم‌افزار شرکت داده‌پردازای ایران

مروجی، سجاد
(کارشناس ارشد کامپیوتر)

مدیر توسعه فناوری‌های نوین وزارت بهداشت

فاطمه حسینی
(کارشناس کامپیوتر)

کارشناس نرم‌افزار مرکز تحقیقات صنایع انفورماتیک

فاطمه قربانی
(کارشناس کامپیوتر)

کارشناس نرم‌افزار مرکز تحقیقات صنایع انفورماتیک

عصمت علی محمد ملایری
(کارشناس ارشد نرم‌افزار)

مدرس دانشگاه آزاد ملایر

فهرست مندرجات

صفحه	عنوان
ن	پیش‌گفتار
س	مقدمه
۱	۱ اهداف و دامنه کاربرد
۱	۲ مراجع الزامی
۱	۳ اصطلاحات، تعریف‌ها، نمادها و کوتاه‌نوشت‌ها
۱	۴ نگرش کلی
۱	۴-۱ ساختار این قسمت از استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸
۲	۵ نمونه تضمین استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸
۲	۵-۱ فلسفه استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸
۲	۵-۲- رویکرد تضمین
۳	۵-۲-۱ اهمیت آسیب‌پذیری‌ها
۳	۵-۲-۲ علت آسیب‌پذیری‌ها
۳	۵-۲-۳ تضمین استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸
۴	۵-۲-۴ تضمین به‌واسطه ارزشیابی
۴	۵-۳ مقیاس تضمین ارزشیابی استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸
۴	۶ مؤلفه‌های تضمین امنیت
۴	۶-۱ ساختار مؤلفه‌ها، خانواده‌ها و دسته‌های تضمین امنیت
۵	۶-۱-۱ ساختار دسته تضمین
۵	۶-۱-۲ ساختار خانواده تضمین
۷	۶-۱-۳ ساختار مؤلفه تضمین
۹	۶-۱-۴ عناصر تضمین
۹	۶-۱-۵- رده‌بندی مؤلفه
۱۰	۶-۲ ساختار EAL
۱۰	۶-۲-۱ نام EAL
۱۱	۶-۲-۲ اهداف
۱۱	۶-۲-۳ نکات کاربردی
۱۱	۶-۲-۴ مؤلفه‌های تضمین
۱۱	۶-۲-۵ ارتباط بین تضمین‌ها و سطوح تضمین
۱۱	۶-۳ ساختار CAP

ادامه فهرست مندرجات

صفحه	عنوان
۱۱	۶-۳-۱ نام CAP
۱۱	۶-۳-۲ اهداف
۱۱	۶-۳-۳ نکات کاربردی
۱۲	۶-۳-۴ مؤلفه‌های تضمین
۱۳	۶-۳-۵ ارتباط بین تضمین و سطوح تضمین
۱۵	۷ سطوح تضمین ارزشیابی
۱۵	۷-۱ رئوس کلی سطح تضمین ارزشیابی (EAL)
۱۶	۷-۲ ارزشیابی جزئیات سطح تضمین
۱۶	۷-۳ ارزشیابی سطح ۱ تضمین (EAL) - آزمون کارکرد
۱۶	۷-۳-۱ اهداف
۱۷	۷-۳-۲ مؤلفه‌های تضمین
۱۷	۷-۴ ارزشیابی سطح ۲ تضمین - آزمون ساختاری (آزمون جعبه سفید)
۱۷	۷-۴-۱ اهداف
۱۸	۷-۴-۲ مؤلفه‌های تضمین
۱۹	۷-۵ ارزشیابی تضمین سطح ۳ - بررسی و آزمون متدولوژیک (روش شناسایی)
۱۹	۷-۵-۱ اهداف
۱۹	۷-۵-۲ مؤلفه‌های تضمین
۲۰	۷-۶ ارزشیابی سطح ۴ تضمین - مرور، آزمون و طراحی به لحاظ متدولوژیک
۲۰	۷-۶-۱ اهداف
۲۱	۷-۷ ارزشیابی سطح ۵ تضمین (EAL5) - طراحی و آزمون نیمه‌رسمی
۲۱	۷-۷-۱ اهداف
۲۲	۷-۷-۲ مؤلفه‌های تضمین
۲۳	۷-۸ ارزشیابی سطح ۶ تضمین - آزمون و طراحی تحقیق شده‌ی نیمه‌رسمی
۲۳	۷-۸-۱ اهداف
۲۳	۷-۸-۲ مؤلفه‌های تضمین
۲۵	۷-۹ ارزشیابی تضمین سطح ۷ - آزمون و طراحی تحقیق شده به شکل رسمی
۲۵	۷-۹-۱ اهداف
۲۵	۷-۹-۲ مؤلفه‌های تضمین
۲۷	۸ بسته‌های تضمین ترکیبی
۲۷	۸-۱ رئوس کلی بسته تضمین ترکیبی (CAP)

ادامه فهرست مندرجات

صفحه	عنوان
۲۸	۲-۸ جزییات بسته تضمین ترکیبی
۲۹	۳-۸ سطح A تضمین ترکیب (CAP-A) - ساختار ترکیبی
۲۹	۱-۳-۸ اهداف
۲۹	۲-۳-۸ مؤلفه‌های تضمین
۳۰	۴-۸ سطح B تضمین ترکیبی (CAP-B) - ترکیب شدن با قاعده
۳۰	۱-۴-۸ اهداف
۳۰	۲-۴-۸ مؤلفه‌های تضمین
۳۱	۵-۸ سطح C تضمین ترکیبی (CAP-C)، آزمون، مرور و ترکیب باقاعده
۳۱	۱-۵-۸ اهداف
۳۱	۲-۵-۸ مؤلفه‌های تضمین
۳۲	۹ دسته APE: ارزشیابی پروفایل محافظت
۳۳	۱-۹ مقدمه PP (APE_INT)
۳۳	۱-۱-۹ اهداف
۳۳	۲-۱-۹ مقدمه PP APE_INT.1
۳۳	۲-۹ ادعاهای تطبیق (APE_CCL)
۳۳	۱-۲-۹ اهداف
۳۳	۲-۲-۹ ادعاهای تطبیق APE_CCL.1
۳۵	۳-۹ تعریف مساله امنیت (APE_SPD)
۳۵	۱-۳-۹ اهداف
۳۵	۲-۳-۹ تعریف مسأله امنیت APE_SPD.1
۳۶	۴-۹ اهداف امنیت (APE_OBJ)
۳۶	۱-۴-۹ اهداف
۳۶	۲-۴-۹ سطح‌بندی مؤلفه
۳۶	۳-۴-۹ اهداف امنیتی APE_OBJ.1 برای محیط عملیاتی
۳۶	۴-۴-۹ اهداف امنیتی APE_OBJ.2
۳۷	۵-۹ تعریف مؤلفه‌های توسعه‌یافته (APE_ECD)
۳۷	۱-۵-۹ اهداف
۳۸	۲-۵-۹ تعریف مؤلفه‌های توسعه‌یافته APE_ECD.1
۳۹	۶-۹ الزامات امنیتی (APE_REQ)
۳۹	۱-۶-۹ اهداف
۳۹	۲-۶-۹ سطح‌بندی مؤلفه

صفحه	عنوان
۳۹	۳-۶-۹ الزامات امنیتی وضع شده APE_REQ.1
۴۰	۴-۶-۹ الزامات امنیتی استنتاج شده APE_REQ.2
۴۱	۱۰ دسته ASE: ارزشیابی هدف امنیتی
۴۲	۱۰-۱ مقدمه ST (ASE_INT)
۴۲	۱۰-۱-۱ اهداف
۴۲	۱۰-۱-۲ ST مقدمه ASE_INT
۴۳	۱۰-۲ ادعاهای انطباق (ASE_CCL)
۴۳	۱۰-۲-۱ اهداف
۴۳	۱۰-۲-۲ مدعیات انطباق ASE_CCL.1
۴۴	۱۰-۳ تعریف مسأله امنیت (ASE_SPD)
۴۴	۱۰-۳-۱ اهداف
۴۴	۱۰-۳-۲ تعریف مسأله امنیتی ASE_SPD.1
۴۵	۱۰-۴ اهداف امنیتی (ASE_OBJ)
۴۵	۱۰-۴-۱ اهداف
۴۵	۱۰-۴-۲ سطح بندی مؤلفه
۴۵	۱۰-۴-۳ اهداف امنیتی برای محیط عملیاتی ASE_OBJ.1
۴۶	۱۰-۴-۴ اهداف امنیتی ASE_OBJ.2
۴۷	۱۰-۵ تعریف مؤلفه های توسعه یافته (ASE_ECD)
۴۷	۱۰-۵-۱ اهداف
۴۷	۱۰-۵-۲ تعریف مؤلفه های توسعه یافته ASE_ECD.1
۴۸	۱۰-۶ الزامات امنیتی (ASE_REQ)
۴۸	۱۰-۶-۱ اهداف
۴۸	۱۰-۶-۲ سطح بندی مؤلفه
۴۸	۱۰-۶-۳ الزامات امنیتی وضع شده ASE_REQ.1
۴۹	۱۰-۶-۴ الزامات امنیتی استنتاج شده ASE_REQ.2
۵۰	۱۰-۷ خلاصه ویژگی های TOE (ASE_TSS)
۵۰	۱۰-۷-۱ اهداف
۵۱	۱۰-۷-۲ سطح بندی مؤلفه
۵۱	۱۰-۷-۳ خلاصه ویژگی های TOE ASE_TSS.1
۵۱	۱۰-۷-۴ خلاصه ویژگی های TOE همراه با خلاصه طراحی معماری ASE_TSS.2
۵۲	۱۱- دسته ADV: توسعه

ادامه فهرست مندرجات

صفحه	عنوان
۵۸	۱۱- ۱ معماری امنیت (ADV_ARC)
۵۸	۱۱-۱-۱ اهداف
۵۸	۱۱-۱-۲ رتبه‌بندی مؤلفه‌ها
۵۸	۱۱-۱-۳ نکات کاربردی
۵۹	۱۱-۱-۴ ADV_ARC.1 شرح طراحی امنیت
۶۰	۱۱-۲ (ADV_FSP) مشخصات عملیات
۶۰	۱۱-۲-۱ اهداف
۶۱	۱۱-۲-۲ رتبه‌بندی مؤلفه‌ها
۶۱	۱۱-۲-۳ نکات کاربردی
۶۴	۱۱-۲-۴ ADV_FSP.1 مشخصات کارکردی پایه
۶۴	۱۱-۲-۵ ADV_FSP.2 مشخصات عملیات اجرای - امنیتی
۶۵	۱۱-۲-۶ ADV_FSP.3 مشخصات عملیات با نتیجه‌گیری کامل
۶۶	۱۱-۲-۷ ADV_FSP.4 مشخصات کارکردی کامل
۶۷	۱۱-۲-۸ ADV_FSP.5 مشخصات کارکردی کامل نیمه - رسمی با اطلاعات اضافی اشتباه
۶۹	۱۱-۲-۹ ADV_FSP.6 مشخصات کارکردی کامل رسمی با خصوصیات اضافی رسمی
۷۰	۱۱-۳ نمایندگی پیاده سازی
۷۰	۱۱-۳-۱ اهداف
۷۰	۱۱-۳-۲ رتبه‌بندی مؤلفه‌ها
۷۰	۱۱-۳-۳ نکات کاربردی
۷۲	۱۱-۳-۴ ارائه پیاده‌سازی TSF ADV_IMP.1
۷۳	۱۱-۳-۵ ADV_IMP.2 مسیردهی کامل ارائه پیاده‌سازی TSF
۷۴	۱۱-۴ (ADV_INT) درونیهای TSF
۷۴	۱۱-۴-۱ اهداف
۷۴	۱۱-۴-۲ رتبه‌بندی مؤلفه
۷۴	۱۱-۴-۳ نکات کاربردی
۷۴	۱۱-۴-۴ ADV_INT.1 زیرمجموعه درونی TSF با ساختار خوب
۷۶	۱۱-۴-۵ ADV_INT.2 درونی‌های خوب ساخته شده
۷۷	۱۱-۴-۶ ADV_INT.3 درونی‌های حداقل پیچیده
۷۸	۱۱-۵ مدل خط‌مشیء امنیت (ADV_SPM)
۷۸	۱۱-۵-۱ اهداف
۷۸	۱۱-۵-۲ رتبه‌بندی مؤلفه

ادامه فهرست مندرجات

صفحه	عنوان
۷۸	۱۱-۵-۳ نکات کاربردی
۸۰	۱۱-۵-۴ ADV_SPM.1 مدل خط‌مشیء امنیتی رسمی TOE
۸۱	۱۱-۶-۱۱ طراحی TOE (ADV_TDS)
۸۱	۱۱-۶-۱۱ اهداف
۸۱	۱۱-۶-۲ سطح‌بندی مؤلفه
۸۱	۱۱-۶-۳ نکات کاربردی
۸۳	۱۱-۶-۴ طراحی پایه‌ای ADV_TDS.1
۸۴	۱۱-۶-۵ طراحی معماری ADV_TDS.2
۸۵	۱۱-۶-۶ طراحی پیمانه‌ای پایه ADV_TDS.3
۸۶	۱۱-۶-۷ طراحی پیمانه‌ای نیمه‌رسمی ADV_TDS.4
۸۸	۱۱-۶-۸ طراحی پیمانه‌ای نیمه رسمی کامل ADV_TDS.5
۸۹	۱۱-۶-۹ طراحی پیمانه‌ای نیمه‌رسمی کامل همراه با ارائه طراحی سطح‌بالای رسمی ADV_TDS.6
۹۰	۱۲ دسته AGD: اسناد راهنما
۹۱	۱۲-۱ راهنمای عملی کاربر (AGD_OPE)
۹۱	۱۲-۱-۱ اهداف
۹۱	۱۲-۱-۲ سطح‌بندی مؤلفه
۹۲	۱۲-۱-۳ نکات کاربردی
۹۲	۱۲-۱-۴ راهنمای عملی عملیات AGD_OPE.1
۹۳	۱۲-۲ رویه‌های تدارک (AGD_PRE)
۹۳	۱۲-۲-۱ اهداف
۹۴	۱۲-۲-۲ سطح‌بندی مؤلفه
۹۴	۱۲-۲-۳ نکات کاربردی
۹۴	۱۲-۲-۴ رویه‌های تدارک AGD_PRE.1
۹۵	۱۳ دسته ALC: پشتیبانی چرخه‌حیات
۹۶	۱۳-۱ قابلیت‌های CM ، (ALC_CMC)
۹۶	۱۳-۱-۱ اهداف
۹۷	۱۳-۱-۲ سطح‌بندی مؤلفه‌ها
۹۷	۱۳-۱-۳ نکات کاربردی
۹۷	۱۳-۱-۴ برچسب‌گذاری TOE
۹۷	۱۳-۱-۴-۱ اهداف
۹۷	۱۳-۱-۵ ALC_CMC.2 کاربرد سیستم CM

ادامه فهرست مندرجات

صفحه	عنوان
۹۸	۱۳-۱-۶ ALC_CMC.3 کنترل‌های مجاز
۱۰۰	۱۳-۱-۷ ALC_CMC.4
۱۰۲	۱۳-۱-۸ پشتیبانی پیشرفته
۱۰۴	۱۳-۲ هدف CM (ALC_CMS)
۱۰۴	۱۳-۲-۱ اهداف
۱۰۵	۱۳-۲-۲ رتبه‌بندی مؤلفه‌ها
۱۰۵	۱۳-۲-۳ نکات کاربردی
۱۰۵	۱۳-۲-۴ ALC_CMS.1 TOE شمول CM
۱۰۶	۱۳-۲-۵ ALC_CMS.2 قسمت‌های TOE ، شمول CM
۱۰۷	۱۳-۲-۶ ALC_CMS.3 پوشش CM ارائه پیاده‌سازی
۱۰۷	۱۳-۲-۷ ALC_CMS.4 مشکل ردیابی پوشش CM
۱۰۸	۱۳-۲-۸ پوشش CM ابزار توسعه
۱۱۰	۱۳-۳ تحویل (ALC_DEL)
۱۱۰	۱۳-۳-۱ اهداف
۱۱۰	۱۳-۳-۲ رتبه‌بندی مؤلفه‌ها
۱۱۰	۱۳-۳-۳ نکات کاربردی
۱۱۱	۱۳-۴ امنیت توسعه (ALC_DVS)
۱۱۱	۱۳-۴-۱ اهداف
۱۱۱	۱۳-۴-۲ رتبه‌بندی مؤلفه
۱۱۱	۱۳-۴-۳ نکات کاربردی
۱۱۲	۱۳-۴-۴ ALC_DVS.1 شناسایی سنجه‌های امنیتی
۱۱۲	۱۳-۴-۵ ALC_DVS.2 مقدار کافی از سنجه‌های امنیتی
۱۱۳	۱۳-۵ تصحیح نقص (ALC_FLR)
۱۱۳	۱۳-۵-۱ اهداف
۱۱۳	۱۳-۵-۲ رتبه‌بندی مؤلفه
۱۱۳	۱۳-۵-۳ نکات کاربردی
۱۱۴	۱۳-۵-۴ ALC_FLR.1 بازسازی نقص اولیه
۱۱۴	۱۳-۵-۵ ALC_FLR.2 روش‌های گزارش نقص
۱۱۶	۱۳-۵-۶ ALC_FLR.3 اصلاح نقص اصولی
۱۱۸	۱۳-۶ تعریف چرخه‌حیات
۱۱۸	۱۳-۶-۱ اهداف

ادامه فهرست مندرجات

صفحه	عنوان
۱۱۸	۱۳-۶-۲ رتبه‌بندی مؤلفه‌ها
۱۱۸	۱۳-۶-۳ نکات کاربردی
۱۱۹	۱۳-۶-۴ ALC_LCD.1 تعریف مدل چرخه حیات توسعه‌دهنده
۱۱۹	۱۳-۶-۵ ALC_LCD.2 مدل چرخه حیات قابل سنجش
۱۲۰	۱۳-۷ ابزار و فنون
۱۲۰	۱۳-۷-۱ اهداف
۱۲۰	۱۳-۷-۲ رتبه‌بندی مؤلفه‌ها
۱۲۱	۱۳-۷-۳ نکات کاربردی
۱۲۱	۱۳-۷-۴ ALC_TAT.1 ابزار توسعه خوب شناخته شده
۱۲۲	۱۳-۷-۵ ALC_TAT.2 مطابق با استانداردهای پیاده سازی
۱۲۲	۱۳-۷-۵-۱-۱ ALC_TAT.2.1D
۱۲۲	۱۳-۷-۶ ALC_TAT.3 برآوردن و پیاده‌سازی استانداردها - تمام قسمت‌ها
۱۲۳	۱۴دسته ATE: آزمون‌ها
۱۲۴	۱۴-۱ (ATE_COV) پوشش (ATE_COV)
۱۲۴	۱۴-۱-۱ اهداف
۱۲۴	۱۴-۱-۲ رتبه‌بندی مؤلفه
۱۲۴	۱۴-۱-۳ نکات کاربردی
۱۲۴	۱۴-۱-۴ ATE_COV.1 مدارک پوشش
۱۲۷	۱۴-۲ عمق (ATE_DPT)
۱۲۷	۱۴-۲-۱ اهداف
۱۲۷	۱۴-۲-۲ رتبه‌بندی مؤلفه
۱۲۷	۱۴-۲-۳ نکات کاربردی
۱۲۷	۱۴-۲-۴ ATE_DPT.1 آزمون: طراحی ابتدایی
۱۲۸	۱۴-۲-۵ ATE_DPT.2 آزمون: پیمانه‌های اجرای امنیت
۱۲۹	۱۴-۲-۶ آزمون ATE_DPT.3 طراحی پیمانه
۱۳۰	۱۴-۲-۷ ATE_DPT.4 آزمون: ارائه پیاده‌سازی
۱۳۱	۱۴-۳ آزمون‌های کارکردی (ATE_FUN)
۱۳۱	۱۴-۳-۱ اهداف
۱۳۱	۱۴-۳-۲ رتبه‌بندی مؤلفه‌ها
۱۳۱	۱۴-۳-۳ نکات کاربردی
۱۳۱	۱۴-۳-۴ ATE_FUN.1 آزمون کارکردی

ادامه فهرست مندرجات

صفحه	عنوان
۱۳۲	۱۴-۳-۵ ATE_FUN.2 سفارش آزمون کارکردی
۱۳۳	۱۴-۴ آزمون مستقل (ATE_IND)
۱۳۳	۱۴-۴-۱ اهداف
۱۳۳	۱۴-۴-۲ رتبه‌بندی مؤلفه‌ها
۱۳۳	۱۴-۴-۳ نکات کارردی
۱۳۴	۱۴-۴-۴ آزمون مستقل - مطابقت
۱۳۵	۱۴-۴-۵ ATE_IND.2 14.4.5.1 Objectives آزمون مستقل - نمونه
۱۳۶	۱۴-۴-۶ ATE_IND.3 تست کردن به صورت مستقل - کامل
۱۳۷	۱۵ گروه AVA ارزیابی آسیب‌پذیری
۱۳۷	۱۵-۱ نکات کاربردی
۱۳۸	۱۵-۲ تحلیل آسیب‌پذیری (AVA_VAN)
۱۳۸	۱۵-۲-۱ اهداف
۱۳۸	۱۵-۲-۲ رتبه‌بندی مؤلفه
۱۳۸	۱۵-۲-۳ AVA_VAN.1 بررسی آسیب‌پذیری‌ها
۱۳۹	۱۵-۲-۴ AVA_VAN.2 تحلیل آسیب‌پذیری
۱۳۹	۱۵-۲-۴-۱ عناصر عمل توسعه‌دهنده
۱۴۰	۱۵-۲-۵ AVA_VAN.3 تجزیه و تحلیل آسیب‌پذیری‌های مورد توجه
۱۴۱	۱۵-۲-۶ تحلیل آسیب‌پذیری‌های منظم
۱۴۲	۱۵-۲-۷ AVA_VAN.5 تجزیه و تحلیل آسیب‌پذیری منظم پیشرفته
۱۴۳	۱۶- گروه ACO: ترکیب
۱۴۶	۱۶-۱-۱ اهداف
۱۴۶	۱۶-۱-۲ سطح‌بندی مؤلفه‌ها
۱۴۶	۱۶-۱-۳ منطق ترکیب
۱۴۷	۱۶ مدارک توسعه (ACO_DEV)
۱۴۷	۱۶-۲-۱ اهداف
۱۴۷	۱۶-۲-۲ رتبه‌بندی مؤلفه
۱۴۷	۱۶-۲-۳ نکات کاربرد
۱۴۸	۱۶-۲-۴ ACO_DEV.1 شرح کارکردی
۱۴۸	۱۶-۲-۵ ACO_DEV.2 طراحی سند اولیه
۱۴۹	۱۶-۲-۶ ACO_DEV.3 مدارک تفصیلی طرح
۱۵۰	۱۶-۳ اتکای مؤلفه وابسته (ACO_REL)

ادامه فهرست مندرجات

صفحه	عنوان
۱۵۰	۱۶-۳-۱ اهداف
۱۵۰	۱۶-۳-۲ رتبه‌بندی مؤلفه
۱۵۰	۱۶-۳-۳ نکات کاربردی
۱۵۱	۱۶-۳-۴ اطلاعات تکیه پایه
۱۵۱	۱۶-۳-۵ ACO_REL.2 اطلاعات تکیه
۱۵۲	۱۶-۴ آزمون TOE ترکیبی (ACO_CTT)
۱۵۲	۱۶-۴-۱ اهداف
۱۵۲	۱۶-۴-۲ رتبه‌بندی مؤلفه
۱۵۲	۱۶-۴-۳ نکات کاربردی
۱۵۳	۱۶-۴-۴ ACO_CTT.1 آزمون واسط
۱۵۴	۱۶-۴-۵ ACO_CTT.2 آزمون واسط دقیق
۱۵۵	۱۶-۵ تجزیه و تحلیل آسیب‌پذیری ترکیب (ACO_VUL)
۱۵۵	۱۶-۵-۱ اهداف
۱۵۵	۱۶-۵-۲ رتبه‌بندی مؤلفه
۱۵۵	۱۶-۵-۳ نکات کاربردی
۱۵۶	۱۶-۵-۴ ACO_VUL.1 مرور آسیب‌پذیری ترکیب
۱۵۶	۱۶-۵-۵ ACO_VUL.2 تحلیل آسیب‌پذیری ترکیب
۱۵۷	۱۶-۵-۶ ACO_VUL.3 تجزیه و تحلیل آسیب‌پذیری ترکیب اولیه - پیشرفته
۱۵۹	پیوست الف (اطلاعاتی) توسعه (ADV)
۱۷۸	پیوست ب (اطلاعاتی) ترکیب ACO
۱۸۸	پیوست پ (اطلاعاتی) منابع متقاطع از وابستگی‌های مولفه تضمین
۱۹۴	پیوست ت (اطلاعاتی) منبع متقاطع از PPها و مولفه‌های تضمین
۱۹۵	پیوست ث (اطلاعاتی) منبع متقاطع از مولفه‌های تضمین و EALها
۱۹۶	پیوست ج (اطلاعاتی) منبع متقاطع از CAPها و مولفه‌های تضمین

پیش‌گفتار

استاندارد "فناوری اطلاعات- فنون امنیتی- معیار ارزشیابی امنیت فناوری اطلاعات- قسمت ۳: مولفه‌های تضمین امنیت" که پیش‌نویس آن در کمیسیون‌های مربوط توسط سازمان استاندارد و تحقیقات صنعتی ایران تهیه و تدوین شده و در یکصد و سی و ششمین اجلاس کمیته ملی استاندارد رایانه و فرآوری داده‌ها مورخ ۹۰/۱۲/۱۸ مورد تصویب قرار گرفته است، اینک به استناد بند یک ماده ۳ قانون اصلاح قوانین و مقررات مؤسسه‌ی استاندارد و تحقیقات صنعتی ایران، مصوب بهمن ماه ۱۳۷۱، به‌عنوان استاندارد ملی ایران منتشر می‌شود. برای حفظ همگامی و هماهنگی با تحولات و پیشرفت‌های ملی و جهانی در زمینه صنایع، علوم و خدمات، استانداردهای ملی ایران در مواقع لزوم تجدید نظر خواهد شد و هر پیشنهادی که برای اصلاح و تکمیل این استانداردها ارائه شود، هنگام تجدید نظر در کمیسیون فنی مربوط مورد توجه قرار خواهد گرفت. بنابراین، باید همواره از آخرین تجدیدنظر استانداردهای ملی استفاده کرد.

منبع و مآخذی که برای تهیه این استاندارد مورد استفاده قرار گرفته به شرح زیر است:

ISO/IEC15408-3:2008– Information technology — Security techniques — Evaluation criteria for IT security —Part 3: Security assurance components

این استاندارد یکی از مجموعه استانداردهای ملی ایران به شماره "ایران- ایزو-آی ای سی ۱۵۴۰۸" است. مؤلفه‌های تضمین امنیت، تعریف شده در این قسمت از این مجموعه استاندارد ملی، مبنای الزامات تضمین امنیت بیان شده در پروفایل محافظت (pp)^۱ یا هدف امنیت (ST)^۲ هستند.

این الزامات یک روش استاندارد صریح و روشن از الزامات تضمین را برای هدف‌های ارزیابی^۳ بنا می‌نهد، این قسمت از این مجموعه استاندارد ملی، یک مجموعه از مؤلفه‌های تضمین، خانواده‌ها^۴ و دسته‌ها^۵ را فهرست می‌کند. این قسمت از این مجموعه استاندارد ملی، همچنین معیار ارزشیابی برای PP ها و ST ها را تعریف و سطوح تضمین ارزشیابی را معرفی می‌کند که این سطوح، مقیاس^۶ پیشین استاندارد ملی ایران- ایزو-آی ای سی ۱۵۴۰۸ را برای تضمین درجه‌بندی TOE ها، تعریف می‌کنند، که سطوح ارزشیابی تضمین (EAL)^۷ نامیده می‌شود.

مخاطبان این قسمت از این مجموعه استاندارد ملی شامل مصرف‌کنندگان، توسعه‌دهندگان و ارزیابان محصولات فناوری اطلاعات امن می‌شوند. این استاندارد، اطلاعات افزوده در مورد مخاطبان هدف، در این استاندارد و همچنین در مورد استفاده از استاندارد ملی ایران- ایزو-آی ای سی ۱۵۴۰۸ توسط گروه‌هایی که شامل مخاطبان هدف می‌شوند، را فراهم می‌آورد. این گروه‌ها مجاز هستند این قسمت از این مجموعه استانداردهای ملی را به شکل پیش رو مورد استفاده قرار دهند:

الف) مصرف‌کنندگانی که، این قسمت از این مجموعه استانداردهای ملی را، در زمان انتخاب مؤلفه‌ها جهت بیان الزامات تضمینی، برای برآورده کردن اهداف امنیتی بیان شده در PP یا ST، به منظور تصمیم‌گیری برای این که کدام یک از سطوح تضمین امنیت از TOE مورد نیاز است، مورد استفاده قرار می‌دهند.

ب) توسعه‌دهندگانی که، به الزامات امنیتی حقیقی یا مشاهده شده‌ی مصرف‌کننده، در ایجاد TOE پاسخ می‌دهند، و یا در هنگام بیان بیانیه‌های الزامات تضمین و تامین رویکردهای تضمین TOE به این قسمت از این مجموعه استاندارد ملی مراجعه می‌کنند.

پ) ارزیاب‌هایی که از الزامات تضمینی تعریف شده در این قسمت از این مجموعه استانداردهای ملی به عنوان بیانیه معیار ارزشیابی در هنگام تعیین تضمین TOE ها و ارزشیابی PP و ST، استفاده می‌کنند.

-
- 1- Protection profile
 - 2 -Security target
 - 3- Target of evaluation
 - 4 -family
 - 5 -class
 - 6- scale
 - 7- Evaluation assurance level

فناوری اطلاعات - فنون امنیتی - معیار ارزیابی امنیت فناوری اطلاعات - قسمت ۳: مؤلفه‌های تضمین امنیتی

۱ اهداف و دامنه کاربرد

هدف از تدوین این استاندارد، تعیین الزامات تضمین استاندارد ملی ایران-ایزو-آی‌ای‌سی ۱۵۴۰۸، است. این الزامات شامل سطوح تضمین ارزشیابی است که مقیاسی را برای اندازه‌گیری تضمین TOE‌های مؤلفه بیان می‌کند، بسته‌های تضمین ترکیبی (CAP۱) است که مقیاسی را برای اندازه‌گیری تضمین TOE‌های ترکیبی معرفی می‌کند، همچنین شامل مؤلفه‌های تضمین تقسیم‌بندی شده از سطوح تضمین و بسته‌هایی که ترکیب می‌شوند و معیار ارزشیابی PP و ST است.

۲ مراجع الزامی

مدارک الزامی زیر حاوی مقرراتی است که در متن این استاندارد ملی ایران به آنها ارجاع داده شده است. بدین ترتیب آن مقررات جزئی از این استاندارد ملی ایران محسوب می‌شود. در صورتی که به مدرکی با ذکر تاریخ انتشار ارجاع داده شده باشد، اصلاحیه‌ها و تجدید نظرهای بعدی آن مورد نظر این استاندارد ملی نیست. در مورد مدارکی که بدون ذکر تاریخ و انتشار به آنها ارجاع داده شده است، همواره آخرین تجدید نظر و اصلاحیه‌های بعدی آنها مورد نظر است. استفاده از مراجع زیر برای این استاندارد الزامی است:

- ۱-۲ استاندارد ملی ایران شماره ایران-ایزو-آی‌ای‌سی ۱-۱۵۴۰۸: سال ۸۸، فن‌آوری اطلاعات- تکنیک‌های امنیتی- معیارهای ارزیابی امنیت IT- قسمت ۱-مقدمه و مدل عمومی
- ۲-۲ استاندارد ملی ایران شماره ایران-ایزو-آی‌ای‌سی ۲-۱۵۴۰۸: سال ۸۸، فن‌آوری اطلاعات- تکنیک‌های امنیتی- معیارهای ارزیابی امنیت فناوری اطلاعات- قسمت ۲- مؤلفه‌های عملیاتی امنیت

۳ اصطلاحات، تعاریف‌ها، نمادها و کوتاه‌نوشت‌ها

در این استاندارد، اصطلاحات و تعاریف، نمادها و کوتاه‌نوشت‌های به کار رفته در استاندارد ملی ایران-ایزو-آی‌ای‌سی ۱-۱۵۴۰۸، به کار می‌رود.

۴ نگرش کلی

- ۱-۴ ساختار این قسمت از استاندارد ملی ایران-ایزو-آی‌ای‌سی ۱۵۴۰۸
- بند ۵ نمونه^۲ استفاده شده در الزامات تضمین امنیت را برای این قسمت از این مجموعه استاندارد ملی، شرح می‌دهد.

1- composed assurance packages

2- paradigm

بند ۶ شرح ساختار دسته‌های تضمین، خانواده‌ها، مؤلفه‌ها، سطوح تضمین ارزیابی همراه با رابطه‌هایشان، و ساختار بسته‌های تضمین ترکیبی می‌باشد.

این بند دسته‌ها و خانواده‌های تضمین موجود در بندهای ۹ تا ۱۶ را نیز شرح می‌دهد.

بند ۷ جزئیات تعریف‌های EALها را بیان می‌کند.

بند ۸ جزئیات تعریف‌های CAPها را بیان می‌کند.

بندهای ۹ تا ۱۶ جزئیات تعریف‌های دسته‌های تضمین این قسمت از این مجموعه استاندارد ملی را بیان می‌کنند.

پیوست الف مثال‌ها و توضیحات بیشتری را در مورد مفهوم دسته توسعه بیان می‌کند.

پیوست ب توضیحی را در مورد مفاهیمی که در وادی ارزشیابی‌های TOE ترکیبی و دسته ترکیب ارائه می‌دهد.

پیوست پ خلاصه‌ای از وابستگی‌های بین مؤلفه‌های تضمین را بیان می‌کند.

۵ نمونه تضمین استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸

هدف این بند مستندسازی حکمتی است که رویکرد استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ را به‌منظور تضمین، پی‌ریزی می‌کند. فهم این بند به خواننده اجازه خواهد داد که منطقی که در ورای این قسمت از الزامات تضمین استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ قرار گرفته است را بفهمد.

۵-۱ فلسفه استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸

فلسفه استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ این است که تهدیدات امنیتی و تعهدات خط‌مشی امنیت سازمانی باید به‌شکل واضحی فصل‌بندی شوند و سنجش امنیت مطرح شده برای هدف مورد درخواست، به طور قابل اثباتی کافی باشد.

سنجش‌هایی باید اتخاذ شوند که احتمال آسیب‌پذیری، توانایی عمل‌کرد آسیب‌پذیری (به‌عنوان مثال: بهره‌کشی به‌شکل عمدی یا آسیب‌رسانی به‌شکل غیرعمدی) و وسعت خرابی‌ای که می‌تواند از عمل‌کرد آسیب‌پذیری رخ دهد را کاهش دهد. به‌علاوه، سنجش‌هایی باید اتخاذ شوند که تعیین متعاقب آسیب‌پذیری‌ها، حذف، کاهش و یا خطراتی که یک آسیب‌پذیری، به کار برده شده و یا به راه انداخته است را، تسهیل می‌کنند.

۵-۲ رویکرد تضمین

فلسفه استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸، فراهم کردن تضمین برپایه ارزشیابی (تحقیق فعال) محصول فناوری اطلاعات یا سامانه‌ی است که مورد اعتماد واقع می‌شود. ارزشیابی، ابزار سنتی فراهم کردن تضمین می‌باشد و مبنایی برای اسناد معیار ارزشیابی پیشین است. در ردیف رویکردهای موجود، استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸، فلسفه مشابه را می‌پذیرد. این استاندارد سنجش اعتبار مستند سازی و سنجش اعتبار محصول فناوری اطلاعات یا سامانه ایجاد شده توسط ارزیابان ماهر را با افزایش اهمیت بر روی دامنه و هدف، عمق و دقت زیاد پیشنهاد می‌دهد.

استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸، نه تنها خدمات‌های مرتبط ابزارهای تضمین را شامل نشد، بلکه پیشنهادی نیز بر آنها ندارد. سایر تحقیقات با توجه به روش‌های متناوب تضمین سود، ادامه می‌یابد. از آنجایی که

رویکردهای مقتضی متناوب، از این فعالیت‌ها پدیدار می‌شوند، به‌عنوان قسمتی از استاندارد ملی ایران-ایزو-آی‌ای‌سی ۱۵۴۰۸ مطرح خواهند شد که برای امکان پذیر شدن معرفی آینده‌شان، بسیار سازمان یافته هستند.

۵-۲-۱ اهمیت آسیب‌پذیری‌ها

فرض بر این است که عامل‌ها تهدید کننده وجود دارند که فعالانه به‌دنبال سوءاستفاده از فرصت‌هایی هستند که خط‌مشی‌های امنیتی را هم در جهت منافع خلاف مقررات و هم فعالیت‌های ناشی از نیت خوب اما در عین حال ناامن، نقض کنند.

همچنین ممکن است عامل‌های تهدیدکننده به‌شکل تصادفی آسیب‌پذیری‌های امنیتی را به راه اندازند و باعث آسیب به سازمان شوند. به‌دلیل نیاز به پردازش اطلاعات حساس و کمبود دسترسی به محصولات یا سامانه‌های قابل اعتماد، به‌شکل کافی، خطر مهمی ناشی از شکست فناوری اطلاعات وجود دارد. بنابراین، احتمالاً، رخنه‌های امنیتی فناوری اطلاعات، مرتبط با کسب و کار به وجود می‌آیند.

شکاف‌های امنیتی فناوری اطلاعات، ناشی از بکار بردن عمدی یا به راه انداختن غیر عمدی آسیب‌پذیری‌ها در کاربرد فناوری اطلاعات مرتبط با کسب و کار به وجود می‌آیند.

گام‌هایی باید به سمت پیش‌گیری کردن از آسیب‌پذیری‌های ناشی از محصولات یا سامانه‌های فناوری اطلاعات برداشته شوند. به‌منظور گسترش عملی پیش‌گیری از آسیب‌پذیری‌ها، آسیب‌پذیری‌ها باید:

الف) حذف شده: یعنی گام‌های فعال باید جهت ظاهر ساختن، برداشتن یا خنثی‌سازی همه‌ی آسیب‌پذیری‌های عملی، برداشته شود.

ب) کمینه کردن: یعنی گام‌های فعال باید برای کاهش هر سطح باقیمانده قابل قبول، پتانسیل اثر شدید هر عملکرد آسیب‌پذیری برداشته شود.

پ) پایش‌شده: گام‌های فعال برای اطمینان این‌که هر تلاشی برای عملکرد یک آسیب‌پذیری باقی مانده، شناسایی خواهد شد بنابراین گام‌هایی برای محدود کردن زیان می‌تواند برداشته شود.

۵-۲-۲ علت آسیب‌پذیری‌ها

آسیب‌پذیری‌ها می‌توانند ناشی از کوتاهی در:

الف) الزامات- یک محصول فناوری اطلاعات ممکن است همه کارکردها و ویژگی‌های ملزم خود را و آسیب‌پذیری‌هایی که هنوز وجود دارد را داشته باشد که آن را از نظر ایمنی نامناسب و غیر موثر سازد.

ب) توسعه - یک محصول فناوری اطلاعات که ویژگی‌هایش را تامین نمی‌کند و/ یا آسیب‌پذیری‌ها در نتیجه توسعه استانداردهای ضعیف یا انتخاب طراحی نادرست گزینه‌ها معرفی شده‌اند.

پ) عملیات- یک محصول فناوری اطلاعات ممکن است به‌شکل درستی با ویژگی‌های صحیح ساختار یافته است اما آسیب‌پذیری‌های ناشی از عدم کنترل‌های کافی بر روی عملیات، معرفی شده‌اند.

۵-۲-۳ تضمین استاندارد ملی ایران-ایزو-آی‌ای‌سی ۱۵۴۰۸

تضمین، زمینه‌ای برای اعتماد است از این نظر که یک محصول فناوری اطلاعات به اهداف امنیتی‌اش می‌رسد.

تضمین می‌تواند از مرجع تا منبع‌هایی نظیر ادعاهای اثبات نشده، تجربه مرتبط پیشینی، یا تجربه‌ی ویژه، طراحی شود. هرچند که این استاندارد، تضمین را از طریق تحقیق فعال، فراهم می‌کند. تحقیق فعال ارزشیابی یک محصول فناوری اطلاعات است به‌ترتیبی که ویژگی‌های امنیتی آن تعیین شود.

۵-۲-۴ تضمین به واسطه ارزشیابی

تعریف ارزشیابی: ارزشیابی، مفهوم سنتی تضمین سود است و آن مبنای رویکرد استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ است. فنون ارزشیابی می‌توانند شامل موارد زیر باشند اما محدود به آن‌ها نمی‌شوند:

- ۱- تحلیل و بررسی فرآیند (ها) و روال (ها)
- ۲- بررسی اینکه فرآیند(ها) و روال(ها) به‌کار برده می‌شوند.
- ۳- تحلیل مطابقت بین بازنمایی‌های طراحی TOE
- ۴- تحلیل باز نمایی طراحی TOE در برابر الزامات.
- ۵- تأیید برهان‌ها.
- ۶- تحلیل اسناد راهنما.
- ۷- تحلیل آزمون‌های کارکردی توسعه داده شده و نتایج به‌دست آمده.
- ۸- آزمایش کارکردی مستقل.
- ۹- تحلیل در مورد آسیب‌پذیری‌ها (شامل فرضیه‌های نقص و کاستی^۱).
- ۱۰- آزمایش نفوذ.

۵-۳ مقیاس تضمین ارزشیابی استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸

فلسفه استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸، اثبات می‌کند که نتایج تضمین بهتر، از به‌کارگیری تلاش برای ارزشیابی بیشتر ناشی می‌شود و این که هدف، به کار بردن حداقل تلاش مورد نیاز برای فراهم آوردن سطح لازم تضمین اجرا است. سطح افزایش تلاش بر پایه این موارد است:

الف) دامنه- یعنی تلاش، مهمتر است زیرا سهم بیشتری در مورد سامانه یا محصول فناوری اطلاعات را شامل می‌شود.

- ب) عمق- یعنی تلاش، مهمتر است زیرا برای سطح بهتری از طراحی و جزئیات پیاده‌سازی استفاده می‌شود.
- پ) دقت زیاد- یعنی تلاش، مهمتر است زیرا به‌شیوه رسمی‌تر و ساخت‌یافته‌تری به‌کار برده می‌شود.

۶ مؤلفه‌های تضمین امنیت

۶-۱ ساختار مؤلفه‌ها، خانواده‌ها و دسته‌های تضمین امنیت

بندهای فرعی زیر ساختار به‌کار رفته در نمایش مؤلفه‌ها، خانواده‌ها و دسته‌های تضمین را شرح می‌دهند. شکل ۱، SARهای تعریف شده در این قسمت از استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ را متصور می‌کند. باید توجه شود که به خلاصه‌ترین مجموعه SARها به‌عنوان یک دسته، اشاره می‌شود. هر دسته شامل

خانواده‌های تضمین است که این خانواده‌ها شامل مؤلفه‌های تضمین می‌شوند، و مؤلفه‌ها به نوبه خود شامل عناصر تضمین می‌شوند.

دسته‌ها و خانواده‌ها، یک رده‌بندی را به منظور دسته‌بندی SARها به کار می‌برند، در حالی که مؤلفه‌ها برای مشخص کردن SARها در PP (پرو فایل محافظت شده) و ST (هدف امنیتی) به کار می‌روند.

۱-۱-۶ ساختار دسته تضمین

شکل ۱ ساختار دسته تضمین را نشان می‌دهد.

۱-۱-۱-۶ نام دسته

هر دسته تضمین با یک نام منحصر به فرد مشخص می‌شود. نام، نشان‌دهنده موضوعاتی است که به وسیله دسته تضمین پوشش داده می‌شوند.

یک شکل اختصاری منحصر به فرد از نام دسته تضمین نیز ایجاد می‌شود. این نام، مفهوم اولیه برای ارجاع به دسته تضمین است. قرارداد پذیرفته شده، یک "A" همراه با دو حرف مرتبط به نام دسته است.

۱-۱-۲ معرفی دسته

هر دسته تضمین یک بند فرعی معرفی دارد که ترکیب دسته و مندرجات متن درون دسته را شرح می‌دهد.

۱-۱-۳ خانواده‌های تضمین

هر دسته تضمین، حداقل شامل یک خانواده تضمین می‌شود. ساختار خانواده‌های تضمین در بند فرعی زیر شرح داده می‌شود.

۱-۱-۴ ساختار خانواده تضمین

شکل ۱ ساختار خانواده تضمین را نشان می‌دهد.

۱-۲-۱ نام خانواده

هر خانواده تضمین با یک نام منحصر به فرد مشخص می‌شود. نام، اطلاعات مشروحی را در مورد موضوعاتی که به وسیله خانواده تضمین در بر گرفته می‌شود را فراهم می‌آورد. هر خانواده تضمین درون دسته تضمین جای می‌گیرد که شامل دیگر خانواده‌های با مفاد یکسان می‌باشد. یک فرم کوچک یکتا از نام خانواده تضمین نیز فراهم می‌شود. این مفهوم اولیه است که برای ارجاع به خانواده تضمین استفاده می‌شود. قراردادی پذیرفته شده است که، فرم کوچک نام دسته، به وسیله یک خط زیر و سپس سه حرف مرتبط با نام خانواده ادامه می‌یابد.

۱-۲-۲ اهداف

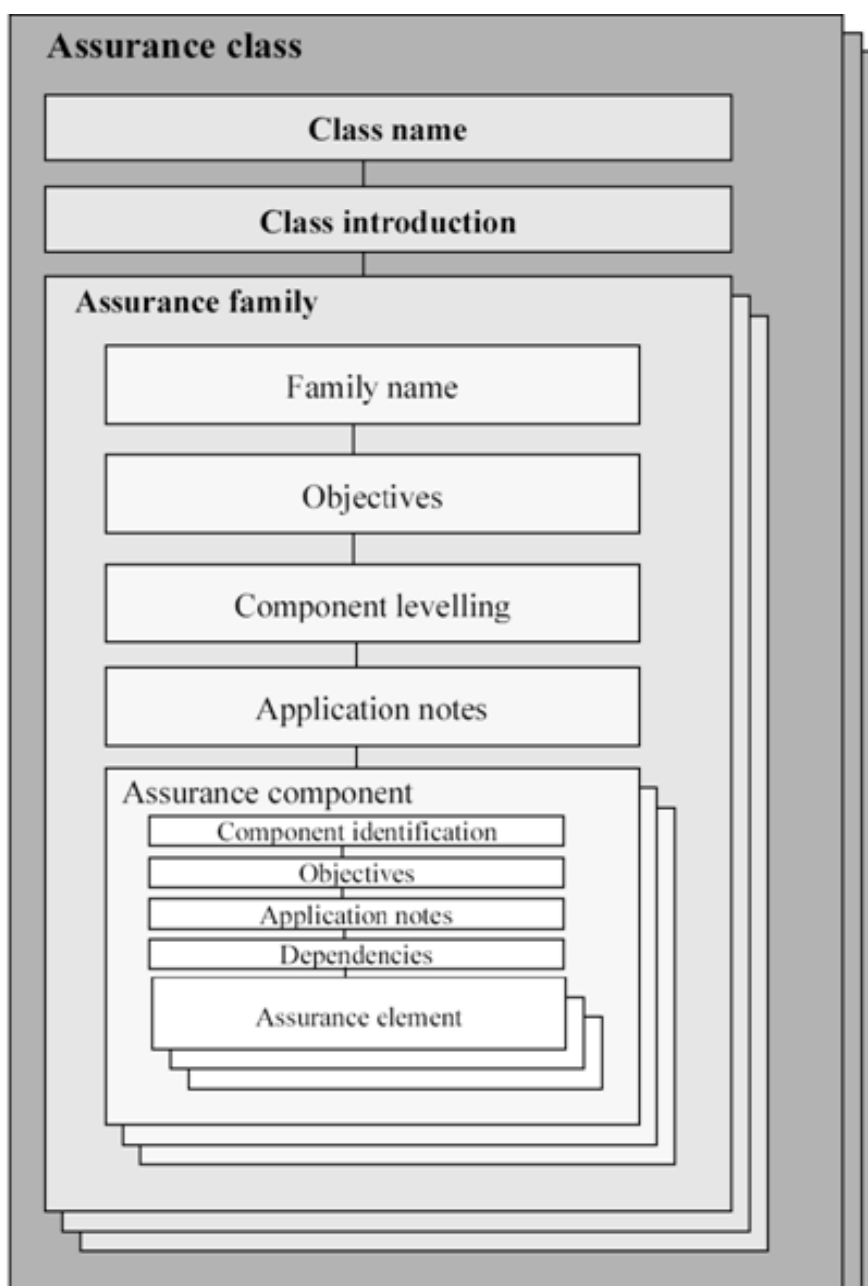
بندهای فرعی خانواده تضمین مفاد خانواده تضمین، را معرفی می‌کنند.

این بندهای فرعی، اهداف را شرح می‌دهند، به ویژه اهدافی را که با نمونه‌ی تضمین استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ مرتبط هستند، که خانواده برای نشان دادن آنها در نظر گرفته می‌شود. شرح خانواده تضمین در یک سطح عمومی حفظ می‌شود. هر گونه جزئیات مورد نیاز برای اهداف در مؤلفه تضمین خاص ضمیمه می‌شوند.

۱-۲-۳ هم سطح کردن مؤلفه

هر خانواده تضمین شامل یک یا بیشتر مؤلفه تضمین می‌شود. این بندهای فرعی خانواده تضمین، مولفه‌های در دسترس را شرح می‌دهند و تمایز بین آن‌ها را بیان می‌کنند. هدف اصلی آن، تفاوت قائل شدن بین مولفه‌های تضمین است، که در ابتدا تعیین شده است که خانواده تضمین یک قسمت لازم یا مفید SARها برای PP/ST است.

خانواده‌های تضمین شامل بیش از یک مولفه هم‌سطح شده هستند و دلیل اینکه چطور مولفه‌ها هم سطح شوند ارائه شده است. این دلیل در اصطلاحات هدف و دامنه، عمق، و/ یا دقت زیاد است.



شکل ۱- سلسله مراتب دسته/خانواده/مولفه/عنصر تضمین

۴-۲-۱-۶ نکته‌های کاربردی

بندهای فرعی نکات کاربردی خانواده تضمین، شامل اطلاعات افزوده برای خانواده تضمین می‌باشد. این اطلاعات باید مورد توجه ویژه، برای استفاده خانواده تضمین باشند (به عنوان مثال، نویسندگان PP و ST، طراحان TOEها(اهداف ارزشیابی) ، ارزیابان). این معرفی، غیررسمی است و به‌عنوان مثال، اخطار در مورد محدودیت‌های مورد استفاده نواحی که توجه خاص نیاز دارند را در بر می‌گیرد.

۵-۲-۱-۶ مؤلفه‌های تضمین

هر خانواده تضمین حداقل یک مؤلفه تضمین را دارد. ساختار مؤلفه‌های تضمین در بندهای فرعی زیر فراهم شده است.

۳-۱-۶ ساختار مؤلفه تضمین

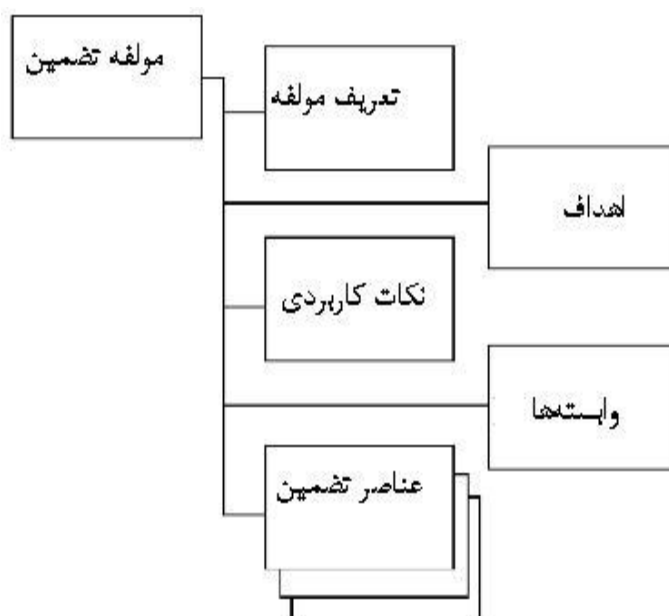
شکل ۲ ساختار مؤلفه تضمین را نشان می‌دهد.

ارتباط بین مؤلفه‌های درون یک خانواده با استفاده از حروف پررنگ مشخص شده است. آن قسمت‌های الزامات که جدید هستند، ارتقاء یافته یا اصلاح شده بوده و فراتر از الزامات مؤلفه قبلی در یک سلسله مراتب هستند، پررنگ شده‌اند.

۱-۳-۱-۶ شناسایی مؤلفه

بندهای فرعی شناسایی مؤلفه شرحی از اطلاعات لازم را برای شناسایی، گروه‌بندی کردن، ثبت نمودن و مرجع یک مؤلفه، فراهم می‌آورد.

به هر مؤلفه تضمین توسط یک نام منحصر به فرد اختصاص داده می‌شود. نام، شرحی از اطلاعات را در مورد موضوعاتی که توسط مؤلفه تضمین پوشش داده می‌شود را، فراهم می‌آورد. هر مؤلفه تضمین درون خانواده تضمینی که هدف امنیتی‌اش را به اشتراک می‌گذارد، قرار می‌گیرد.



شکل ۲- ساختار مؤلفه تضمین

همچنین یک فرم کوتاه منحصر به فردی از نام مؤلفه تضمین فراهم می‌شود. این مفهوم اصلی است که برای مراجعه به مؤلفه تضمین استفاده می‌شود. قرارداد شده است که فرم کوتاه نام خانواده، به همراه یک مکث و سپس یک کاراکتر عددی استفاده شود. کاراکترهای عددی برای مؤلفه‌ها درون هر خانواده به طور ترتیبی اختصاص داده شده‌اند و از ۱ شروع می‌شوند.

۶-۱-۳-۲ اهداف

بند فرعی اهداف مؤلفه تضمین، اگر ارائه شود، شامل اهداف ویژه برای مؤلفه تضمین خاص می‌شود. برای آن مؤلفه‌های تضمینی که این بند فرعی را دارند مفاد ویژه مؤلفه و توضیح جزئیات بیشتر اهداف را ارائه می‌کند.

۶-۱-۳-۳ نکات کاربردی

بند فرعی نکات کاربردی یک مؤلفه تضمین، اگر ارائه شود، شامل اطلاعات افزوده جهت تسهیل استفاده از مؤلفه است.

۶-۱-۳-۴ وابستگی‌ها

وابستگی بین مؤلفه‌های تضمین، زمانی ایجاد می‌شود که یک مؤلفه به خودی خود کافی نبوده و به حضور مؤلفه دیگری وابسته باشد.

هر مؤلفه تضمین یک فهرست کامل از وابستگی‌ها به دیگر مؤلفه‌های تضمین را فراهم می‌کند. برخی مؤلفه‌ها برای اینکه نشان دهند که هیچ وابستگی شناسایی نشده است ممکن است "هیچ وابستگی" را در فهرست قرار دهند. مؤلفه‌های وابسته ممکن است وابستگی‌هایی به دیگر مؤلفه‌ها داشته باشند.

فهرست وابستگی، کمترین مجموعه مؤلفه‌های تضمین را که وابسته می‌شوند شناسایی می‌کند. مؤلفه‌هایی که به شکل سلسله مراتبی نسبت به یک مؤلفه، در فهرست وابستگی هستند، همچنین ممکن است برای کفایت وابستگی استفاده شوند.

در موقعیت‌های خاص، وابستگی‌های نشان داده شده ممکن است قابل به کارگیری نباشند. نویسنده PP/ST، به وسیله فراهم کردن یک دلیل برای اینکه چرا یک وابستگی قابل به کارگیری نیست، ممکن است عدم کفایت آن وابستگی را انتخاب کند.

۶-۱-۳-۵ عناصر تضمین

یک مجموعه از عناصر تضمین برای هر مؤلفه تضمین فراهم می‌شود. یک عنصر تضمین، یک الزام امنیتی است که، اگر بیشتر تقسیم شود، بازدهی یک نتیجه ارزشیابی معنا دار را نخواهد داشت. عنصر تضمین، کوچکترین الزام امنیتی شناخته شده در استاندارد ملی ایران-ایزو-آی‌ای‌سی ۱۵۴۰۸ است.

هر عنصر تضمین، متعلق به یکی از سه مجموعه عناصر تضمین است.

الف) عناصر عمل توسعه دهنده: فعالیت‌هایی که بایستی به وسیله توسعه دهنده انجام شوند. این مجموعه از اعمال، با مواد مدرکی^۱ اشاره شده در مجموعه عناصر پیش رو، بیشتر واجد شرایط می‌شوند. الزامات برای اعمال توسعه دهنده، به وسیله پیوست حرف "D" به شماره عنصر شناسایی می‌شوند.

1 - evidential material

ب) مندرجات و معرفی عناصر مدرک: مدرک مورد نیاز و این که، چه مدرکی بایستی نشان داده شود، و چه اطلاعاتی بایستی رسانده شود و الزامات برای مندرجات و معرفی مدرک به وسیله پیوست حرف "C" به شماره عنصر شناسایی می‌شوند.

پ) عناصر عمل ارزیاب: فعالیت‌هایی هستند که بایستی به وسیله ارزیاب انجام شوند. این مجموعه از فعالیت‌ها به طور واضح شامل صورت‌بندی هستند که الزامات تعیین شده در مندرجات و معرفی عناصر مدرک با آن مواجه شده‌اند. همچنین شامل اعمال واضح و تحلیل‌هایی هستند که علاوه بر آنهایی که تا کنون توسط ارزیاب آماده شده‌اند باید انجام شوند. همچنین فعالیت‌های تلویحی ارزیاب به مثابه نتیجه عناصر عمل ارزیاب که در مندرجات و معرفی الزامات مدرک وجود ندارد، هستند. الزامات برای اعمال ارزیاب به وسیله پیوست حرف "E" به شماره عنصر مشخص شناسایی می‌شوند.

اعمال ارزیاب و مندرجات و معرفی مدرک الزامات تضمینی را تعریف می‌کند که مسئولیت ارزیاب را در تضمین اثبات TOE نشان می‌دهند. با دیدن این الزامات ارزیاب می‌تواند اعتمادی را که TOE از نظر کارکردی و الزامات تضمین PP و ST برآورده می‌کند، افزایش دهد.

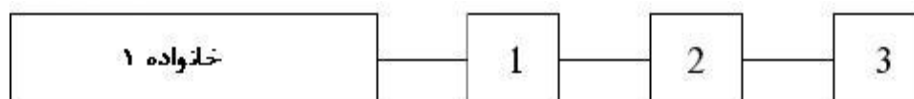
اعمال ارزیاب مسئولیت‌های ارزیاب را در دو جنبه ارزشیابی تعریف می‌کند. اولین جنبه اعتبار PP/ST در تطابق با دسته‌های APE و ASE در طبقه‌های APE است: ارزشیابی پروفایل محافظت و ASE ارزشیابی هدف امنیت. جنبه دوم تایید تطبیق TOE با SFRها و SARها است. با ثابت کردن اینکه PP/ST معتبر است و اینکه الزامات به وسیله TOE دیده می‌شوند، ارزیاب می‌تواند مبنایی را برای اعتماد فراهم کند که TOE در محیط عملیاتی خودش بتواند مسائل امنیتی تعریف شده را حل کند. عناصر عمل توسعه دهنده، مندرجات و معرفی عناصر مدرک، وضوح عناصر عمل عناصر ارزیاب، تلاش ارزیاب را مشخص می‌کند که بایستی در تأیید ادعاهای امنیتی ساخته شده در ST ی TOE صرف شود.

۴-۱-۶ عناصر تضمین

هر عنصر یک الزام را نشان می‌دهد. این توضیح الزامات به شکل واضح، مختصر و بدون ابهام در نظر گرفته می‌شوند. بنابراین، هیچ جمله ترکیبی وجود ندارد: هر الزام مجزا به شکل یک عنصر منفرد، توضیح بیان می‌شود.

۵-۱-۶ رده‌بندی مؤلفه

این قسمت از این مجموعه استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸، شامل دسته‌های خانواده‌ها و مؤلفه‌هایی می‌شود که بر اساس تضمین مرتبط، گروه‌بندی می‌شوند. در آغاز هر دسته یک دیاگرام وجود دارد که خانواده‌ها را در دسته و مؤلفه‌ها را در هر خانواده نشان می‌دهد.



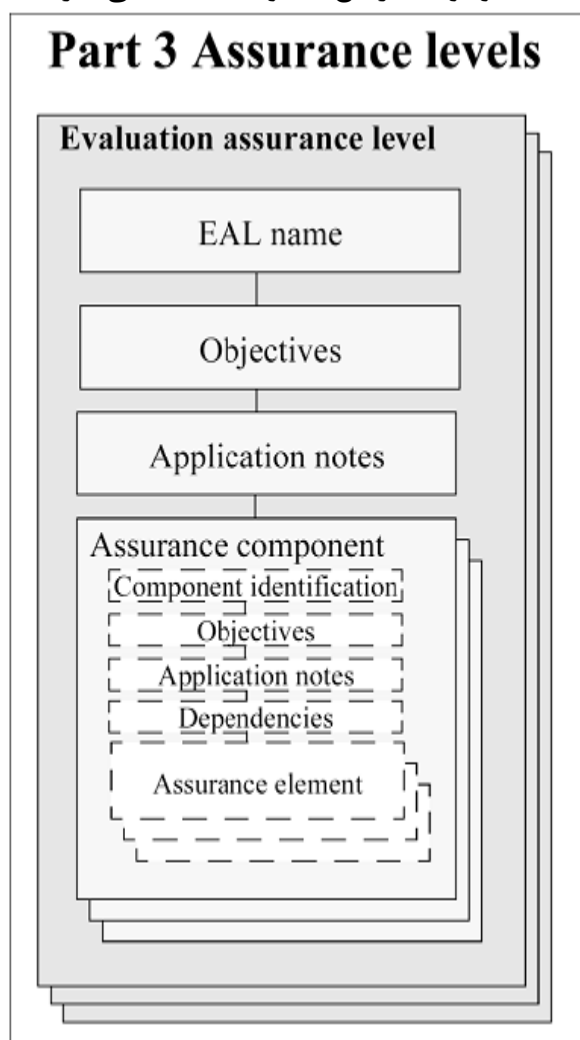
شکل ۳- دیاگرام تجزیه و تحلیل یک دسته نمونه

در شکل ۳، در قسمت بالا، دسته‌ای که نشان داده شده است شامل خانواده‌ی تکی می‌شود. این خانواده شامل سه مؤلفه است که به شکل خطی سلسله مراتبی هستند. (به عنوان مثال، مؤلفه ۲ بیش از مؤلفه ۱ به اعمال ویژه،

مدرك ویژه یا دقت زیاد در فعالیت‌ها و مدارك نیاز دارد). خانواده‌های تضمین در این قسمت از این مجموعه استاندارد ملی همگی به‌شکل خطی سلسله مراتبی هستند، اگرچه خطی بودن یک معیار اجباری برای خانواده‌های تضمینی که در آینده اضافه می‌شوند نیست.

۲-۶ ساختار EAL

شکل ۴ EALها و ساختار تعریف شده مربوط به آنها را در این قسمت از این مجموعه استاندارد ملی نشان می‌دهد. باید توجه شود که همان‌طور که در شکل، مندرجات مؤلفه‌های تضمین نشان داده شده‌اند، فهمیده می‌شود که این اطلاعات در یک EAL و توسط ارجاع به مؤلفه‌های داخلی تعریف شده در استاندارد می‌باشند.



شکل ۴- ساختار EAL

۲-۶-۱ نام EAL

هر EAL با یک نام منحصر به‌فرد مشخص می‌شود. نام، شرحی از اطلاعات در مورد EAL مورد نظر را فراهم می‌کند.

یک فرم کوچک منحصر به‌فرد از نام EAL نیز ایجاد می‌شود. این نام، مفهوم کلیدی برای ارجاع به EAL است.

۶-۲-۲ اهداف

زیر بند اهداف EAL، منظور EAL را ارائه می‌کند.

۶-۲-۳ نکات کاربردی

بند نکات کاربردی EAL، در صورت ارائه، شامل اطلاعاتی ویژه به کاربران EAL است. (به‌عنوان مثال، در مورد نویسندگان ST و PP، طراحان TOE مورد نظر این EAL، ارزیابان). ارائه به‌شکل غیررسمی است و برای مثال، هشدار در مورد محدودیت‌های به‌کارگیری و محدوده‌ای که توجه خاص نیاز دارند را دربر می‌گیرد.

۶-۲-۴ مؤلفه‌های تضمین

مجموعه‌ای از مؤلفه‌های تضمین برای هر EAL انتخاب شده است. سطح بالاتری از تضمین را نسبت به EAL مورد نظر می‌توانیم توسط موارد زیر به‌دست آوریم:

الف- مؤلفه‌های تضمین افزنده از خانواده‌های تضمین دیگر.

ب- جایگزینی یک مؤلفه تضمین با مؤلفه تضمین سطح بالاتر از یک خانواده مشابه تضمین.

۶-۲-۵ ارتباط بین تضمین‌ها و سطوح تضمین

شکل ۵ ارتباط بین SARها و سطوح تضمین تعریف شده در استاندارد را نشان می‌دهد. در صورتی که مؤلفه‌های تضمین دیگر، درون عناصر تضمین تجزیه و تحلیل شوند، عناصر تضمین نمی‌توانند به‌صورت منفرد توسط سطوح تضمین مورد اشاره قرار می‌گیرند. باید توجه شود که پیکان در شکل، از یک EAL به یک مؤلفه تضمین درون دسته‌ای که تعریف می‌شود اشاره می‌کند.

۶-۳-۳ ساختار CAP

ساختار CAPها مشابه EALها است. تفاوت اصلی بین این دو بسته در نوع TOEیی است که به‌کار می‌گیرند، EALها، TOEهای مؤلفه و CAPها، TOEهای ترکیبی را به‌کار می‌گیرند.

شکل ۶، CAPها و ساختار تعریف شده مربوط به آنها را در این قسمت از این مجموعه استاندارد ملی، نشان می‌دهد. باید توجه شود که همان‌طور که شکل، مندرجات مؤلفه‌های تضمین را نشان می‌دهد، مشخص است که این اطلاعات در یک CAP و با عطف به مؤلفه‌های تعریف شده واقعی در استاندارد وجود دارد.

۶-۳-۱ نام CAP

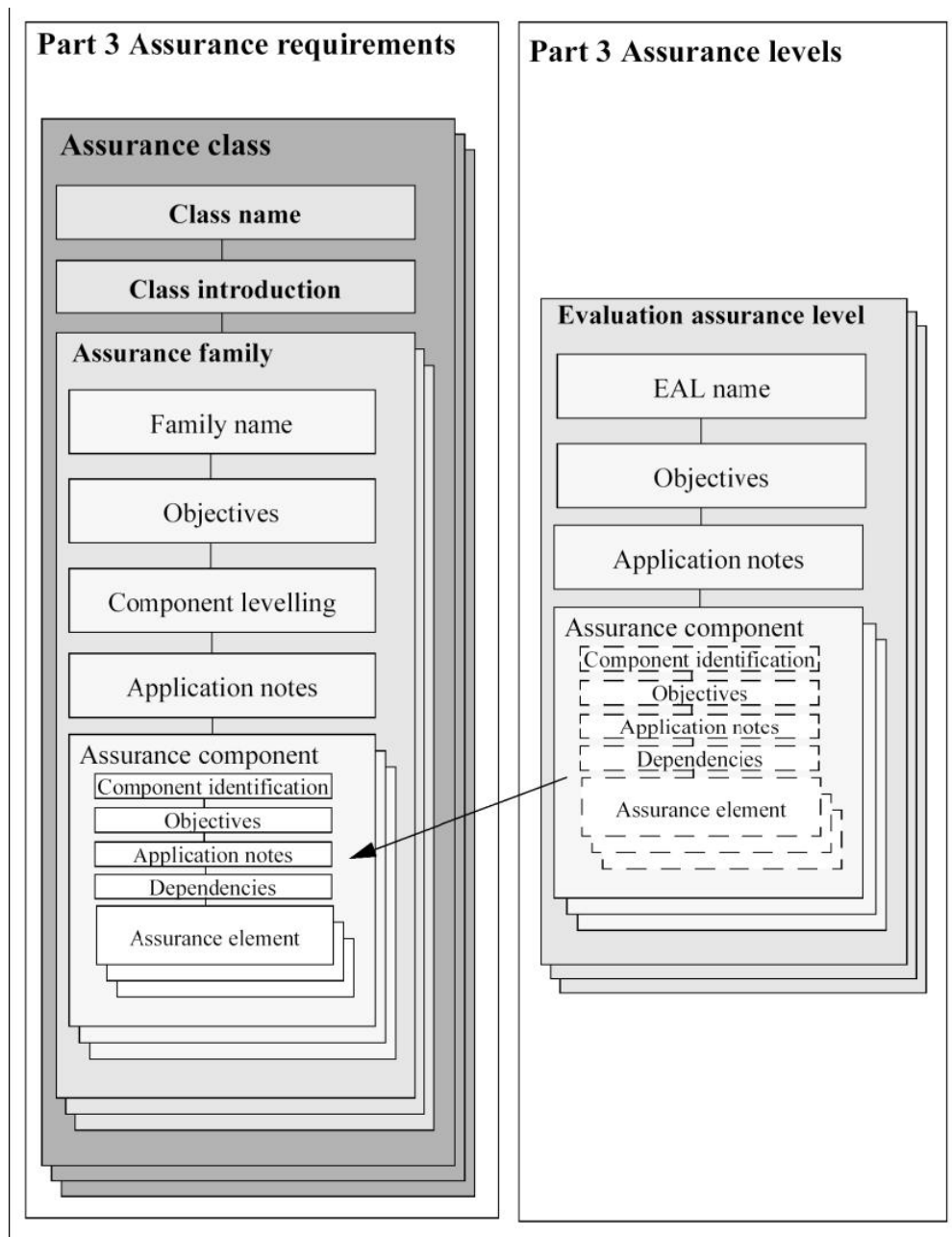
هر CAP با یک نام منحصر به‌فرد مشخص می‌شود. نام، مشخص کننده اطلاعاتی در مورد CAP است. یک فرم کوتاه منحصر به‌فرد از نام CAP نیز ایجاد می‌شود. این نام اختصاری، مفهوم اصلی برای ارجاع به CAP است.

۶-۳-۲ اهداف

زیربند اهداف CAP، منظور CAP را ارائه می‌کند.

۶-۳-۳ نکات کاربردی

بند نکات کاربردی CAP، در صورت ارائه، شامل اطلاعاتی در مورد مطالب ویژه به کاربران CAP است، (به‌عنوان مثال، در مورد نویسندگان ST و PP، طراحان TOE مورد نظر این EAL، ارزیابان). ارائه به‌شکل غیررسمی است و برای مثال، شامل هشدار در مورد حدود به‌کارگیری و محدوده‌هایی که ملزم توجه ویژه است.

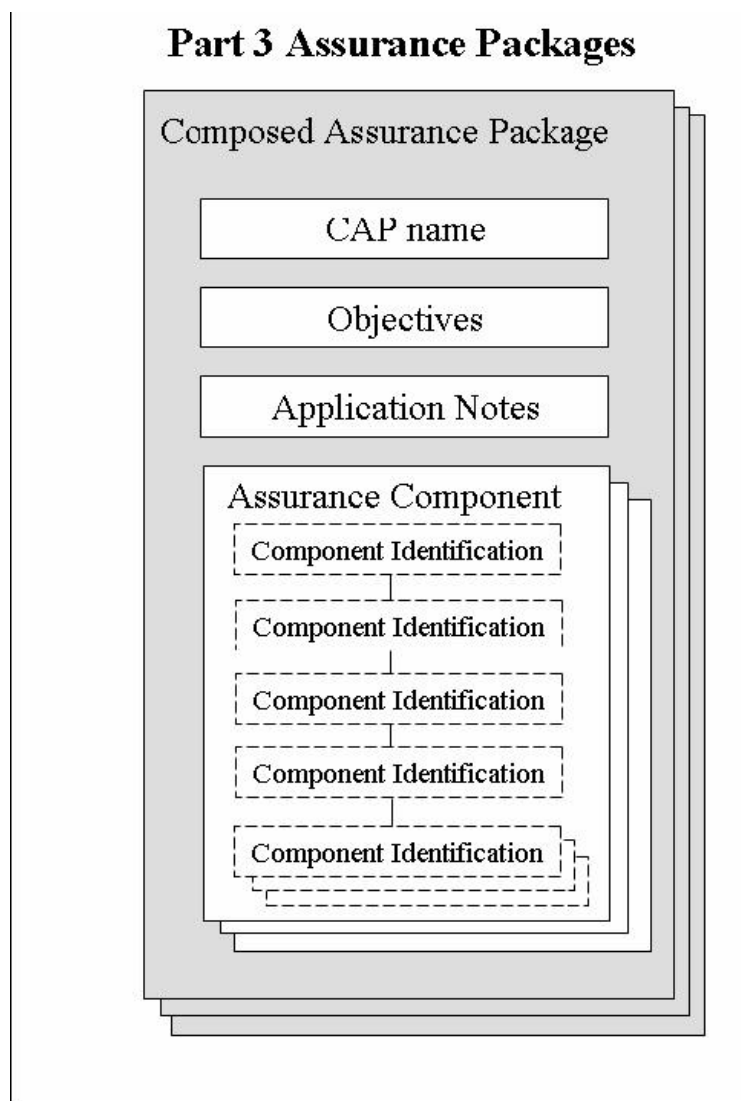


شکل ۵- ارتباط بین سطح تضمین و تضمین

۴-۳-۶ مؤلفه‌های تضمین

مجموعه‌ای از مؤلفه‌های تضمین که برای هر CAP انتخاب شده است. برخی وابستگی‌ها، فعالیت‌های انجام‌شده در طی ارزشیابی مؤلفه وابسته را شناسایی می‌کند که به فعالیت TOE ترکیبی تکیه دارند. جایی که به‌وضوح مشخص نشده است که وابستگی به فعالیت مؤلفه وابسته است، وابستگی به‌دیگر فعالیت ارزشیابی TOE ترکیبی وجود دارد. سطح بالاتری از تضمین را نسبت به CAP مورد نظر می‌توانیم توسط موارد زیر به‌دست آوریم:

- الف- مؤلفه‌های تضمین افزوده از خانواده‌های تضمین دیگر.
- ب- جایگزینی یک مؤلفه تضمین با مؤلفه تضمین سطح بالاتر از همان خانواده تضمین.
- (ACO): مؤلفه‌های ترکیبی موجود در بسته‌های تضمین CAP، نباید برای تقویت ارزشیابی‌های مؤلفه TOE مؤلفه به کار گرفته شوند، زیرا تضمین معنی داری را برای مؤلفه فراهم نمی‌آورند.

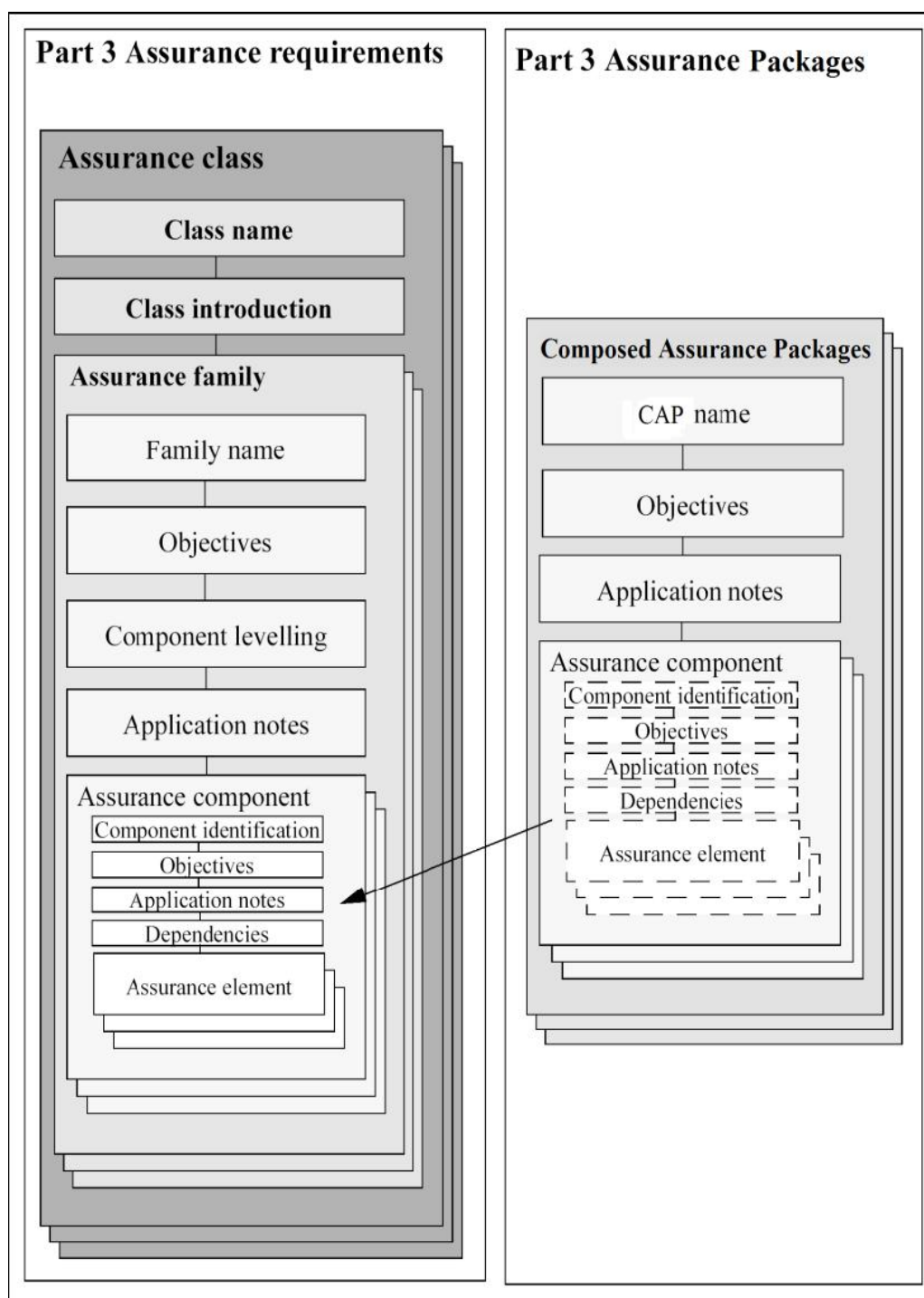


شکل ۶- ساختار CAP

۶-۳-۵ ارتباط بین تضمین و سطوح تضمین

شکل ۷، ارتباط بین SARها(الزامات تضمین امنیت) و بسته‌های تضمین ترکیبی تعریف شده در استاندارد را نشان می‌دهد. در صورتی که مؤلفه‌های تضمین دیگر، درون عناصر تضمین تجزیه و تحلیل شوند، عناصر تضمین

نمی‌توانند به صورت منفرد توسط سطوح تضمین مورد توجه قرار گیرند. باید توجه شود که پیکان در شکل، از یک CAP به یک مؤلفه تضمین درون دسته‌ی که تعریف می‌شود اشاره می‌کند.



شکل ۷- ارتباط بین تضمین و بسته تضمین ترکیبی

۷ سطوح تضمین ارزشیابی

سطوح تضمین ارزشیابی (EAL) یک مقیاس افزایشی را فراهم می‌کند که سطح تضمین به‌دست آورده را با هزینه و امکان پیدا کردن درجه‌ی تضمین هماهنگ می‌کند. رویکرد استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ مفاهیم جدا از هم تضمین را در TOE در انتهای ارزشیابی و نگهداری تضمین در طی استفاده‌ی عملیاتی TOE را مشخص می‌کند.

باید توجه داشت که همه‌ی خانواده‌ها و مؤلفه‌ها از این قسمت از این مجموعه استاندارد ملی در EALها نیستند. این، به آن معنی نیست که این موارد تضمین‌های مورد نیاز را فراهم نمی‌کنند. در عوض، انتظار می‌رود که این خانواده‌ها و مؤلفه‌ها برای افزایش EAL در PPها و STها برای فراهم نمودن امکانات، مورد توجه قرار گرفته شود.

۷-۱ رئوس کلی سطح تضمین ارزشیابی (EAL)

جدول ۶ خلاصه‌ی EAL را معرفی می‌کند. ستون‌ها یک مجموعه‌ی مرتب شده‌ی سلسله مراتبی را از EALها معرفی می‌کنند، در حالی که سطرها خانواده‌های تضمین را معرفی می‌کنند. هر شماره در ماتریس نتیجه یک مؤلفه‌ی تضمین خاص در جایی که قابل کاربرد است مشخص می‌کند.

به‌عنوان زمینه در بند فرعی بعد، هفت سطح تضمین ارزشیابی معرفی شده به‌شکل سلسله مراتبی در استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ برای رتبه‌بندی تضمین TOE مشخص شده‌اند. آنها به‌شکل سلسله مراتبی قرار گرفته‌اند زیرا هر EAL تضمین بیشتری از EALهای پایین‌تر خود دارد. افزایش در تضمین از EAL به EAL دیگر توسط جانشینی مؤلفه‌ی تضمین بالاتر از همان خانواده‌ی تضمین انجام می‌شود (به‌عنوان مثال، افزایش دقت، دامنه، و یا عمق) و از اضافه نمودن مؤلفه‌های تضمین از خانواده‌های دیگر تضمین انجام می‌شود. این EALها شامل ترکیب مناسبی از مؤلفه‌های تضمین شرح داده شده در بند ۶ این قسمت از این مجموعه استاندارد ملی می‌شوند. به‌طور دقیق‌تر، هر EAL بیشتر از یک خانواده نیست و همه‌ی وابسته‌های تضمین هر مؤلفه مورد توجه قرار می‌گیرند. هنگامی که مؤلفه‌ها در استاندارد مشخص می‌شوند، می‌توان ترکیب‌های دیگر تضمین را نشان داد.

به‌طور مشخص، مفهوم "افزایش" افزودن مؤلفه‌های تضمین را (از خانواده‌های تضمینی که در EAL موجود نیستند) یا جانشینی مؤلفه‌های تضمین (با مؤلفه‌های تضمینی که از نظر مرتبه بالاتر هستند و در عین حال همگی در یک خانواده قرار دارند) با یک EAL، امکان پذیر می‌کند. در ساختار تضمین تعریف شده در استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸، تنها EALها ممکن است افزایش داده شوند. مفهوم "EAL منهای مؤلفه تضمین سازنده" توسط این استاندارد به‌عنوان یک ادعای معتبر به رسمیت شناخته نمی‌شود. افزایش در قسمتی از مطالبات، التزام را جهت توجیه کاربردپذیری و ارزش افزوده مؤلفه‌های تضمین افزوده به EAL با آن انتقال می‌دهد. یک EAL همچنین ممکن است با الزامات تضمین وضع شده به‌طور صریح گسترش یابد.

جدول ۱- خلاصه سطح تضمین ارزشیابی

دسته تضمین	خانواده	مؤلفه های تضمین از نظر سطح ارزشیابی تضمین					
		EAL1	EAL2	EAL3	EAL4	EAL5	EAL6
							EAL7

							تضمین	
1	1	1	1	1	1		ADV_ARC	توسعه
6	5	5	4	3	2	1	ADV_FSP	
2	2	1	1				ADV_IMP	
3	3	2					ADV_INT	
1	1						ADV_SPM	
6	5	4	3	2	1		ADV_TDS	
1	1	1	1	1	1	1	AGD_OPE	اسناد راهنما
1	1	1	1	1	1	1	AGD_PRE	
5	5	4	4	3	2	1	ALC-CMC	پشتیبانی چرخه حیات
5	5	5	4	3	2	1	ALC_CMS	
1	1	1	1	1	1		ALC_DEL	
2	2	1	1	1			ALC_DVS	
							ALC_FLR	
2	1	1	1	1			ALC_LCD	
3	3	2	1				ALC_TAT	
1	1	1	1	1	1	1	ASE_CCL	ارزشیابی هدف امنیتی
1	1	1	1	1	1	1	ASE_ECD	
1	1	1	1	1	1	1	ASE_INT	
2	2	2	2	2	2	1	ASE_OBJ	
2	2	2	2	2	2	1	ASE_REQ	
1	1	1	1	1	1		ASE_SPD	
1	1	1	1	1	1	1	ASE_TSS	
3	3	2	2	2	1		ATE_COV	آزمون‌ها
4	3	3	2	1			ATE_DPT	
2	2	1	1	1	1		ATE_FUN	
3	2	2	2	2	2	1	ATE_IND	
5	5	4	3	2	2	1	AVA-VAN	تشخیص آسیب‌پذیری

۷-۲ ارزشیابی جزئیات سطح تضمین

بندهای فرعی زیر ارائه‌ی تعریف‌های EALها، مشخص نمودن تفاوت‌ها بین الزامات خاص و نوشتن این ویژگی‌ها به‌شکل پررنگ می‌باشد.

۷-۳ ارزشیابی سطح ۱ تضمین (EAL) - آزمون کارکرد

۷-۳-۱ اهداف

EAL1 در جایی که اطمینان در عملیات صحیح مورد نیاز است، اما تهدیدهای امنیتی جدی نیستند کاربرد دارند. آن در جایی که تضمین مستقل برای پشتیبانی از رقابتی که برای حفاظت از اطلاعات شخصی یا مشابه ایجاد می‌شود مورد نیاز است، ارزشمند می‌شوند.

EAL1 ارزشیابی TOE را به‌عنوان یک مدل در دسترس برای مشتری، شامل آزمون مستقل در برابر مشخصات، و یک آزمون ارائه سند راهنما فراهم می‌کند. این به آن معنی است که ارزشیابی یک EAL1 می‌تواند به‌شکل موفقیت‌آمیزی با کمترین هزینه انجام شود.

ارزشیابی در این سطح باید مدارکی فراهم آورد که عملیات TOE به‌شیوه‌ی سازگار با مستندسازی خود فراهم می‌آورد.

۷-۳-۲ مؤلفه‌های تضمین

EAL1 یک سطح پایه تضمین را توسط تحلیل کارکردهای امنیتی به کار گرفته شده‌ی کارکردی و ویژگی‌های واسط و سند راهنما برای درک رفتار امنیتی فراهم می‌کند. تحلیل به‌وسیله آزمون مستقل کارکردهای امنیتی TOE پشتیبانی می‌شود. این EAL افزایش قابل ملاحظه‌ای را در تضمین در مورد سیستم یا محصول فناوری اطلاعاتی ارزشیابی نشده فراهم می‌آورد.

جدول ۲- EAL1

مؤلفه های تضمین	دسته تضمین
ADV_FSP.1 مشخصه عملکردی ابتدایی	ADV: توسعه
AGD_OPE.1 راهنمای عملیاتی کاربر	AGD: اسناد راهنما
AGD_PRE.1 رویکردهای مقدماتی	
ALC_CMC.1 برچسب زنی TOE	ALC: پشتیبانی چرخه حیات
ALC_CMS.1 پوشش TOE CM	
ASE_CCL.1 ادعاهای تطبیق	ASE: ارزشیابی هدف امنیتی
ASE_ECD.1 شرح مفصل مؤلفه‌ها	
ASE_INT.1 معرفی ST	
ASE_OBJ.2 اهداف امنیتی برای محیط عملیاتی	
ASE_REQ.2 توضیح دادن الزامات امنیتی	
ASE_SPD.1 شرح مشکل امنیتی	
ASE_TSS.1 مشخصه خلاصه TOE	
ATE_IND.2 آزمون مستقل - تطبیق	ATE: آزمون‌ها
AVA_VAN.2 تحلیل آسیب پذیری	AVA: ارزیابی آسیب پذیری

۷-۴ ارزشیابی سطح ۲ تضمین - آزمون ساختاری (آزمون جعبه سفید)

۷-۴-۱ اهداف

EAL2 به همکاری توسعه‌دهنده برای ارسال اطلاعات طراحی شده و نتایج تست نیاز دارد، اما نباید تلاش مضاعفی را نسبت به فعالیت‌های تجاری خوب در قسمت توسعه‌دهنده درخواست کند. همچنین نباید به شکل قابل ملاحظه‌ای سرمایه‌گذاری هزینه‌ای یا زمانی را افزایش دهد.

بنابراین EAL2 در شرایطی که توسعه‌دهندگان یا کاربران نیاز به سطح پایین‌تر امنیت تضمین شده‌ی مستقل در غیاب رکورد آماده و در دسترس توسعه یافته کامل دارند به کار می‌رود. چنین موقعیتی ممکن است ناشی از زمانی باشد که سیستم‌های امنیتی باقی مانده محدود باشند یا دسترسی به توسعه دهنده محدود شده باشد.

۷-۴-۲ مؤلفه‌های تضمین

EAL2 تضمین را توسط تحلیل کارکردهای امنیتی، استفاده‌ی کارکردی و مشخصات واسط، سندسازی راهنما و طراحی سطح بالای TOE، برای فهمیدن رفتار امنیتی فراهم می‌کند. تحلیل توسط آزمون مستقل کارکردهای آزمون TSF، شواهد آزمون توسعه‌دهنده که مبتنی بر مشخصات کارکردی است، تأیید مستقل اختیاری نتایج آزمون توسعه‌دهنده، قدرت تحلیل کارکرد و شواهد جستجوی توسعه‌دهنده برای آسیب‌پذیری‌های آشکار (نظیر آسیب‌پذیری‌ها در دامنه‌ی عمومی) پشتیبانی می‌شود. EAL2 همچنین تضمین را به واسطه‌ی فهرست پیکره‌بندی TOE، و شواهد روال‌های انتقال امنیت فراهم می‌کند.

این EAL افزایش قابل ملاحظه‌ای را در تضمین از EAL1 به وسیله نیاز آزمون توسعه‌دهنده، تحلیل آسیب‌پذیری، و آزمون مستقل مبتنی بر مشخصات جزئی‌تر TOE ارائه می‌دهد.

جدول ۳- EAL2

مؤلفه‌های تضمین	دسته تضمین
ADV_ARC.1 تعریف معماری امنیتی	ADV: توسعه
ADV_FSP.2 مشخصات کارکردی اجرای امنیت	
ADV_TDS.1 طراحی ابتدایی	
AGD_OPE.1 راهنمای عملیاتی کاربر	AGD: اسناد راهنما
AGD_PRE.1 روش‌های مقدماتی	
ALC_CMS.2 استفاده از سامانه CM	ALC: پشتیبانی چرخه حیات
ALC_CMC.2 قسمت‌هایی از پوشش CM TOE	
ALC_DEL.1 روش‌های تحویل	
ASE_CCL.1 ادعاهای تطبیق	ASE: ارزشیابی هدف امنیتی
ASE_ECD.1 شرح مفصل مؤلفه‌ها	
ASE_INT.1 معرفی ST	
ASE_OBJ.2 اهداف امنیتی	
ASE_REQ.2 الزامات امنیتی منتج شده	
ASE_SPD.1 شرح مشکل امنیتی	
ASE_TSS.1 مشخصه خلاصه TOE	
ATE_COV.1 مدرک پوشش	ATE: آزمون‌ها
ATE_FUN.1 آزمایش عملکردی	
ATE_IND.2 آزمایش مستقل- نمونه	
AVA_VAN.2 تحلیل آسیب‌پذیری	AVA: ارزیابی آسیب‌پذیری

۷-۵ ارزشیابی تضمین سطح ۳- بررسی و آزمون متدولوژیک (روش شناسایی)

۷-۵-۱ اهداف

EAL3 اجازه می‌دهد یک توسعه‌دهنده‌ی وظیفه‌شناس حداکثر تضمین را از مهندسی امنیت مثبت در طراحی مرحله بدون تغییر مهمی از فعالیت‌های افزایش دقت موجود به‌دست آورد.

EAL3 در شرایطی که توسعه‌دهندگان یا کاربران نیاز به سطح محدود امنیت تضمین شده مستقل دارند و نیاز به تحقیق و بررسی TOE و توسعه آن بدون مهندسی اساسی مجدد دارند به‌کار می‌رود.

۷-۵-۲ مؤلفه‌های تضمین

EAL3 تضمین را توسط تحلیل کارکردهای امنیت، استفاده کارکردی و مشخصات واسط، مستندسازی راهنما و طراحی سطح بالای TOE، برای فهمیدن رفتار امنیتی فراهم می‌کند.

تحلیل به‌وسیله آزمون مستقل کارکردهای امنیتی TOE، شواهد آزمون توسعه‌دهنده مبتنی بر مشخصات کارکردی و طراحی سطح بالا، تأیید مستقل اختیاری نتایج آزمون توسعه‌دهنده، قدرت تحلیل کارکرد و شواهد جستجوی توسعه‌دهنده برای آسیب‌پذیری‌های آشکار (نظیر آسیب‌پذیری‌ها در محدوده عمومی) پشتیبانی می‌شود.

این EAL افزایش قابل ملاحظه‌ای در تضمین EAL2 را توسط نیاز به پوشش کاملتر آزمون کارکردهای امنیت و مکانیسم‌ها و روال‌هایی که این اطمینان را فراهم می‌کند که TOE در طی توسعه مداخله نخواهد کرد، نشان می‌دهد.

جدول ۴- EAL3

مؤلفه‌های تضمین	دسته تضمین
ADV_ARC.1 تعریف معماری امنیتی	ADV: توسعه
ADV_FSP.3 مشخصات کارکردی با خلاصه کامل	
ADV_TDS.1 طراحی معماری	
AGD_OPE.1 راهنمای عملیاتی کاربر	AGD: اسناد راهنما
AGD_PRE.1 روش‌های مقدماتی	
ALC_CMC.3 کنترل‌های تصدیق هویت	ALC: پشتیبانی چرخه حیات
ALC_CMS.3 اجرای معرفی پوشش CM	
ALC_DEL.1 روش‌های تحویل	
ALC_DVS.1 شناسایی اقدامات امنیتی	
ALC_LCD.1 مدل چرخه حیات تعریف‌شده توسعه‌دهنده	
ASE_CCL.1 ادعاهای تطبیق	ASE: ارزشیابی هدف امنیتی
ASE_ECD.1 شرح مفصل مؤلفه‌ها	
ASE_INT.1 معرفی ST	

ASE_OBJ.2 اهداف امنیتی	
ASE_REQ.2 الزامات امنیتی منتج شده	
ASE_SPD.1 شرح مشکل امنیتی	
ASE_TSS.1 مشخصه خلاصه TOE	
ATE_COV.2 تحلیل پوشش	ATE: آزمون‌ها
ATE_DPT.1 آزمون: طراحی ابتدایی	
ATE_FUN.1 آزمون عملکردی	
ATE_IND.2 آزمایش مستقل - نمونه	
AVA_VAN.2 تحلیل آسیب‌پذیری	AVA: ارزیابی آسیب‌پذیری

۷-۶ ارزشیابی سطح ۴ تضمین - مرور، آزمون و طراحی به لحاظ متدولوژیک

۷-۶-۱ اهداف

EAL4 اجازه می‌دهد که یک توسعه‌دهنده حداکثر تضمین را از مهندسی امنیت مثبت مبتنی بر فعالیت‌های اقتصادی مناسب توسعه بدست آورد، که در عین دقت بالا مستلزم دانش تخصصی و اساسی، مهارت و دیگر منابع نیست. EAL4 بالاترین سطحی است که به لحاظ اقتصادی به منظور بهبود خط تولید موجود موجه است. بنابراین EAL4 در شرایطی که توسعه‌دهندگان یا کاربران به سطح بالای مناسبی از امنیت تضمین شده مستقل در TOE های قراردادی نیاز دارند و برای متحمل کردن هزینه‌های مهندسی امنیتی خاص اضافی آماده می‌شوند کاربرد دارد.

۷-۶-۲ مؤلفه‌های تضمین

EAL4 تضمین را به وسیله تحلیل کارکردهای امنیت، استفاده‌ی کارکردی و کامل مشخصات واسط، سندسازی راهنما، طراحی سطح بالا و سطح پایین TOE و زیر مجموعه‌ی پیاده‌سازی، به منظور فهم رفتار امنیتی فراهم می‌کند. تضمین به شکل اضافی از طریق مدل غیررسمی خط مشی امنیتی TOE به دست می‌آید. تحلیل به وسیله آزمون مستقل کارکردهای امنیتی TOE، شواهد آزمون توسعه مبتنی بر مشخصات کارکردی و طراحی سطح بالا، تایید مستقل اختیاری نتایج آزمون توسعه، قدرت تحلیل کارکردی، شواهد جستجوی توسعه‌دهنده در مورد آسیب‌پذیری‌ها و تحلیل آسیب‌پذیری مستقل اثبات مقاومت در برابر نفوذ مهاجمانی که از قدرت تهاجمی پایینی برخوردار هستند پشتیبانی می‌شود.

EAL4 همچنین تضمین را طی استفاده از کنترل‌های محیطی توسعه و مدیریت پیکر بندی اضافی TOE شامل اتوماسیون و شواهد روال‌های نقل و انتقال امنیت فراهم می‌کند.

این EAL افزایش قابل توجهی را در تضمین EAL3 به وسیله نیاز به شرح بیشتر طراحی، زیر مجموعه‌ای از پیاده‌سازی و مکانیسم‌های اصلاح شده و یا روال‌هایی که این اطمینان را فراهم می‌کنند که TOE ارتباطات پنهانی با توسعه یا حمل و نقل نخواهد داشت نشان می‌دهد.

جدول ۵- EAL4

دسته تضمین	مؤلفه‌های تضمین
ADV: توسعه	ADV_ARC.1 تعریف معماری امنیتی
	ADV_FSP.4 مشخصات کارکردی کامل
	ADV_IMP.1 ارائه پیاده سازی TSF
	ADV_TDS.3 طراحی پیمانه‌ای ابتدایی
AGD: اسناد راهنما	AGD_OPE.1 راهنمای عملیاتی کاربر
	AGD_PRE.1 روش‌های مقدماتی
ALC: پشتیبانی چرخه حیات	ALC_CMC.4 پشتیبانی تولید، روش‌های پذیرش و اتوماسیون
	ALC_CMS.4 ردیابی مشکل پوشش CM
	ALC_DEL.1 روش‌های تحویل
	ALC_DVS.1 شناسایی اقدامات امنیتی
	ALC_LCD.1 مدل چرخه حیات تعریف شده توسعه دهنده
	ALC_TAT.1 ابزارهای به خوبی تعریف شده توسعه
ASE: ارزشیابی هدف امنیتی	ASE_CCL.1 ادعاهای تطبیق
	ASE_ECD.1 شرح مفصل مؤلفه‌ها
	ASE_INT.1 معرفی ST
	ASE_OBJ.2 اهداف امنیتی
	ASE_REQ.2 الزامات امنیتی منتج شده
	ASE_SPD.1 شرح مشکل امنیتی
	ASE_TSS.1 مشخصه خلاصه TOE
ATE: آزمون‌ها	ATE_COV.2 تحلیل پوشش
	ATE_DPT.2 آزمون: ماجول‌های اجرای امنیت
	ATE_FUN.1 آزمون عملکردی
	ATE_IND.2 آزمون: آمایش مستقل - نمونه
AVA: ارزیابی آسیب پذیری	AVA_VAN.3 تحلیل آسیب پذیری مورد توجه

۷-۷ ارزشیابی سطح ۵ تضمین (EAL5) - طراحی و آزمون نیمه رسمی

۷-۷-۱ اهداف

EAL5 به توسعه دهنده این اجازه را می‌دهد که حداکثر تضمین را از مهندسی امنیت مبتنی بر فعالیت‌های سخت توسعه تجاری که به وسیله برنامه‌های کاربردی مناسب تکنیک‌های مهندسی امنیت خاص پشتیبانی می‌شوند به دست آورد. چنین TOE احتمالاً با قصد رسیدن به تضمین EAL5 طراحی می‌شود و توسعه

خواهد یافت. این به این معنی است که هزینه‌های اضافی در مورد الزامات EAL5، وابسته به توسعه شدید بدون کاربرد تکنیک‌های خاص، زیاد نخواهد بود.

بنابراین EAL5 در شرایطی که توسعه دهندگان یا کاربران نیاز به سطح بالایی از امنیت تضمین شده‌ی مستقل در توسعه طراحی شده دارند و نیاز به راهکار توسعه‌ی شدید، بدون تحمیل هزینه‌های نامعقول در مورد تکنیک‌های مهندسی امنیت خاص دارند قابل کاربرد است.

۷-۲ مؤلفه‌های تضمین

EAL5 تضمین را توسط تحلیل کارکردهای امنیت، استفاده از ویژگی‌های کامل و کارکردی واسط، راهنمایی مستند و طراحی سطح بالا و سطح پایین TOE و همه‌ی پیاده‌سازی‌ها، به‌منظور فهم رفتار امنیتی فراهم می‌کند. تضمین به‌شکل اضافی در طی مدل رسمی خط‌مشیء امنیتی TOE و ارائه‌ی نیمه رسمی ویژگی‌های کارکردی و طراحی سطح بالا و نمایش نیمه‌رسمی مطابقت بین آن‌ها به‌دست آورده می‌شود. همچنین به طراحی TOE مایجولار نیز نیاز می‌شود.

تحلیل، توسط آزمون مستقل کارکردهای امنیتی TOE، شواهد آزمون توسعه‌دهنده‌ی مبتنی بر ویژگی‌های کارکردی، طراحی سطح بالا و طراحی سطح پایین، پیکره‌بندی مستقل اختیاری در مورد نتایج آزمون توسعه دهنده، نقاط قوت تحلیل کارکردی، شواهد جستجوی توسعه‌دهنده در مورد آسیب‌پذیری‌ها، نمایش تحلیل آسیب‌پذیری‌های مستقل مقاوم نسبت به نفوذ مهاجمان دارای قدرت بالقوه حمله‌ی، پشتیبانی می‌شود. تحلیل، همچنین شامل اعتبار تحلیل کانال پنهانی توسعه‌دهنده می‌شود.

EAL5 همچنین، تضمین را طی استفاده از کنترل‌های محیطی توسعه‌دهنده و مدیریت فراگیر پیکربندی TOE شامل اتوماسیون و شواهد روال‌های نقل و انتقال امنیت فراهم می‌کند. این EAL افزایش قابل توجهی در تضمین را از EAL4 توسط نیاز به توصیف طراحی نیمه‌رسمی، پیاده‌سازی کامل، معماری (و در نتیجه قابلیت تحلیل پذیری) ساختاری بیشتر، تحلیل کانال پنهانی و مکانیسم‌های اصلاح شده و یا روال‌هایی که این اطمینان را فراهم می‌کنند که TOE با توسعه، مداخله‌ی پنهانی نخواهد داشت.

جدول ۶- EAL5

مؤلفه‌های تضمین	دسته تضمین
ADV_ARC.1 تعریف معماری امنیتی	ADV: توسعه
ADV_FSP.5 مشخصات کارکردی کامل نیمه‌رسمی همراه با اطلاعات افزوده خطا	
ADV_IMP.1 ارائه پیاده‌سازی TSF	
ADV_INT.2 ورودی‌های به‌خوبی ساخته شده	
ADV_TDS.4 طراحی پیمانه‌ای نیمه‌رسمی	
AGD_OPE.1 راهنمای عملیاتی کاربر	AGD: اسناد راهنما
AGD_PRE.1 روش‌های مقدماتی	
ALC_CMC.4 پشتیبانی تولید، روش‌های پذیرش و اتوماسیون	

ALC_CMS.5 پوشش CM ابزارهای توسعه	
ALC_DEL.1 روش‌های تحویل	
ALC_DVS.1 شناسایی اقدامات امنیتی	
ALC_LCD.1 مدل چرخه حیات تعریف شده توسعه دهنده	
ALC_TAT.2 تطبیق با استانداردهای پیاده سازی	
ASE_CCL.1 ادعاهای تطبیق	ASE: ارزشیابی هدف امنیتی
ASE_ECD.1 شرح مبسوط مؤلفه‌ها	
ASE_INT.1 معرفی ST	
ASE_OBJ.2 اهداف امنیتی	
ASE_REQ.2 الزامات امنیتی منتج شده	
ASE_SPD.1 شرح مشکل امنیتی	
ASE_TSS.1 مشخصه خلاصه TOE	
ATE_COV.2 تحلیل پوشش	ATE: آزمون‌های
ATE_DPT.2 آزمون: طراحی پیمانه‌ای	
ATE_FUN.1 آزمون عملکردی	
ATE_IND.2 آزمون مستقل - نمونه	
AVA_VAN.3 تحلیل منظم آسیب پذیری	AVA: ارزیابی آسیب پذیری

۷-۸ ارزشیابی سطح ۶ تضمین - آزمون و طراحی تحقیق شده نیمه رسمی

۷-۸-۱ اهداف

EAL6 اجازه می‌دهد توسعه دهندگان به تضمین بالایی از کاربرد تکنیک‌های مهندسی امنیت نسبت به محیط توسعه سخت به منظور تولید یک TOE اضافی برای محافظت سرمایه‌های ارزشمند در برابر خطرات مهم دست یابند.

بنابراین EAL6 برای توسعه‌ی TOE‌های امنیتی برای استفاده در موقعیت‌های پر خطر که ارزش سرمایه‌های حفاظت شده آنقدر مهم است که هزینه‌های اضافی را توجیه می‌کند به کار می‌رود.

۷-۸-۲ مؤلفه‌های تضمین

EAL6 تضمین را توسط تحلیل کارکردهای امنیتی، استفاده از ویژگی‌های واسط کامل و کاربردی، راهنمای مستند، طراحی سطح بالا و سطح پایین TOE و نمایش ساختاری پیاده‌سازی، برای فهم رفتار امنیتی فراهم می‌کند. تضمین به شکل اضافی از طریق مدل رسمی خط‌مشی امنیتی TOE نمایش نیمه رسمی ویژگی‌های کارکردی، طراحی سطح بالا، طراحی سطح پایین و نمایش نیمه رسمی مطابقت بین آن‌ها به دست می‌آید. همچنین یک طراحی TOE واحد و لایه‌ای نیز مورد نیاز می‌باشد.

تحلیل، توسط آزمون مستقل کارکردهای امنیتی TOE، شواهد آزمون توسعه‌دهنده‌ی مبتنی بر ویژگی‌های کارکردی، طراحی سطح بالا و طراحی سطح پایین، تأیید مستقل اختیاری نتایج آزمون توسعه‌دهنده، نقاط قوت تحلیل کارکردی، شواهد جستجوی توسعه‌دهنده برای آسیب‌پذیری‌ها، نمایش تحلیل آسیب‌پذیری‌های مستقل مقاوم نسبت به نفوذ مهاجمان دارای قدرت حمله‌ی بالقوه، پشتیبانی می‌شود. تحلیل، همچنین شامل اعتبار تحلیل کانال سیستماتیک پنهانی توسعه‌دهنده نیز می‌شود.

EAL6 همچنین تضمین را از طریق استفاده از فرایند توسعه‌ی ساختاری، کنترل‌های محیط توسعه، مدیریت فراگیر پیکره‌بندی TOE که شامل اتوماسیون کامل و شواهد روال‌های نقل و انتقال امنیت می‌شود، فراهم می‌کند. این EAL افزایش قابل توجهی را در تضمین از EAL5 به وسیله نیاز به تحلیل فراگیرتر، نمایش ساختاری پیاده‌سازی، ساختار معمارگونه‌تر (به عنوان مثال لایه‌ای)، تحلیل آسیب‌پذیری مستقل فراگیرتر، شناسایی کانال پنهانی سیستماتیک، مدیریت پیکره‌بندی اصلاح شده و کنترل‌های محیطی توسعه نشان می‌دهد.

جدول ۷- EAL6

دسته تضمین	مؤلفه های تضمین
ADV: توسعه	ADV_ARC.1 تعریف معماری امنیتی
	ADV_FSP.5 مشخصات کارکردی کامل نیمه رسمی همراه با اطلاعات افزوده خطا
	ADV_IMP.2 ترسیم کامل ارائه پیاده سازی TSF
	ADV_INT.3 ورودی‌های به طور حداقل پیچیده
	ADV_SPM.1 مدل رسمی خط مشی امنیتی TOE
AGD: اسناد راهنما	ADV_TDS.5 طراحی پیمانه‌ای کامل نیمه رسمی
	AGD_OPE.1 راهنمای عملیاتی کاربر
	AGD_PRE.1 روش‌های مقدماتی
ALC: پشتیبانی چرخه حیات	ALC_CMC.5 پشتیبانی پیشرفته
	ALC_CMS.5 پوشش CM ابزارهای توسعه
	ALC_DEL.1 روش‌های تحویل
	ALC_DVS.2 کافی بودن اقدامات امنیتی
	ALC_LCD.1 مدل چرخه حیات تعریف شده توسعه‌دهنده
	ALC_TAT.3 تطبیق با استانداردهای پیاده سازی - تمام قسمت‌ها
	ASE_CCL.1 ادعاهای تطبیق
	ASE_ECD.1 شرح مفصل مؤلفه‌ها

ASE_INT.1 معرفی ST	
ASE_OBJ.2 اهداف امنیتی	
ASE_REQ.2 الزامات امنیتی منتج شده	
ASE_SPD.1 شرح مشکل امنیتی	
ASE_TSS.1 مشخصه خلاصه TOE	
ATE_COV.3 تحلیل بادقت زیاد پوشش	ATE: آزمون‌ها
ATE_DPT.3 آزمون: طراحی پیمانه‌ای	
ATE_FUN.2 سفارش آزمون عملکردی	
ATE_IND.2 آزمون مستقل- نمونه	
AVA_VAN.5 تحلیل منظم پیشرفته آسیب‌پذیری	AVA: ارزیابی آسیب‌پذیری

۷-۹ ارزشیابی تضمین سطح ۷- آزمون و طراحی تحقیق شده به شکل رسمی

۷-۹-۱ اهداف

EAL7 برای توسعه‌ی TOE‌های امنیتی برای استفاده در موقعیت‌هایی با خطر بسیار زیاد و یا مکان‌هایی که ارزش بالای سرمایه‌ها هزینه‌های بیشتر را توجیه می‌کند به کار می‌رود. برنامه کاربردی EAL7 در حال حاضر به TOE‌هایی به کارکرد امنیتی به شدت تمرکز یافته محدود می‌شود که این کارکرد پاسخگو به تحلیل رسمی گسترده است.

۷-۹-۲ مؤلفه‌های تضمین

EAL7 تضمین را توسط تحلیل کارکردهای امنیتی، استفاده از ویژگی‌های واسط کامل و کاربردی، راهنمای مستند، طراحی سطح بالا و سطح پایین TOE، و نمایش ساختاری پیاده‌سازی، برای فهم رفتار امنیتی فراهم می‌کند.

تضمین به شکل اضافی در طی مدل رسمی خط‌مشی امنیتی TOE، نمایش رسمی ویژگی‌های کارکردی، طراحی سطح بالا، نمایش نیمه رسمی طراحی سطح پایین و نمایش نیمه رسمی و رسمی مطابقت بین آن‌ها به شکلی مناسب، به دست آورده می‌شود. همچنین یک طراحی TOE واحد و لایه‌ای و ساده نیز مورد نیاز می‌باشد.

تحلیل، توسط آزمون مستقل کارکردهای امنیتی TOE، شواهد آزمون توسعه‌دهنده مبتنی بر ویژگی‌های کارکردی، طراحی سطح بالا و طراحی سطح پایین، تأیید مستقل کامل نتایج آزمون توسعه‌دهنده، نقاط قوت تحلیل کارکردی، شواهد جستجوی توسعه‌دهنده برای آسیب‌پذیری‌ها، نمایش تحلیل آسیب‌پذیری‌های مستقل مقاوم نسبت به نفوذ مهاجمان دارای قدرت بالای حمله بالقوه، پشتیبانی می‌شود. تحلیل، همچنین شامل اعتبار تحلیل کانال سیستماتیک پنهانی توسعه دهنده می‌شود.

EAL7 همچنین، تضمین را از طریق استفاده از فرایند توسعه‌ی ساختاری، کنترل‌های محیط توسعه، مدیریت فراگیر پیکره‌بندی TOE که شامل اتوماسیون کامل می‌شود و شواهد روال‌های نقل و انتقال امنیت، فراهم می‌کند.

این EAL افزایش قابل توجهی را در تضمین نسبت به EAL6 به وسیله نیاز به تحلیل فراگیرتر استفاده‌ی نمایش‌های رسمی و مطابقت رسمی و آزمون فراگیر نشان می‌دهد.

جدول ۸- EAL6

دسته تضمین	مولفه های تضمین
ADV: توسعه	ADV_ARC.1 تعریف معماری امنیتی
	ADV_FSP.5 مشخصات کارکردی کامل نیمه رسمی همراه با مشخصات رسمی افزوده
	ADV_IMP.2 ترسیم کامل ارائه پیاده سازی TSF
	ADV_INT.3 ورودی های به طور حداقل پیچیده
	ADV_SPM.1 مدل رسمی خط مشی امنیتی TOE
	ADV_TDS.6 طراحی پیمانهای کامل نیمه رسمی همراه با ارائه رسمی طراحی سطح بالا
AGD: اسناد راهنما	AGD_OPE.1 راهنمای عملیاتی کاربر
	AGD_PRE.1 روش های مقدماتی
ALC: پشتیبانی چرخه زندگی	ALC_CMC.5 پشتیبانی پیشرفته
	ALC_CMS.5 پوشش CM ابزارهای توسعه
	ALC_DEL.1 روش های تحویل
	ALC_DVS.2 کافی بودن اقدامات امنیتی
	ALC_LCD.2 مدل قابل اندازه گیری چرخه حیات
	ALC_TAT.3 تطبیق با استانداردهای پیاده سازی - تمام قسمت ها
ASE: ارزیابی هدف امنیتی	ASE_CCL.1 ادعاهای تطبیق
	ASE_ECD.1 شرح مفصل مؤلفه ها
	ASE_INT.1 معرفی ST
	ASE_OBJ.2 اهداف امنیتی
	ASE_REQ.2 الزامات امنیتی منتج شده
	ASE_SPD.1 شرح مشکل امنیتی
	ASE_TSS.1 مشخصه خلاصه TOE
ATE: آزمون ها	ATE_COV.3 تحلیل با دقت زیاد پوشش
	ATE_DPT.4 آزمون: ارائه پیاده سازی

ATE_FUN.2 سفارش آزمون عملکردی	
ATE_IND.2 آزمون مستقل - کامل	
AVA_VAN.5 تحلیل منظم پیشرفته آسیب پذیری	AVA: ارزیابی آسیب پذیری

۸ بسته‌های تضمین ترکیبی

بسته‌های تضمین ترکیبی (CAP) مقیاس رشدی را فراهم می‌کنند که سطح تضمین به‌دست آورده شده را با هزینه و امکان اندوختن درجه تضمین برای TOE‌های ترکیبی هماهنگ می‌کند. توجه به این نکته مهم است که تنها تعداد کمی از خانواده‌ها و مؤلفه‌ها از این قسمت استاندارد، شامل CAP‌ها می‌شوند. این، به‌علت ماهیت ساخت آنها بر نتایج ارزشیابی موجودیت‌های ارزیابی‌شده پیشین است (مؤلفه‌های پایه و مؤلفه‌های وابسته) و نمی‌توان گفت که آنها تضمین خوب و قابل ملاحظه‌ای را فراهم نمی‌کنند.

۸-۱ رئیس کلی بسته تضمین ترکیبی (CAP)

CAP‌ها برای TOE‌های ترکیبی به‌کار گرفته می‌شوند، که شامل مؤلفه‌هایی هستند که ارزشیابی TOE‌ی مؤلفه شده‌اند (مراجعه به پیوست B). مؤلفه‌های منفرد با EAL یا بسته تضمین دیگر در ST تضمین خواهند شد. انتظار می‌رود که سطح پایه‌ای تضمین در TOE‌ی ترکیبی از طریق کاربرد EAL1 به‌دست بیاید، که می‌تواند با اطلاعاتی راجع به مؤلفه‌هایی که معمولاً در دامنه عمومی در دسترس هستند به‌دست آورده شود. (EAL1 می‌تواند به‌شکل خاص هم درون مؤلفه و هم درون TOE‌های ترکیبی به‌کار گرفته شود). CAP‌ها یک شیوه جایگزین را برای رسیدن به سطوح بالاتر تضمین برای TOE‌های ترکیبی از کاربرد EAL‌های بالاتر از EAL1 فراهم می‌کنند.

درحالی که یک مؤلفه وابسته می‌تواند با استفاده از مؤلفه پایه‌ای تضمین شده و ارزشیابی شده قبلی که الزامات خط‌مشی فناوری اطلاعات را در محیط دارد ارزشیابی شود، هیچ تضمین رسمی از واکنش بین مؤلفه‌ها یا امکان معرفی نتایج آسیب‌پذیری‌ها از ترکیب را فراهم نمی‌کند. بسته‌های تضمین ترکیبی به این واکنش‌ها و به سطوح بالاتر تضمین توجه دارند و تضمین می‌کنند که واسط بین مؤلفه‌ها خودش موضوع مورد آزمون شده است. تحلیل آسیب‌پذیری TOE ترکیبی همچنین با توجه به امکان معرفی آسیب‌پذیری‌ها به‌عنوان نتیجه ترکیب مؤلفه‌ها انجام می‌شود.

جدول ۹، خلاصه‌ای از CAP‌ها را نمایش می‌دهد. ستون‌ها، به‌شکل سلسله‌مراتبی مجموعه CAP‌ها را نمایش می‌دهند، در حالی که سطرها خانواده‌های تضمین را نشان می‌دهند. هر شماره در ماتریس نتیجه نشان دهنده مؤلفه تضمین خاصی است که به‌کار می‌رود. به‌طور مختصر در بند بعدی، سه بسته تضمین ترکیبی به‌صورت سلسله مراتبی در این استاندارد برای درجه‌بندی تضمین TOE ترکیبی معرفی می‌شوند. آنها به‌شکل سلسله مراتبی قرار گرفته‌اند زیرا هر CAP تضمین بیشتری را از CAP‌های پایین‌تر خودش نشان می‌دهد.

افزایش در تضمین از یک CAP به CAP‌ی دیگر به‌وسیله جایگزینی مؤلفه تضمین بالاتر از خانواده یکسان (به‌عنوان مثال، افزایش دقت، دامنه، و یا عمق) و از اضافه نمودن مؤلفه تضمین از دیگر خانواده‌های تضمین (به‌عنوان مثال، اضافه نمودن الزامات جدید) انجام می‌شود. نتایج این افزایش‌ها در تجزیه و تحلیل وسیع‌تر ترکیب برای شناسایی فشردگی روی نتایج ارزشیابی به‌دست آمده برای TOE‌های مؤلفه جدا می‌باشد.

این CAPها شامل ترکیب مناسبی از مؤلفه‌های تضمین شرح داده شده در بند ۶ این قسمت از این مجموعه استاندارد ملی استاندارد ملی ایران-ایزو-آی‌ای‌سی ۱۵۴۰۸ می‌شوند. به عبارت دقیق‌تر، هر CAP بیش از یک مؤلفه از هر خانواده تضمین را شامل نمی‌شود و همه وابسته‌های تضمین هر مؤلفه مورد توجه قرار گرفته شده‌اند. CAPها، تنها به مقاومت در برابر حمله با یک حمله بالقوه بر پایه افزایش توجه می‌کنند. این به‌علت سطح اطلاعات طراحی‌ای است که از طریق ACO_DEV می‌تواند فراهم بشود، و به‌علت محدودیت برخی از عامل‌ها مرتبط با حمله بالقوه (دانش TOE ترکیبی) و متعاقباً تأثیر دقت زیاد تحلیل آسیب‌پذیری که می‌تواند توسط ارزیاب انجام شود است.

جدول ۹_ خلاصه‌ای از سطح تضمین ترکیب

دسته تضمین	خانواده تضمین	مؤلفه‌های تضمین توسط بسته‌های تضمین ترکیبی		
		CAP-A	CAP-B	CAP-C
ترکیب	ACO_COR	1	1	1
	ACO_CTT	1	2	2
	ACO_DEV	1	2	3
	ACO_REL	1	1	2
	ACO_VUL	1	2	3
مستندات راهنما	AGD_OPE	1	1	1
	AGD_PRE	1	1	1
پشتیبانی چرخه حیات	ALC_CMC	1	1	1
	ALC_CMS	2	2	2
	ALC_DEL			
	ALC_DVS			
	ALC_FLR			
	ALC_LCD			
	ALC_TAT			
ارزیابی هدف امنیتی	ASE_CCL	1	1	1
	ASE_ECD	1	1	1
	ASE_INT	1	1	1
	ASE_OBJ	1	2	2
	ASE_REQ	1	2	2
	ASE_SPD		1	1
	ASE_TSS	1	1	1

۸-۲ جزئیات بسته تضمین ترکیبی

بندهای فرعی زیر تعریف‌های CAPها، تفاوت‌های مشخص بین الزامات خاص و ویژگی‌های نوشته شده این الزامات که به صورت پررنگ مشخص شده‌اند را نشان می‌دهد.

۸-۳ سطح A تضمین ترکیب (CAP-A) - ساختار ترکیبی

۸-۳-۱ اهداف

CAP-A زمانی قابل کاربرد است که TOE ترکیب شده یکپارچه می شود و اطمینان در عملکرد امنیتی درست نتیجه ترکیبی نیاز می شود. این مساله به همکاری توسعه دهنده مؤلفه وابسته برای حمل اطلاعات طراحی و نتایج تست از تصدیق مؤلفه وابسته بدون اینکه به درگیری با توسعه دهنده مؤلفه پایه نیاز داشته باشد، نیاز دارد. بنابراین CAP-A در آن شرایطی قابل کاربرد است که توسعه دهندگان یا کاربران، نیاز کمی دارند که سطح امنیتی تضمین شده مستقل را در غیاب رکورد توسعه کامل و آماده، اداره کنند.

۸-۳-۲ مؤلفه های تضمین

CAP-A، تضمین را توسط تحلیل هدف امنیتی برای TOE ترکیبی فراهم می آورد. SFR ها در TOE ترکیبی ST با استفاده از خروجی هایی از ارزشیابی های TOE های مؤلفه (به عنوان مثال، ST، مستند راهنما) و ویژگی واسطه های بین TOE های مؤلفه در TOE ترکیبی برای فهم رفتار امنیتی، تحلیل می شوند. تحلیل به وسیله آزمایش مستقل واسطه های مبتنی بر مؤلفه پشتیبانی می شود که این واسطه ها توسط مؤلفه های وابسته پشتیبانی می شوند، همانطور که در اطلاعات مورد اعتماد شرح داده شد، شواهد آزمون توسعه دهنده، مبتنی بر اطلاعات قابل اعتماد، اطلاعات توسعه و اصول ترکیب، و اطلاعات مستقل اختیاری در مورد نتایج آزمون توسعه دهنده است.

همچنین تحلیل، توسط مرور آسیب پذیری های TOE ترکیبی توسط ارزیاب، پشتیبانی می شود. CAP-A همچنین، تضمینی را از طریق شناسایی منحصربه فرد TOE ترکیبی فراهم می کند. (به عنوان مثال، TOE فناوری اطلاعات و مستند راهنما).

جدول ۱۰ CAP-A

مؤلفه های تضمین	دسته تضمین
ACO_COR.1 اصول ترکیب	ACO: ترکیب
ACO_CCT.1 آزمون واسط	
ACO_DEV.1 شرح کارکرد	
ACO_REL.1 اطلاعات پایه ای	
ACO_VUL.1 رتوس کلی آسیب پذیری ترکیبی	
AGD_OPE.1 راهنمای عملی کاربر	AGD: مستندات راهنما
AGD_PRE.1 روال های آماده سازی	
ALC_CMC.1 برچسب زنی TOE	ALC: پشتیبانی چرخه حیات
ALC_CMS.1 قسمت های پوشش TOE CM	
ASE_CCL.1 مدعیات انطباق	ASE: ارزیابی هدف امنیتی
ASE_ECD.1 تعریف ترکیبات گسترش یافته	
ASE_INT.1 مقدمه	
ASE_OBJ.1 اهداف امنیتی محیط عملیاتی	

	ASE_REQ.1 الزامات امنیتی وضع شده
	ASE_TSS.1 خلاصه ویژگی های TOE

۸-۴ سطح B تضمین ترکیبی (CAP-B) - ترکیب شدن با قاعده

۸-۴-۱ اهداف

CAP-B در شرایطی که توسعه دهندگان یا کاربران نیاز به سطح متوسطی از امنیت تضمین شده مستقل دارند و به تحقیق کامل TOE ترکیبی و توسعه آن بدون مهندسی مجدد اساسی نیاز دارند به کار می رود.

۸-۴-۲ مؤلفه های تضمین

CAP-B، تضمین را به وسیله تحلیل هدف امنیتی کامل برای TOE ترکیبی، فراهم می کند. SFRها در STی TOE ترکیبی با استفاده از خروجی هایی از ارزشیابی های TOE های ترکیبی (به عنوان مثال، ST، مستند راهنما)، ویژگی واسطه های بین TOE های ترکیبی و طراحی TOE (شرح زیرسیستم های TSF) مندرج در اطلاعات توسعه ترکیبی برای فهم رفتار امنیتی، تحلیل می شوند.

تحلیل به وسیله آزمایش مستقل واسطه های مبتنی بر مؤلفه پشتیبانی می شود که این واسطه ها توسط مؤلفه های وابسته پشتیبانی می شوند، همانطور که در اطلاعات مورد اعتماد شرح داده شد (اکنون شامل طراحی TOE نیز می شود)، شواهد آزمون توسعه دهنده، مبتنی بر اطلاعات قابل اعتماد، اطلاعات توسعه و اصول ترکیب و اطلاعات مستقل اختیاری در مورد نتایج آزمون توسعه دهنده است. همچنین تحلیل، توسط تجزیه و تحلیل آسیب پذیری های TOE ترکیبی توسط ارزیاب، اثبات مقاومت در برابر مهاجمان دارای پتانسیل حمله ابتدایی، پشتیبانی می شود.

این CAP افزایش قابل ملاحظه ای در تضمین را از CAP-A توسط نیاز به آزمون کامل تر پوشش کارکرد امنیتی، نشان می دهد.

جدول ۱۱ CAP-B

دسته تضمین	مؤلفه های تضمین
ACO: ترکیب	ACO_COR.1 اصول ترکیب
	ACO_CCT.2 آزمون واسط بسیار دقیق
	ACO_DEV.2 شواهد مبنایی طراحی
	ACO_REL.1 اطلاعات پایه ای
	ACO_VUL.2 تحلیل آسیب پذیری ترکیبی
AGD: مستندات راهنما	AGD_OPE.1 راهنمای عملی کاربر
	AGD_PRE.1 روال های آماده سازی
ALC: پشتیبانی چرخه حیات	ALC_CMC.1 برچسب زنی TOE
	ALC_CMS.2 قسمت های پوشش CM TOE
ASE: ارزیابی هدف امنیتی	ASE_CCL.1 مدعیات انطباق
	ASE_ECD.1 تعریف ترکیبات گسترش یافته
	ASE_INT.1 مقدمه

	ASE_OBJ.2 اهداف امنیتی محیط عملیاتی
	ASE_REQ.2 الزامات امنیتی نتیجه شده
	تعریف مساله امنیتی ASE_SPD.1
	ASE_TSS.1 خلاصه ویژگی‌های TOE

۸-۵ سطح C تضمین ترکیبی (CAP-C)، آزمون، مرور و ترکیب باقاعده

۸-۵-۱ اهداف

CAP-A به توسعه‌دهنده اجازه می‌دهد که حداکثر تضمین را از تحلیل مثبت واکنش‌ها بین مؤلفه‌های TOE ترکیبی، که ، با وجود دقت زیاد، به‌دست‌رسی کامل به همه شواهد ارزشیابی مؤلفه پایه نیاز ندارند، به‌دست آورد. بنابراین CAP-C در همه محیط‌هایی که توسعه‌دهندگان یا کاربران نیاز به سطح متوسط تا بالایی از امنیت تضمین شده مستقل در محصول قراردادی TOE‌های ترکیبی دارند و موجب هزینه‌های مهندسی امنیت ویژه اضافی می‌شوند، به‌کار می‌رود.

۸-۵-۲ مؤلفه‌های تضمین

CAP-C، تضمین را توسط تحلیل هدف امنیتی کامل برای TOE ترکیبی فراهم می‌کند. SFRها در STی TOE ترکیبی با استفاده از خروجی‌های ارزشیابی‌های TOE‌های مؤلفه (به‌عنوان مثال، ST، مستند راهنما)، ویژگی‌های واسطه‌های بین TOE‌های مؤلفه و طراحی TOE (شرح پیمانه‌های TSF) مندرج در اطلاعات توسعه ترکیبی برای فهم رفتار امنیتی، تحلیل می‌شوند.

تحلیل به‌وسیله آزمایش مستقل واسطه‌های مبتنی بر مؤلفه پشتیبانی می‌شود که این واسطه‌ها توسط مؤلفه‌های وابسته پشتیبانی می‌شوند، همانطور که در اطلاعات مورد اعتماد شرح داده شد (اکنون شامل طراحی TOE نیز می‌شود)، شواهد آزمون توسعه‌دهنده، مبتنی بر اطلاعات قابل اعتماد، اطلاعات توسعه و اصول ترکیب و اطلاعات مستقل اختیاری در مورد نتایج آزمون توسعه‌دهنده است. همچنین، این تحلیل، توسط تجزیه و تحلیل آسیب‌پذیری TOE ترکیبی به‌وسیله مقاومت اثبات شده ارزیاب در برابر حمله‌ها با نیروی بالقوه حمله‌ی پیشرفته، پشتیبانی می‌شود.

این CAP، افزایش قابل ملاحظه‌ای را در تضمین از CAP-B توسط نیاز به شرح بیشتر طراحی و اثبات مقاومت در برابر یک حمله بالقوه قوی، نشان می‌دهد.

جدول ۱۲ CAP-C

مؤلفه‌های تضمین	دسته تضمین
ACO_COR.1 اصول ترکیب	ACO: ترکیب
ACO_CCT.2 آزمون واسط بسیار دقیق	
ACO_DEV.3 شواهد جزئی طراحی	
ACO_REL.2 اطلاعات مورد اتکا	
ACO_VUL.3 تحلیل آسیب‌پذیری ترکیبی تسهیلاتی پایه‌ای	
AGD_OPE.1 راهنمای عملی کاربر	AGD: مستندات راهنما

	AGD_PRE.1 روال‌های آماده‌سازی
ALC: پشتیبانی چرخه حیات	ALC_CMC.1 برچسب‌زنی TOE
	ALC_CMS.2 قسمت‌های پوشش TOE CM
ASE: ارزیابی هدف امنیتی	ASE_CCL.1 مدعیات انطباق
	ASE_ECD.1 تعریف ترکیبات گسترش‌یافته
	ASE_INT.1 مقدمه
	ASE_OBJ.2 اهداف امنیتی محیط عملیاتی
	ASE_REQ.2 الزامات امنیتی نتیجه شده
	ASE_SPD.1 تعریف مسأله امنیتی
	ASE_TSS.1 خلاصه ویژگی‌های TOE

۹ دسته APE: ارزشیابی پروفایل محافظت

ارزشیابی PP برای اثبات اینکه PP سالم و از نظر درونی یکپارچه است، نیاز می‌شود و همچنین این ارزشیابی اگر PP مبتنی بر یک یا بیشتر از ppهای دیگر یا بسته‌هایی باشد که PP دلیل صحت این PPها و بسته‌ها است نیاز می‌شود.



شکل ۸-APE: تجزیه دسته ارزشیابی پروفایل محافظت

این بند باید در ارتباط با پیوست الف، ب و پ در قسمت اول استاندارد ISO/IEC15408 استفاده شود، این بندها بسیاری از مفاهیم را توضیح می‌دهند و مثال‌های زیادی ارائه می‌کنند. شکل ۸ خانواده‌های درون این دسته، و سلسله مراتب مؤلفه‌های درون این خانواده‌ها را نشان می‌دهد.

۹-۱ مقدمه PP (APE_INT)

۹-۱-۱ اهداف

هدف این خانواده شرح TOE به صورت روایت است. ارزشیابی مقدمه PP برای اثبات اینکه PP به شکلی صحیح شناسایی شده است و منبع PP و رئیس کلی TOE با یکدیگر سازگار هستند، نیاز می شود.

۹-۱-۲ مقدمه PP APE_INT.1

وابستگی ها: هیچ وابستگی ای وجود ندارد.

۹-۱-۲-۱ عناصر عمل توسعه دهنده

۹-۱-۲-۱-۱ APE_INT.1.1D

توسعه دهنده باید مقدمه PP را فراهم کند.

۹-۱-۲-۲ عناصر تشکیل دهنده و ارائه کننده

۹-۱-۲-۲-۱ APE_INT.1.1C

مقدمه PP باید شامل منبع PP و رئیس کلی TOE باشد.

۹-۱-۲-۲-۲ APE_INT.1.2C

منبع PP باید به شکلی منحصر به فرد PP را شناسایی کند.

۹-۱-۲-۲-۳ APE_INT.1.3C

رئیس کلی TOE باید خلاصه ای از کاربرد و خصوصیات مهم امنیتی TOE باشد.

۹-۱-۲-۲-۴ APE_INT.1.4C

رئیس کلی TOE باید نوع TOE را مشخص کند.

۹-۱-۲-۲-۵ APE_INT.1.5C

رئیس کلی TOE باید هر نرم افزار / سخت افزار / میان افزار غیر TOE یی را نسبت به TOE مشخص کند.

۹-۱-۳ عناصر عمل ارزیاب

ارزیاب باید تأیید کند که اطلاعات فراهم شده، همه الزامات را برای شواهد ارائه کننده و تشکیل دهنده مدرک دارند.

۹-۲ ادعاهای تطبیق (APE_CCL)

۹-۲-۱ اهداف

هدف این خانواده تعیین اعتبار ادعای انطباق است. علاوه بر این، این خانواده که چطور ST و دیگر PP ها باید مدعی انطباق با PP باشند.

۹-۲-۲ ادعاهای تطبیق APE_CCL.1

وابستگی ها: مقدمه PP APE_INT.1

۹-۲-۲-۱ عناصر اقدام توسعه دهنده

APE_CCL.1.1D۱-۱-۲-۲-۹

توسعه‌دهنده باید ادعای انطباق را فراهم کند.

APE_CCL.1.2D۲-۱-۲-۲-۹

توسعه‌دهنده باید اصول انطباق را فراهم کند.

APE_CCL.1.3D۳-۱-۲-۲-۹

توسعه‌دهنده باید وضعیت انطباق را فراهم کند.

۹-۲-۲-۲ عناصر تشکیل‌دهنده و ارائه کننده

APE_CCL.1.1.C ۱-۲-۲-۲-۹

ادعای انطباق، باید شامل انطباق استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ باشد که نسخه استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ را به انطباق سند PP معرفی می‌کند.

APE_CCL.1.2C۲-۲-۲-۲-۹

ادعای انطباق استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸، باید انطباق سند PP را با قسمت دوم استاندارد یا قسمت دوم استاندارد توسعه‌داده شده، شرح دهد.

APE_CCL.1.3C ۳-۲-۲-۲-۹

ادعای انطباق استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸، باید انطباق سند PP را با قسمت تأیید شده استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ یا قسمت گسترش‌یافته استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ شرح دهد.

APE_CCL.1.4C۴-۲-۲-۲-۹

ادعای انطباق استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ باید با تعریف مؤلفه‌های گسترش‌یافته، سازگار باشد.

APE_CCL.1.5C۵-۲-۲-۲-۹

ادعای انطباق، باید همه PPها و بسته‌های الزامات امنیتی را که PP مدعی انطباق با آن است شناسایی کند.

APE_CCL.1.6C۶-۲-۲-۲-۹

ادعای انطباق، باید هر گونه انطباق PP را با بسته‌های تأیید یا بسته‌های اضافه‌شده شرح دهد.

APE_CCL.1.7C۷-۲-۲-۲-۹

اصول ادعای انطباق، باید اثبات کند که نوع TOE با نوع TOE در PPهایی که مدعی انطباق‌شان هستیم سازگار است.

APE_CCL.1.8C۸-۲-۲-۲-۹

اصول ادعای انطباق باید اثبات کند که حالت تعریف مسأله امنیت، با حالت تعریف مسأله امنیت در PPهایی که مدعی انطباق‌شان هستیم سازگار است.

APE_CCL.1.9C ۹-۲-۲-۲-۹

اصول ادعای انطباق، باید اثبات کند که اهداف امنیتی، با اهداف امنیتی در PP هایی که مدعی انطباقشان هستیم سازگار هستند.

APE_CCL.1.10C ۱۰-۲-۲-۲-۹

اصول ادعای انطباق، باید اثبات کند که الزامات امنیتی با الزامات امنیتی در PP هایی که مدعی انطباقشان هستیم سازگار است.

APE_CCL.1.11C ۱۱-۲-۲-۲-۹

وضعیت انطباق، باید انطباق مورد نیاز هر PP/ST را با PP به عنوان انطباق اکید PP یا PP قابل اثبات، شرح دهد.

۳-۲-۲-۹ عناصر عمل ارزیاب

APE_CCL.1.1E ۱-۳-۲-۲-۹

ارزیاب باید تأیید کند که اطلاعات فراهم شده، همه الزامات لازم برای محتوای مدرک و ارائه آن را دارند.

۳-۹ تعریف مسأله امنیت (APE_SPD)

۱-۳-۹ اهداف

این قسمت از سند PP، مسأله امنیت را توسط TOE و محیط عمل TOE نشان می دهد. ارزشیابی تعریف مسأله امنیت، برای اثبات اینکه مسأله امنیت مورد نظر توسط TOE و محیط عملش، به طور واضح تعریف می شود مورد نیاز است.

۲-۳-۹ تعریف مسأله امنیت APE_SPD.1

وابسته ها: هیچ وابستگی ای وجود ندارد.

۱-۲-۳-۹ مؤلفه های عمل توسعه دهنده

APE_SPD.1.1D ۱-۲-۲-۳-۹

توسعه دهنده باید تعریف مسأله امنیت را فراهم آورد.

۲-۲-۳-۹ مؤلفه های محتوا و ارائه

APE_SPD.1.1C ۱-۲-۲-۳-۹

تعریف مسأله امنیت باید تهدیدات را شرح دهد.

APE_SPD.1.2C ۲-۲-۲-۳-۹

همه تهدیدات اعم از عامل تهدید، تهدید دارایی و اقدامات خسارت بار باید شرح داده شوند.

APE_SPD.1.3C ۳-۲-۲-۳-۹

تعریف مسأله امنیت باید OSP ها را شرح دهد.

APE_SPD.1.4C ۴-۲-۲-۳-۹

تعریف مسأله امنیتی باید مفروضات محیط عملیاتی TOE را شرح دهد.

۹-۳-۲-۳ عناصر عمل ارزیاب

۱-۳-۲-۳-۹ APE_SPD.1.1E

ارزیاب باید تأیید کند که اطلاعات فراهم شده، همه الزامات را برای محتوای مدرک و ارائه آن دارند.

۹-۴ اهداف امنیتی (APE_OBJ)

۹-۴-۱ اهداف

اهداف امنیتی، خلاصه توضیحی از پاسخ به مسأله امنیتی تعریف شده از طریق خانواده تعریف مسأله امنیتی (APE_SPD) هستند.

ارزشیابی اهداف امنیتی باید نشان دهد که اهداف امنیتی به صورت مناسب و کامل تعریف مشکل امنیتی را مورد توجه قرار داده است و تفکیک این مشکل میان TOE و محیط عملیاتی آن به صورت واضح تعریف شده است.

۹-۴-۲ سطح بندی مؤلفه

مؤلفه‌ها در این خانواده بر این اساس سطح بندی می‌شوند که آیا تنها اهداف امنیتی را برای محیط عملیاتی تعیین می‌کنند یا برای اهداف امنیتی TOE نیز تعیین می‌کنند.

۹-۴-۳ اهداف امنیتی APE_OBJ.1 برای محیط عملیاتی

وابسته‌ها: وابستگی‌ای وجود ندارد.

۹-۴-۳-۱ مؤلفه‌های عمل توسعه دهنده

۹-۴-۳-۱-۱ APE_OBJ.1.1D

توسعه دهنده باید توضیحات مربوط به اهداف امنیتی را فراهم کند.

۹-۴-۳-۲ مؤلفه‌های محتوا و ارائه

۹-۴-۳-۲-۱ APE_OBJ.1.1C

وضعیت اهداف امنیتی باید اهداف امنیتی را برای محیط عملیاتی شرح دهد.

۹-۴-۳-۳ مؤلفه‌های عمل ارزیاب

۹-۴-۳-۳-۱ APE_OBJ.1.1E

ارزیاب باید تأیید کند که اطلاعات فراهم شده همه الزامات را برای محتوای مدرک و ارائه آن دارند.

۹-۴ اهداف امنیتی APE_OBJ.2

وابسته‌ها: تعریف مسأله امنیتی APE_SPD.1

۹-۴-۴-۱ مؤلفه‌های عمل توسعه دهنده

۹-۴-۴-۱-۱ APE_OBJ.2.1D

توسعه دهنده باید توضیحات مربوط به اهداف امنیتی را فراهم کند.

APE_OBJ.2.2D۲-۱-۴-۴-۹

توسعه‌دهنده باید اصول اهداف امنیتی را فراهم کند.

۲-۴-۴-۹ مؤلفه‌های محتوا و ارائه

APE_OBJ.2.1C۱-۲-۴-۴-۹

سند توضیح اهداف امنیتی باید اهداف امنیتی را برای TOE و محیط عملیاتی، شرح دهد.

APE_OBJ.2.2C۲-۲-۴-۴-۹

اصول اهداف امنیتی باید هر هدف امنیتی را برای پشتیبانی TOE در برابر تهدیدات به‌وجود آمده به‌وسیله هدف امنیتی و OSP‌های اجرا شده به‌وسیله آن هدف امنیتی، دنبال کند.

APE_OBJ.2.3C۳-۲-۴-۴-۹

اصول اهداف امنیتی، باید هر هدف امنیتی را برای پشتیبانی محیط عملیاتی در برابر تهدیدات به‌وجود آمده به‌وسیله هدف امنیتی، OSP‌های اجرا شده به‌وسیله آن هدف امنیتی و فرضیات تأکیدشده به‌وسیله آن هدف امنیتی، دنبال کند.

APE_OBJ.2.4C۴-۲-۴-۴-۹

اصول اهداف امنیتی باید اثبات کند که اهداف امنیتی با همه تهدیدات مقابله می‌کنند.

APE_OBJ.2.5C۵-۲-۴-۴-۹

اصول اهداف امنیتی باید اثبات کنند که اهداف امنیتی، همه OSP‌ها را اجرا می‌کنند.

APE_OBJ.2.6C۶-۲-۴-۴-۹

اصول اهداف امنیتی باید اثبات کنند که اهداف امنیتی همه مفروضات را برای محیط عملیاتی، پشتیبانی می‌کنند.

۳-۴-۴-۹ عناصر عمل ارزیاب

APE_OBJ.2.1E۱-۳-۴-۴-۹

ارزیاب باید تأیید کند که اطلاعات فراهم‌شده، همه الزامات را برای محتوای مدرک و ارائه آن دارند.

۵-۹ تعریف مؤلفه‌های توسعه‌یافته (APE_ECD)

۱-۵-۹ اهداف

الزامات امنیتی توسعه‌یافته، الزاماتی هستند که نه بر پایه مؤلفه‌های قسمت دوم استاندارد استاندارد ملی ایران- ایزو-آی‌ای‌سی ۱۵۴۰۸ هستند و نه بر پایه این قسمت از این مجموعه استاندارد ملی، بلکه بر اساس مؤلفه‌های توسعه‌یافته هستند: مؤلفه‌هایی که توسط مولف PP تعریف شده‌اند.

ارزشیابی تعریف مؤلفه‌های توسعه‌یافته، برای تعیین اینکه آن‌ها واضح و بدون ابهام هستند، و اینکه این مؤلفه‌ها ضروری هستند، به‌عنوان مثال، آن‌ها ممکن است که به‌شکل واضحی استفاده از مؤلفه‌های قسمت دوم استاندارد یا این قسمت از این مجموعه استاندارد ملی را بیان نکنند، لازم است.

۹-۵-۲ تعریف مؤلفه‌های توسعه‌یافته APE_ECD.1

وابسته‌ها: وابسته‌ای وجود ندارد.

۹-۵-۲-۱ مؤلفه‌های عمل توسعه‌دهنده

۹-۵-۲-۱-۱ APE_ECD.1.1D1

توسعه‌دهنده باید شرح الزامات امنیتی را فراهم نماید.

۹-۵-۲-۱-۲ APE_ECD.1.2D2

توسعه‌دهنده باید تعریف مؤلفه‌های توسعه یافته را فراهم نماید.

۹-۵-۲-۲ مؤلفه‌های ارائه و محتوا

۹-۵-۲-۲-۱ APE_ECD.1.1C1

سند شرح الزامات امنیتی باید همه الزامات امنیتی توسعه یافته را تعریف کند.

۹-۵-۲-۲-۲ APE_ECD.1.2C2

تعریف مؤلفه‌های توسعه‌یافته، باید مؤلفه توسعه‌یافته را برای هر الزام امنیتی توسعه‌یافته تعریف کند.

۹-۵-۲-۲-۳ APE_ECD.1.3C3

تعریف مؤلفه‌های توسعه‌یافته باید شرح دهد که چطور هر مؤلفه توسعه‌یافته به دسته‌ها، خانواده‌ها و مؤلفه‌های موجود در استاندارد، مرتبط می‌شوند.

۹-۵-۲-۲-۴ APE_ECD.1.4C4

سند تعریف مؤلفه‌های توسعه‌یافته باید از روش‌شناسی، دسته‌ها، خانواده‌ها و مؤلفه‌های موجود در استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ به‌عنوان مدلی برای ارائه، استفاده نماید.

۹-۵-۲-۲-۵ APE_ECD.1.5C5

مؤلفه‌های توسعه‌یافته باید دارای عناصر هدف و قابل اندازه‌گیری باشند به‌طوری که انطباق یا عدم انطباق با این عناصر قابل اثبات باشد.

۹-۵-۳ مؤلفه‌های عمل ارزیاب

۹-۵-۳-۱ APE_ECD.1.1E1

ارزیاب باید تأیید کند که اطلاعات فراهم‌شده، همه الزامات را برای محتوای مدرک و ارائه آن دارند.

۹-۵-۳-۲ APE_ECD.1.2E2

ارزیاب باید تأیید کند که ممکن است هیچ مؤلفه بسط یافته‌ای با استفاده از مؤلفه‌های موجود به صورت روشن بیان نشود.

۹-۶ الزامات امنیتی (APE_REQ)

۹-۶-۱ اهداف

SFRها، شرحی شناخته شده، بدون ابهام و شفاف از رفتار امنیتی را شکل می دهد که از TOE انتظار می رود. SARها، توضیح شناخته شده، بدون ابهام و شفاف از فعالیت های مورد انتظاری است که برای به دست آوردن تضمین در TOE، متعهد می شود را شکل می دهد. ارزشیابی الزامات امنیتی برای تضمین اینکه این الزامات، شفاف، بدون ابهام و شناخته شده هستند ضروری است.

۹-۶-۲ سطح بندی مؤلفه

مؤلفه ها در این خانواده بر اساس اینکه آیا همان طور که هستند شرح داده می شوند، یا اینکه SFRها بر اساس اهداف امنیتی که برای TOE است نتیجه گرفته شده اند، سطح بندی می شوند.

۹-۶-۳ الزامات امنیتی وضع شده APE_REQ.1

وابسته ها: تعریف مؤلفه های توسعه یافته APE_ECD.1

۹-۶-۳-۱ عناصر عمل توسعه دهنده

۹-۶-۳-۱-۱ APE_REQ.1.1D

توسعه دهنده باید سند توضیح الزامات امنیتی را فراهم کند.

۹-۶-۳-۱-۲ APE_REQ.1.2D

توسعه دهنده باید اصول الزامات امنیتی را فراهم کند.

۹-۶-۳-۲ عناصر محتوا و ارائه

۹-۶-۳-۲-۱ APE_REQ.1.1C

سند توضیح الزامات امنیتی باید SFRها و SARها را شرح دهد.

۹-۶-۳-۲-۲ APE_REQ.1.2C

همه موضوعات، اهداف، عملیات ها، ویژگی های امنیتی، موجودیت های بیرونی و دیگر اصطلاحاتی که در SFRها و SARها استفاده می شوند باید تعریف شوند.

۹-۶-۳-۲-۳ APE_REQ.1.3C

شرح الزامات امنیتی باید تمامی عملیات های صورت گرفته بر روی الزامات امنیتی را شناسایی کند.

۹-۶-۳-۲-۴ APE_REQ.1.4C

کلیه عملیات ها باید به شکل صحیح انجام شوند.

۹-۶-۳-۲-۵ APE_REQ.1.5C

هر مسأله وابسته به الزامات امنیتی یا باید برآورده شود یا اساس الزامات امنیتی باید برآورده نشدن وابستگی را توجیه کند.

APE_REQ.1.6C۶-۲-۳-۶-۹

سند شرح الزامات امنیتی باید از نظر درونی یکپارچه و سازگار باشد.

۳-۳-۶-۹ عناصر عمل ارزیاب

APE_REQ.1.1E۱-۳-۳-۶-۹

ارزیاب باید تأیید کند که اطلاعات فراهم شده همه الزامات را برای محتوای مدرک و ارائه آن دارند.

APE_REQ.2.۴-۶-۹ الزامات امنیتی استنتاج شده APE_REQ.2

وابسته‌ها: اهداف امنیتی APE_OBJ.2

تعریف مؤلفه‌های توسعه یافته APE_ECD.1

۱-۴-۶-۹ عناصر عمل توسعه دهنده

APE_REQ.2.1D۱-۱-۴-۶-۹

توسعه دهنده باید سند شرح الزامات امنیتی را فراهم نماید.

APE_REQ.2.2D۲-۱-۴-۶-۹

توسعه دهنده باید اصول الزامات امنیتی را فراهم نماید.

۲-۴-۶-۹ عناصر محتوا و ارائه

APE_REQ.2.1C۱-۲-۴-۶-۹

سند شرح الزامات امنیتی باید SFRها و SARها را شرح دهد.

APE_REQ.2.2C۲-۲-۴-۶-۹

همه موضوعات، اهداف، عملیات‌ها، ویژگی‌های امنیتی، موجودیت‌های بیرونی و دیگر اصطلاحاتی که در SFRها و SARها استفاده می‌شوند باید تعریف شوند.

APE_REQ.2.3C۳-۲-۴-۶-۹

سند شرح الزامات امنیتی، باید کلیه عملیات‌های صورت گرفته بر روی الزامات امنیتی را مشخص نماید.

APE_REQ.2.4C۴-۲-۴-۶-۹

تمامی عملیات‌ها باید به شکل صحیح انجام شوند.

APE_REQ.2.5C۵-۲-۴-۶-۹

هر مسأله وابسته به الزامات امنیتی یا باید برآورده شود یا اساس الزامات امنیتی باید برآورده نشدن وابستگی را توجیه کند.

APE_REQ.2.6C۶-۲-۴-۶-۹

اصول الزامات امنیتی باید هرگونه پشتیبانی SFR از اهداف امنیتی TOE را ردیابی کند.

APE_REQ.2.7C۷-۲-۴-۶-۹

اصول الزامات امنیتی، باید اثبات کند که SFRها همه اهداف امنیتی برای TOE را دارند.

APE_REQ.2.8C۸-۲-۴-۶-۹

اصول الزامات امنیتی باید توضیح دهد که چرا SARها انتخاب می‌شوند.

APE_REQ.2.9C۹-۲-۴-۶-۹

سند شرح الزامات امنیتی باید از نظر درونی یکپارچه و سازگار باشد.

۳-۴-۶-۹ عناصر عمل ارزیاب

APE_REQ.2.1E۱-۳-۴-۶-۹

ارزیاب باید تأیید کند که اطلاعات فراهم‌شده، همه الزامات را برای محتوای مدرک و ارائه آن دارند.

۱۰ دسته ASE: ارزشیابی هدف امنیتی

برای اینکه اثبات کنیم که ST درست و از نظر درونی یکپارچه و سازگار است و نیز اگر ST بر اساس یکی یا بیش از یک بسته PP است و اینکه آن ST یک نصب درست از آن بسته‌های PP است به ارزشیابی ST نیاز است. اگر بخواهیم که ST به‌عنوان اساسی برای ارزشیابی TOE، مناسب باشد، این ویژگی‌ها لازم هستند. این بند با پیوست‌های الف، ب و پ در قسمت اول استاندارد استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ در ارتباط است. این پیوست‌ها مفاهیمی که در اینجا مطرح می‌شود را روشن‌تر می‌سازند و دارای مثال‌های فراوانی در این زمینه هستند.

شکل ۹، خانواده‌های درون این دسته، و سلسله مراتب مؤلفه‌های درون این خانواده‌ها را نشان می‌دهد.



شکل ۹-ASE: تجزیه دسته ارزشیابی هدف امنیتی

۱۰-۱-۱ مقدمه ST (ASE_INT)

۱۰-۱-۱ اهداف

هدف این خانواده، تعریف TOE در سه سطح انتزاعی است: منبع TOE، دیدگاه کلی TOE و شرح TOE. برای اثبات اینکه ST و TOE به درستی مشخص شده‌اند، و TOE به درستی در سه سطح انتزاعی شرح داده شده است و این سه شرح با یکدیگر سازگار هستند، به ارزشیابی مقدمه ST نیاز داریم.

۱۰-۱-۲ ST مقدمه ASE_INT

وابسته‌ها: هیچ وابسته‌ای وجود ندارد.

۱۰-۱-۲-۱ عناصر عمل توسعه دهنده

۱۰-۱-۲-۱-۱ ASE_INT.1.1D

توسعه دهنده باید مقدمه ST را فراهم کند.

۱۰-۱-۲-۲ عناصر محتوی و ارائه

۱۰-۱-۲-۲-۱ ASE_INT.1.1C

مقدمه ST، باید شامل منبع ST، منبع TOE، رئوس کلی TOE و شرح TOE باشد.

۱۰-۱-۲-۲-۲ ASE_INT.1.2C

منبع ST باید ST را به شکلی منحصر به فرد مشخص نماید.

۱۰-۱-۲-۲-۳ ASE_INT.1.3C

منبع TOE باید TOE را شناسایی کند.

۱۰-۱-۲-۲-۴ ASE_INT.1.4C

رئوس کلی TOE باید ویژگی‌های امنیتی مهم و کاربردی TOE را خلاصه نماید.

۱۰-۱-۲-۲-۵ ASE_INT.1.5C

رئوس کلی TOE باید نوع TOE را شناسایی کند.

۱۰-۱-۲-۲-۶ ASE_INT.1.6C

رئوس کلی TOE باید هر سخت افزار / نرم افزار / میان افزار غیر TOE یی را که مورد نیاز TOE است را مشخص کند.

۱۰-۱-۲-۲-۷ ASE_INT.1.7C

شرح TOE باید دامنه فیزیکی TOE را شرح دهد.

۱۰-۱-۲-۲-۸ ASE_INT.1.8C

شرح TOE باید دامنه منطقی TOE را شرح دهد.

۱۰-۱-۲-۳ عناصر عمل ارزیاب

ASE_INT.1.1E ۱-۳-۲-۱-۱۰

ارزیاب باید تأیید کند که اطلاعات فراهم شده همه الزامات محتوای مدرک و ارائه آن را دارند.

ASE_INT.1.2E ۲-۳-۲-۱-۱۰

ارزیاب باید تأیید کند که منبع TOE، رئوس کلی TOE و شرح TOE با یکدیگر سازگار هستند.

۱۰-۲ ادعاهای انطباق (ASE_CCL)

۱۱-۲-۱ اهداف

هدف این خانواده تعیین اعتبار ادعای انطباق است. علاوه بر این، این خانواده مشخص می‌کند که چطور STها مدعی انطباق با PP هستند.

ASE_CCL.1 ۲-۲-۱۰ مدعیات انطباق

وابسته‌ها: مقدمه ASE_INT.1 ST

تعریف مؤلفه‌های توسعه یافته ASE_ECD

الزامات امنیتی وضع شده ASE_REQ.1

۱۰-۲-۲-۱ عناصر عمل توسعه دهنده

ASE_CCL.1.1D ۱-۱-۲-۲-۱۰

توسعه دهنده باید سند ادعای انطباق را فراهم نماید.

ASE_CCL.1.2D ۲-۱-۲-۲-۱۰

توسعه دهنده باید اصول ادعای انطباق را فراهم نماید.

۱۰-۲-۲-۲ عناصر محتوی و ارائه

ASE_CCL.1.1C ۱-۲-۲-۲-۱۰

ادعای انطباق باید در برگیرنده ادعای انطباق مجموعه استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ باشد که این نسخه استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ که ادعای انطباق با ST و TOE را دارند شناسایی می‌کند.

ASE_CCL.1.2C ۲-۲-۲-۲-۱۰

سند ادعای انطباق استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ باید انطباق ST را با قسمت دوم استاندارد، چه با قسمتی که کاملاً منطبق با قسمت دوم استاندارد است و چه با قسمت دوم توسعه یافته استاندارد، شرح دهد.

ASE_CCL.1.3C ۳-۲-۲-۲-۱۰

سند ادعای انطباق استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ باید انطباق ST را با این قسمت از این مجموعه استاندارد ملی استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸، چه با قسمتی که کاملاً منطبق با این قسمت استاندارد است و چه با این قسمت توسعه یافته استاندارد، شرح دهد.

ASE_CCL.14C ۴-۲-۲-۲-۱۰

سند ادعای انطباق استاندارد ملی ایران-ایزو-آی‌ای سی ۱۵۴۰۸ باید با تعریف مؤلفه‌های توسعه یافته سازگار باشد.

ASE_CCL.1.5C ۵-۲-۲-۲-۱۰

سند ادعای انطباق، باید همه PPها و بسته‌های الزام امنیتی که ادعای انطباق با ST را دارند مشخص کند.

ASE_CCL.1.6C ۶-۲-۲-۲-۱۰

سند ادعای انطباق، باید هر گونه انطباق ST با بسته را چه این بسته، منطبق یافته باشد و چه توسعه یافته، شرح دهد.

ASE_CCL.1.7C ۷-۲-۲-۲-۱۰

اصول ادعای انطباق، باید اثبات کند که نوع TOE با نوع TOE در PPهایی که انطباق آن‌ها ادعا می‌شود سازگار است.

ASE_CCL.1.8C ۸-۲-۲-۲-۱۰

اصول ادعای انطباق، باید اثبات نماید که سند شرح تعریف مسأله امنیتی، با همین سند در PPهایی که انطباق‌شان ادعا می‌شود سازگار است.

ASE_CCL.1.9C ۹-۲-۲-۲-۱۰

اصول ادعای انطباق، باید اثبات کند که سند شرح اهداف امنیتی، با همین سند در PPهایی که انطباق‌شان ادعا می‌شود سازگار است.

ASE_CCL.1.1C ۱۰-۲-۲-۲-۱۰

اصول ادعای انطباق باید اثبات کند که سند شرح الزامات امنیتی، با همین سند در PPهایی که انطباق‌شان ادعا می‌شود سازگار است.

۳-۲-۲-۲-۱۰ عناصر عمل ارزیاب

ASE_CCL.1.1E ۱-۳-۲-۲-۱۰

ارزیاب باید تأیید کند که اطلاعات فراهم شده، همه الزامات را برای محتوای مدرک و ارائه آن دارند.

۳-۱۰ تعریف مسأله امنیت (ASE_SPD)

۱۱-۳-۱۰ اهداف

این قسمت از ST، مسأله امنیت را توسط TOE و محیط عملیاتی TOE تعریف می‌کند. برای ارزشیابی تعریف مسأله امنیتی باید اثبات کنیم که مسأله امنیتی مورد نظر که توسط TOE و محیط عملیاتی‌اش مورد توجه قرار گرفته شده‌اند، به‌وضوح تعریف شده‌اند.

۲-۳-۱۰ تعریف مسأله امنیتی ASE_SPD.1

وابسته‌ها: هیچ وابستگی‌ای وجود ندارد.

۱۰-۳-۱-۱ عناصر عمل توسعه‌دهنده

ASE_SPD.1.1D ۱-۱-۲-۳-۱۰

توسعه‌دهنده باید تعریف مسأله امنیتی را فراهم کند.

۱۰-۳-۲-۱ عناصر ارائه و محتوی

ASE_SPD.1.1C ۱-۲-۲-۳-۱۰

تعریف مسأله امنیتی باید تهدیدات را شرح دهد.

ASE_SPD.1.2C ۲-۲-۲-۳-۱۰

همه تهدیدات اعم از عامل تهدید، دارایی، و فعالیت خسارت‌بار باید شرح داده شوند.

ASE_SPD.1.3C ۳-۲-۲-۳-۱۰

تعریف مسأله امنیتی باید OSPها را شرح دهد.

ASE_SPD.1.4C ۴-۲-۲-۳-۱۰

تعریف مسأله امنیتی باید همه مفروضات را درباره محیط عملیاتی TOE شرح دهد.

۱۰-۳-۳-۱ عناصر عمل ارزیاب

ASE_SPD.1.1E ۱-۳-۲-۳-۱۰

ارزیاب باید تأیید کند که اطلاعات فراهم شده، همه الزامات را برای محتوای مدرک و ارائه آن دارند.

۱۰-۴ اهداف امنیتی (ASE_OBJ)

۱۰-۴-۱ اهداف

اهداف امنیتی یک توضیح مختصر از پاسخ به مسأله امنیتی تعریف شده از طریق خانواده تعریف مسأله امنیتی (ASE_SPD) است.

برای ارزشیابی اهداف امنیتی باید اثبات کنیم که اهداف امنیتی به شکل کافی و کامل، تعریف مسأله امنیتی را نشان می‌دهند که تقسیم این مسأله، بین TOE و محیط عملیاتی‌اش به طور واضح تعریف شده است.

۱۰-۴-۲ سطح‌بندی مؤلفه

مؤلفه‌ها در این خانواده بر اساس اینکه آیا اهداف امنیتی را تنها برای محیط عملیاتی تعیین می‌کنند یا برای TOE نیز تعیین می‌کنند، سطح‌بندی می‌شوند.

۱۰-۴-۳ اهداف امنیتی برای محیط عملیاتی ASE_OBJ.1

وابسته‌ها: هیچ وابستگی‌ای وجود ندارد.

۱۰-۳-۴ عناصر عمل توسعه‌دهنده

ASE_OBJ.1.1D ۱-۱-۳-۴-۱۰

توسعه‌دهنده باید سند شرح اهداف امنیتی را فراهم کند.

۱۰-۴-۳-۲ عناصر ارائه و محتوی

ASE_OBJ.1.1C ۱-۲-۳-۴-۱۰

سند شرح اهداف امنیتی باید اهداف امنیتی را برای محیط عملیاتی شرح دهد.

۱۰-۴-۳-۳ عناصر عمل ارزیاب

ASE_OBJ.1.1E ۱-۳-۳-۴-۱۰

ارزیاب باید تأیید کند که اطلاعات فراهم شده، همه الزامات را برای محتوای مدرک و ارائه آن دارند.

ASE_OBJ.2 ۴-۴-۱۰ اهداف امنیتی

وابسته‌ها: تعریف مساله امنیتی ASE_SPD.1

۱۰-۴-۴-۱ عناصر عمل توسعه‌دهنده

ASE_OBJ.2.1D ۱-۱-۴-۴-۱۰

توسعه‌دهنده باید سند شرح اهداف امنیتی را فراهم کند.

ASE_OBJ.2.2D ۲-۱-۴-۴-۱۰

توسعه‌دهنده باید اصول اهداف امنیتی را فراهم کند.

۱۰-۴-۴-۲ عناصر ارائه و محتوا

ASE_OBJ.2.1C ۱-۲-۴-۴-۱۰

شرح اهداف امنیتی، باید اهداف امنیتی را برای TOE و محیط عملیاتی، شرح دهد.

ASE_OBJ.2.2C ۲-۲-۴-۴-۱۰

اصول اهداف امنیتی، باید هر هدف امنیتی را برای پشتیبانی از TOE در برابر تهدیدات به‌وجود آمده به‌وسیله هدف امنیتی،OSPهای اجرا شده به‌وسیله آن هدف امنیتی،دنبال کند.

ASE_OBJ.2.3C ۳-۲-۴-۴-۱۰

اصول اهداف امنیتی، باید هر هدف امنیتی را برای پشتیبانی محیط عملیاتی در برابر تهدیدات به‌وجود آمده به‌وسیله هدف امنیتی،OSPهای اجرا شده به‌وسیله آن هدف امنیتی و فرضیات تأکیدشده به‌وسیله آن هدف امنیتی،دنبال کند.

ASE_OBJ.2.4C ۴-۲-۴-۴-۱۰

اصول اهداف امنیتی باید اثبات کند که اهداف امنیتی در برابر همه تهدیدات می‌ایستند.

ASE_OBJ.2.5C ۵-۲-۴-۴-۱۰

اصول اهداف امنیتی باید اثبات کند که اهداف امنیتی، همه OSPها را اجرا می‌کنند.

۱۰-۴-۲-۶ ASE_OBJ.2.6C

اصول اهداف امنیتی باید اثبات کنند که اهداف امنیتی از همه مفروضات محیط عملیاتی پشتیبانی می‌کنند.

۱۰-۴-۳ عناصر عمل ارزیاب

۱۰-۴-۳-۱ ASE_OBJ.2.1E

ارزیاب باید تأیید کند که اطلاعات فراهم‌شده، همه الزامات را برای محتوای مدرک و ارائه آن دارند.

۱۰-۵ تعریف مؤلفه‌های توسعه‌یافته (ASE_ECD)

۱۰-۵-۱ اهداف

الزامات امنیتی توسعه‌یافته، الزاماتی هستند که مبتنی بر مؤلفه‌های استاندارد ملی ایران-ایزو-آی‌سی ۲-۱۵۴۰۸ یا این قسمت از مجموعه استاندارد ملی استاندارد ملی ایران-ایزو-آی‌سی ۱۵۴۰۸ نیستند، بلکه بر اساس مؤلفه‌های توسعه‌یافته هستند: مؤلفه‌هایی که توسط مؤلف ST تعریف شده‌اند. ارزشیابی تعریف مؤلفه‌های توسعه‌یافته برای تعیین اینکه آن‌ها شفاف و بدن ابهام هستند و اینکه این مؤلفه‌ها ضروری هستند، یعنی، آشکارا با استفاده از مؤلفه‌های استاندارد ملی ایران-ایزو-آی‌سی ۲-۱۵۴۰۸ یا این قسمت از استاندارد ملی ایران-ایزو-آی‌سی ۱۵۴۰۸ بیان نمی‌شوند.

۱۰-۵-۲ تعریف مؤلفه‌های توسعه‌یافته ASE_ECD.1

وابسته‌ها: هیچ وابستگی‌ای وجود ندارد.

۱۰-۵-۲-۱ عناصر عمل توسعه‌دهنده

۱۰-۵-۲-۱-۱ ASE_ECD.1.1D

توسعه‌دهنده باید سند شرح الزامات امنیتی را فراهم کند.

۱۰-۵-۲-۱-۲ ASE_ECD.1.2D

توسعه‌دهنده باید تعریف مؤلفه‌های توسعه‌یافته را فراهم کند.

۱۰-۵-۲-۲ عناصر ارائه و محتوی

۱۰-۵-۲-۲-۱ ASE_ECD.1.1C

سند شرح الزامات امنیتی، باید همه الزامات امنیتی توسعه‌یافته را مشخص کند.

۱۰-۵-۲-۲-۲ ASE_ECD.1.2C

تعریف مؤلفه‌های توسعه‌یافته، باید مؤلفه توسعه‌یافته برای هر الزام امنیتی توسعه‌یافته را مشخص کند.

۱۰-۵-۲-۲-۳ ASE_ECD.1.3C

تعریف مؤلفه‌های توسعه‌یافته، باید شرح دهد که هر مؤلفه توسعه‌یافته‌ای چطور به مؤلفه‌ها، خانواده‌ها و دسته‌های استاندارد موجود، مرتبط می‌شود.

۱۰-۵-۲-۲-۴ ASE_ECD.1.4C

تعریف مؤلفه‌های توسعه‌یافته، باید از مؤلفه‌ها، خانواده‌ها، دسته‌ها و متدولوژی‌های استاندارد موجود به‌عنوان مدلی برای ارائه استفاده نماید.

۱۰-۵-۲-۵ ASE_ECD.1.5C

مؤلفه‌های توسعه‌یافته باید دارای عناصر هدف و قابل اندازه‌گیری باشند به‌طوری که انطباق یا عدم انطباق با این عناصر قابل اثبات باشد.

۱۰-۵-۲-۳ عناصر عمل ارزیاب

۱۰-۵-۲-۱ ASE_ECD.1.1E

ارزیاب باید تأیید کند که اطلاعات فراهم شده، همه الزامات را برای محتوا و ارائه مدرک دارند.

۱۰-۵-۲-۳ ASE_ECD.1.2E

ارزیاب باید تأیید کند که مؤلفه‌های توسعه‌یافته می‌توانند با استفاده از مؤلفه‌های موجود به‌شکلی واضح بیان شوند.

۱۰-۶ الزامات امنیتی (ASE_REQ)

۱۰-۶-۱۱ اهداف

شکل SFRها، توضیح شناخته‌شده، بدون ابهام و شفاف از رفتار امنیتی است که از TOE انتظار داریم. شکل SARها، توضیح شناخته‌شده، بدون ابهام و شفاف از فعالیت‌های مورد انتظاری است که برای به‌دست آوردن تضمین در TOE، متعهد می‌شود. ارزشیابی الزامات امنیتی برای تضمین اینکه این الزامات، شفاف، بدون ابهام و شناخته شده هستند ضروری است.

۱۰-۶-۲ سطح‌بندی مؤلفه

مؤلفه‌ها در این خانواده همان‌طور که قرار گرفته‌اند سطح‌بندی می‌شوند.

۱۰-۶-۳ الزامات امنیتی وضع شده ASE_REQ.1

وابسته‌ها: تعریف مؤلفه‌های توسعه‌یافته ASE_ECD.1

۱۰-۶-۳-۱ عناصر عمل توسعه دهنده

۱۰-۶-۳-۱ ASE_REQ.1.1D

توسعه‌دهنده باید سند شرح الزامات امنیتی را فراهم کند.

۱۰-۶-۳-۳ ASE_REQ.1.2D

توسعه‌دهنده باید اصول الزامات امنیتی را فراهم کند.

۱۰-۶-۳-۲ عناصر ارائه و محتوی

۱۰-۶-۳-۱ ASE_REQ.1.1C

سند شرح الزامات امنیتی باید SFRها و SARها را شرح دهد.

ASE_REQ.1.2C ۲-۲-۳-۶-۱۰

همه موضوعات، اهداف، عملیات‌ها، ویژگی‌های امنیتی، موجودیت‌های بیرونی و دیگر اصطلاحاتی که در SFRها و SARها استفاده می‌شوند باید تعریف شوند.

ASE_REQ.1.3C ۳-۲-۳-۶-۱۰

شرح الزامات امنیتی باید کلیه عملیات‌ها بر روی الزامات امنیتی را شناسایی کند.

ASE_REQ.1.4C ۴-۲-۳-۶-۱۰

کلیه عملیات‌ها باید به شکلی صحیح انجام شود.

ASE_REQ.1.5C ۵-۲-۳-۶-۱۰

هر موضوع وابسته به الزامات امنیتی باید تأمین شود، یا اصول الزامات امنیتی باید توجیه کند که موضوع وابسته به الزامات امنیتی، تأمین نشده است.

ASE_REQ.1.6C ۶-۲-۳-۶-۱۰

سند شرح الزامات امنیتی باید از نظر درونی یکپارچه و سازگار باشد.

۳-۳-۶-۱۰ عناصر عمل ارزیاب

ASE_REQ.1.1E ۱-۳-۳-۶-۱۰

ارزیاب باید تأیید کند که اطلاعات فراهم شده همه الزامات را برای محتوا و ارائه مدرک دارند.

ASE_REQ.2 ۴-۶-۱۰ الزامات امنیتی استنتاج شده

وابسته‌ها: اهداف امنیتی ASE_OBJ.2

تعریف مؤلفه‌های توسعه یافته ASE_ECD.1

۱-۴-۶-۱۰ عناصر عمل توسعه دهنده

ASE_REQ.2.1D ۱-۴-۶-۱۰

توسعه دهنده باید سند شرح الزامات امنیتی را فراهم کند.

ASE_REQ.2.2D ۲-۴-۶-۱۰

توسعه دهنده باید اصول الزامات امنیتی را فراهم کند.

۲-۴-۶-۱۰ عناصر ارائه و محتوا

ASE_REQ.2.1C ۱-۲-۴-۶-۱۰

سند شرح الزامات امنیتی باید SFRها و SARها را شرح دهد.

ASE_REQ.2.2C ۲-۲-۴-۶-۱۰

همه موضوعات، اهداف، عملیات‌ها، ویژگی‌های امنیتی، موجودیت‌های بیرونی و دیگر اصطلاحاتی که در SFRها و SARها استفاده می‌شوند باید تعریف شوند.

۱۰-۶-۴-۲-۳ ASE_REQ.2.3C

سند شرح الزامات امنیتی باید کلیه عملیات‌ها بر روی الزامات امنیتی را شناسایی کند.

۱۰-۶-۴-۲-۴ ASE_REQ.2.4C

کلیه عملیات‌ها باید به‌شکلی صحیح انجام شود.

۱۰-۶-۴-۲-۵ ASE_REQ.2.5C

هر موضوع وابسته به الزامات امنیتی باید تأمین شود، یا اصول الزامات امنیتی باید توجیه کند که موضوع وابسته به الزامات امنیتی، تأمین نشده است.

۱۰-۶-۴-۲-۶ ASE_REQ.2.6C

اصول الزامات امنیتی باید هر گونه پشتیبانی SFR را نسبت به اهداف امنیتی TOE بررسی کند.

۱۰-۶-۴-۲-۷ ASE_REQ.2.7C

اصول الزامات امنیتی باید اثبات کند که SFRها همه اهداف امنیتی را برای TOE دارند.

۱۰-۶-۴-۲-۸ ASE_REQ.2.8C

اصول الزامات امنیتی باید توضیح دهند که چرا SARها انتخاب شده‌اند.

۱۰-۶-۴-۲-۹ ASE_REQ.2.9C

سند شرح الزامات امنیتی باید از نظر درونی یکپارچه و سازگار باشد.

۱۰-۶-۴-۳ عناصر عمل ارزیاب

۱۰-۶-۴-۳-۱ ASE_REQ.2.1E

ارزیاب باید تأیید کند که اطلاعات فراهم‌شده همه الزامات را برای محتوا و ارائه مدرک دارند.

۱۰-۷-۱ خلاصه ویژگی‌های TOE (ASE_TSS)

۱۰-۷-۱۱ اهداف

سند خلاصه ویژگی‌های TOE به ارزیابان و مشتریان بالقوه، این توانایی را می‌دهد که اطلاعات کلی در مورد این مسأله که چطور TOE پیاده‌سازی می‌شود به‌دست آورند. ارزشیابی ویژگی‌های خلاصه TOE بدین منظور لازم است که تعیین کنیم که آیا به‌اندازه کافی می‌تواند شرح دهد که TOE چطور: SFRهایش را می‌بیند.

خودش را در برابر تداخل، دخالت پنهانی منطقی و انشعاب محافظت می‌کند. و این‌که آیا خلاصه ویژگی‌های TOE با دیگر سندهای شرح TOE سازگار است یا خیر.

۱۰-۷-۲ سطح‌بندی مؤلفه

مؤلفه‌ها در این خانواده بر اساس اینکه آیا خلاصه ویژگی‌های TOE تنها نیاز دارد که شرح دهد TOE چطور SFRهایش را می‌بیند یا علاوه بر آن نیاز دارد که شرح دهد TOE چطور از خودش در برابر تداخل، دخالت پنهانی منطقی و انشعاب محافظت می‌کند، سطح‌بندی می‌شوند.

این شرح اضافی ممکن است در شرایطی که معماری امنیتی ویژه‌ای برای TOE نیاز باشد استفاده گردد.

۱۰-۷-۳ خلاصه ویژگی‌های TOE ASE_TSS.1

وابسته‌ها: سند مقدمه ASE_INT.1 ST

الزامات امنیتی وضع شده ASE_REQ.1

ویژگی‌های کارکردی پایه‌ای ADV_FSP.1

۱۰-۷-۳-۱ عناصر عمل توسعه‌دهنده

۱۰-۷-۳-۱-۱ ASE_TSS.1.1D

توسعه‌دهنده باید خلاصه ویژگی‌های TOE را فراهم کند.

۱۰-۷-۳-۲ عناصر ارائه و محتوا

۱۰-۷-۳-۲-۱ ASE_TSS.1.1C

خلاصه ویژگی‌های TOE باید شرح دهد که چطور TOE هر SFR را می‌بیند.

۱۰-۷-۳-۳ عناصر عمل ارزیاب

۱۰-۷-۳-۳-۱ ASE_TSS.1.1E

ارزیاب باید تأیید کند که اطلاعات فراهم‌شده، همه الزامات را برای محتوا و ارائه مدرک دارند.

۱۰-۷-۳-۳-۲ ASE_TSS.1.2E

ارزیاب باید تأیید کند که خلاصه ویژگی‌های TOE با رؤس کلی TOE و سند شرح TOE سازگار است.

۱۰-۷-۴ خلاصه ویژگی‌های TOE همراه با خلاصه طراحی معماری ASE_TSS.2

وابسته‌ها: سند مقدمه ASE_INT.1 ST

الزامات امنیتی وضع شده ASE_REQ.1

شرح معماری امنیتی ADV_ARC.1

۱۰-۷-۴-۱ عناصر عمل توسعه‌دهنده

۱۰-۷-۴-۱-۱ ASE_TSS.2.1D

توسعه‌دهنده باید خلاصه ویژگی‌های TOE را فراهم کند.

۱۰-۷-۴-۲ عناصر محتوا و ارائه

۱۰-۷-۴-۲-۱ ASE_TSS.1C

خلاصه ویژگی‌های TOE باید شرح دهد که TOE چگونه با هر SFR مطابقت می‌کند.

ASE_TSS.2.2C ۲-۲-۴-۷-۱۰

خلاصه ویژگی‌های TOE باید شرح دهد که TOE چگونه از خودش در برابر تداخل و دخالت‌های پنهانی منطقی محافظت می‌کند.

ASE_TSS.2.3C ۲-۳-۴-۷-۱۰

خلاصه ویژگی‌های TOE باید شرح دهد که TOE چگونه از خودش در برابر انشعاب محافظت می‌کند.

۳-۴-۷-۱۰ عناصر عمل ارزیاب

ASE_TSS.2.1E ۱-۳-۴-۷-۱۰

ارزیاب باید تأیید کند که اطلاعات فراهم‌شده همه الزامات را برای محتوای مدرک و ارائه آن دارند.

ASE_TSS.2.2E ۲-۳-۴-۷-۱۰

ارزیاب باید تأیید کند که ویژگی‌های خلاصه TOE با رئوس کلی TOE و سند شرح TOE سازگار است.

۱۱- دسته ADV : توسعه

الزامات دسته توسعه، اطلاعاتی در مورد TOE ارائه می‌کند. دانش بدست آمده توسط این اطلاعات به‌عنوان مبنایی برای انجام تجزیه و تحلیل آسیب‌پذیری و آزمون بر روی TOE مورد استفاده قرار می‌گیرد، همچنانکه در دسته‌های AVA و ATE تشریح شده است.

دسته توسعه شامل شش خانواده از الزامات مورد نیاز برای ساختن و ارائه دادن TSF در سطوح مختلف و اشکال مختلف از انتزاع می‌باشد. این خانواده‌ها عبارتند از:

- الزامات مورد نیاز برای شرح (مفهوم سطح‌های مختلف) طراحی و پیاده‌سازی SFRها(ADV- (FSP,ADV-TDS,ADV-IMP

- الزامات مورد نیاز برای شرح ویژگی‌های معماری- محوری تفکیک دامنه، حفاظت‌های اولیه و غیرمسیر جنبی از قابلیت‌های امنیتی (ADV_ARC)

- الزامات مورد نیاز برای یک مدل خط‌مشی امنیتی و نگاشت مطابقت بین مدل خط‌مشی امنیتی و مشخصات کارکردی (ADV_SPM).

- الزامات مورد نیاز در ساختار درونی TSF، که جنبه‌هایی مانند پیمانه‌ای، طبقه‌بندی، به حداقل رساندن پیچیدگی را در بر می‌گیرد(ADV_INT).

هنگام مستندسازی قابلیت‌های امنیتی TOE، دو خاصیت وجود دارد که باید نشان داد. خاصیت اول این است که قابلیت‌های امنیتی به‌درستی کار می‌کند؛ همانطور که مشخص شده انجام می‌دهد. خاصیت دوم و اینکه احتمالاً سخت‌تر می‌توان نشان داد این است که TOE نمی‌تواند به روشی بکار رود که قابلیت‌های امنیتی بتوانند خراب شوند یا کنار گذاشته شوند. این خواص تا حدودی نیاز به رویکردهای مختلفی در تجزیه و تحلیل دارد و به‌همین دلیل خانواده‌های درون ADV ساختار بندی شده‌اند، تا پشتیبانی کنند از این دیدگاه‌های متفاوت. مشخصات کارکردی خانواده‌های (ADV_FSP)، طراحی TOE(ADV_TDS)، نمایش پیاده‌سازی(ADV_IMP)

و مدل خط‌مشی امنیتی (ADV_SPM) که با ویژگی‌های اول در ارتباط است: مشخصات عملیاتی امنیت. خانواده‌ها معماری امنیت (ADV_ARC) و ورودی‌های TSF (ADV_INT) با خاصیت دوم در ارتباط است: مشخصات طراحی TOE که قابلیت‌های امنیتی را نشان می‌دهد نمی‌تواند متوقف شود یا خراب شود. باید توجه شود که نیاز است که هر دو مشخصات فهمیده شوند: هرچه اطمینان از برآورده شدن مشخصات بیشتر باشد، TOE قابل اطمینان‌تر است. مؤلفه‌ها در خانواده‌ها طوری طراحی شده‌اند که با افزایش سلسله مراتب مؤلفه‌ها تضمین بیشتری بدست می‌آید.

الگوی خانواده‌های مورد هدف در ویژگی اول یکی از موارد تجزیه طراحی است. در بالاترین سطح، یک مشخصه عملکردی از TSF از برحسب واسطه‌هایش (توصیف کارهایی که TSF انجام می‌دهد بر حسب تقاضاها به TSF برای سرویس‌ها و نتایج پاسخ‌ها)، تجزیه TSF به واحدهای کوچکتر (وابسته به اطمینان مورد انتظار و پیچیدگی TOE) و این که TSF چگونه عملیاتش را انجام می‌دهد (در سطحی از جزئیات متناسب با سطح تضمین) و نشان‌دادن پیاده‌سازی TSF. یک مدل رسمی از رفتار امنیتی نیز ممکن است ارائه شود. تمام سطوح تجزیه در تعیین کامل بودن و صحت دیگر سطوح، تضمین اینکه سطوح به‌صورت متقابل پشتیبانی کننده هستند مورد استفاده قرار می‌گیرند. الزامات ارائه چندین TSF به خانواده‌های مختلف تقسیم می‌شود برای اجازه به نویسندگی PP/ST به منظور تعیین اینکه کدامیک از نمایش‌های TSF مورد نیاز است. سطح انتخاب شده تضمین مطلوب/بدست آمده را، تحمیل خواهد کرد.

شکل ۱۰ رابطه میان نمایش‌های TSF مختلف از دسته ADV، همچنین رابطه آنها با دیگر دسته‌ها را نشان می‌دهد. چنان که شکل نشان می‌دهد، دسته‌های APE و ASE الزامات مربوطه میان SFRها و اهداف امنیتی TOE را تعریف می‌کند. دسته ASE همچنین الزامات مربوطه میان اهداف امنیتی و SFRها را تعریف می‌کند و مشخصات خلاصه TOE، چگونگی برآوردن SFRها را توضیح می‌دهد. فعالیت‌های ALC_CMC.5.2E شامل تصدیق‌هایی TSF می‌باشد که تحت دسته‌های ATE و AVA تست شده و توسط کلیه سطح‌های تجزیه ADV شرح داده می‌شود.

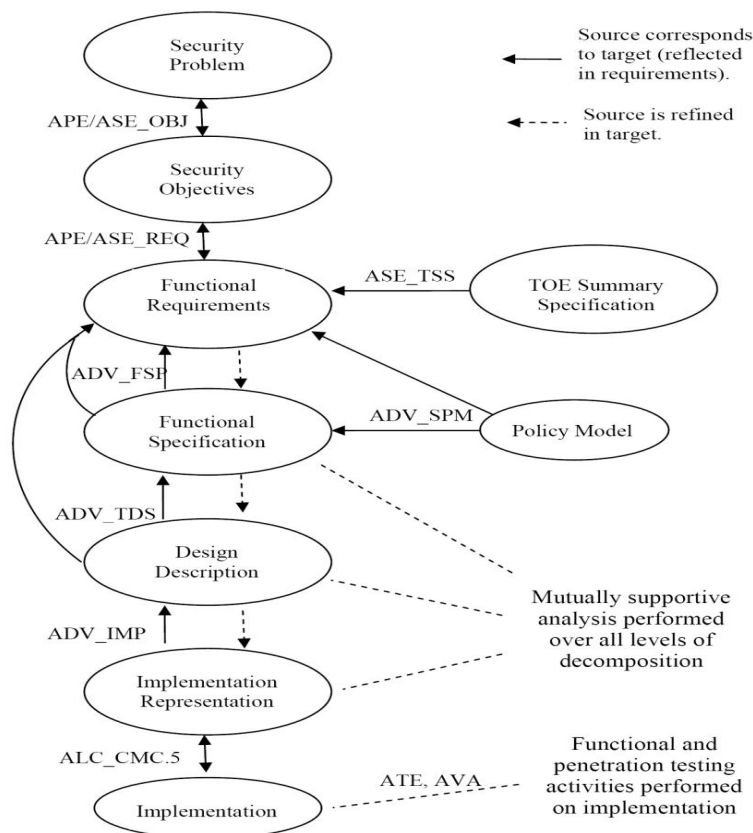
سایر الزامات مربوطه نشان داده شده در شکل ۱۰ در دسته ADV تعریف شده‌اند.

خانواده (ADV_SPM) مدل خط‌مشی امنیت، الزامات SFRهای انتخاب‌شده مدل رسمی را مشخص می‌کند و تشابه بین مشخصات خصوصیات عملکردی و مدل‌های رسمی را فراهم می‌کند. هر خانواده ضمانت مخصوص نمایش TSF (مانند مشخصات خصوصیات کارکردی^۱ (ADV_FSP)، طراحی TOE (ADV_TDS) و نمایش پیاده‌سازی^۲ (ADV_IMP)) الزامات ارتباط نمایش TSF به SFRها را مشخص می‌کند.

کلیه ماجول‌بندی‌ها باید ماجول‌بندی‌های دیگر را تحت تأثیر قرار دهند (یعنی پشتیبانی متقابل)؛ توسعه‌دهنده نهایی عناصر مؤلفه‌های C، را تأمین می‌کند. تضمین‌های مرتبط به این فاکتور در طول آنالیز برای هر سطح از ماجول‌بندی با مراجعه به ماجول‌بندی‌های دیگر به‌دست می‌آید (در یک مدل بازگشتی)؛ ارزیاب قراردادها را به‌عنوان قسمتی از عنصر دوم E تصدیق می‌کند. آگاهی به‌دست آمده از شکل تجزیه ماجول‌های پایه و اساس کارکرد و تلاش آزمون نفوذ می‌باشد.

^۱ -Functional specification

1 -Implementation representation



شکل ۱۰- رابطه ساختارهای ADV با یکدیگر و با سایر خانواده‌ها

خانواده ADV_INT به دلیل اینکه با ساختار درونی TSF مرتبط است در این شکل نشان داده نشده است و تنها به صورت غیر مستقیم به بهبود فرایند نمایش‌های TSF مرتبط می‌شود. به صورت مشابه خانواده ADV_ARC به دلیل آنکه به جای نمایش TSF به صحت معماری مرتبط است، در شکل نشان داده نشده است. هر دو خانواده ADV_INT و ADV_ARC مربوط به آنالیز ویژگی‌هایی است که TOE نمی‌تواند عملکرد امنیتی آن، را از بین ببرد.

عملکرد امنیتی TOE (TSF) از شامل تمام قسمت‌های TOE است که برای اجرای SFRها باید به آن استناد کرد. TSF شامل هر دو قابلیت است که به صورت مستقیم SFRها را اجرا می‌کند و قابلیت است که به صورت مستقیم SFRها را اجرا نمی‌کند و اجرای آن بیشتر به روش غیرمستقیم انجام می‌شود که شامل قابلیت است با توانمندی که موجب می‌شود SFRها را نقض (مختل) کنند. این شامل قسمت‌هایی از TOE است که در راه اندازهایی که مسئول قرار دادن TSF در موقعیت ایمن می‌باشد، احضار می‌شوند.

چندین مفهوم در مهم در توسعه اجزاء خانواده‌های ADV بکار گرفته شده است. این مفاهیم در حالی که به طور مختصر در اینجا آمده، در نکات کاربردی برای خانواده‌ها توضیح داده می‌شود.

یک نکته از همه مهمتر این است که هرچه اطلاعات بیشتری در دسترس باشد اطمینان بیشتری از عملیات امنیتی حاصل می‌شود که (۱) به طور صحیح پیاده‌سازی شود (۲) نمی‌تواند از بین رود

۳) نمی‌تواند نادیده گرفته شود. این امر از طریق بررسی و تحقیقی انجام می‌شود که مستندات سازی صحیح بوده و سازگاری با دیگر مستندات دارند و که برای ما اطمینان حاصل می‌کند که فعالیتهای آزمون می‌توان بکار گرفته شده (آزمون قبولی و آزمون کارکردی) جامع هستند. این بر طبقه‌بندی مؤلفه‌های خانواده‌ها تأثیرگذار است. بطور کلی مؤلفه‌ها براساس میزان اطلاعات طبقه بندی می‌شوند.

در صورتیکه برای کل TOE ها صدق نمی‌کند، ولی در این حالت TSF آنقدر پیچیده است، که قسمتهایی از TSF وجود دارد که خواستار آزمایش بیشتر نسبت به قسمت‌های دیگر TSF می‌باشند.

متأسفانه تعیین این قسمت‌ها تا حدودی ذهنی است، بنابراین اصطلاحات و ترکیبات طوری تعریف می‌شوند که وقتی میزان اطمینان افزایش یابد، مسئولیت تخمین این که کدام قسمت از TSF نیاز به آزمایش بیشتر دارد از توسعه‌دهنده به ارزیاب منتقل می‌شود. برای کمک به بیان این مفهوم اصطلاحات زیر معرفی شده‌است. لازم به ذکر است که در خانواده‌های دسته، این اصطلاحات هنگام بیان کردن قسمت‌های مرتبط - TOE SFR () که عناصر و واحدهای کار گنجانده شده در مشخصات کارکردی (ADV_FSP) ، طراحی TOE (ADV_TDS) و نمایش پیاده‌سازی خانواده‌های (ADV_IMP) استفاده می‌شود. در حالی که مفهوم کلی (برخی قسمت‌های TOE جالب‌تر از قسمت‌های دیگر هستند) برای سایر خانواده کاربرد دارد، معیارها به‌نحو متفاوتی به‌منظور به‌دست آوردن اطمینان مورد نیاز بیان شده‌اند.

همه قسمت‌های TSF امنیت دارند، بدین معنی که آنها باید امنیت TOE مطابق با SFR های بیان شده ارائه دهند و الزامات مورد نیاز برای جداسازی دامن و عدم کنار گذاشتن تأمین کنند. یکی از جنبه‌های ارتباط‌های امنیتی درجه قسمتی از TSF است که امنیت مورد نیاز را اجرا می‌کند. از آنجا که قسمت‌های مختلف TOE نقش‌های مختلف (و یا هیچ نقش آشکاری را) در مورد نیازهای امنیتی اعمال می‌کنند ، این یک زنجیره از ارتباط SFR ایجاد می‌کند: در یک سر این زنجیره قسمتهایی از TOE وجود دارد که مجری - SFR نامیده می‌شوند. چنین قسمت‌هایی نقش مستقیمی در اجرای هر SFR در TOE بازی می‌کنند.

چنین SFR هایی به هر قابلیت ارائه شده توسط یکی از SFR های موجود در ST اشاره می‌کند. لازم به ذکر است که تعریف ایفا کردن یک نقش برای قابلیت اجرای - SFR از نظر کمی غیر ممکن است. برای مثال ، در اجرای اختیاری کنترل دسترسی به مکانیزم (مبدل عددی به قیاسی)^۱ ، نمایش بسیار باریک از اجرای - SFR ممکن است تعدادی خطوط از کدها باشد که در واقع انجام بررسی صفات یک موضوع در برابر صفات جسم باشد. نمایش گسترده‌تر شامل موجودیت نرم افزار (به‌عنوان مثال ، کارکرد C) خواهد بود که شامل چندین خط کد می‌باشد.

ارائه گسترده‌تر همچنان شامل کسانی در کارکرد C ، از وقتی که آنها مسئولیت اجرای تصمیم بازگردانده شده توسط بررسی ویژگی را بر عهده دارد، می‌باشد.

همچنان نمایش گسترده‌تر شامل هر کدی در درخت^۲ تماس^۳ می‌باشد (یا معادل زبان های برنامه نویسی برای پیاده‌سازی زبان استفاده می‌شود) برای آن کارکرد پ (به‌عنوان مثال ، یک کارکرد مرتب‌سازی که کنترل

1- DAC

2 - tree

3 - call

دستیابی به لیست ورودی‌ها در مطابقت اولیه پیاده سازی الگوریتم را مرتب می‌کند. در برخی موضوع‌ها، مؤلفه آنقدر مجری خط‌مشی امنیت نیست بلکه بیشتر نقش حمایت را ایفا می‌کند؛ چنین مؤلفه‌هایی پشتیبانی^۱ از SFR نامیده شده است.

یکی از ویژگی‌های پشتیبانی از SFR که قابل اطمینان است، قابلیت است که صحت پیاده سازی SFR توسط عملیاتی بدون خطا را حفظ می‌کند. چنین قابلیت‌هایی ممکن است به قابلیت اجرای SFR وابسته باشد، اما معمولاً وابستگی در سطح کارکردی است؛ به عنوان مثال، مدیریت حافظه، مدیریت بافر^۲ و غیره. پایین‌تر کردن زنجیره ارتباط امنیت قابلیت است که عدم دخالت^۳ SFR نامیده می‌شوند. چنین قابلیت‌هایی هیچ نقشی در پیاده سازی SFRها ندارد و به احتمال زیاد قسمتی از TSF به دلیل محیط آن می‌باشد؛ به عنوان مثال، هر کد در حال اجرا در یک حالت ممتاز^۴ سخت افزار بر روی سامانه عامل. قسمتی از TSF برای این کار باید در نظر گرفته شود زیرا، اگر به خطر بیفتد (توسط کدهای مخرب و یا جایگزین)، می‌تواند عملکرد صحیح SFR را توسط عامل خود در حالت سخت‌افزاری ممتاز خدشه دار کنند. نمونه‌ای از قابلیت دخالت نکردن از SFR ممکن است مجموعه‌ای از عملیات ممیز شناور ریاضی باشد که در حالت شالوده^۵ برای ملاحظات سرعت پیاده سازی شده است.

خانواده معماری (معماری امنیتی (ADV_ARC)) جهت الزامات و تحلیل TOE مبتنی بر مشخصات تفکیک دامنه، حفاظت از خود و قابلیت نادیده گرفتن سلسله مراتب ارائه می‌شود. این مشخصات به SFRها در آن مرتبط می‌شود، اگر این مشخصات ارائه نشود، احتمالاً به شکست مکانیزم‌ها بکارگیرنده SFRها منجر خواهد شد. کارکرد و طراحی مرتبط به این مشخصات قسمتی از تسلسل شرح داده شده در بالا را مورد توجه قرار نمی‌دهد، اما در مقابل به صورت جداگانه به دلیل طبیعت اساساً متفاوتش و الزامات تحلیل مورد بحث قرار می‌گیرد.

اختلاف در تجزیه و تحلیل و پیاده سازی SFRها (قابلیت اجرای SFR و قابلیت پشتیبانی از SFR) و پیاده سازی مشخصات امنیتی تا حدی اساسی TOE که شامل قالب بندی، محافظت از خود و موارد مهم غیر قابل صرف نظر^۶ می‌باشد، این است که قابلیت مرتبط با SFR بیشتر یا کمتر به طور مستقیم قابل مشاهده است و در حالی که خواص فوق الذکر نیاز به درجات مختلف تجزیه و تحلیل در یک مجموعه بسیار گسترده‌تر از قابلیت‌ها دارد، نسبتاً برای تست آسان می‌باشد. علاوه بر این، عمق تجزیه و تحلیل برای چنین خواصی بسته به طرح TOE متفاوت خواهد بود. خانواده های ADV برای مورد توجه قرار دادن این امر به وسیله یک خانواده جداگانه (معماری امنیت (ADV_ARC)) اختصاص داده شده برای تحلیل قالب بندی، محافظت از خود و الزامات غیرقابل صرف نظر شکل گرفته است، در حالی که دیگر خانواده‌ها به تحلیل عملکرد پشتیبانی کننده از SFRها مربوط می‌شود.

حتی در مواردی که شرح‌های مختلف برای سطوح مختلف از انتزاع لازم است، نیاز نیست هر ارائه TSF در یک سند مجزا باشد. در واقع، ممکن است موردی باشد که یک تک سند الزامات مستندات را برای بیش از یک ارائه

1 - SFR supporting
2 - buffer management
3 - noninterfering
4- privileged
5 - kernel
6 - non-bypassability

TSF برآورده کند، به دلیل اینکه اطلاعاتی درمورد هر یک از این ارائه‌های TSF مورد نیاز به جای ساختار سند بدست آمده است.

سه نوع سبک خصوصیات به وسیله این کلاس ایجاد می‌شود: غیررسمی، نیمه‌رسمی و رسمی. کلیه مشخصات کارکرد و مستندات طرح TOE همیشه به سبک غیررسمی یا نیمه‌رسمی نوشته می‌شوند. سبک نیمه‌رسمی ابهام را در این اسناد بیش از ارائه غیررسمی کاهش می‌دهد. علاوه بر ارائه سبک نیمه‌رسمی، خصوصیات رسمی نیز مورد نیاز است. ارزش این است که شرح TSF با بیش از یک روش تکمیلی، اطمینان حاصل شود که TSF به‌طور کامل و با دقت مشخص شده است.

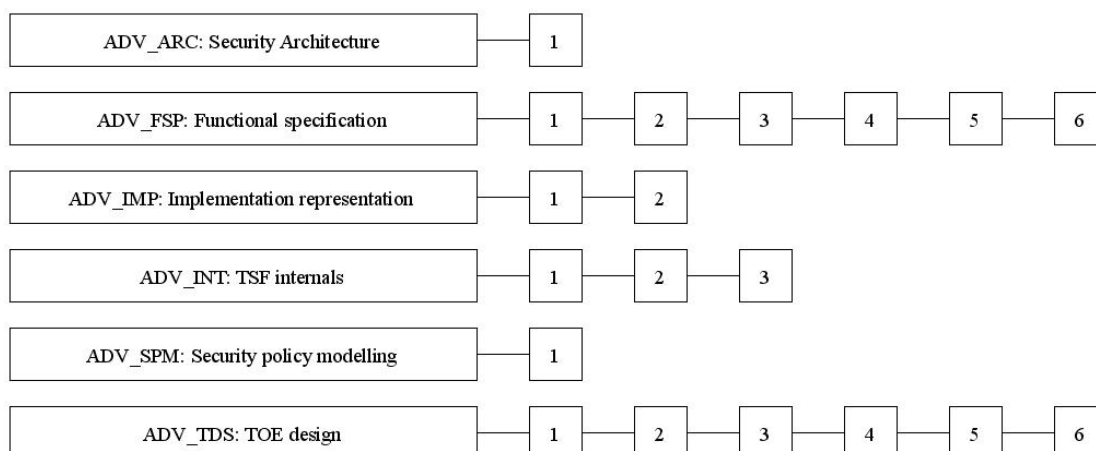
مشخصات غیررسمی به شکل نثر در زبان طبیعی نوشته شده است. زبان طبیعی در اینجا به معنای زبان محاوره‌ای استفاده می‌شود (به عنوان مثال اسپانیایی، آلمانی، فرانسوی، انگلیسی، هلندی).

مشخصات غیررسمی تابع هیچ علامت‌گذاری و یا دیگر محدودیت‌های خاص به جزء آنهایی که به عنوان قراردادهای معمولی برای آن زبان مورد نیاز است (به عنوان مثال دستور زبان و نحو) نیستند. در حالی که هیچ محدودیت علامت‌گذاری بکار گرفته نشود، مشخصات غیررسمی مستلزم آن است که برای عباراتی که در متن استفاده می‌شود معانی تعریف شده را ارائه کند مگر آن که برای استفاده عادی پذیرفته شده باشد.

تفاوت بین اسناد نیمه‌رسمی و غیررسمی فقط در قالب‌بندی و یا نمایش آنها می‌باشد: علامت‌گذاری نیمه‌رسمی شامل چیزهایی مانند واژه‌نامه صریح و روشن از، عبارات، ارائه یک فرمت استاندارد شده، و غیره می‌باشد. مشخصات نیمه‌رسمی در قالب‌های عرضه استاندارد نوشته شده است. اگر در زبان طبیعی نوشته شده باشد عرضه باید از عبارات بدون تناقض استفاده کند. عرضه نیز ممکن است از زبان / نمودار ساخت یافته استفاده کند (به عنوان مثال نمودارهای جریان داده^۱، بیان نمودارهای انتقال، نمودارهای رابطه- موجودیت، نمودارهای ساخت یافته داده و فرآیند یا نمودارهای ساختار برنامه). این که آیا براساس نمودارها یا زبان طبیعی باشد، مجموعه قراردادهای باید در ارائه استفاده شود. واژه‌نامه کلماتی که به صورت دقیق و ثابت مورد استفاده قرار می‌گیرند صریحاً مشخص می‌کند؛ به همین شکل، قالب استاندارد شده بر محافظت شدید در نظر گرفته شده دلالت می‌کند که با قاعده سند را به صورتی که وضوح را به حداکثر برساند آماده می‌کند. لازم به ذکر است که اساساً قسمت‌های مختلف TSF ممکن است قراردادهای^۲ نشانه‌گذاری نیمه‌رسمی متفاوتی داشته باشد و سبک‌های ارائه (تا زمانی که تعداد مختلف "نشانه‌گذاری نیمه‌رسمی" کوچک است)؛ این مورد همچنان با مفهوم ارائه نیمه‌رسمی مطابقت می‌کند.

یک مشخصه رسمی مبتنی بر مفاهیم ریاضیاتی به خوبی بیان شده در نشانه‌گذاری نوشته شده است و نوعاً با نثرهای تشریحی (غیر رسمی) پشتیبان همراه است. این مفاهیم ریاضیاتی برای تعریف نحو و معنای نشانه‌گذاری و قوانین اثبات که از دلیل منطقی پشتیبانی می‌کند مورد استفاده قرار می‌گیرد. قوانین نحوی و معنایی باید چگونگی تشخیص به‌طور بدون ابهام ساختارها و تعیین معانی آنها را شرح دهد. نیاز است که دلایلی وجود داشته باشد که استنتاج تناقض‌ها و تمام قوانین پشتیبان نشانه‌گذاری مورد نیاز برای تعریف و ارجاع غیرممکن است. شکل ۱۱ خانواده‌ها را در این کلاس و سلسله مراتب مؤلفه‌های این خانواده‌ها را نشان می‌دهد.

1 - data-flow
2 - convention



شکل ۱۱- ADV: تجزیه دسته توسعه

۱-۱۱ معماری امنیت (ADV_ARC)

۱-۱-۱۱ اهداف

هدف از این خانواده ارائه شرح معماری امنیت TSF برای توسعه‌دهنده می‌باشد. این امر باعث آنالیز اطلاعاتی می‌شود که وقتی با سند دیگر نمایش داده شده برای TSF ترکیب می‌شود، تأیید کند که TSF به خواص مورد نظر دست یافته است. شرح معماری امنیت از درخواست تلویحی پشتیبانی می‌کند که تجزیه و تحلیل امنیتی TOE با بررسی TSF، می‌تواند حاصل شود؛ بدون معماری دقیق، قابلیت کلی TOE باید بررسی شود.

۱-۱-۲ رتبه‌بندی مؤلفه‌ها

این خانواده تنها شامل یک مؤلفه است.

۱-۱-۳ نکات کاربردی

خصوصیات دفاع از خود، تفکیک دامنه، و قابلیت عدم صرفنظر از قابلیت‌های امنیتی اظهار شده در قسمت دوم SFRها مجزا می‌باشند، زیرا دفاع از خود^۱ و غیر، قابلیت عدم صرفنظر از قابلیت‌های امنیتی به طور مستقیم دخالت زیادی در TSF ندارند. در عوض، آنها خواصی از TSF هستند که از طریق طراحی TOE و TSF حاصل، و با راه اندازی دقیق این طراحی اجرا می‌شوند. رویکرد بکار رفته در این خانواده برای توسعه‌دهنده می‌باشد که TSF را طوری طراحی کند، که خواص فوق الذکر را نشان دهد و سندی فراهم کند که این خصوصیات TSF را توضیح دهد.

این توضیح با همان جزئیاتی فراهم می‌شود که در شرح عناصر اجرای SFR از TOE در سند طراحی TOE ارائه شده است.

ارزیاب مسئول بررسی شواهد و مدارک و جفت کردن آنها با دیگر مدارک تحویل داده شده برای TOE و TSF و تعیین این که آیا خصوصیات بانجام رسیده‌اند.

مشخصات اجرای قابلیت امنیت SFRها (در مشخصات فنی کارکردی (ADV_FSP) و طراحی TOE (ADV_TDS)) لزوماً مکانیسم‌های بکار گرفته شده در پیاده‌سازی خود حفاظتی و قابلیت عدم صرفنظر (به عنوان مثال مکانیزم مدیریت حافظه) را تشریح نمی‌کند.

بنابراین، مواد مورد نیاز برای اطمینان از این که این الزامات برآورده می‌شوند، تطبیق بهتر با یک نمایش جدا از ماحول‌بندی طراحی TSF می‌باشند که در ADV_FSP و ADV_TDS ارائه شده است.

این مسئله دلیل نمی‌شود که توصیف معماری امنیتی توسط این مولفه نمی‌تواند مرجع باشد و یا از مواد ماحول‌بندی طراحی استفاده کند؛ اما این احتمال وجود دارد که جزئیات موجود در اسناد تجزیه (ماحول‌بندی) به توضیحات مقرر شده برای سند شرح معماری امنیت مربوط نمی‌شود.

شرح صحت معماری را می‌تواند بعنوان آنالیز آسیب‌پذیری توسعه‌دهنده در نظر گرفته شود، و در آن توجیه دلیل این که TSF درست است و همه SFRهای آن را اجرا می‌کند را فراهم می‌کند.

درجایی که صحت از طریق مکانیزم‌های امنیتی خاص حاصل می‌شود، این امر به عنوان قسمتی از الزامات (ATE_DPT) آزمایش خواهد شد؛

در جایی که صحت تنها از طریق معماری حاصل می‌شود، رفتار (behaviour) به عنوان قسمتی از AVA تست خواهد شد: الزامات ارزیابی آسیب پذیری.

این خانواده متشکل از الزاماتی برای توصیف معماری امنیتی است که خود حفاظتی، جداسازی دامنه، اصول قابلیت عدم صرفنظر را تشریح می‌کند، از جمله توضیحاتی در مورد چگونگی پشتیبانی این اصول توسط قسمتی از TOE که برای ارزش‌دهی اولیه TSF استفاده می‌شود، می‌باشد.

اطلاعات دیگر در مورد خصوصیات معماری امنیت خود حفاظتی، جداسازی دامنه و اصول قابلیت عدم صرفنظر می‌توان در ضمیمه A.1، ADV_ARC یافت: مواد تکمیلی در معماری‌های امنیتی.

۱۱-۱-۴ ADV_ARC.1 شرح طراحی امنیت

وابسته‌ها: ADV_FSP.1 مشخصات عملیات اولیه

ADV_TDS.1 طراحی اولیه

۱۱-۱-۴-۱ عناصر عمل توسعه‌دهنده

۱۱-۱-۴-۱.۱ ADV_ARC.1.1D

توسعه‌دهنده باید TOE را طراحی و پیاده‌سازی کند. بنابراین خواص امنیتی از TSF کنار گذاشته نمی‌شود.

۱۱-۱-۴-۱.۲ ADV_ARC.1.2D

توسعه‌دهنده باید TSF را طراحی و پیاده‌سازی کند بنابراین می‌تواند از تغییرات خودش توسط موجودیت‌های فعال غیر قابل اعتماد محافظت کند.

ADV_ARC.1.3D ۳-۱-۴-۱-۱۱

توسعه‌دهنده باید شرح معماری امنیتی TSF را تهیه کند.

۱۱-۴-۲ عناصر ارائه و محتوی

ADV_ARC.1.1C ۱-۲-۴-۱-۱۱

شرح معماری امنیتی باید سطح تفصیلی متناسب با شرح مفهوم اجرای از SFR بیان شده در مستندات طراحی TOE، باشد.

ADV_ARC.1.2C ۲-۲-۴-۱-۱۱

شرح معماری امنیتی باید تشریح کند که قلمرو امنیتی توسط TSF سازگار با SFRها نگهداری می‌شود.

ADV_ARC.1.3C ۳-۲-۴-۱-۱۱

شرح معماری امنیتی چگونگی امن بودن فرایند آغازی TSF را تشریح کند.

ADV_ARC.1.4C ۴-۲-۴-۱-۱۱

شرح معماری امنیتی باید نشان دهد که TSF از خودش از خرابی محافظت کند.

ADV_ARC.1.5C ۵-۲-۴-۱-۱۱

شرح معماری امنیتی باید نشان دهد که TSF مانع صرفنظر کردن SFR اجرایی است.

۱۱-۴-۳ عناصر عمل ارزیاب

ADV_ARC.1.1E ۱-۳-۴-۱-۱۱

اطلاعاتی که کلیه الزامات محتوی و ارائه مدارک را برآورده می‌کند باید توسط ارزیاب تأیید شود.

۱۱-۲ (ADV_FSP) مشخصات عملیات

۱۱-۲-۱ اهداف

این خانواده عهده‌دار الزامات مشخصات کارکردی، که واسطه‌های TSF را تشریح می‌کند (TSFIs) می‌باشد. TSFI ها شامل تمام واسطه‌های کاربران که سرویس‌های TSF را درخواست می‌کند (با ارائه داده‌ها توسط TSF پردازش می‌شود) و پاسخ‌های متناظر به درخواست^۱ آن سرویس‌ها می‌باشد. آن چگونگی به انجام رساندن درخواست آن خدمات و نیز ارتباطات را هنگامی که TSF از محیط عملیاتی درخواست می‌کند شرح نمی‌کند. این اطلاعات به‌ترتیب توسط خانواده‌های طراحی TOE (ADV_TDS) و با استناد به (ACO_REL) مؤلفه وابسته اشاره می‌شود.

این خانواده به‌طور مستقیم تضمین می‌کند با مجاز دانستن این‌که ارزیاب متوجه شود که چگونه TSF درخواست‌های SFR را برآورده می‌کند. آن همچنین تضمین به‌صورت غیرمستقیم، به‌عنوان ورودی بر سایر خانواده‌ها و دسته‌های تضمین، ارائه می‌کند.

¹ - invocation

- ADV_ARC ، جایی که شرح TSFI برای درک بهتر از چگونگی محافظت TSF در مقابل خرابی (مثال: تخریب حفاظت از خود یا تفکیک قلمرو) و/یا کنار گذاشتن ممکن است بکار گرفته شود.
- ATE، که در آن شرح TSFI ها ورودی مهم برای هر دو تست توسعه دهنده و تست ارزیاب می باشد.
- AVA ، که در آن شرح TSFI ها برای جستجوی آسیب پذیری استفاده می شود.

۱۱-۲-۲ رتبه بندی مؤلفه ها

مؤلفه ها در این خانواده در درجه ای از جزئیات مورد نیاز از توصیف TSFI و فرمالیته درجه مورد نیاز از شرح TSFI رتبه بندی شده اند.

۱۱-۲-۳ نکات کاربردی

پس از تعیین TSFI ها (نگاه کنید به الف-۲-۱ تعیین TSFI برای راهنمایی و نمونه های تعیین TSFI) ، آنها شرح داده می شوند. در مؤلفه های سطح پایین تر ، توسعه دهنده توجه مستندانش (و توجه تجزیه و تحلیل ارزیاب) بر روی جنبه های مربوط- امنیتی TOE متمرکز می شود. سه دسته از TSFIs ها تعریف می شوند بر اساس ارتباط خدمات موجود از طریق آنها باید SFR ها درخواست شود.

- اگر خدمات در دسترس از طریق رابط به یکی از SFR های تحمیل شده بر TSF ردیابی کرد، آنگاه که رابط کاربری آن مجری از SFR نامیده می شوند. توجه داشته باشید که این امکان وجود دارد که واسطه ممکن است با ارائه خدمات متنوع و ارائه نتایج ، که بعضی از آنها ممکن است مجری - SFR باشد و بعضی از آنها ممکن است نباشد.

- واسطه ها (و یا خدمات موجود از طریق واسطه های مربوط به) خدماتی است که قابلیت اجرای از SFR به آن بستگی دارد، اما فقط لازم است که در جهت خط مشی های امنیتی TOE محافظت می شوند، درست عمل کند، حمایت از SFR نامیده می شوند.

- واسطه ها به خدمات که بر روی قابلیت اجرای از SFR هیچگونه وابستگی ندارد که SFR غیر مد/خله گر نامیده می شود.

لازم به ذکر است برای این که واسطه ها حمایت از SFR یا عدم دخالت SFR آن باید هیچ خدمات اجرای از SFR یا نتایج نداشته باشد. در مقابل واسطه های اجرای از SFR ممکن است خدمات پشتیبانی از SFR داشته باشد (برای نمونه، توانایی تنظیم ساعت سیستم ممکن است خدمات اجرای از SFR واسطه باشد، اما اگر همان واسطه برای نمایش تاریخ سیستم بکار گرفته شود، ممکن است تنها خدمات حمایت از SFR باشد. نمونه ای از پشتیبانی از SFR مطلق واسطه یک سیستمی است که واسطه را فرا می خواند که هر دو توسط کاربران و توسط قسمتی از TSF که از طرف کاربران در حال اجرا است مورد استفاده قرار می گیرد.

همانطور که اطلاعات بیشتر در مورد TSFIs در دسترس می شود ، اطمینان بیشتری می توان به دست آورد که واسطه ها به درستی طبقه بندی/ تجزیه و تحلیل شده است. الزامات ساختاری هستند به طوری که در پایین ترین سطح ، اطلاعات مورد نیاز برای واسطه های بدون مداخله از SFR حداقل لازم صحیح برای ارزیاب در این تصمیم به صورت مؤثر می باشد. در سطوح بالاتر ، اطلاعات بیشتر در دسترس می شود به طوری که ارزیاب اطمینان بیشتری در تعیین دارد.

هدف از تعریف این برچسبها (اعمال از SFR ، پشتیبانی از SFR ، و عدم دخالت از SFR) و برای گردآوری الزامات مختلف براساس هر کدام از آنها هست (در مؤلفه‌های تضمین پایین‌تر) در اولین جایی که تجزیه و تحلیل مورد توجه واقع می‌شود ارائه می‌شود و شواهد برآن است که تجزیه و تحلیل انجام می‌شود.

اگر مستندات توسعه‌دهنده واسطه‌های TSF به‌درجه مشخص شده در الزامات مورد نیاز برای واسطه‌های اجرای از SFR (که به عبارت دیگر، اگر بیش از مستندات مورد نیاز) را تشریح کند ، نیازی برای توسعه‌دهنده برای ایجاد شواهدی جدید برای مطابقت الزامات وجود ندارد.

به‌طور مشابه، چون برچسبها صرفاً به معنای متفاوت بودن انواع واسطه‌ها مطابق با الزامات می‌باشد، برای توسعه‌دهنده برای به‌روز کردن مدارک تنها نیاز به برچسب زدن واسطه به‌عنوان اجرای از SFR ، پشتیبانی از SFR و عدم دخالت از SFR نیست. هدف اصلی برچسب زدن این است که توسعه‌دهندگان را مجاز می‌دارد با روش‌های کمتر تکامل یافته ۱ توسعه (مربوط به محصول، مانند واسطه‌ی گمارده شده و مستندات طرح) تنها مدارک لازم و بدون هزینه‌های غیر ضروری را تأمین کند.

آخرین عنصر ج از هر مؤلفه مطابق با این خانواده مکاتبات مستقیم بین SFRها و مشخصات کارکردی را تأمین می‌کند که نشانه‌هایی از وسطه‌ها برای احضار هر یک از SFR های خواسته شده استفاده می‌شود.

در مواردی که ST حاوی چنین الزامات کارکردی به‌عنوان الزامات ISO/IEC 15408-2 حفاظت از اطلاعات مازاد (FDP_RIP) باشد ، عملکرد آنها ممکن است خود را در TSFIs ها آشکار نسازد، از مشخصات کارکردی و یا ردیابی انتظار می‌رود این SFRs را شناسایی کند؛ در برداشتن آنها با خصوصیات عملکرد کمک می‌کند که اطمینان حاصل کنیم از این که آنها در سطوح پایین‌تر تجزیه، درجایی که به آنها مربوطه می‌باشد، از دست نرفته است.

۱۱-۲-۳ جزئیات در مورد واسطه‌ها

الزامات مجموعه‌ای از جزئیات مربوط به TSFI های تهیه شده را مشخص می‌کند. برای اهداف مورد نیاز، واسطه‌ها (به درجات گوناگون با جزئیات) برحسب اهداف آنها، روش استفاده، پارامترها، شرح پارامترها و پیغام‌های خطا مشخص می‌شوند.

هدف از واسطه تشریح هدف کلی سطح عالی از واسطه می‌باشد (مثال: دستورات^۲ GUI فرایند، دریافت بسته‌های^۳ شبکه ، ارائه خروجی چاپگر و غیره).

روش استفاده از واسطه توصیف چگونه قرار است که واسطه مورد استفاده قرار گیرد، می‌باشد. این توضیحات بهتر است در پیرامون تعامل‌های متفاوت موجود در آن واسطه ساخته شوند.

برای مثال ، اگر واسطه دستورات یونیکس^۴ باشد ls , mv , cp و برای آن واسطه اثر متقابل خواهد داشت. روش استفاده برای هر تعامل، کنشهایی که انجام می‌شود، هم رفتار مشاهده شده در واسطه (به‌عنوان مثال

1- mature
2- command
3- packet
4 - unix

برنامه‌نویس API را فراخوانی می‌کند، کاربران ویندوز^۱ تغییراتی در تنظیمات دردفتر ثبت اسناد^۲ و نیز رفتار واسط‌های دیگر (به‌عنوان مثال تولید سابقه ممیزی) را توصیف می‌کند.

پارامترها ورودی‌ها به و خروجیها از یک واسطه صریح هستند که رفتار واسطه را کنترل می‌کند. به‌عنوان مثال، پارامترها آرگومان‌های^۳ عرضه شده به API هستند؛ زمینه‌های مختلف در یک بسته برای پروتکل شبکه داده؛ ارزش‌های اصلی فردی در دفتر ثبت اسناد ویندوز؛ سیگنال در سراسر مجموعه‌ای از سوزن بر روی یک تراشه؛ پرچم‌ها که می‌تواند برای Is تنظیم شود، و غیره. پارامترها "" شناسایی شده با یک لیست ساده از آنچه آنها می‌شوند.

شرح پارامتر در مورد چپستی پارامتر به‌روش معنی‌داری توضیح می‌دهد. به‌عنوان مثال، شرح پارامتر قابل قبول برای واسط `foo(i)` می‌تواند: "پارامتر `i` یک عدد صحیح است، تعداد کاربرانی که در حال حاضر به سامانه وارد شده‌اند را نشان می‌دهد" باشد. شرح مانند "پارامتر `i` یک عدد صحیح است" قابل قبول نمی‌باشد.

شرح عملکردهای واسط آنچه را که واسطه انجام می‌دهد را تشریح می‌کند. این باجزئیات بیشتری نسبت به هدف می‌باشد، در حالی که "هدف" دلیل آن که یکی ممکن است مایل به استفاده از آن باشد را نشان می‌دهد، "عملکردها" همه چیزهایی که آن انجام می‌دهد را نشان می‌دهد.

در مواردی که عملکرد واسطه به SFR ها مرتبط نیست. در شرح آن گفته شده است که بیان شود، منظور شرح صرفاً روشن می‌کند که حقیقتاً به SFR مرتبط نیست.

در شرح پیام خطا شرایطی که آن را ایجاد کرده، چه پیامی است و معنای هر کد خطا شناسایی می‌شود. پیام خطا توسط TSF ایجاد شده است که نشان دهنده مشکل یا درجه بی‌نظمی که مواجه شده‌اند، می‌باشد. الزامات این خانواده به انواع پیام‌های خطا اشاره می‌کند:

- پیام خطای "مستقیم" یک وابسته - امنیتی است که از طریق احضار TSFI خاص واکنش می‌دهد.
- پیام خطای "غیر مستقیم" نمی‌تواند به الزام احضار TSFI ویژه‌ای مربوط شود به‌دلیل آن‌که، آن از شرایط گسترده سیستم نتیجه می‌شود (به‌عنوان مثال مصرف منابع، وقفه‌های اتصال، و غیره). پیام‌های خطا که مربوط به امنیت نیستند نیز "غیر مستقیم" در نظر گرفته می‌شوند.
- "باقی مانده" خطاهایی هستند که هر گونه خطای دیگر مانند آنهایی که ممکن است در داخل کد ارجاع داده شوند.

به‌عنوان مثال، استفاده از کد بررسی وضعیت^۴ که تمام وضعیت‌هایی را که منطقی اتفاق نمی‌افتد را چک می‌کند (به‌عنوان مثال آخرین "else" بعد از لیستی از بیانیه‌های "case")، که پیام خطای catch-all را برقرار می‌کند؛ در یک TOE عملیاتی، این پیام‌های خطا بهتر است که هرگز دیده نشود. یک مثال مشخصات کارکردی در الف - ۲ - ۳ ارائه شده است.

1- windows
2 -registry
3 - argument
4- condition-checking

۱۱-۲-۴ ADV_FSP.1 مشخصات کارکردی پایه

وابسته‌ها: هیچ وابسته‌ای ندارد.

۱۱-۲-۴-۱ عناصر عمل توسعه‌دهنده

۱۱-۲-۴-۱-۱ ADV_FSP.1.1D

توسعه‌دهنده باید مشخصات عملیات را مقرر کند.

۱۱-۲-۴-۱-۲ ADV_FSP.1.2D

توسعه‌دهنده باید فراهم کند ترسیمی کند اثر مشخصات کارکردی به SFRها.

۱۱-۲-۴-۲ عناصر ارائه و محتوا

۱۱-۲-۴-۲-۱ ADV_FSP.1.1C

مشخصات کارکردی باید توصیف کند هدف و روش استفاده‌ی بکارگیری برای هر SFR و پشتیبانی SFR از TSFI.

۱۱-۲-۴-۲-۲ ADV_FSP.1.2C

مشخصات کارکردی باید تعریف کند کلیه پارامترهای که وابسته است به هر تأکید SFR و پشتیبانی SFR از TSFI.

۱۱-۲-۴-۲-۳ ADV_FSP.1.3C

مشخصات کارکردی باید فراهم کند منطقی را برای دسته‌بندی مجازی از واسط‌ها به‌عنوان عدم تداخل SFR.

۱۱-۲-۴-۲-۴ ADV_FSP.1.4C

دنبال‌کردن و پیگیری باید اثبات کند که SFRها اثر می‌کند بر TSFIها در مشخصات کارکردی.

۱۱-۲-۴-۳ عناصر عمل ارزیاب

۱۱-۲-۴-۳-۱ ADV_FSP.1.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۱-۲-۴-۳-۲ ADV_FSP.1.2E

ارزیاب مشخصات کارکردی که پشتیبان کامل و صحیح از SFRها می‌باشد را باید مشخص کند.

۱۱-۲-۵ ADV_FSP.2 مشخصات عملیات اجرای-امنیتی

وابسته‌ها: ADV_TDS.1 طراحی ابتدایی

۱۱-۲-۵-۱ عناصر عمل توسعه‌دهنده

۱۱-۲-۵-۱-۱ ADV_FSP.2.1D

توسعه‌دهنده باید مشخصات کارکردی را برقرار کند.

ADV_FSP.2.2D ۲-۱-۵-۲-۱۱

توسعه‌دهنده باید ردیابی از مشخصات کارکردی به SFR ها را ارائه کند.

۲-۱۱-۲-۵ عناصر ارائه و محتوا

ADV_FSP.2.1C ۱-۲-۵-۲-۱۱

مشخصات کارکردی باید TSF را به‌طور کامل بیان کند.

ADV_FSP.2.2C ۲-۲-۵-۲-۱۱

مشخصات عملیات باید هدف و روش استفاده TSFI ها را تشریح کند.

ADV_FSP.2.3C ۳-۲-۵-۲-۱۱

مشخصات عملیات باید کل پارامترهای مربوط به TSFI را شناسایی و شرح دهد.

ADV_FSP.2.4C ۴-۲-۵-۲-۱۱

TSFI برای هر اجرای SFR، مشخصات عملیات باید عملکردهای اجرای SFR مرتبط با TSFI را شرح دهد.

ADV_FSP.2.5C ۵-۲-۵-۲-۱۱

برای TSFI های اجرای SFR، مشخصات عملیات باید پیام‌های خطای مستقیم حاصل از پردازش مرتبط با عملکردهای اجرای SFR را شرح دهد.

ADV_FSP.2.6C ۶-۲-۵-۲-۱۱

ردیابی باید نشان دهد که در مشخصات کارکردی SFR ها TSFI ها را طرح می‌کند.

۳-۱۱-۲-۵ عناصر عمل ارزیاب

ADV_FSP.2.1E ۱-۳-۵-۲-۱۱

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

ADV_FSP.2.2E ۲-۳-۵-۲-۱۱

ارزیاب باید مشخص کند که مشخصات عملیات، یک نمونه کامل و صحیح SFR ها می‌باشد.

ADV_FSP.3 ۶-۲-۱۱ مشخصات عملیات با نتیجه‌گیری کامل

وابسته‌ها: ADV_TDS.1 طراحی مقدماتی

۱-۱۱-۲-۶ عناصر عمل توسعه‌دهنده

ADV_FSP.3.1D ۱-۱-۶-۲-۱۱

توسعه‌دهنده باید مشخصات کارکردی را مقرر کند.

ADV_FSP.3.2D ۲-۱-۶-۲-۱۱

توسعه‌دهنده باید اثری از مشخصات کارکردی SFR ها را ارائه کند.

۱۱-۲-۶-۲ عناصر ارائه و محتوی

۱۱-۲-۶-۲-۱ ADV_FSP.3.1C

مشخصات کارکردی باید TSF را به طور کامل نشان دهد.

۱۱-۲-۶-۲-۲ ADV_FSP.3.2C

مشخصات عملیات باید هدف و روش استفاده TSFI ها را تشریح کند.

۱۱-۲-۶-۲-۳ ADV_FSP.2.3C

مشخصات عملیات باید کل پارامترهای مربوط به TSFI را شناسایی و شرح دهد.

۱۱-۲-۶-۲-۴ ADV_FSP.3.4C

TSFI برای هر اجرای SFR، مشخصات عملیات باید عملکردهای اجرای SFR مرتبط با TSFI را شرح دهد.

۱۱-۲-۶-۲-۵ ADV_FSP.3.5C

برای هر TSFI اجرای SFR، مشخصات کارکردی باید پیامهای خطای مستقیم حاصل از اثرات اجرای امنیتی و استثنای مرتبط با احضار TSFI را شرح دهد.

۱۱-۲-۶-۲-۶ ADV_FSP.3.6C

مشخصات کارکردی باید عملکردهای پشتیبانی - SFR و دخالت های - منفی - SFR مرتبط با TSFI را خلاصه کند.

۱۱-۲-۶-۲-۷ ADV_FSP.3.7C

ردیابی باید نشان دهد که در مشخصات کارکردی SFR ها TSFI ها را طرح می کند.

۱۱-۲-۶-۳ عناصر عمل ارزیاب

۱۱-۲-۶-۳-۱ ADV_FSP.3.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می کند.

۱۱-۲-۶-۳-۲ ADV_FSP.3.2E

ارزیاب مشخصات کارکردی را که پشتیبان کامل و صحیحی از SFR ها باشد را مشخص می کند.

۱۱-۲-۷ ADV_FSP.4 مشخصات کارکردی کامل

وابسته ها: ADV_TDS.1 طراحی مقدماتی

۱۱-۲-۷-۱ عناصر عمل توسعه دهنده

۱۱-۲-۷-۱-۱ ADV_FSP.4.1D

توسعه دهنده باید مشخصات کارکردی را مقرر کند.

۱۱-۲-۷-۱-۲ ADV_FSP.4.2D

توسعه‌دهنده باید نشانی از مشخصات کارکردی SFRها را ارائه کند.

۱۱-۲-۷-۲ عناصر ارائه و محتوی

ADV_FSP.4.1C ۱-۲-۷-۲-۱۱

مشخصات کارکردی باید TSF را به‌طور کامل بیان کند.

ADV_FSP.4.2C ۲-۲-۷-۲-۱۱

مشخصات عملیات باید هدف TSFIها و روش استفاده از آن را تشریح کند.

ADV_FSP.4.3C ۳-۲-۷-۲-۱۱

مشخصات عملیات باید کل پارامترهای مربوط به TSFI را شناسایی و شرح دهد.

ADV_FSP.4.4C ۴-۲-۷-۲-۱۱

مشخصات عملیات باید عملکردهای مرتبط با TSFI را توصیف کند.

ADV_FSP.4.5C ۵-۲-۷-۲-۱۱

مشخصات کارکردی باید پیغام‌های خطای مستقیم که ممکن است از فراخوانی هر TSFI نتیجه شود را شرح دهد.

ADV_FSP.4.6C ۶-۲-۷-۲-۱۱

ردیابی باید نشان دهد که در مشخصات کارکردی SFRها TSFIها را طرح می‌کند.

۱۱-۲-۷-۳ عناصر عمل ارزیاب

ADV_FSP. 4.1E ۱-۳-۷-۲-۱۱

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

ADV_FSP.4.2E ۲-۳-۷-۲-۱۱

ارزیاب مشخصات کارکردی را که پشتیبان کامل و صحیحی از SFRها باشد را مشخص می‌کند.

۱۱-۲-۸ ADV_FSP.5 مشخصات کارکردی کامل نیمه - رسمی با اطلاعات اضافی اشتباه

وابسته‌ها: ADV_TDS.1 طراحی مقدماتی

ADV_IMP.1 ارائه پیاده‌سازی TSF.

۱۱-۲-۸-۱-۱ عناصر عمل توسعه‌دهنده

ADV_FSP.5.1D ۱-۱-۸-۲-۱۱

توسعه‌دهنده باید مشخصات کارکردی را ارائه کند.

ADV_FSP.5.2D ۲-۱-۸-۲-۱۱

توسعه‌دهنده باید ردیابی از مشخصات کارکردی به SFRها را تهیه کند.

۱۱-۲-۸-۲ عناصر ارائه و محتوی

۱۱-۲-۸-۲-۱ ADV_FSP.5.1C

مشخصات کارکردی باید کاملاً TSF را بیان کند.

۱۱-۲-۸-۲-۲ ADV_FSP.5.2C

مشخصات کارکردی باید TSFI را با سبک نیمه رسمی تشریح کند.

۱۱-۲-۸-۲-۳ ADV_FSP.5.3C

مشخصات کارکردی باید هدف TSFI ها و روش استفاده از آن را تشریح کند.

۱۱-۲-۸-۲-۴ ADV_FSP.5.4C

مشخصات کارکردی باید تمام پارامترهای مربوط به TSFI را شناسایی و شرح دهد.

۱۱-۲-۸-۲-۵ ADV_FSP.5.5C

مشخصات کارکردی باید عمل‌های مرتبط با TSFI را توصیف کند.

۱۱-۲-۸-۲-۶ ADV_FSP.5.6C

مشخصات کارکردی باید تمام پیام‌های خطای مستقیم که ممکن است از فراخوانی هر TSFI نتیجه شود را شرح دهد.

۱۱-۲-۸-۲-۷ ADV_FSP.5.7C

مشخصات کارکردی باید پیام‌های خطای مستقیم که از فراخوانی هر TSFI نتیجه نمی‌شود را توصیف کند.

۱۱-۲-۸-۲-۸ ADV_FSP.5.8C

مشخصات کارکردی باید هر یک از پیام‌های خطا موجود در پیاده‌سازی TSF که هنوز از فراخوانی TSFI نتیجه نشده است را توجیه کند.

ردیابی باید نشان دهد که در مشخصات کارکردی SFR ها TSFI ها طرح می‌کند.

۱۱-۲-۸-۲-۹ ADV_FSP.5.9C

توسعه‌دهنده باید ردیابی از مشخصات کارکردی به SFR ها را ارائه کند.

۱۱-۲-۸-۳ عناصر عمل ارزیاب

۱۱-۲-۸-۳-۱ ADV_FSP.5.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۱-۲-۸-۳-۲ ADV_FSP.5.2E

ارزیاب مشخصات کارکردی که پشتیبان کامل و صحیحی از SFR ها باشد را مشخص می‌کند.

۱۱-۲-۹ ADV_FSP.6 مشخصات کارکردی کامل رسمی با خصوصیات اضافی رسمی

وابسته‌ها: ADV_TDS.1 : طراحی مقدماتی

ADV_IMP.1 ارائه پیاده‌سازی TSF .

۱۱-۲-۹-۱-۱ عناصر عمل توسعه‌دهنده

۱۱-۲-۸-۱-۱ ADV_FSP.5.1D

توسعه‌دهنده باید مشخصات کارکردی را ارائه کند.

۱۱-۲-۹-۱-۲ ADV_FSP.6.2D

توسعه‌دهنده باید معرفی رسمی از مشخصات کارکردی TSF تهیه کند.

۱۱-۲-۹-۱-۳ ADV_FSP.6.3D

توسعه‌دهنده باید ردیابی از مشخصات کارکردی به SFR ها را تهیه کند.

۱۱-۲-۹-۲ عناصر ارائه و محتوا

۱۱-۲-۹-۲-۱ ADV_FSP. 6.1C

مشخصات کارکردی باید کاملاً TSF را بیان کند.

۱۱-۲-۹-۲-۲ ADV_FSP.6.2C

مشخصات کارکردی باید TSFI را با سبک رسمی تشریح کند.

۱۱-۲-۹-۲-۳ ADV_FSP.6.3C

مشخصات کارکردی باید هدف TSFI ها و روش استفاده از آن را تشریح کند.

۱۱-۲-۹-۲-۴ ADV_FSP.6.4C

مشخصات کارکردی باید تمام پارامترهای مربوط به TSFI را شناسایی و شرح دهد.

۱۱-۲-۹-۲-۵ ADV_FSP.6.5C

مشخصات کارکردی باید عمل‌های مرتبط با TSFI را توصیف کند.

۱۱-۲-۹-۲-۶ ADV_FSP.6.6C

مشخصات کارکردی باید تمام پیام‌های خطای مستقیم که ممکن است از فراخوانی هر TSFI نتیجه شود را شرح دهد.

۱۱-۲-۹-۲-۷ ADV_FSP.6.7C

مشخصات کارکردی باید تمام پیام‌های خطای موجود در ارائه پیاده‌سازی را توصیف کند.

۱۱-۲-۹-۲-۸ ADV_FSP.5.8C

مشخصات کارکردی باید دلیل هر یک از پیام‌های خطا موجود در پیاده‌سازی TSF که هنوز از فراخوانی TSFI نتیجه نشده است را ارائه کند. در غیر این صورت در مشخصات کارکردی توصیف شده علت همراه نبودن با TSFI را توجیه کند.

۱۱-۲-۹-۲-۹ ADV_FSP.6.9C

برای معرفی رسمی مشخصات کارکردی TSF باید TSFI را با سبک رسمی توصیف کرد و در جایی که نیاز باشد با متن غیررسمی پشتیبانی می‌شود. توسعه‌دهنده باید ردیابی از مشخصات کارکردی به SFRها را ارائه کند.

۱۱-۲-۹-۳ عناصر عمل ارزیاب

۱۱-۲-۸-۳-۱ ADV_FSP.5.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۱-۲-۹-۳-۲ ADV_FSP.6.2E

ارزیاب مشخصات کارکردی که پشتیبان کامل و صحیحی از SFRها باشد را مشخص می‌کند.

۱۱-۳-۳ نمایندگی پیاده سازی

۱۱-۳-۱ اهداف

عملکرد نمایندگی پیاده‌سازی خانواده (ADV_IMP) برای توسعه‌دهنده موجب دردسترس بودن ارائه پیاده‌سازی (و در سطوح بالاتر، پیاده‌سازی) TOE است به‌صورتی که توسط ارزیاب بتوان تجزیه و تحلیل کرد. نمایندگی پیاده‌سازی در فعالیت‌های تجزیه و تحلیل برای خانواده‌های دیگر (به‌عنوان مثال تجزیه و تحلیل طراحی TOE) برای نشان دادن این که TOE مطابق با طرح خود می‌باشد و ارائه کردن مبنایی برای تجزیه و تحلیل در نواحی دیگری از ارزشیابی (به‌عنوان مثال، برای جستجو آسیب پذیری) بکار گرفته می‌شود. از نمایش پیاده‌سازی انتظار می‌رود به‌شکلی باشد که فعالیت‌های داخلی مفصل TSF را نشان دهد. این ممکن است کد منبع نرم‌افزار، کد منبع میان‌افزار، نمودارهای سخت‌افزار و یا کد زبان طراحی سخت‌افزار مدار مجتمع^۱ یا طرح بندی^۲ اطلاعات باشد.

۱۱-۳-۲ رتبه‌بندی مؤلفه‌ها

مؤلفه‌ها در این خانواده براساس مقدار پیاده‌سازی مطابق با نگاشت توصیف طراحی TOE، رتبه‌بندی می‌شوند.

۱۱-۳-۳ نکات کاربردی

کد منبع، نمودارهای سخت‌افزار و یا کد زبان طراحی سخت‌افزار مدار مجتمع یا طرح بندی اطلاعات که برای ساخت سخت‌افزارهای واقعی استفاده می‌شوند که نمونه‌هایی از قسمت‌های ارائه پیاده‌سازی هستند.

1-IC

2- layout

توجه به این نکته مهم است که در حالی که ارائه پیاده سازی برای ارزیاب بایستی در دسترس باشد، ولی این بدان معنی نیست که ارزیاب آن را تصرف کند.

به عنوان مثال، توسعه دهنده ممکن است بخواهد که ارزیاب عرضه پیاده سازی در موقعیت انتخابی توسعه دهنده را مرور کند.

ارائه پیاده سازی کل در دسترس می باشد برای اطمینان از این که فعالیت های تجزیه و تحلیل به علت نبود اطلاعات محدود نیستند.

با این حال هنگامی که فعالیت های تجزیه و تحلیل در حال انجام می باشد همه عرضه ها مورد بررسی قرار می گیرند.

این تقریباً در همه موارد غیر عملی است، علاوه بر این واقعیت که به احتمال زیاد منتج به تضمین - بهتر TOE در مقابل نمونه برداری هدف مورد نظر از ارائه پیاده سازی نمی شود.

و اداری ساختن ارائه پیاده سازی در دسترس آنالیز تجزیه های طراحی TOE دیگر را مجاز می دارد (به عنوان مثال، مشخصات کارکردی، طراحی TOE)، و برای به دست آوردن اطمینان از قابلیت های امنیتی تشریح شده در سطح بالاتری در طراحی که در واقع ظاهر می شود که در TOE پیاده سازی شود.

قراردادها برای تعیین کردن در برخی از قالب های ارائه پیاده سازی ممکن است آن را مشکل یا غیر ممکن سازد. از خود ارائه پیاده سازی چه نتیجه واقعی از کامپایل¹ یا زمان اجرا تفسیر خواهد شد.

به عنوان مثال، دستورات کامپایلر برای کامپایلرهای زبان C موجب خواهد شد که کامپایلر کل قسمت های کد را محروم و یا شامل سازد.

به همین دلیل، مهم است که چنین اطلاعات "اضافی" یا ابزارهای مرتبط (اسکرپت ها، کامپایلرها، و غیره) ارائه شود به طوری که نمایش پیاده سازی می تواند به درستی مشخص شود.

هدف از مسيردهی بین ارائه پیاده سازی و شرح طراحی TOE کمک به تجزیه و تحلیل ارزیاب می باشد.

زمانی که طراحی TOE با قسمت های مربوط ارائه پیاده سازی تجزیه و تحلیل شود، فعالیت های داخلی TOE ممکن است بهتر درک شود.

مسيردهی به عنوان راهنما ارائه پیاده سازی خدمت می کند در مؤلفه پایین تر، فقط یک زیر مجموعه از ارائه پیاده سازی به شرح طراحی TOE مسيردهی می شود.

به دلیل عدم اطمینان از قسمت های ارائه پیاده سازی که نیاز به مسيردهی دارد، توسعه دهنده ممکن است انتخاب کند که یا کل ارائه پیاده سازی را از قبل مسيردهی کند یا صبر کند تا ببیند که ارزیاب کدام قسمت های ارائه پیاده سازی نیاز به مسيردهی است.

ارائه پیاده سازی توسط توسعه دهنده برای تبدیل به پیاده سازی واقعی دستکاری می شود.

به عنوان مثال، توسعه دهنده ممکن است با فایل های حاوی منبع کد کار می کند، در نهایت برای این که قسمتی از TSF شود، کامپایل می شود.

توسعه دهنده ارائه پیاده سازی را در قالبی که توسط توسعه دهنده بکار می رود در دسترس می سازد، به طوری که ارزیاب ممکن است از تکنیک خودکار در تجزیه و تحلیل استفاده کند.

همچنین این اطمینان را افزایش می‌دهد که ارائه پیاده‌سازی که مورد بررسی واقع می‌شود، در واقع همانی است که در تولید TSF استفاده شده است. (همانطور که مخالفت می‌کند به موردی، که آن در قالب ارائه جایگزین تأمین می‌شود، مانند سند پردازش واژه).

باید توجه داشت که قالب‌های دیگری از ارائه پیاده‌سازی نیز ممکن است توسط توسعه‌دهنده مورد استفاده قرار گیرد؛ این قالب‌ها نیز تأمین می‌شوند.

هدف کلی این است که ارزیاب را با مورد بررسی قراردادن اطلاعاتی که کارایی تلاش‌های تجزیه و تحلیل ارزیاب را به حداکثر رساند، تأمین کنیم.

برخی قالب‌های ارائه پیاده‌سازی ممکن است به اطلاعات اضافی نیاز باشد به دلیل این که آنها موانع قابل توجهی برای درک و تجزیه و تحلیل مطرح می‌کنند.

مثالها عبارتند از "پوشش"^۱ که منبع یا کد منبعی که به روش‌های دیگر مبهم هستند به‌طوری که آن را مانع از درک و یا تجزیه و تحلیل می‌کند.

قالب‌های ارائه پیاده‌سازی به‌طور معمول از توسعه‌دهنده TOE با برداشتن یک نسخه از ارائه پیاده‌سازی و اجرای یک پوشش یا مبهم کردن برنامه منتج می‌شود.

در حالی که ارائه پوشش آن چیزی است که کمپایل شده است و ممکن است به پیاده‌سازی (از لحاظ ساختار) نزدیکتر از اصلی باشد، ارائه غیر پوشش^۲، تأمین چنین کدهای مبهم ممکن است زمان قابل توجه بیشتری برای انجام وظایف تجزیه و تحلیل ارائه صرف شود.

وقتی که چنین قالب‌های ارائه ایجاد می‌شود، مؤلفه‌ها نیاز به جزئیات ابزار/ الگوریتم‌های پوشش بکار رفته، دارد به‌طوری که ارائه غیر پوشش می‌تواند تأمین شود، و از اطلاعات اضافی برای بدست آوردن اطمینان از فرایند پوشش که نمی‌تواند سازش با هر قابلیت امنیتی کند، استفاده می‌شود.

۱۱-۳-۴ ارائه پیاده‌سازی TSF ADV_IMP.1

وابسته‌ها: ADV_TDS.3 طراحی پیمانه‌ای مقدماتی

ALC_TAT.1 ابزار توسعه به‌خوبی تعریف شده

۱۱-۳-۴-۱ عناصر عمل توسعه‌دهنده

۱۱-۳-۴-۱-۱ ADV_IMP.1.1D

توسعه‌دهنده ارائه پیاده‌سازی برای کل TSF را در دسترس می‌سازد

۱۱-۳-۴-۱-۲ ADV_IMP.1.2D

توسعه‌دهنده مسیره‌ی بین شرح طراحی TOE و نمونه ارائه پیاده‌سازی را برقرار کند.

۱۱-۳-۴-۲ عناصر ارائه و محتوا

۱۱-۳-۴-۲-۱ ADV_IMP.1.1C

1- shrouded
2-unshrouded

ارائه پیاده‌سازی باید TSF را تعریف کند به سطح جزئیاتی که بتوان TSF را بدون تصمیمهای طراحی بیشتر ایجاد کرد.

ADV_IMP.1.2C ۲-۲-۴-۳-۱۱

نشان دادن پیاده‌سازی باید به قالب استفاده شده توسط کارکنان توسعه باشد.

ADV_IMP.1.3C ۳-۲-۴-۳-۱۱

مسیردهی بین شرح طراحی TOE و نمونه ارائه پیاده‌سازی باید مطابقت آنها را نشان دهد.

۱۱-۳-۴-۳ عناصر عمل ارزیاب

ADV_IMP.1.1E ۱-۳-۴-۳-۱۱

ارزیاب باید آن را تأیید کند که برای نمونه انتخاب شده ارائه پیاده‌سازی، اطلاعات ارائه شده کلیه الزامات محتوی و ارائه مدارک را برآورده می‌کند.

۱۱-۳-۵ ADV_IMP.2 مسیردهی کامل ارائه پیاده‌سازی TSF

وابسته‌ها: ADV_TDS.3 طراحی پیمانه‌ای مقدماتی

ALC_TAT.1 ابزار توسعه به‌خوبی تعریف شده

۱۱-۳-۵-۱ عناصر عمل توسعه‌دهنده

ADV_IMP.2.1D ۱-۵-۳-۱۱

توسعه‌دهنده ارائه پیاده‌سازی را برای کل TSF در دسترس می‌سازد.

ADV_IMP.2.2D ۲-۱-۵-۳-۱۱

توسعه‌دهنده مسیردهی بین شرح طراحی TOE و تمام ارائه پیاده‌سازی را برقرار کند.

۱۱-۳-۵-۲ عناصر ارائه و محتوا

ADV_IMP. 2.1C ۱-۲-۵-۳-۱۱

ارائه پیاده‌سازی باید TSF را تعریف کند به سطح جزئیاتی که بتوان TSF را بدون تصمیمهای طراحی بیشتر ایجاد کرد.

ADV_IMP. 2.2C ۲-۲-۵-۳-۱۱

نشان دادن پیاده‌سازی باید به‌صورت استفاده شده توسط کارکنان توسعه باشد.

ADV_IMP. 2.3C ۳-۲-۵-۳-۱۱

مسیردهی بین شرح طراحی TOE و تمام ارائه پیاده‌سازی باید مطابقت آنها را نشان دهد.

۱۱-۳-۵-۳ عناصر عمل ارزیاب

ADV_IMP. 2.1E ۱-۳-۵-۳-۱۱

ارزیاب باید آن را تأیید کند که برای نمونه انتخاب شده ارائه پیاده‌سازی، اطلاعات ارائه شده کلیه الزامات محتوی و ارائه مدارک را برآورده می‌کند.

۱۱-۴ (ADV_INT) درونیهای TSF

۱۱-۴-۱ اهداف

این خانواده به ارزیابی ساختار درونی TSF اشاره می‌کند. TSF‌های درونی که به خوبی ساخته شده‌اند پیاده‌سازی آنها راحت‌تر است و احتمال کم دارد که شامل معایبی باشد که منجر به آسیب‌پذیری‌ها شود؛ و همچنین آسان‌تر است که بدون معرفی معایب نگهداری شود.

۱۱-۴-۲ رتبه‌بندی مؤلفه

مؤلفه‌ها در این خانواده براساس ساختار و میزان پیچیدگی مورد نیاز رتبه‌بندی می‌شود. ADV_INT.1 زیرمجموعه خوب ساخته شده درونی TSF، مکان‌های مورد نیاز برای درونی‌های خوب ساخته شده فقط در قسمت‌های انتخاب شده از TSF هستند.

در EAL این مؤلفه شامل نمی‌شود بدلیل این‌که این مؤلفه برای استفاده در شرایط خاص به نمایش گذاشته می‌شود (به‌عنوان مثال ضامن برای یک پیمانه نهفته که از بقیه TSF‌ها جدا شده است احساس نگرانی می‌کند) و به‌طور گسترده‌ای قابل اجرا نخواهد بود.

در سطح بعد، الزامات درونی با ساختار خوب بر تمامی TSF قرار می‌گیرند. درنهایت، میزان پیچیدگی در بالاترین مؤلفه معرفی می‌شود.

۱۱-۴-۳ نکات کاربردی

این الزامات هنگامی که در ساختار درونی TSF بکار گرفته می‌شود، معمولاً منجر به بهبود کمک‌هایی به توسعه‌دهنده و ارزیاب در فهم TSF می‌شود و همچنین پایه و اساسی برای طراحی و ارزشیابی مناسب بودن آزمون فراهم می‌کند.

علاوه بر این، بهبود فهم TSF باید توسعه‌دهنده را در تسهیل در نگهداشت‌پذیری آن کمک کند. الزامات در این خانواده در سطح انتزاعی نسبتاً خوب ارائه شده است. تنوع گسترده‌ای از TOE‌ها برای رمزی کردن هر چیزی خاص‌تر از "ساختار خوب" و یا "پیچیدگی حداقل" باشد، را غیر ممکن می‌سازد.

قضاوتها در ساختار و پیچیدگی انتظار می‌رود که از فن‌آوری‌های خاص مورد استفاده در TOE مشتق شده باشد. به‌عنوان مثال، به احتمال زیاد نرم‌افزار با ساختار خوب در نظر گرفته می‌شود اگر آن خصوصیات ذکر شده در رشته مهندسی نرم‌افزار به نمایش گذاشته شود.

مؤلفه‌های این خانواده برای شناسایی استانداردهای مربوط به اندازه‌گیری مشخصه‌های با ساختار خوب و نه بیش از حد پیچیده خوانده می‌شود.

۱۱-۴-۱۱ ADV_INT.1 زیرمجموعه درونی TSF با ساختار خوب

وابسته‌ها: ADV_IMP.1 ارائه پیاده‌سازی TSF

ADV_TDS.3 طراحی پیمانه‌ای مقدماتی

1.ALC_TAT ابزار توسعه با ساختار خوب

۱۱-۴-۴ اهداف

هدف از این مؤلفه فراهم کردن واسطه‌هایی برای نیاز قسمت‌های خاصی از TSF که دارای ساختار خوب باشد، می‌باشد.

قصد این است که کل TSF با استفاده از اصول مهندسی دقیق طراحی و پیاده‌سازی شده باشد، اما فقط تجزیه و تحلیل یک زیر مجموعه خاص انجام می‌شود.

۱۱-۴-۴ نکات کاربردی

این مؤلفه نیاز به نویسنده PP یا ST که واگذاری اسناد را با زیر مجموعه‌ای از TSF شرح دهد.

این زیر مجموعه برحسب درونیهای TSF می‌باشد که در هر لایه‌ای از انتزاع ممکن است شناخته شود.

به‌عنوان مثال: الف) عناصر ساختاری TSF همان‌طور که در طراحی TOE شناسایی شده (به‌عنوان مثال "توسعه‌دهنده باید زیر سیستم ممیزی را طراحی و پیاده‌سازی کند به‌طوری که آن درونی‌های با ساختار خوب داشته باشد").

پیاده‌سازی (به‌عنوان مثال "توسعه‌دهنده باید طراحی و پیاده‌سازی فایل‌های encrypt.c و decrypt.c را طراحی و پیاده‌سازی کند به‌طوری که آن درونی‌های با ساختار خوب داشته باشد." و یا "توسعه‌دهنده باید مدار مجتمع چیپ^۱ ۶۲۲۷ را طراحی و پیاده‌سازی کند تراشه به‌طوری که آن درونیهای با ساختار خوب داشته باشد.")

احتمال دارد این با مراجعه به SFRهای خواسته شده به آسانی انجام نشود (به‌عنوان مثال "توسعه‌دهنده باید قسمتی از TSF که نرم‌افزاری^۲ فراهم می‌کند و در FPR_ANO.2 تعریف شده است را طراحی و پیاده‌سازی کند طوری که آن درونیهای با ساختار خوب داشته باشد"). به دلیل آن که این مرکز توجه تجزیه و تحلیل را نشان نمی‌دهد.

این مؤلفه مقدار محدودی دارد و در مواردی مناسب است که به‌طور بالقوه - مخرب کاربرها/مطالب، محدودیت دارند یا برای دسترسی به TSFIها به‌شدت کنترل می‌شوند یا در حالی که مفهوم دیگری از حفاظت وجود داشته باشد (به‌عنوان مثال، تفکیک دامنه) طوری که مطمئن سازد که زیر مجموعه انتخاب شده از TSF نمی‌تواند با بقیه TSF به‌طور مخالف تأثیرگذار است. به‌عنوان مثال، قابلیت نهفته، که از بقیه TSF مجزا است، به‌خوبی ساخته شده است).

۱۱-۴-۴ عناصر عمل توسعه‌دهنده

۱۱-۴-۴-۱ ADV_INT.1.1D

توسعه‌دهنده باید طراحی و پیاده‌سازی کند [واگذاری : زیر مجموعه‌ای از TSF] طوری که درونی‌های با ساختار خوب داشته باشد.

۱۱-۴-۴-۲ ADV_INT.1.2D

1 - Chip

2- Anonymity

توسعه‌دهنده باید شرح درونی و توجیهات را فراهم کند.

۱۱-۴-۴ عناصر ارائه و محتوی

ADV_INT.1.1C ۱-۴-۴-۱۱

توجیهات باید خصیصه‌های مورد استفاده برای تشخیص‌دادن مفهوم "ساختار خوب" را توضیح دهد.

ADV_INT.1.2C ۲-۴-۴-۱۱

شرح درونی TSF باید نشان دهد که زیر مجموعه واگذاری TSF به‌خوبی ساخته می‌شود.

۱۱-۴-۵ عناصر عمل ارزیاب

ADV_INT.1.1E ۱-۵-۴-۱۱

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

ADV_INT.1.2E ۲-۵-۴-۱۱

ارزیاب باید تجزیه و تحلیل بر روی زیرمجموعه واگذارشده TSF انجام دهد.

۱۱-۴-۵ ADV_INT.2 درونی‌های خوب ساخته شده

وابسته‌ها: ADV_IMP.1 ارائه پیاده‌سازی TSF

ADV_TDS.3 طرح پیمانه‌ای مقدماتی

ALC_TAT.1 ابزار توسعه خوب تعریف شده

۱۱-۴-۵ اهداف

هدف از این مؤلفه فراهم کردن واسطه‌هایی برای نیاز قسمت‌های خاصی از TSF که دارای ساختار خوب باشد، می‌باشد.

قصد این است که کل TSF با استفاده از اصول مهندسی دقیق طراحی و پیاده‌سازی شده باشد، اما فقط تجزیه و تحلیل یک زیر مجموعه خاص انجام می‌شود.

۱۱-۴-۵ نکات کاربردی

انتظار می‌رود که توجیهات در مورد مناسبت ساختاری از فن‌آوری ویژه مورد استفاده در TOE مشتق شود. این مؤلفه برای شناسایی استانداردها در مورد سنجش خصیصه‌هایی که به‌خوبی ساخته می‌شوند، خواسته می‌شود.

۱۱-۴-۵ عناصر عمل توسعه‌دهنده

ADV_INT.2.1D ۱-۳-۵-۴-۱۱

توسعه‌دهنده باید تمامی TSF را طراحی و پیاده‌سازی کند طوری که درونی‌های با ساختار خوب داشته باشد.

ADV_INT.2.2D ۲-۳-۵-۴-۱۱

توسعه‌دهنده باید شرح درونی و توجیهات را فراهم کند.

۱۱-۴-۵ عناصر ارائه و محتوا

ADV_INT. 2.1C ۱-۴-۵-۴-۱۱

توجیهات باید خصیصه‌های مورد استفاده برای تشخیص دادن مفهوم "ساختار خوب" را شرح دهد.

ADV_INT.2.2C ۲-۴-۵-۴-۱۱

شرح درونی TSF باید نشان دهد که زیر مجموعه واگذار شده TSF به‌خوبی ساخته می‌شود.

۱۱-۴-۵ عناصر عمل ارزیاب

ADV_INT. 2.1E ۱-۵-۵-۴-۱۱

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

ADV_INT.2.2E ۲-۵-۵-۴-۱۱

ارزیاب باید تجزیه و تحلیل بر روی زیرمجموعه واگذار شده TSF انجام دهد.

۱۱-۴-۶ ADV_INT.3 درونی‌های حداقل پیچیده

وابسته‌ها: ADV_IMP.1 ارائه پیاده‌سازی TSF

ADV_TDS.3 طرح پیمانه‌ای مقدماتی

ALC_TAT.1 ابزار توسعه خوب تعریف شده

۱۱-۴-۶ اهداف

هدف از این مؤلفه فراهم کردن واسطه‌هایی برای نیاز قسمت‌های خاصی از TSF که دارای ساختار خوب باشد، می‌باشد.

قصد این است که کل TSF با استفاده از اصول مهندسی دقیق طراحی و پیاده سازی شده باشد، اما فقط تجزیه و تحلیل یک زیر مجموعه خاص انجام می‌شود.

۱۱-۴-۶ نکات کاربردی

انتظار می‌رود که توجیهات در مورد مناسبت ساختاری از فن‌آوری ویژه مورد استفاده در TOE مشتق شود. این مؤلفه برای شناسایی استانداردها در مورد سنجش ساختاری و پیچیدگی، فراخوانده می‌شود.

۱۱-۴-۶ عناصر عمل توسعه‌دهنده

ADV_INT.2.1D ۱-۳-۶-۴-۱۱

توسعه‌دهنده باید تمامی TSF را طراحی و پیاده‌سازی کند طوری که درونی‌های با ساختار خوب داشته باشد.

ADV_INT.2.2D ۲-۳-۶-۴-۱۱

توسعه‌دهنده باید شرح درونی و توجیهات را فراهم کند.

۱۱-۴-۶ عناصر ارائه و محتوا

۱۱-۴-۶-۴-۱ ADV_INT. 2.1C

توجیهات باید خصیصه‌های مورد استفاده برای تشخیص دادن مفهوم "ساختار خوب"^۱ و "پیچیده"^۲ را شرح دهد.

۱۱-۴-۶-۲ ADV_INT.3.2C

شرح درونی TSF باید نشان دهد تمامی TSF به خوبی ساخته می‌شود و بیش از حد پیچیده نیست.

۱۱-۴-۶-۵ عناصر عمل ارزیاب

۱۱-۴-۶-۵-۱ ADV_INT. 2.1E

ارزیاب باید تأیید کند که اطلاعات ارائه شده تمامی الزامات محتوی و ارائه مدارک را برآورده می‌کند.

۱۱-۴-۶-۵-۲ ADV_INT.2.2E

ارزیاب باید تجزیه و تحلیل بر روی زیرمجموعه واگذار شده TSF انجام دهد.

۱۱-۵ مدل خط‌مشیء امنیت (ADV_SPM)

۱۱-۵-۱ اهداف

هدف از این خانواده فراهم کردن تضمین اضافی برای توسعه یک مدل خط‌مشیء رسمی امنیتی TSF، و ایجاد مطابقت بین مشخصات کارکردی و مدل خط‌مشیء امنیتی می‌باشد.

برای حفظ انسجام داخلی از مدل خط‌مشیء امنیت چشم داشت می‌شود که به طور رسمی اصول امنیتی از خصیصه‌های خود از طریق اثبات ریاضی برقرار کند.

۱۱-۵-۲ رتبه‌بندی مؤلفه

این خانواده فقط شامل یک مؤلفه است.

۱۱-۵-۳ نکات کاربردی

نامناسبی‌ها در TOE یا از عدم موفقیت در درک الزامات امنیتی است یا از پیاده‌سازی ناقص این الزامات امنیتی ناشی می‌شود.

شناختن الزامات امنیتی به قدر کافی باشد که متقاعد کند که درک آنها ممکن است غامض است بدلیل آنکه تعریف باید به قدر کافی دقیق باشد تا از نتایج نامناسب یا از معایب نامحسوس در حین پیاده‌سازی TOE ممانعت کند.

درس‌تاسر طراحی، پیاده‌سازی و فرایندهای بازنگری، الزامات امنیتی مدل ممکن است به عنوان طراحی دقیق و راهنمای پیاده‌سازی بکار رود، در نتیجه برقرار کردن امنیت افزایشی که الزامات امنیتی مدل توسط TOE را برآورده می‌کند.

دقت مدل و راهنمای نهایی به طور قابل توجهی توسط طرح کردن مدل در زبان رسمی و تأیید الزامات امنیتی از طریق اثبات رسمی بهبود یافته است.

1- well-structured

2 - complex

ایجاد مدل خط‌مشیء امنیتی رسمی به شناسایی و از بین بردن عناصر مبهم، متناقض و یا غیر قابل اجرا کمک می‌کند.

هنگامی که TOE ساخته شده است، مدل‌های رسمی در خدمت تلاش‌های ارزشیابی شده با مشارکت قضاوت ارزیاب از درک توسعه‌دهنده در مورد قابلیت‌های امنیتی که در حال اجرا هستند و اینکه آیا ناسازگاری و تناقض بین الزامات امنیتی و طراحی TOE وجود دارد.

اطمینان در مدل‌ها با اثبات این که شامل هیچ ناسازگاری و تناقض نیست همراه است.

مدل امنیتی رسمی، ارائه رسمی دقیق از جنبه‌های مهم امنیت و ارتباط آنها با رفتار TOE است. و آن مجموعه‌ای از قوانین و تمریناتی را که اداره می‌کند چگونگی مدیریت، حفاظت TSF را شناسایی می‌کند و در غیراین‌صورت منابع سامانه را کنترل می‌کند.

مدل شامل مجموعه‌ای از محدودیت‌ها و خواصی هستند که مشخص می‌کند که چگونه اطلاعات و منابع کامپیوتری که برای نقض SFRها استفاده می‌شود را ممانعت کند، باتفاق مجموعه‌ای از استدلال‌های مهندسی متقاعدکننده که نشان می‌دهد این محدودیت‌ها و خواص نقش کلیدی در اجرای SFRها ایفا می‌کند.

این شامل صورت‌گرایی که قابلیت‌های امنیتی را بیان می‌کند، و همچنین به‌عنوان متن کمکی که مدل را به ما توضیح دهند و آن را با متن ارائه کنند.

رفتار امنیت TSF در هر دو شرایط رفتارهای بیرونی (به‌عنوان مثال چگونه TSF با بقیه TOE و با محیط‌های عملیاتی خود در تعامل است)، و همچنین رفتارهای درونی الگوبرداری شده است.

مدل خط‌مشیء امنیتی TOE به‌صورت غیررسمی از تحقق آن با در نظر گرفتن الزامات امنیتی پیشنهاد شده از ST استخراج می‌شود.

استخراج غیررسمی موفق باشد. اگر اصول TOE ("ویژگیها" نیز نامیده می‌شوند) در نظر گرفته شده توسط خصوصیات آن اجرا می‌شود.

هدف از روش‌های رسمی واقع شدن مطابق با افزایش دقت زیاد در اجرا است.

استدلال غیررسمی همیشه به مغالطه مستعد هستند؛

به‌خصوص اگر روابط بین موضوع‌ها، اشیاء و عملیات، بیشتر و بیشتر درگیر شود.

به‌منظور به‌حداقل رساندن خطر وضعیت ناامن ورود قوانین و خصیصه‌های مدل خط‌مشیء امنیت باخواص مربوطه و مشخصه‌ها مطابق با برخی سیستم رسمی مسيردهی می‌شوند، پس از آن سختی و مقاومت، برای به‌دست آوردن ویژگی‌های امنیتی با استفاده از قضایا و اثبات رسمی می‌توانند مورد استفاده قرار گیرند.

در حالی که اصطلاح "مدل‌های خط‌مشیء رسمی امنیتی" در محافل دانشگاهی مورد استفاده قرار می‌گیرد، در رویکرد ایزو ۱۵۴۰۸^۱ هیچ تعریف ثابتی از "امنیت" ندارد؛ و آن برابر آن چه SFRها مدعی می‌شوند. بنابراین، مدل خط‌مشیء رسمی امنیتی صرفاً ارائه رسمی مجموعه‌ای از SFRهایی که خواسته می‌شود، می‌باشد.

اصطلاح خط‌مشیء امنیتی به‌طور متداول فقط با خط‌مشی‌های کنترل دسترسی، چه مبتنی بر پرچسب^۲ (کنترل دسترسی اجباری) یا مبتنی بر کاربر (کنترل دسترسی اختیاری) همراه است.

¹ ISO/IEC 15408

² labelbased -

با این حال، یک خط‌مشیء امنیتی به کنترل دسترسی محدود نمی‌شود؛ خط‌مشی‌های ممیزی هم وجود دارد، خط‌مشی‌های تعیین هویت، خط‌مشی‌های تعیین اعتبار و صحت اسناد، خط‌مشی‌های رمزنگاری، خط‌مشی‌های مدیریت، و هر گونه خط‌مشی‌های امنیتی که توسط TOE قابل اجرا هستند، همانطور که در PP/ST توصیف شده است.

ADV_SPM.1.1D شامل انتساب برای تشخیص این خط‌مشی‌هایی که بطور رسمی مدل شده است.

۱۱-۵-۴ ADV_SPM.1 مدل خط‌مشیء امنیتی رسمی TOE

وابسته‌ها: ADV_FSP.4 مشخصات کامل کارکردی

۱۱-۵-۴ ۱ عناصر عمل توسعه‌دهنده

توسعه‌دهنده باید مدل خط‌مشیء رسمی امنیتی را فراهم کند
[انتساب : لیستی از خط‌مشی‌ها که بطور رسمی مدل شده است]

۱۱-۵-۴ ۲ ADV_SPM.1.2D

برای هر خط‌مشیء پوشش یافته توسط مدل خط‌مشیء رسمی امنیت، مدل باید قسمت مربوط به بیانیه‌ای از SFRها که خط‌مشیء را تشکیل می‌دهند را تشخیص دهد.

۱۱-۵-۴ ۳ ADV_SPM.1.3D

توسعه‌دهنده باید اثبات رسمی از مطابقت بین مدل و هر گونه خصوصیات کارکردی رسمی ارائه کنند.

۱۱-۵-۴ ۴ ADV_SPM.1.4D

توسعه‌دهنده باید اثبات مطابقت بین مدل و خصوصیات کارکردی را ارائه می‌کند.

۱۱-۵-۴ ۲ عناصر ارائه و محتوی

۱۱-۵-۴ ۱ ADV_SPM.1.1C

مدل باید در سبک رسمی باشد، توسط متن توضیحی چنانکه نیاز است، حمایت شود و خط‌مشی‌های امنیتی TSF که مدل شده است را شناسایی کند .

۱۱-۵-۴ ۲ ADV_SPM.1.2C

برای خط‌مشی‌های که مدل شده است، مدل باید امنیت را برای TOE تعریف کند و اثبات رسمی که TOE نمی‌تواند به وضعیتی که امن نیست برسد را برقرار کند.

۱۱-۵-۴ ۳ ADV_SPM.1.3C

مطابقت بین مدل و خصوصیات کارکردی باید در سطح رعایت اداب و رسوم صحیح باشد.

۱۱-۵-۴ ۴ ADV_SPM.1.4C

مطابقت باید نشان دهد که مشخصات کارکردی نامتناقض و کامل، با توجه به مدل، می‌باشد.

۱۱-۵-۴ ۵ ADV_SPM.1.5C

ارائه مطابقت باید نشان دهد که واسطه‌ها در خصوصیات کارکردی با توجه به خط‌مشی‌ها در انتساب ADV_SPM.1.1D نامتناقض و کامل هستند.

۱۱-۵-۴-۳ عناصر عمل ارزیاب

۱۱-۵-۴-۱ ADV_SPM.1.1E

ارزیاب باید تأیید کند که اطلاعات ارائه شده تمام الزامات مورد نیاز برای محتوا و ارائه مدارک را برآورده می‌کند.

۱۱-۶ طراحی TOE (ADV_TDS)

۱۱-۶-۱۱ اهداف

سند شرح طراحی TOE هم زمینه شرح TSF را فراهم می‌کند و هم شرح کامل TSF را فراهم می‌کند. همان‌طور که تضمین نیاز به افزایش دارد، سطح جزئیات فراهم‌شده در سند شرح نیز افزایش می‌یابد. همان‌طور که اندازه و پیچیدگی TSF افزایش می‌یابد، سطوح چندگانه تجزیه متناسب می‌شوند. هدف از الزامات طراحی، فراهم نمودن اطلاعات است (متناسب با سطح تضمین مورد نظر) در نتیجه می‌توان تصمیمی را برای فهم الزامات کارکردی امنیتی گرفت.

۱۱-۶-۲ سطح‌بندی مؤلفه

مؤلفه‌ها در این خانواده براساس اندازه اطلاعاتی که با توجه به TSF نیاز با ارائه‌شان می‌شود و بر اساس درجه رسمیت مورد نیاز سند شرح طراحی، سطح بندی می‌شوند.

۱۱-۶-۳ نکات کاربردی

هدف از سند طراحی فراهم نمودن اطلاعات کافی برای تعیین حدود TSF و شرح اینکه چطور TSF الزامات کارکردی امنیتی را پیاده‌سازی می‌کند است. اندازه و ساختار مستند طراحی به پیچیدگی TOE و تعداد SFRها بستگی خواهد داشت، در حالت کلی، پیچیدگی زیاد TOE همراه با تعداد زیادی SFR به مستند طراحی بیشتری نیاز دارد تا این‌که یک TOE بسیار ساده داشته باشیم همراه با تعداد کمی SFR. TOE‌های بسیار پیچیده (در ارتباط با تضمین فراهم‌شده) برای تولید سطوح مختلف تجزیه و تحلیل در شرح طراحی مفید خواهند بود، در حالی‌که TOE‌های بسیار ساده هم به شرح سطح بالای پیاده‌سازی‌شان و هم به شرح سطح پایین پیاده‌سازی‌شان نیاز ندارند.

این خانواده از دو سطح تجزیه و تحلیل استفاده می‌کند: زیرسیستم و پیمانه.

پیمانه خاص‌ترین شرح کارکرد است: یک پیمانه شرح پیاده‌سازی است. توسعه‌دهنده باید قادر به پیاده‌سازی TOEی شرح داده شده توسط پیمانه، بدون نیاز به طراحی اضافی باشد. زیرسیستم، شرح طراحی TOE است، و شرح سطح بالایی را از این‌که چه قسمتی از TOE در حال انجام کار است و چطور کار می‌کند، فراهم می‌کند. یک زیرسیستم، ممکن است به چند زیرسیستم سطح پایین، یا پیمانه تقسیم شود. TOE‌های بسیار پیچیده، برای این‌که یک شرح کافی و مفید از این‌که چطور TOE کار می‌کند ارائه دهند، ممکن است به زیرسیستم‌های مختلفی نیاز داشته باشند. TOE‌های بسیار ساده، در مقایسه با TOE‌های پیچیده، ممکن است به سطح زیرسیستم شرح، نیاز نداشته باشند و پیمانه خود به تنهایی بتواند شرح دهد که TOE چطور کار می‌کند.

رویکرد عمومی پذیرفته شده برای مستند طراحی این است که هر چه سطح تضمین افزایش می‌یابد، میزان اهمیت شرح، از حالت عمومی (سطح زیرسیستم) به سمت جزئیات بیشتر (سطح پیمانه) منتقل شود. در مواردی که سطح پیمانه انتزاعی، به دلیل ساده بودن شرح TOE در سطح پیمانه، سطحی مناسب است، هنوز سطح تضمین را برای زیرسیستم شرح، فراخوانی می‌کند و شرح سطح پیمانه، خود به تنهایی کافی خواهد بود. هرچند برای TOE های پیچیده، این مورد وجود ندارد: یک اندازه زیاد از (سطح-پیمانه) جزئیات، بدون همراهی سطح زیرسیستم شرح، ممکن است غیر قابل درک باشند.

این رویکرد، از این پارادایم عمومی پیروی می‌کند که فراهم نمودن جزئیات اضافی درباره پیاده‌سازی TSF، به ما تضمین بیشتری در مورد اینکه SFR ها به درستی پیاده‌سازی می‌شوند می‌دهد و اطلاعاتی را فراهم می‌کند که می‌تواند برای اثبات این مسأله در آزمون، مورد استفاده قرار بگیرد. (آزمون‌ها: ATE)

در الزامات این خانواده، اصطلاح واسطه، به معنی ارتباط (بین دو زیرسیستم یا پیمانه) است. واسطه، به شرح این مسأله می‌پردازد که چطور ارتباط، تقاضا می‌شود. این مسأله، شبیه جزئیات TSFI است. (ویژگی‌های کارکردی را ببینید. (ADV_FSP)). اصطلاح تعامل، برای شناختن هدف ارتباط به کار می‌رود و بیان می‌دارد که چرا دو زیرسیستم یا پیمانه در حال ارتباط با یکدیگر هستند.

۱۱-۶-۳-۱ جزئیات زیرسیستم‌ها و پیمانه‌ها

الزامات، مجموعه‌ای از جزئیات را در مورد زیرسیستم‌ها و پیمانه‌ها بیان می‌کنند:

الف) زیرسیستم‌ها و پیمانه‌ها همراه با لیست ساده‌ای که توضیح می‌دهد آن‌ها چه هستند مشخص می‌شوند.

ب) (پیمانه‌ها و زیرسیستم‌ها (چه به صورت ضمنی و چه به طور واضح) به گروه‌های مختلفی نظیر SFR اجرایی، SFR پشتیبان، یا SFR غیر مداخله‌گر تقسیم می‌شوند. کاربرد این اصطلاحات، مشابه کاربرد آن‌ها در قسمت ویژگی‌های کارکردی است. (ADV_FSP)

پ) رفتار یک زیرسیستم، در واقع، کاری است که انجام می‌دهد. همچنین، این رفتار ممکن است به گروه‌هایی نظیر SFR اجرایی، SFR پشتیبان یا SFR غیرمداخله‌گر، گروه‌بندی شود. رفتار خود زیرسیستم SFR بیشتر از زیرسیستم‌های SFR وابسته، طبقه‌بندی نمی‌شود. به عنوان مثال، زیرسیستم SFR اجرایی می‌تواند رفتاری به خوبی رفتار SFR پشتیبان یا رفتار SFR غیرمداخله‌گر داشته باشد.

ت) خلاصه رفتار زیرسیستم، رئوس کلی فعالیت‌هایی است که انجام می‌دهد. (به عنوان مثال، زیرسیستم TCP، دیتاگرام‌های IP را به جریان‌های بایتی معتبر، اسمبل می‌کند).

ث) شرح رفتار زیرسیستم، توضیح همه کارهایی است که انجام می‌دهد. این شرح، باید به حدی جزئیات را بیان کند که بتوان به آسانی تعیین کرد که آیا این رفتار هیچ وابستگی‌ای به اجرای SFR ها دارد یا نه.

ج) شرح تعامل بین زیرسیستم‌ها یا پیمانه‌ها دلیل ارتباط پیمانه‌ها یا زیرسیستم‌ها را مشخص می‌کند، و ویژگی‌های اطلاعاتی را که عبور می‌دهند مشخص می‌کند. نیازی نیست که اطلاعات ویژگی‌های واسطه، در سطح یکسانی از جزئیات تعریف شوند. به عنوان مثال، این کافی است که بگوییم " زیرسیستم X یک بلاک حافظه را از مدیر حافظه درخواست می‌کند که با مکانی از حافظه در تعامل است."

چ) شرح واسطه‌ها جزئیات این که چطور تعاملات میان پیمانه‌ها به شکلی موفق صورت می‌گیرد را فراهم می‌سازد. به جای شرح دلیل این که پیمانه‌ها با هم در ارتباط هستند یا هدف از ارتباطشان (که شرح تعاملات است) شرح

واسطها جزئیات این که چطور ارتباط انجام می‌شود را بر حسب ساختار و محتوای پیامها، مخابره‌ها، ارتباطات پردازش داخلی و... توضیح می‌دهد.

ح) هدف، توضیح می‌دهد که چطور پیمانہ کارکرد آنها را فراهم می‌کند. هدف، به اندازه کافی جزئیات را فراهم می‌کند به طوری که دیگر نیازی به تصمیم‌گیری‌های اضافی برای طراحی نیست. انطباق بین ارائه پیداده‌سازی که پیمانہ را پیداده‌سازی می‌کند و هدف پیمانہ باید به راحتی نمایان باشد.

خ) به غیر از پیمانہ‌هایی که شرح دادیم، یک پیمانہ بر حسب آن چیزی که در عنصر تعریف می‌شود شرح داده می‌شود.

زیرسیستم‌ها و پیمانہ‌ها، و SFR اجرایی و ... همگی با جزئیات بیشتری در ADV_TDS A.4: زیرسیستم‌ها و پیمانہ‌ها، توضیح داده شده‌اند.

۱۱-۶-۴ طراحی پایه‌ای ADV_TDS.1

وابسته‌ها: ویژگی‌های کارکردی امنیت اجرایی ADV_FSP.2

۱۱-۶-۴-۱ عناصر عمل توسعه‌دهنده

۱۱-۶-۴-۱-۱ ADV_TDS.1.1D1

توسعه‌دهنده باید طراحی TOE را فراهم کند.

۱۱-۶-۴-۱-۲ ADV_TDS.1.2D2

توسعه‌دهنده باید نقشه‌ای از TSFI ویژگی‌های کارکردی را نسبت به پایین‌ترین سطح تجزیه موجود در طراحی TOE، فراهم کند.

۱۱-۶-۴-۲ عناصر ارائه و محتوی

۱۱-۶-۴-۲-۱ ADV_TDS.1.1C1

طراحی باید ساختار TOE را در ارتباط با زیرسیستم، شرح دهد.

۱۱-۶-۴-۲-۲ ADV_TDS.1.2C2

طراحی باید همه زیرسیستم‌های TSF را شناسایی کند.

۱۱-۶-۴-۲-۳ ADV_TDS.1.3C3

طراحی باید رفتار هر SFR پشتیبان یا SFR غیر مداخله‌گر در TSF زیرسیستم را همراه با جزئیات کافی شرح دهد تا تعیین کند که SFR اجرایی نیست.

۱۱-۶-۴-۲-۴ ADV_TDS.1.4C4

طراحی باید رفتار SFR اجرایی زیرسیستم SFR اجرایی را خلاصه کند.

۱۱-۶-۴-۲-۵ ADV_TDS.1.5C5

طراحی باید سند شرح واکنش‌های میان زیرسیستم‌های SFR اجرایی TSF، و زیرسیستم‌های SFR اجرایی TSF و دیگر زیرسیستم‌های TSF را فراهم کند.

ADV_TDS.1.6C۶-۲-۴-۶-۱۱

نقشه، باید اثبات کند که همه رفتارهای شرح داده شده در طراحی TOE با TSFI‌هایی که آن را خواسته‌اند نگاشت شده‌اند.

۱۱-۶-۴-۳ عناصر عمل ارزیاب

ADV_TDS.1.1E۱-۳-۴-۶-۱۱

ارزیاب باید تأیید کند که اطلاعات فراهم‌شده، همه الزامات را برای محتوای مدرک و ارائه آن دارند.

ADV_TDS.1.2E۲-۳-۴-۶-۱۱

ارزیاب باید تعیین کند که طراحی الزامات کارکردی امنیتی به شکل دقیق و کامل است.

ADV_TDS.2.۵-۶-۱۱ طراحی معماری

وابسته‌ها: ویژگی‌های کارکردی همراه با خلاصه کامل ADV_FSP.3

۱۱-۶-۵-۱ عناصر عمل توسعه‌دهنده

ADV_TDS.2.1D۱-۱-۵-۶-۱۱

توسعه‌دهنده باید طراحی TOE را فراهم کند.

ADV_TDS.2.2D۲-۱-۵-۶-۱۱

توسعه‌دهنده باید نقشه‌ای از TSFI ویژگی‌های کارکردی را نسبت به پایین‌ترین سطح تجزیه موجود در طراحی TOE، فراهم کند.

۱۱-۶-۵-۲ عناصر ارائه و محتوی

ADV_TDS.2.1C۱-۲-۵-۶-۱۱

طراحی باید ساختار TOE را در ارتباط با زیرسیستم، شرح دهد.

ADV_TDS.2.2C۲-۲-۵-۶-۱۱

طراحی باید همه زیرسیستم‌های TSF را شناسایی کند.

ADV_TDS.2.3C۳-۲-۵-۶-۱۱

طراحی باید رفتار هر SFR پشتیبان یا SFR غیر مداخله‌گر در TSF زیرسیستم را همراه با جزئیات کافی شرح دهد تا تعیین کند که SFR اجرایی نیست.

ADV_TDS.2.4C۴-۲-۵-۶-۱۱

طراحی باید رفتار SFR اجرایی زیرسیستم SFR اجرایی را شرح دهد.

ADV_TDS.2.5C۵-۲-۵-۶-۱۱

طراحی باید رفتار SFR پشتیبان و SFR غیر مداخله‌گر زیرسیستم‌های SFR اجرایی را خلاصه کند.

ADV_TDS.2.6C۶-۲-۵-۶-۱۱

طراحی باید رفتار زیرسیستم‌های SFR پشتیبان را خلاصه کند.

ADV_TDS.2.7C۷-۲-۵-۶-۱۱

طراحی باید سند شرح واکنش‌های بین همه زیرسیستم‌های TSF را فراهم کند.

ADV_TDS.2.8C۸-۲-۵-۶-۱۱

نقشه، باید اثبات کند که همه رفتارهای شرح داده شده در طراحی TOE نسبت به TSFI‌هایی که آن را خواسته‌اند نگاشت شده است.

۳-۵-۶-۱۱ عناصر عمل ارزیاب

ADV_TDS.2.1E۱-۳-۵-۶-۱۱

ارزیاب باید تأیید کند که اطلاعات فراهم شده، همه الزامات را برای محتوای مدرک و ارائه آن دارند.

ADV_TDS.2.2E۲-۳-۵-۶-۱۱

ارزیاب باید تعیین کند که طراحی الزامات کارکردی امنیتی به صورت کامل و دقیق است.

۶-۶-۱۱ طراحی پیمانه‌ای پایه ADV_TDS.3

وابسته‌ها: ویژگی‌های کارکردی کامل ADV_FSP.4

۱-۶-۶-۱۱ عناصر عمل توسعه‌دهنده

ADV_TDS.3.1D۱-۱-۶-۶-۱۱

توسعه‌دهنده باید طراحی TOE را فراهم کند.

ADV_TDS.3.2D۲-۱-۶-۶-۱۱

توسعه‌دهنده باید نقشه‌ای از TSFI ویژگی‌های کارکردی را نسبت به پایین‌ترین سطح تجزیه موجود در طراحی TOE، فراهم کند.

۲-۶-۶-۱۱ عناصر ارائه و محتوی

ADV_TDS.3.1C۱-۲-۶-۶-۱۱

طراحی باید ساختار TOE را در ارتباط با زیرسیستم شرح دهد.

ADV_TDS.3.2C۲-۲-۶-۶-۱۱

طراحی باید TSF مرتبط به پیمانه‌ها را شرح دهد.

ADV_TDS.3.3C۳-۲-۶-۶-۱۱

طراحی باید همه زیرسیستم‌های TSF را شناسایی کند.

ADV_TDS.3.4C۴-۲-۶-۶-۱۱

طراحی باید سند شرح هر زیرسیستم TSF را فراهم نماید.

ADV_TDS.3.5C۵-۲-۶-۶-۱۱

طراحی باید سند شرح واکنش‌های بین همه زیرسیستم‌های TSF را فراهم کند.

ADV_TDS.3.6C۶-۲-۶-۶-۱۱

طراحی باید نقشه‌ای از زیرسیستم‌های TSF را نسبت به پیمانه‌های TSF فراهم نماید.

ADV_TDS.3.7C۷-۲-۶-۶-۱۱

طراحی باید هر پیمانه SFR اجرایی مرتبط به هدفش و واکنش با دیگر پیمانه‌ها را شرح دهد.

ADV_TDS.3.8C۸-۲-۶-۶-۱۱

طراحی، باید هر پیمانه SFR اجرایی را در ارتباط با واسطه‌های SFR مربوطه، مقادیر بازگشتی از آن واسطه‌ها، واکنش با آن‌ها و واسطه‌های فراخوانی شده به دیگر پیمانه‌ها شرح دهد.

ADV_TDS.3.9C۹-۲-۶-۶-۱۱

طراحی باید هر پیمانه SFR پشتیبان یا پیمانه SFR غیر مداخله‌گر را در ارتباط با هدفش و واکنش با دیگر پیمانه‌ها شرح دهد.

ADV_TDS.3.10C۱۰-۲-۶-۶-۱۱

نقشه، باید اثبات کند که همه رفتارهای شرح داده شده در طراحی TOE نسبت به TSFI‌هایی که آن را خواسته‌اند نگاشت شده است.

۱۱-۶-۶-۳ عناصر عمل ارزیاب

ADV_TDS.3.1E۱-۳-۶-۶-۱۱

ارزیاب باید تأیید کند که اطلاعات فراهم شده، همه الزامات را برای محتوای مدرک و ارائه آن دارند.

ADV_TDS.3.2E۲-۳-۶-۶-۱۱

ارزیاب باید تعیین کند که طراحی همه الزامات کارکردی امنیت به صورت کامل و دقیق است.

۱۱-۶-۷ طراحی پیمانه‌ای نیمه رسمی ADV_TDS.4

وابسته‌ها: ویژگی کارکردی نیمه رسمی کامل همراه با اطلاعات خطای اضافی ADV_FSP.5

۱۱-۷-۶-۱ عناصر عمل توسعه دهنده

ADV_TDS.4.1D۱-۱-۷-۶-۱۱

توسعه دهنده باید طراحی TOE را فراهم نماید.

ADV_TDS.4.2D۲-۱-۷-۶-۱۱

توسعه دهنده باید نقشه‌ای از TSFI ویژگی‌های کارکردی را نسبت به پایین‌ترین سطح تجزیه موجود در طراحی TOE، فراهم کند.

۱۱-۷-۶-۲ عناصر محتوای و ارائه

ADV_TDS.4.1C ۱-۲-۷-۶-۱۱

طراحی باید ساختار TOE ی مرتبط با زیر سیستم‌ها را شرح دهد.

ADV_TDS.4.2C ۲-۲-۷-۶-۱۱

طراحی باید TSF مرتبط با پیمانه‌ها، تعیین هر پیمانه به‌عنوان SFR اجرایی، SFR پشتیبان، یا SFR غیر مداخله‌گر را شرح دهد.

ADV_TDS.4.3C ۳-۲-۷-۶-۱۱

طراحی، باید همه زیرسیستم‌های TSF را شناسایی کند.

ADV_TDS.4.4C ۴-۲-۷-۶-۱۱

طراحی باید شرح نیمه‌رسمی هر زیرسیستم TSF را که توسط متن توضیحی و رسمی در جای مناسب خود پشتیبانی می‌شود فراهم نماید.

ADV_TDS.4.5C ۵-۲-۷-۶-۱۱

طراحی باید شرح واکنش‌های میان زیرسیستم‌های TSF را فراهم نماید.

ADV_TDS.4.6C ۶-۲-۷-۶-۱۱

طراحی باید نقشه‌ای از زیرسیستم‌های TSF را نسبت به پیمانه‌های TSF فراهم نماید.

ADV_TDS.4.7C ۷-۲-۷-۶-۱۱

طراحی باید هر SFR اجرایی و پیمانه SFR پشتیبان مرتبط با هدفش و واکنش با دیگر پیمانه‌ها را شرح دهد.

ADV_TDS.4.8C ۸-۲-۷-۶-۱۱

طراحی، باید هر پیمانه SFR اجرایی و پیمانه SFR پشتیبان را در ارتباط با واسطه‌های SFR مربوطه، مقادیر بازگشتی از آن واسطه‌ها، واکنش با آن‌ها و واسطه‌های فراخوانی شده به‌دیگر پیمانه‌ها را شرح دهد.

ADV_TDS.4.9C ۹-۲-۷-۶-۱۱

طراحی، باید هر پیمانه SFR غیر مداخله‌گر را در ارتباط با هدفش و واکنش با دیگر پیمانه‌ها، شرح دهد.

ADV_TDS.4.10C ۱۰-۲-۷-۶-۱۱

نقشه، باید اثبات کند که رفتار شرح داده شده در طراحی TOE به TSFI‌هایی که خواسته شده‌اند، نگاشت شده است.

۳-۷-۶-۱۱ عناصر عمل ارزیاب

ADV_TDS.4.1E ۱-۳-۷-۶-۱۱

ارزیاب باید تأیید کند که اطلاعات فراهم شده، همه الزامات را برای محتوای مدرک و ارائه آن دارند.

ADV_TDS.4.2E ۲-۳-۷-۶-۱۱

ارزیاب باید تعیین کند که طراحی همه الزامات کارکردی امنیتی به‌صورت دقیق و کامل صورت گرفته است.

۱۱-۶-۸ طراحی پیمانه‌ای نیمه رسمی کامل ADV_TDS.5

وابسته‌ها: ویژگی‌های کارکردی نیمه رسمی کامل همراه با اطلاعات خطای اضافی ADV_FSP.5

۱۱-۶-۸-۱ عناصر عمل توسعه دهنده

۱۱-۶-۸-۱-۱ ADV_TDS.5.1D

توسعه‌دهنده باید طراحی TOE را فراهم کند.

۱۱-۶-۸-۱-۲ ADV_TDS.5.2D

توسعه‌دهنده باید نقشه‌ای از TSFI ویژگی کارکردی را نسبت به پایین‌ترین سطح تجزیه موجود در طراحی TOE، فراهم کند.

۱۱-۶-۸-۲ عناصر ارائه و محتوی

۱۱-۶-۸-۲-۱ ADV_TDS.5.1C

طراحی، باید ساختار TOE را در ارتباط با زیرسیستم‌ها شرح دهد.

۱۱-۶-۸-۲-۲ ADV_TDS.5.2C

طراحی، باید TSF را در ارتباط با پیمانه‌ها، طراحی هر پیمانه به‌عنوان SFR اجرایی، SFR پشتیبان یا SFR غیرمداخله‌گر، شرح دهد.

۱۱-۶-۸-۲-۳ ADV_TDS.5.3C

طراحی، باید همه زیرسیستم‌های TSF را مشخص کند.

۱۱-۶-۸-۲-۴ ADV_TDS.5.4C

طراحی، باید شرح نیمه‌رسمی هر زیرسیستم TSF را که توسط متن توضیحی رسمی مناسب ارائه شده باشد فراهم کند.

۱۱-۶-۸-۲-۵ ADV_TDS.5.5C

طراحی، باید شرح واکنش‌های میان همه زیرسیستم‌های TSF را فراهم کند.

۱۱-۶-۸-۲-۶ ADV_TDS.5.6C

طراحی، باید نقشه‌ای از زیرسیستم‌های TSF را نسبت به پیمانه‌های TSF، فراهم نماید.

۱۱-۶-۸-۲-۷ ADV_TDS.5.7C

طراحی، باید شرح نیمه‌رسمی هر پیمانه را در رابطه با هدفش، واکنش‌هایش، واسطه‌هایش، مقادیر بازگشتی از واسطه‌ها، و واسطه‌های فراخوانی به‌دیگر پیمانه‌ها، که توسط یک متن توضیحی رسمی مناسب، پشتیبانی شود را فراهم نماید.

۱۱-۶-۸-۲-۸ ADV_TDS.5.8C

نقشه، باید اثبات کند که کلیه رفتارهای شرح داده شده در طراحی TOE به TSFI یی که آن را می‌خواهد نگاشت شده است.

۱۱-۶-۸-۳ عناصر عمل ارزیاب

ADV_TDS.5.1E ۱-۳-۸-۶-۱۱

ارزیاب باید تأیید کند اطلاعات فراهم شده، همه الزامات را برای محتوای مدرک و ارائه آن دارند.

ADV_TDS.5.2E ۲-۳-۸-۶-۱۱

ارزیاب باید تعیین کند که طراحی همه الزامات کارکردی امنیتی به صورت دقیق و کامل است.

۱۱-۶-۹ طراحی پیمانه‌ای نیمه‌رسمی کامل همراه با ارائه طراحی سطح بالای رسمی ADV_TDS.6

وابسته‌ها: ویژگی‌های کارکردی نیمه‌رسمی کامل همراه با ویژگی‌های رسمی اضافی ADV_FSP.6

۱۱-۶-۹-۱ عناصر عمل توسعه‌دهنده

ADV_TDS.6.1D ۱-۱-۹-۶-۱۱

توسعه‌دهنده باید طراحی TOE را فراهم کند.

ADV_TDS.6.2D ۲-۱-۹-۶-۱۱

توسعه‌دهنده باید نقشه‌ای را از TSFI ویژگی‌های کارکردی نسبت به پایین‌ترین سطح تجزیه موجود در طراحی TOE فراهم آورد.

ADV_TDS.6.3D ۳-۱-۹-۶-۱۱

توسعه‌دهنده باید ویژگی‌های رسمی زیرسیستم‌های TSF را فراهم کند.

ADV_TDS.6.4D ۴-۱-۹-۶-۱۱

توسعه‌دهنده باید اثبات مطابقت بین ویژگی‌های رسمی زیرسیستم‌های TSF و ویژگی‌های رسمی مشخصات کارکردی را فراهم آورد.

۱۱-۶-۹-۲ عناصر ارائه و محتوی

ADV_TDS.6.1C ۱-۲-۹-۶-۱۱

طراحی باید ساختار TOE را در ارتباط با زیرسیستم‌ها شرح دهد.

ADV_TDS.6.2C ۲-۲-۹-۶-۱۱

طراحی باید TSF مرتبط به پیمانه‌ها، تخصیص هر پیمانه به SFR اجرایی، SFR پشتیبان یا SFR غیرمداخله‌گر را شرح دهد.

ADV_TDS.6.3C ۳-۲-۹-۶-۱۱

طراحی باید همه زیرسیستم‌های TSF را مشخص کند.

ADV_TDS.6.4C ۴-۲-۹-۶-۱۱

طراحی باید شرح نیمه‌رسمی هر زیرسیستم TSF را که توسط متن توضیحی رسمی مناسبی ارائه شود را فراهم کند.

ADV_TDS.6.5C۵-۲-۹-۶-۱۱

طراحی باید شرح واکنش‌های میان همه زیرسیستم‌های TSF را فراهم آورد.

ADV_TDS.6.6C۶-۲-۹-۶-۱۱

طراحی باید نقشه‌ای از زیرسیستم‌های TSF را نسبت به پیمانه‌های TSF، فراهم نماید.

ADV_TDS.6.7C۷-۲-۹-۶-۱۱

طراحی باید به سبک نیمه‌رسمی هر پیمانه را در ارتباط با هدفش، واسطه‌هایش مقادیر بازگشتی از واسطه‌ها، و واسطه‌های فراخوانی شده به دیگر پیمانه‌ها، که توسط متن توضیحی رسمی مناسبی پشتیبانی شود، شرح دهد.

ADV_TDS.6.8C۸-۲-۹-۶-۱۱

ویژگی‌های رسمی زیرسیستم‌های TSF، باید کاربرد TSF را به شکل رسمی، که توسط یک متن توضیحی رسمی مناسب، پشتیبانی شود، شرح دهد.

ADV_TDS.6.9C۹-۲-۹-۶-۱۱

نقشه باید اثبات کند که رفتار شرح داده شده در طراحی TOE به TSF ی که آن را می‌خواهد نگاشت می‌شود.

ADV_TDS.6.10C۱۰-۲-۹-۶-۱۱

اثبات تطابق بین ویژگی‌های رسمی زیرسیستم‌های TSF و ویژگی‌های رسمی مشخصات کارکردی، باید اثبات کند که همه رفتارهای شرح داده شده در طراحی TOE، پالایش کامل و دقیق TSFI یی است که آن را می‌خواهد.

۱۱-۹-۶-۳ عناصر عمل ارزیاب

ADV_TDS.6.1E۱-۳-۹-۶-۱۱

ارزیاب باید تأیید کند که اطلاعات فراهم شده، همه الزامات را برای محتوای مدرک و ارائه آن دارند.

ADV_TDS.6.2E۲-۳-۹-۶-۱۱

ارزیاب باید تعیین کند که طراحی همه الزامات کارکردی امنیتی، کامل و دقیق است.

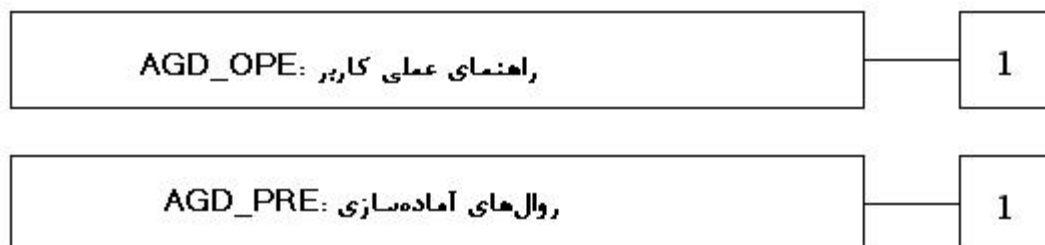
۱۲ دسته AGD: اسناد راهنما

دسته اسناد راهنما الزامات مستند راهنما را برای همه نقش‌های کاربر فراهم می‌آورد. به منظور عملکرد و آمادگی امن TOE لازم است که همه جنبه‌های مربوط به کاربرد امن TOE شرح داده شود. این دسته همچنین امکان پیکربندی یا کاربرد اشتباهاً تصادفی TOE را نشان می‌دهد.

در بسیاری موارد بهتر است که راهنما به صورت سندهای جداگانه برای آمادگی و عملکرد TOE تهیه شود، یا حتی برای نقش‌های مختلف کاربری مانند کاربر نهایی، مدیران، برنامه‌نویسان کاربردی که از واسطه‌های سخت‌افزاری یا نرم‌افزاری استفاده می‌کنند، سندهای راهنمای جداگانه‌ای تهیه شود.

دسته اسناد راهنما به دو خانواده تقسیم می‌شود، یکی راهنمای آمادگی کاربر است (که برای انتقال TOE فرستاده شده به پیکربندی ارزیابی شده‌اش در محیط عملیاتی همانطور که در ST شرح داده شد چه کاری

باید انجام بشود) و دیگری راهنمای عملی کاربر است (که می‌گوید که در طی عمل TOE در پیکره‌بندی ارزیابی شده‌اش چه کاری باید انجام شود).
 شکل ۱۲ خانواده‌های درون این دسته و سلسله مراتب مؤلفه‌ها را درون خانواده‌ها نشان می‌دهد.



شکل ۱۲: تجزیه دسته مستندات راهنما

۱۲-۱ راهنمای عملی کاربر (AGD_OPE)

۱۲-۱-۱ اهداف

راهنمای عملی کاربر به نوشته‌هایی اشاره می‌کند که توسط انواع مختلف کاربران TOE در پیکره‌بندی ارزیابی شده‌اش استفاده می‌شود: کاربران نهایی، مسئولان نگهداری و مدیریت TOE برای اینکه به شیوه‌ای صحیح حداکثر امنیت را برقرار سازند، و توسط دیگران (مانند برنامه‌نویسان) که در حال استفاده از واسطه‌های بیرونی TOE هستند.

راهنمای عملی کاربر، کارکرد امنیتی فراهم شده توسط TSF را شرح می‌دهد و دستورالعمل و راهنمایی را فراهم می‌کند، (که شامل هشدارها نیز می‌شود) و به فهم TSF کمک می‌کند و شامل اطلاعات حیاتی در مورد امنیت، و اعمال حیاتی امنیتی مورد نیاز برای استفاده امنیتی از آن می‌شود. باید هیچ گونه راهنمایی گمراه‌کننده و غیر منطقی در مستند راهنما وجود نداشته باشد، و روال‌های امن برای همه حالت‌های عملی نشان داده شده باشند. حالت‌های غیر امن باید به شکلی آسان قابل یافتن باشند..

راهنمای عملی کاربر این میزان از اطمینانی را فراهم می‌کند که کاربران، مدیران، تهیه‌کنندگان برنامه‌های کاربردی و دیگر استفاده‌کنندگان از واسطه‌های بیرونی TOE کارکرد امنیتی TOE را درک خواهند کرد و از آن همان‌طور که می‌خواهند استفاده خواهند نمود.

ارزشیابی راهنمای عملی کاربر شامل تحقیق در مورد این است که آیا TOE می‌تواند به شیوه‌ای استفاده شود که نامطمئن باشد اما کاربر TOE به شکلی قابل قبول باور داشته باشد که مطمئن است. هدف، به حداقل رساندن خطر خطای انسانی و یا دیگر خطاها در عملیاتی است که ممکن است غیرفعال شود، یا برای فعال نمودن کارکردهای امنیتی شکست بخورد، که نتیجه آن عدم کشف حالت نامطمئن است.

۱۲-۱-۲ سطح بندی مؤلفه

این خانواده تنها شامل یک مؤلفه است.

۱۲-۱-۳ نکات کاربردی

نقش‌ها و گروه‌های مختلف کاربری ممکن است وجود داشته باشند که توسط TOE شناخته می‌شوند و می‌توانند با TSF وارد واکنش شوند. این گروه‌ها و نقش‌های کاربری باید به‌وسیله راهنمای عملی کاربر مورد توجه قرار گیرند. این گروه‌ها و نقش‌ها ممکن است به‌طور کلی به دو گروه کاربران مدیر و کاربرانی که مدیر نیستند تقسیم شود، یا به‌شکل خاص‌تر به این گروه‌ها تقسیم شود، افرادی که مسئولیت دریافت، پذیرش، نصب و نگهداری TOE را دارند، برنامه‌نویسان برنامه‌های کاربردی، ویرایشگران، نویسندگان، مدیریت‌های روزانه و کاربران نهایی. هر نقشی می‌تواند دارای مجموعه وسیعی از قابلیت‌ها باشد یا می‌تواند فقط یک قابلیت داشته باشد.

الزامات AGD_OPE.1.1C دارای این خصوصیت است که هرگونه هشدار به کاربران در طی عملیات TOE را با توجه به تعریف مسأله امنیت و اهداف امنیتی برای محیط شرح داده شده در PP/ST به‌شکل مناسبی در راهنمای عملی کاربر می‌آورد.

مفهوم ارزش‌های امنیتی، به آن صورتی که در AGD_OPE به‌کار گرفته شده است، با جایی که کاربر بر پارامترهای امنیتی کنترل دارد ارتباط دارد. باید برای چنین پارامترهایی هم برای تنظیمات امن و هم تنظیمات غیر امن، راهنما تهیه شود.

AGD_OPE.1.4C نیاز دارد که راهنمای عملی کاربر واکنش‌های مناسب را برای همه رویدادهای امنیتی شرح دهد. اگر چه بسیاری از رویدادهای مربوط به امنیت، نتیجه اجرای کارکردها هستند، اما همیشه این طور نیست. به‌عنوان مثال، وقتی که یک نفوذی کشف می‌شود گزارش ویرایش را متوقف می‌کند. علاوه بر این، یک رویداد امنیتی ممکن است به‌عنوان نتیجه زنجیره خاصی از کارکردها باشد، یا برعکس، رویدادهای امنیتی مختلف به‌وسیله یک کارکرد، راه‌اندازی شوند.

AGD_OPE.1.7C نیاز دارد که راهنمای عملی کاربر شفاف و منطقی باشد. راهنمایی گمراه کننده یا غیر منطقی ممکن است باعث شود زمانی که TOE امن نیست کاربر TOE تصور کند که امن است. به‌عنوان مثال، یک شرح دستورالعمل که می‌تواند به بیش از یک روش تجزیه شود، ممکن است باعث یک نتیجه غیر امن شود و این راهنمایی، یک راهنمایی گمراه کننده محسوب می‌شود. یک مثال از راهنمایی غیر منطقی این می‌تواند باشد که روالی دنبال شود که بسیار پیچیده است و به‌طور منطقی این انتظار نمی‌رود که کاربر چنین روالی را پیروی کند.

۱۲-۱-۴ راهنمای عملی عملیات AGD_OPE.1

وابسته‌ها: ویژگی‌های کارکردی عملیاتی AGD_OPE.1

۱۲-۱-۴-۱ عناصر اقدام توسعه دهنده

AGD_OPE.1.1D۱-۱-۴-۱-۱۲

توسعه دهنده باید راهنمای عملی عملیاتی را فراهم آورد.

۱۲-۱-۴-۲ عناصر عامل‌ها تشکیل دهنده و ارائه کننده

AGD_OPE.1.1C۱-۲-۴-۱-۱۲

راهنمای عملی عملیات، باید برای هر نقش کاربر، کارکردهای در دسترس کاربر و امتیازاتی که باید در محیط پردازش امن که شامل هشدارهای مناسب است کنترل شوند، شرح دهد.

AGD_OPE.1.2C۲-۲-۴-۱-۱۲

راهنمای عملی کاربر برای انجام عملیات، باید برای هر نقش کاربر، شرح دهد که چطور واسطه‌های موجود توسط TOE و به یک روش امن مورد استفاده قرار می‌گیرند.

AGD_OPE.1.3C۳-۲-۴-۱-۱۲

راهنمای عملی کاربر برای انجام عملیات، باید برای هر نقش کاربر، واسطه‌ها و کارکردهای موجود، به ویژه، همه پارامترهای امنیتی تحت کنترل کاربر و نشان دادن ارزش‌های امنیتی به شکل مناسب توضیح دهد.

AGD_OPE.1.4C۴-۲-۴-۱-۱۲

راهنمای عملی کاربر برای انجام عملیات، باید برای هر نقش کاربر، به طور شفاف هر نوع رویداد امنیتی مرتبط به کارکردهای در دسترس کاربر را که نیاز دارد انجام شود که شامل تغییر ویژگی‌های امنیتی موجودیت‌های تحت کنترل TSF می‌شود را، معرفی نماید.

AGD_OPE.1.5C۵-۲-۴-۱-۱۲

راهنمای عملی کاربر برای عملیات باید همه سبک‌های ممکن عملکرد TOE (شامل خرابی عملکرد یا خطای عملیاتی) و ترتیب و مفاهیم آن‌ها برای نگهداری عملکرد امنیتی را شناسایی کند.

AGD_OPE.1.6C۶-۲-۴-۱-۱۲

راهنمای عملی کاربر برای انجام عملیات، باید برای هر نقش کاربر، اندازه‌های امنیتی را که باید به ترتیب دنبال کند تا اهداف امنیتی برای محیط‌های شرح داده شده در ST به دست آید را شرح دهد.

AGD_OPE.1.7C۷-۲-۴-۱-۱۲

راهنمای عملی کاربر برای انجام عملیات، باید شفاف و منطقی باشد.

۱۲-۴-۱-۳ عناصر اقدام ارزیاب

AGD_OPE.1.1E ۱-۳-۴-۱-۱۲

ارزیاب باید تأیید کند که اطلاعات فراهم شده همه الزامات را برای عامل‌ها تشکیل دهنده و ارائه کننده مدرک دارند.

۱۲-۲ رویه‌های تدارک (AGD_PRE)

۱۲-۲-۱ اهداف

رویه‌های تدارک برای تضمین اینکه TOE به روشی مطمئن توسط توسعه دهنده دریافت و نصب شده است مفید هستند الزامات آمادگی، برای انتقال امن از TOE تحویل داده شده به محیط عملیاتی اصلی‌اش فراخوانی می‌کنند. این شامل تحقیق در مورد این زمینه است که آیا TOE می‌تواند به روشی نامطمئن پیکره‌بندی و نصب شود اما کاربر TOE به صورت منطقی تصور کند که مطمئن است.

۱۲-۲-۲ سطح بندی مؤلفه

این خانواده شامل تنها یک مؤلفه است.

۱۲-۲-۳ نکات کاربردی

مشخص است که کاربرد این الزامات بسیار متنوع خواهد بود و بستگی دارد به این که آیا TOE در یک محیط عملیاتی تحویل می شود یا باید در سایت مالک TOE نصب شود و غیره. اولین فرآیندی که توسط رویه های تدارک پوشش داده می شود پذیرش مطمئن مشتری TOE ی دریافت شده مطابق با رویه های حمل توسعه دهنده است.

اگر توسعه دهنده، رویه های حمل را تعریف نکرده است، امنیت پذیرش باید به صورت های دیگر تضمین شود. نصب TOE شامل تبدیل محیط عملیاتی TOE به حالتی است که با اهداف امنیتی محیط عملیاتی فراهم شده در ST مطابقت کند. همچنین ممکن است موردی باشد که نیازی به نصب نداشته باشد، مثلاً یک کارت هوشمند.

در این مورد ممکن است که نیاز و تحلیل رویه های نصب نامناسب باشد.

الزامات، در این خانواده تضمین، به علت کمیابی و شاید استفاده قدیم رویه های تدارک، جدا از خانواده راهنمای کاربر برای عملیات، نشان داده می شوند.

۱۲-۲-۴ رویه های تدارک AGD_PRE.1

وابسته ها: هیچ وابسته ای وجود ندارد.

۱۲-۲-۴-۱ عناصر اقدام توسعه دهنده

۱۲-۲-۴-۱-۱ AGD_PRE.1.1D

توسعه دهنده باید رویه های تدارک TOE را فراهم نماید.

۱۲-۲-۴-۲ عناصر تشکیل دهنده و ارائه کننده

۱۲-۲-۴-۲-۱ AGD_PRE.1.1C

رویه های تدارک باید همه مراحل لازم برای پذیرش مطمئن TOE ی حمل شده را مطابق با رویه های حمل توسعه دهنده، شرح دهند.

۱۲-۲-۴-۲-۲ AGD_PRE.1.2C

رویه های تدارک باید همه مراحل لازم را برای نصب مطمئن TOE و تدارک مطمئن محیط عملیاتی، مطابق با اهداف امنیتی برای محیط عملیاتی شرح داده شده در ST، شرح دهند.

۱۲-۲-۴-۳ عناصر اقدام ارزیاب

۱۲-۲-۴-۳-۱ AGD_PRE.1.1E

ارزیاب باید تأیید کند که اطلاعات فراهم شده، همه الزامات را برای عامل ها تشکیل دهنده و ارائه کننده مدرک دارند.

ارزیاب باید رویه‌های تدارک را برای تأیید اینکه TOE می‌تواند به‌شکلی مطمئن برای عملیات آماده شود، به کار گیرد.

۱۳دسته ALC: پشتیبانی چرخه‌حیات

پشتیبانی از چرخه‌حیات برقراری نظم و انضباط و کنترل در فرآیندهای بهبود TOE در توسعه و نگهداری آن می‌باشد. اگر تجزیه و تحلیل امنیت و تولید شواهد و مدارک به‌طور مرتب به‌عنوان قسمتی جدایی ناپذیر از فعالیت‌های توسعه و نگهداری انجام شود، اطمینان از ارتباط بین الزامات امنیتی TOE و TOE بیشتر حاصل می‌شود.

در چرخه‌حیات محصول تشخیص داده می‌شود که آیا TOE تحت مسئولیت توسعه‌دهنده یا کاربر باشد به جای این‌که آن در توسعه یا محیط کاربر واقع شود. نقطه انتقال لحظه‌ای است که در آن TOE به کاربر سپرده می‌شود. همچنین این نقطه انتقال از دسته ALC به دسته AGD می‌باشد.

دسته ALC از هفت خانواده تشکیل شده است. تعریف چرخه‌حیات (ALC_LCD) توضیحات در سطح عالی از چرخه‌حیات TOE می‌باشد؛ قابلیت‌های CM، (ALC_CMC) توضیحات مفصل‌تر از مدیریت موارد تنظیمات می‌باشد.

دامنه (ALC_CMS) نیاز به حداقل مجموعه‌ای از موارد تنظیمات دارد که به‌روش تعریف شده اداره می‌شود. امنیت توسعه (ALC_DVS) به فیزیکی توسعه‌دهنده، طریقه عمل، کارکنان و پیمان‌های امنیت دیگر مربوط می‌شود. ابزار و فنون (ALC_TAT) با ابزار توسعه و پیاده‌سازی استانداردها توسط توسعه‌دهنده به کار گرفته می‌شود؛ اصلاح معایب (ALC_FLR) از طریق درست کردن معایب امنیتی حاصل می‌شود.

تحویل (ALC_DEL)، روش‌های مورد استفاده برای تحویل TOE به مشتری را نشان می‌دهد. رخ دادن فرایندهای تحویل در حین توسعه TOE ترجیحاً با انتقال مشخص می‌شود و در چارچوب ادغام و مراحل پذیرش در خانواده‌های دیگر از این دسته به‌کار گرفته می‌شود. در طول این دسته، توسعه و عبارات مربوطه (توسعه‌دهنده، توسعه) بیشتر مفهوم کلی‌تر در نظر گرفته شده است و شامل توسعه و تولید می‌باشد. با در نظر گرفتن این‌که تولید صریحاً به‌منظور فرآیند انتقال ارائه پیاده‌سازی به TOE نهایی است. شکل ۱۳ خانواده‌ها در درون این دسته و سلسله مراتب مؤلفه‌ها در داخل خانواده را نشان می‌دهد.



شکل ۱۳- ALC: تجزیه دسته پشتیبان چرخه

۱۳-۱ قابلیت‌های CM ، (ALC_CMC)

۱۳-۱-۱ اهداف

مدیریت تنظیمات به منظور افزایش اطمینان از اینکه TOE ، SFR ها را برآورده می‌کند، می‌باشد. CM با نیاز به نظم و انضباط و کنترل فرآیندهای بهبود و اصلاح TOE و اطلاعات مربوطه، این اطمینان را برقرار می‌کند. سیستم‌های CM در جای خود ارائه می‌شوند برای اطمینان از درستی قسمت‌های TOE توسط ارائه یک روش ردیابی هرگونه تغییر، و با تضمین اینکه تمام تغییرات مجاز است، آنها را کنترل می‌کند.

هدف از این خانواده داشتن قابلیت‌های خاص برای سیستم CM توسعه‌دهنده مورد نیاز می‌باشد. اینها به معنای کاهش احتمال تغییرات تصادفی یا غیر مجاز موارد تنظیماتی که رخ می‌دهد، می‌باشد. سیستم CM بهتر است از درستی TOE در مراحل طراحی اولیه، از طریق تمام تلاش‌های نگهداری بعدی، اطمینان حاصل کند.

هدف از معرفی ابزار خودکار CM افزایش اثربخشی سیستم CM می‌باشد. تا زمانی که سیستم‌های خودکار و دستی CM بتوانند bypass شوند یا نادیده گرفته شدند یا ناکافی اثبات شوند، از تغییر غیرمجاز جلوگیری می‌شود و سیستم‌های خودکار کمتر در معرض خطای انسانی یا سهل‌انگاری قرار می‌گیرند.

همچنین هدف این خانواده شامل موارد زیر می‌باشد:

الف) صحیح بودن و کامل بودن TOE را قبل از تحویل به مشتری تضمین کند.

ب) تضمین می‌کند که هیچ موارد تنظیمی در طول ارزشیابی از دست نرفته است.
پ) از اصلاحات غیرمجاز، افزایش یا حذف پیکره‌بندی قسمت‌های TOE جلوگیری کند.

۱۳-۱-۲ سطح‌بندی مؤلفه‌ها

مؤلفه‌های این خانواده مبتنی بر توانمندی‌های سیستم CM، هدف مستندات CM و گواهینامه مقرر شده توسط توسعه‌دهنده سطح‌بندی شده است.

۱۳-۱-۳ نکات کاربردی

مادامی که مناسب است CM از مراحل اولیه طراحی به کار رفته و تا آینده ادامه پیدا می‌کند، مورد نیاز این خانواده است که قبل از پایان ارزشیابی CM در مرتبه‌ای باشد و در بهره‌گیری

۱۳-۱-۴ برچسب‌گذاری TOE

وابستگی‌ها: پوشش TOE CM ALC_CMC.1

۱۳-۱-۴-۱ اهداف

مرجع منحصربه‌فرد مورد نیاز است تا، بدون هیچ ابهامی مطمئن شویم کدام نمونه از TOE در حال ارزشیابی است. اتیکت TOE با مرجع آن کاربران را مطلع می‌سازد از این که مطمئن شوند کدام نمونه از TOE را آنها استفاده می‌کنند.

۱۳-۱-۴-۲ عناصر عمل توسعه‌دهنده

۱۳-۱-۴-۲-۱ ALC_CMC.1.D1

توسعه‌دهنده باید TOE و مرجعی برای آن برقرار کند.

۱۳-۱-۴-۳ عناصر ارائه و محتوی

۱۳-۱-۴-۳-۱ ALC_CMC.1.C1

باید به TOE با مرجع منحصربه‌فرد آن اتیکت زده شود.

۱۳-۱-۴-۴ عناصر عمل ارزیاب

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۱-۵ کاربرد سیستم CM

وابسته‌ها: ALC_CMS.1 TOE پوشش TOE CM

۱۳-۱-۵-۱ اهداف

مرجع منحصربه‌فرد مورد نیاز است تا، بدون هیچ ابهامی مطمئن شویم کدام نمونه از TOE در حال ارزشیابی است. اتیکت TOE با مرجع آن کاربران را مطلع می‌سازد از این که مطمئن شوند کدام نمونه از TOE را آنها

استفاده می‌کنند. شناسایی منحصر بفرد موارد تنظیمات منجر به فهم روشنی از ترکیب TOE می‌شود که به نوبه خود به تعیین مواردی که مشمول الزامات ارزشیابی برای TOE است کمک می‌کند. استفاده از سیستم CM ضمانت نگهداری از موارد تنظیمات به‌روشنی کنترل شده را افزایش می‌دهد.

۱۳-۱-۵-۲ عناصر عمل توسعه‌دهنده

ALC_CMC.2.1D ۱-۲-۵-۱-۱۳

توسعه‌دهنده باید TOE و مرجعی برای آن مقرر کند.

ALC_CMC.2.2D ۲-۲-۵-۱-۱۳

توسعه‌دهنده باید مستندات CM را ارائه کند.

ALC_CMC.2.3D ۳-۲-۵-۱-۱۳

توسعه‌دهنده باید از یک سیستم CM استفاده کند.

۱۳-۱-۵-۳ عناصر ارائه و محتوی

ALC_CMC.2.1C ۱-۳-۵-۱-۱۳

TOE با مرجع منحصر بفرد خود باید اتیکت زده شود.

ALC_CMC.2.2C ۲-۳-۵-۱-۱۳

مستندات CM باید روش مورد استفاده برای شناسایی منحصر بفرد موارد تنظیمات را شرح دهد.

ALC_CMC.2.3C ۳-۳-۵-۱-۱۳

سیستم CM باید به‌صورت منحصر بفرد تمام موارد تنظیمات را شناسایی کند.

۱۳-۱-۵-۴ عناصر عمل ارزیاب

ALC_CMC.2.1E ۱-۴-۵-۱-۱۳

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۱-۶-۱ ALC_CMC.3 ۶-۱-۱۳ کنترل‌های مجاز

وابسته‌ها: ALC_CMS.1 TOE پوشش TOE CM

ALC_DVS.1 شناسایی سنج‌های امنیتی

ALC_LCD.1 تعریف مدل چرخه‌حیات توسعه‌دهنده

۱۳-۱-۶-۱ اهداف

مرجع منحصر به‌فرد مورد نیاز است تا، بدون هیچ ابهامی مطمئن شویم کدام نمونه از TOE در حال ارزشیابی است. اتیکت TOE با مرجع آن کاربران را مطلع می‌سازد از این که مطمئن شوند کدام نمونه از TOE را آنها استفاده می‌کنند. شناسایی منحصر به‌فرد موارد تنظیمات منجر به فهم روشنی از ترکیب TOE می‌شود که به نوبه

خود به تعیین مواردی که مشمول الزامات ارزشیابی برای TOE است کمک می‌کند. استفاده از سیستم CM ضمانت نگهداری از موارد تنظیمات به‌روشنی کنترل شده را افزایش می‌دهد. ارائه کنترل برای اطمینان از این که تغییرات غیرمجاز در TOE ("کنترل دستیابی به CM) انجام نشده است، می‌باشد و نیز اطمینان از عملکرد مناسب و استفاده از سیستم CM می‌باشد و به حفظ درستی و بی‌نقصی از TOE کمک می‌کند.

۱۳-۱-۶-۲ عناصر عمل توسعه‌دهنده

ALC_CMC.3.1D ۱-۲-۶-۱۳

توسعه‌دهنده باید TOE و یک مرجع برای آن مقرر کند.

ALC_CMC.3.2D ۲-۲-۶-۱۳

توسعه‌دهنده باید مستندات CM را فراهم کند.

ALC_CMC.3.3D ۳-۲-۶-۱۳

توسعه‌دهنده باید از سیستم CM استفاده کند.

۱۳-۱-۶-۳ عناصر ارائه و محتوا

ALC_CMC.3.1C ۱-۳-۶-۱۳

TOE با مرجع منحصربه‌فرد خود باید اتیکت زده شود.

ALC_CMC.3.2C ۲-۳-۶-۱۳

مستندات CM باید روش مورد استفاده برای شناسایی منحصربه‌فرد موارد تنظیمات را شرح دهد.

ALC_CMC.3.3C ۳-۳-۶-۱۳

سیستم CM باید به‌صورت منحصربه‌فردی تمام موارد تنظیم را شناسایی کند.

ALC_CMC.3.4C ۴-۳-۶-۱۳

سیستم CM باید سنج‌ها را طوری که تنها تغییرات مجاز به‌موارد تنظیمات داده شود را برقرار می‌کند.

ALC_CMC.3.5C ۵-۳-۶-۱۳

مستندات CM باید شامل طرح CM باشد.

ALC_CMC.3.6C ۶-۳-۶-۱۳

طرح CM باید چگونگی استفاده از سیستم CM برای توسعه TOE را شرح دهد.

ALC_CMC.3.7C ۷-۳-۶-۱۳

مدارک باید نشان دهد که تمام موارد تنظیمات تحت سیستم CM نگهداری می‌شود.

ALC_CMC.3.8C ۸-۳-۶-۱۳

مدارک باید نشان دهد که سیستم CM مطابق با طرح CM عمل می‌کند.

۱۳-۱-۶-۴ عناصر عمل ارزیاب

۱۳-۱-۶-۴ ALC_CMC.3.1E

ارزیاب باید تأیید کند که اطلاعات ارائه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۱-۷ ALC_CMC.4

وابسته‌ها: ALC_CMS.1 پوشش TOE CM

ALC_DVS.1 شناسایی سنج‌های امنیت

ALC_LCD.1 تعریف مدل چرخه حیات توسعه‌دهنده

۱۳-۱-۷ اهداف

مرجع منحصر به فرد مورد نیاز است تا ، بدون هیچ ابهامی مطمئن شویم کدام نمونه از TOE در حال ارزشیابی است. اتیکت TOE با مرجع آن کاربران را مطلع می‌سازد از این که مطمئن شوند کدام نمونه از TOE را آنها استفاده می‌کنند. شناسایی منحصر به فرد موارد تنظیمات منجر به فهم روشنی از ترکیب TOE می‌شود که به نوبه خود به تعیین مواردی که مشمول الزامات ارزشیابی برای TOE است کمک می‌کند. استفاده از سیستم CM ضمانت نگهداری از موارد تنظیمات به‌روزش کنترل شده را افزایش می‌دهد.

ارائه کنترل برای اطمینان از این که تغییرات غیرمجاز در TOE ("کنترل دستیابی به CM) انجام نشده است، می‌باشد و نیز اطمینان از عملکرد مناسب و استفاده از سیستم CM می‌باشد و به حفظ درستی و بی‌نقصی از TOE کمک می‌کند.

هدف از مراحل پذیرش این است که اطمینان حاصل شود که قسمت‌هایی از TOE با کیفیت مساوی هستند و برای تأیید آن است که ایجاد یا اصلاحات موارد تنظیمات مجاز می‌باشد. مراحل پذیرش یک عنصر اساسی در فرایندهای یکپارچه‌سازی و در مدیریت چرخه حیات از TOE می‌باشد.

در محیط‌های توسعه که در آن موارد تنظیمات پیچیده است، برای کنترل تغییرات بدون پشتیبانی از ابزارهای خودکار مشکل و دشوار است. به‌طور خاص این ابزار خودکار باید قادر به پشتیبانی از تغییرات زیادی که در حین توسعه رخ می‌دهد، باشد و اطمینان حاصل شود که آن تغییرات مجاز هستند. هدف از این مؤلفه این است که مطمئن شود که موارد تنظیمات از طریق روش‌های خودکار کنترل می‌شوند. اگر TOE توسط توسعه‌دهندگان مختلف توسعه یافته است، به‌عنوان مثال یکپارچه‌سازی باید رخ دهد، استفاده از ابزار خودکار کافی است.

روش‌های حمایت از تولید کمک می‌کند به این که اطمینان حاصل شود که ایجاد TOE از مجموعه موارد تنظیمات تحت مدیریت به‌درستی با روش مجاز انجام می‌کند، به‌ویژه در مورد زمانی که توسعه‌دهندگان مختلف دخالت دارند و فرآیندهای یکپارچه‌سازی باید اجرا شوند.

۱۳-۱-۷-۲ عناصر عمل توسعه‌دهنده

۱۳-۱-۷-۲ ALC_CMC.4.1D

توسعه‌دهنده باید TOE و یک مرجع برای آن را مقرر کند.

ALC_CMC.4.2D ۱۳-۱-۷-۲-۲

توسعه‌دهنده باید مستندات CM را ارائه دهد.

ALC_CMC.4.3D ۱۳-۱-۷-۲-۳

توسعه‌دهنده باید از سیستم CM استفاده کند.

ALC_CMC.4.1C ۱۳-۱-۷-۳-۳ عناصر ارائه و محتوی

ALC_CMC.4.2C ۱۳-۱-۷-۳-۲

به TOE با مرجع منحصربه‌فردی، باید اتیکت زده شود.

ALC_CMC.4.3C ۱۳-۱-۷-۳-۳

مستندات CM باید روش مورد استفاده برای شناسایی منحصربه‌فرد موارد تنظیمات را شرح دهد.

ALC_CMC.4.4C ۱۳-۱-۷-۳-۴

سیستم CM باید تمام موارد تنظیمات را به‌صورت منحصربه‌فرد شناسایی کند.

ALC_CMC.4.5C ۱۳-۱-۷-۳-۵

سیستم CM باید سنجه‌های خودکار به‌طوری که تنها تغییرات مجاز در موارد تنظیمات داده شود، را تهیه کند.

ALC_CMC.4.6C ۱۳-۱-۷-۳-۶

سیستم CM باید از ایجاد TOE با روش‌های خودکار را پشتیبانی کند.

ALC_CMC.4.7C ۱۳-۱-۷-۳-۷

مستندات CM باید شامل طرح CM باشد.

ALC_CMC.4.8C ۱۳-۱-۷-۳-۸

طرح CM باید چگونگی استفاده از سیستم CM برای توسعه TOE را نشان دهد.

ALC_CMC.4.9C ۱۳-۱-۷-۳-۹

طرح CM روش‌های مورد استفاده برای پذیرش تغییرات و یا به تازگی ایجاد موارد تنظیمات به‌عنوان قسمتی از TOE، را باید نشان دهد.

ALC_CMC.4.10C ۱۳-۱-۷-۳-۱۰

مدارک باید تمام موارد تنظیمات که تحت سیستم CM نگهداری می‌شوند را نشان دهد.

ALC_CMC.4.1E ۱۳-۱-۷-۴-۱

اسناد باید نشان دهد که سیستم CM مطابق با طرح CM عمل می‌کند.

ALC_CMC.4.1E ۱۳-۱-۷-۴-۴ عناصر عمل ارزیاب

ALC_CMC.4.1E ۱۳-۱-۷-۴-۱

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۱-۸ پشتیبانی پیشرفته

وابسته‌ها: ALC_CMS.1 TOE شمول CM

ALC_DVS.2 شناسایی سنج‌های امنیتی

ALC_LCD.1 تعریف مدل چرخه‌حیات توسعه‌دهنده

۱۳-۱-۸-۱ اهداف

مرجع منحصربه‌فرد مورد نیاز است تا، بدون هیچ ابهامی مطمئن شویم کدام نمونه از TOE در حال ارزشیابی است. اتیکت TOE با مرجع آن کاربران را مطلع می‌سازد از این که مطمئن شوند کدام نمونه از TOE را آنها استفاده می‌کنند. شناسایی منحصربه‌فرد موارد تنظیمات منجر به فهم روشنی از ترکیب TOE می‌شود که به نوبه خود به تعیین مواردی که مشمول الزامات ارزشیابی برای TOE است کمک می‌کند. استفاده از سیستم CM ضمانت نگهداری از موارد تنظیمات به‌روشنی کنترل شده را افزایش می‌دهد.

ارائه کنترل برای اطمینان از این که تغییرات غیرمجاز در TOE ("کنترل دستیابی به CM) انجام نشده است، می‌باشد و نیز اطمینان از عملکرد مناسب و استفاده از سیستم CM می‌باشد و به‌حفظ درستی و بی‌نقصی از TOE کمک می‌کند.

هدف از مراحل پذیرش این است که اطمینان حاصل شود که قسمت‌هایی از TOE با کیفیت مساوی هستند و برای تأیید آن است که ایجاد یا اصلاحات موارد تنظیمات مجاز می‌باشد. مراحل پذیرش یک عنصر اساسی در فرایندهای یکپارچه‌سازی و در مدیریت چرخه‌حیات از TOE می‌باشد.

در محیط‌های توسعه که در آن موارد تنظیمات پیچیده است، برای کنترل تغییرات بدون پشتیبانی از ابزارهای خودکار مشکل و دشوار است. به‌طور خاص این ابزار خودکار باید قادر به پشتیبانی از تغییرات زیادی که در حین توسعه رخ می‌دهد، باشد و اطمینان حاصل شود که آن تغییرات مجاز هستند. هدف از این مؤلفه این است که مطمئن شود که موارد تنظیمات از طریق روش‌های خودکار کنترل می‌شوند. اگر TOE توسط توسعه‌دهندگان مختلف توسعه یافته است، به‌عنوان مثال یکپارچه‌سازی باید رخ دهد، استفاده از ابزار خودکار کافی است.

روش‌های حمایت از تولید کمک می‌کند به این که اطمینان حاصل شود که ایجاد TOE از مجموعه موارد تنظیمات تحت مدیریت به‌درستی با روش مجاز انجام می‌کند، به‌ویژه در مورد زمانی که توسعه‌دهندگان مختلف دخالت دارند و فرایندهای یکپارچه‌سازی باید اجرا شوند.

نیاز است که سیستم CM قادر به شناسایی نسخه‌ای از ارائه پیاده‌سازی باشد که در آن TOE ایجاد می‌شود و کمک می‌کند به این که اطمینان حاصل کنیم که بی‌نقصی از این مواد توسط تدابیر فنی مناسب، فیزیکی و حفاظ‌های رویه‌ای مناسب حفظ شده است.

ارائه روش‌های خودکار در تعیین تغییرات بین نسخه‌های TOE، شناسایی این که کدام موارد تنظیمات توسط اصلاحات سایر موارد تنظیمات تأثیر گذار است، و در تعیین تأثیر تغییرات بین نسخه‌های پی‌درپی TOE، کمک

می‌کند. این به‌نوبه خود می‌تواند اطلاعات ارزشمندی در تعیین این که آیا تغییرات در نتایج TOE در تمام موارد تنظیمات با یکدیگر سازگار است، ارائه کند.

۱۳-۱-۸-۲ عناصر عمل توسعه‌دهنده

ALC_CMC.5.1D ۱-۲-۸-۱-۱۳

توسعه‌دهنده باید TOE و یک مرجع برای آن را مقرر کند.

ALC_CMC.5.2D ۲-۲-۸-۱-۱۳

توسعه‌دهنده باید مستندات CM را ارائه کند.

ALC_CMC.5.3D ۳-۲-۸-۱-۱۳

توسعه‌دهنده باید از سیستم CM استفاده کند.

۱۳-۱-۸-۳ عناصر ارائه و محتوا

ALC_CMC.5.1C ۱-۳-۷-۱-۱۳

به TOE باید با مرجع منحصربه‌فردی اتیکت زده شود.

ALC_CMC.5.2C ۲-۳-۸-۱-۱۳

مستندات CM باید روشی که برای شناسایی منحصربه‌فرد موارد تنظیمات به کار می‌رود را شرح دهد.

ALC_CMC.5.3C ۳-۳-۸-۱-۱۳

اسناد CM باید توجیه کند که روش‌های قابل پذیرش برای بازنگری مناسب و کافی از تغییرات به تمام موارد تنظیمات ارائه کند.

ALC_CMC.5.4C ۴-۳-۸-۱-۱۳

سیستم CM تمام موارد تنظیمات را به‌صورت منحصربه‌فردی باید شناسایی کند.

ALC_CMC.4.4C ۳-۸-۱-۱۳

سیستم CM باید سنجه‌های خودکار به‌طوری که تنها تغییرات مجاز در موارد تنظیمات داده شود را مقرر می‌کند.

ALC_CMC.5.6C ۶-۳-۸-۱-۱۳

سیستم CM باید در ایجاد TOE توسط روش‌های خودکار، پشتیبانی کند.

ALC_CMC.5.7C ۷-۳-۸-۱-۱۳

سیستم CM باید اطمینان حاصل کند که شخص مسئول پذیرش موارد تنظیمات به CM همان کسی که آن را توسعه داده، نیست.

ALC_CMC.5.8C ۸-۳-۸-۱-۱۳

سیستم CM باید موارد تنظیمات که شامل TSF می‌باشد، را شناسایی کند.

ALC_CMC.5.9C ۱۳-۱-۸-۳-۹

سیستم CM باید از ممیزی تمام تغییرات TOE توسط روش‌های خودکار، از جمله بنیانگذار، تاریخ و زمان در ممیزی، پشتیبانی کند.

ALC_CMC.5.10C ۱۳-۱-۸-۳-۱۰

سیستم CM باید روش‌های خودکار برای شناسایی همه موارد تنظیمات دیگری که توسط تغییر مورد تنظیم داده شده تحت تأثیر قرار گرفته است، را ارائه کند.

ALC_CMC.5.11C ۱۳-۱-۸-۳-۱۱

سیستم CM باید قادر به شناسایی نسخه ارائه پیاده‌سازی که در آن TOE بوجود آمده است، باشد.

ALC_CMC.5.12C ۱۳-۱-۸-۳-۱۲

مستندات CM باید شامل طرح CM باشد.

ALC_CMC.5.13C ۱۳-۱-۸-۳-۱۳

طرح CM باید نشان دهد که چگونه سیستم CM برای توسعه TOE استفاده می‌شود.

ALC_CMC.5.14C ۱۳-۱-۸-۳-۱۵

طرح CM باید روش‌های مورد استفاده برای پذیرفتن تغییرات یا به تازگی ایجاد موارد تنظیمات به‌عنوان قسمتی از TOE را نشان دهد.

مستندات باید تمام موارد تنظیمات که تحت سیستم CM نگهداری می‌شوند را نشان دهد.

مستندات باید نشان دهد که سیستم CM مطابق با طرح CM عمل می‌کند.

۱۳-۱-۸-۴ عناصر عمل ارزیاب

ALC_CMC.5.1E ۱۳-۱-۷-۴-۱

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

ALC_CMC.5.2E ۱۳-۱-۸-۴-۲

ارزیاب باید تعیین کند که استفاده از نتایج روش‌های پشتیبانی از تولید در TOE همان‌طوری است که توسط توسعه‌دهنده برای فعالیت‌های آزمون مقرر شده است.

۱۳-۲ هدف CM (ALC_CMS)

۱۳-۲-۱ اهداف

هدف از این خانواده شناسایی مواردی است که شامل موارد تنظیمات می‌شود و از این‌رو تحت الزامات CM از توانمندی‌های CM (ALC_CMC) قرار می‌گیرد. بکارگیری مدیریت تنظیمات در این موارد اضافی اطمینان بیشتری حاصل می‌شود که تمامیت TOE حفظ می‌شود.

۱۳-۲-۲ رتبه‌بندی مؤلفه‌ها

مؤلفه‌های این خانواده مبتنی بر یکی از موارد زیر که باید شامل موارد تنظیمات باشد، رتبه‌بندی می‌شود: TOE و مدارک ارزشیابی مورد نیاز توسط SARها؛ قسمت‌هایی از TOE؛ ارائه پیاده‌سازی؛ نقص امنیتی؛ ابزار توسعه و اطلاعات مرتبط.

۱۳-۲-۳ نکات کاربردی

در حالی که در محدوده CM (ALC_CMS) فهرستی از موارد تنظیمات را صادر می‌کند و در هر مورد از این فهرست که تحت CM، قابلیت‌های CM (ALC_CMC) است مطالب فهرست تنظیمات را به صلاح‌دید توسعه‌دهنده واگذار می‌کنند. محدوده CM (ALC_CMS) این صلاح‌دید را با شناسایی مواردی که باید در فهرست تنظیمات باشد محدود می‌کند و از این رو تحت الزامات CM از قابلیت‌های CM (ALC_CMC) می‌باشد.

۱۳-۲-۴ ALC_CMS.1 TOE شمول CM

وابسته‌ها: هیچ وابسته‌ای وجود ندارد.

۱۳-۲-۴-۱ اهداف

سیستم CM می‌تواند تغییرات را تنها در مواردی که تحت CM قرار گرفته‌اند (مانند: موارد تنظیمات که در فهرست تنظیمات شناخته شده‌اند) کنترل کند. با قراردادن TOE و مدارک ارزشیابی مورد نیاز توسط SARهای دیگر در ST تحت CM تضمین می‌کند که آن‌ها به شیوه‌ای کنترل شده با مجوز تغییر داده شوند.

۱۳-۲-۴-۲ نکات کاربردی

ALC_CMS.1.1C الزاماتی را معرفی می‌کند که خود TOE و مدارک ارزشیابی توسط SARها در ST که در فهرست تنظیمات گنجانده می‌شود، نیاز است. از این رو موضوع الزامات CM از قابلیت‌های CM (ALC_CMC) می‌باشد.

۱۳-۲-۴-۳ عناصر عمل توسعه‌دهنده

۱۳-۲-۴-۳-۱ ALC_CMS.1.1D

توسعه‌دهنده باید فهرست تنظیمات را برای TOE مقرر کند.

۱۳-۲-۴-۴ عناصر ارائه و محتوی

۱۳-۲-۴-۴-۱ ALC_CMS.1.1C

فهرست تنظیمات باید شامل موارد زیر باشد:

خود TOE؛ و مدارک ارزشیابی مورد نیاز توسط SARها.

۱۳-۲-۴-۴-۲ ALC_CMS.1.2C

فهرست تنظیمات باید موارد تنظیمات را به صورت منحصربه‌فرد شناسایی کند.

۱۳-۲-۴-۵ عناصر عمل ارزیاب

۱۳-۲-۴-۵-۱ ALC_CMS.1.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۲-۵ ALC_CMS.2 قسمت‌های TOE، شمول CM

وابسته‌ها: هیچ وابسته‌ای وجود ندارد.

۱۳-۲-۵-۱ اهداف

سیستم CM می‌تواند تغییرات را تنها در مواردی که تحت CM قرار گرفته‌اند (مانند: موارد تنظیمات که در فهرست تنظیمات شناخته شده‌اند) کنترل کند. با قراردادن TOE و مدارک ارزشیابی مورد نیاز توسط SARهای دیگر در ST تحت CM تضمین می‌کند که آن‌ها به شیوه‌ای کنترل شده با مجوز تغییر داده شوند.

۱۳-۲-۵-۲ نکات کاربردی

ALC_CMS.1.1C الزاماتی را معرفی می‌کند که خود TOE و مدارک ارزشیابی توسط SARها در ST که در فهرست تنظیمات گنجانده می‌شود، نیاز است. از این‌رو موضوع الزامات CM از قابلیت‌های CM (ALC_CMC) می‌باشد.

ALC_CMS.2.3C الزامات مربوط به فهرست تنظیمات را معرفی می‌کند، که توسعه‌دهنده هر مورد تنظیماتی مربوطه TSF را نشان دهد. "توسعه‌دهنده" در اینجا به کسی نشانی نمی‌رود، بلکه به سازمان مسئول توسعه مورد نظر است.

۱۳-۲-۵-۳ عناصر عمل توسعه‌دهنده

۱۳-۲-۵-۳-۱ ALC_CMS.2.1D

توسعه‌دهنده باید فهرست تنظیمات TOE را مقرر کند.

۱۳-۲-۵-۴ عناصر ارائه و محتوی

۱۳-۲-۵-۴-۱ ALC_CMS.2.1C

فهرست تنظیمات باید شامل موارد زیر باشد:

خود TOE؛ و مدارک ارزشیابی مورد نیاز توسط SARها و قسمت‌هایی که شامل TOE است.

۱۳-۲-۵-۴-۲ ALC_CMS.2.2C

فهرست تنظیمات باید موارد تنظیمات را به طور منحصربه‌فردی شناسایی کند.

۱۳-۲-۵-۴-۳ ALC_CMS.2.2C

فهرست تنظیمات برای هر مورد تنظیمات مربوطه TSF باید توسعه‌دهنده آن مورد را نشان دهد.

۱۳-۲-۵-۵ عناصر عمل ارزیاب

۱۳-۲-۵-۵-۱ ALC_CMS.2.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۲-۶ ALC_CMS.3 پوشش CM ارائه پیاده‌سازی

وابسته‌ها: هیچ وابسته‌ای وجود ندارد.

۱۳-۲-۶-۱ اهداف

سیستم CM می‌تواند تغییرات را تنها در مواردی که تحت CM قرار گرفته‌اند (مانند: موارد تنظیمات که در فهرست تنظیمات شناخته شده‌اند) کنترل کند. با قراردادن TOE و مدارک ارزشیابی مورد نیاز توسط SAR های دیگر در ST تحت CM تضمین می‌کند که آن‌ها به شیوه‌ای کنترل شده با مجوز تغییر داده شوند.

۱۳-۲-۶-۲ نکات کاربردی

ALC_CMS.3.1C الزاماتی را معرفی می‌کند که خود TOE و مدارک ارزشیابی توسط SARها در ST که در فهرست تنظیمات گنجانده می‌شود، نیاز است. از این‌رو موضوع الزامات CM از قابلیت‌های CM (ALC_CMC) می‌باشد.

۱۳-۲-۶-۳ عناصر عمل توسعه‌دهنده

ALC_CMS.3.1D

توسعه‌دهنده باید فهرست تنظیمات TOE را مقرر کند.

۱۳-۲-۶-۴ عناصر ارائه و محتوی

۱۳-۲-۶-۴-۱ ALC_CMS.3.1C

فهرست تنظیمات باید شامل موارد زیر باشد:

خود TOE؛ و مدارک ارزشیابی مورد نیاز توسط SARs و قسمت‌های شامل TOE و ارائه پیاده‌سازی.

۱۳-۲-۶-۴-۲ ALC_CMS.3.2C

فهرست تنظیمات باید موارد تنظیمات را بطور منحصربه‌فردی شناسایی کند.

۱۳-۲-۶-۴-۳ ALC_CMS.3.3C

فهرست تنظیمات برای هر مورد تنظیمات مربوطه TSF باید توسعه‌دهنده آن مورد را نشان دهد.

۱۳-۲-۶-۵ عناصر عمل ارزیاب

۱۳-۲-۶-۵-۱ ALC_CMS.3.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۲-۷ ALC_CMS.4 مشکل ردیابی پوشش CM

وابسته‌ها: هیچ وابسته‌ای ندارد.

۱۳-۲-۷-۱ اهداف

سیستم CM می‌تواند تغییرات را تنها در مواردی که تحت CM قرار گرفته‌اند (مانند: موارد تنظیمات که در فهرست تنظیمات شناخته شده‌اند) کنترل کند. با قراردادن TOE و مدارک ارزشیابی مورد نیاز توسط SARهای دیگر در ST تحت CM تضمین می‌کند که آن‌ها به شیوه‌ای کنترل شده با مجوز تغییر داده شوند. با قراردادن معایب امنیتی تحت CM اطمینان حاصل می‌شود که گزارشات نقص امنیتی از دست نداده یا فراموش نشده و توسعه‌دهنده را مجاز می‌دارد برای رفع معایب امنیتی پیگیری کند.

۱۳-۲-۷-۱ نکات کاربردی

ALC_CMS.3.1C الزاماتی را معرفی می‌کند که خود TOE و مدارک ارزشیابی توسط SARها در ST که در فهرست تنظیمات گنجانده می‌شود، نیاز است. از این‌رو موضوع الزامات CM از قابلیت‌های CM (ALC_CMC) می‌باشد

این امر مستلزم این است که اطلاعات در مورد معایب امنیتی قبلی و رفع آن و همچنین جزئیات بیشتر در خصوص معایب امنیتی فعلی حفظ و نگهداری شود.

۱۳-۲-۷-۳ عناصر عمل توسعه‌دهنده

۱۳-۲-۷-۳-۱ ALC_CMS.4.1D

توسعه‌دهنده باید فهرست تنظیمات TOE را مقرر کند.

۱۳-۲-۷-۴ عناصر ارائه و محتوی

۱۳-۲-۷-۴-۱ ALC_CMS.4.1C

فهرست تنظیمات باید شامل موارد زیر باشد:

خود TOE؛ و مدارک ارزشیابی مورد نیاز توسط SARها و قسمت‌های شامل TOE و ارائه پیاده‌سازی و گزارشات نقص امنیتی و وضع رفع آن.

۱۳-۲-۷-۴ ALC_CMS.4.2C

فهرست تنظیمات باید توسعه‌دهنده هر مورد تنظیمات مربوطه TSF را نشان دهد.

۱۳-۲-۷-۴-۳ ALC_CMS.4.3C

فهرست تنظیمات برای هر مورد تنظیمات مربوطه TSF باید توسعه‌دهنده آن مورد را نشان دهد.

۱۳-۲-۷-۵ عناصر عمل ارزیاب

۱۳-۲-۶-۵-۱ ALC_CMS.4.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۲-۸ پوشش CM ابزار توسعه

وابسته‌ها: هیچ وابسته‌ای وجود ندارد.

۱۳-۲-۸-۱ اهداف

سیستم CM می‌تواند تغییرات اقلامی که تحت CM قرار گرفته‌اند (مانند: موارد تنظیمات که در فهرست تنظیمات شناخته شده‌اند) را کنترل کند. با قراردادن TOE و مدارک ارزشیابی مورد نیاز توسط SARهای دیگر در ST تحت CM تضمین می‌کند که آن‌ها به شیوه‌ای کنترل شده با مجوز تغییر داده شوند.

با قراردادن معایب امنیتی تحت CM اطمینان حاصل می‌شود که گزارشات نقص امنیتی از دست نداده یا فراموش نشده و توسعه‌دهنده را مجاز می‌دارد برای رفع معایب امنیتی پیگیری کند. ابزارهای توسعه نقش مهمی در اطمینان از تولید نسخه با کیفیت از TOE دارد. بنابراین، مهم است که تغییرات در این ابزار کنترل شود.

۱۳-۲-۸-۲ نکات کاربردی

ALC_CMS.3.1C الزاماتی را معرفی می‌کند که خود TOE و مدارک ارزشیابی توسط SARها در ST که در فهرست تنظیمات گنجانده می‌شود، نیاز است. از اینرو موضوع الزامات CM از قابلیت‌های CM (ALC_CMC) می‌باشد.

نمونه‌هایی از ابزار توسعه زبان‌های برنامه‌نویسی و کمپایلرها هستند. اطلاعات مربوط به موارد تولید TOE (مانند گزینه‌های کمپایلر، گزینه‌های تولید، گزینه‌های ساخت) نمونه‌ای از اطلاعات مربوط به ابزار توسعه می‌باشند.

۱۳-۲-۸-۳ عناصر عمل توسعه‌دهنده

۱۳-۲-۷-۳-۱ ALC_CMS.4.1D

توسعه‌دهنده باید فهرست تنظیمات را برای TOE برقرار کند.

۱۳-۲-۸-۴ عناصر ارائه و محتوی

۱۳-۲-۸-۴-۱ ALC_CMS.4.1C

فهرست تنظیمات باید شامل موارد زیر باشد:

خود TOE؛ و مدارک ارزشیابی مورد نیاز توسط SARها و قسمت‌های شامل TOE و ارائه پیاده‌سازی و گزارشات نقص امنیتی و وضع رفع آن؛ ابزار توسعه و اطلاعات مرتبط

۱۳-۲-۸-۴-۲ ALC_CMS.5.2C

لیست تنظیمات به‌طور منحصربه‌فرد باید موارد تنظیمات را تشخیص دهد.

۱۳-۲-۸-۴-۳ ALC_CMS.5.3C

فهرست تنظیمات برای هر مورد تنظیمات مربوطه TSF باید توسعه‌دهنده آن مورد را نشان دهد.

۱۳-۲-۸-۵ عناصر عمل ارزیاب

۱۳-۲-۶-۵-۱ ALC_CMS.5.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۳ تحویل (ALC_DEL)

۱۳-۳-۱ اهداف

نگرانی این خانواده انتقال امن از TOE تمام شده از محیط توسعه به مسئولیت کاربر می‌باشد. الزامات مورد نیاز برای تحویل، کنترل سیستم و امکانات توزیع و روش‌هایی برای شرح سنج‌ها، برای ارائه تضمین ضروری هستند تا امنیت TOE در حین توزیع از TOE به کاربران حفظ شود. برای توزیع معتبر TOE، روش‌های که برای توزیع TOE استفاده شده است به اهداف شناسایی شده در PP/ST در رابطه با امنیت TOE در حین توزیع، اشاره می‌کند.

۱۳-۳-۲ رتبه‌بندی مؤلفه‌ها

این خانواده حاوی تنها یک مؤلفه است. افزایش سطح حفاظت متناسب با نیاز به روش‌های تحویل با پتانسیل حمله احتمالی در خانواده تجزیه و تحلیل آسیب‌پذیری (AVA_VAN)، تأسیس می‌شود.

۱۳-۳-۳ نکات کاربردی

انتقال از پیمانکارها به توسعه‌دهنده یا بین سایت‌های مختلف توسعه در اینجا ذکر نشده فقط در خانواده امنیت توسعه (ALC_DVS) در نظر گرفته شده است. پایان مرحله تحویل، توسط انتقال TOE به‌عهده کاربر مشخص می‌شود. الزامی نیست که این همزمان با ورود TOE در محل کاربر باشد.

مراحل تحویل، اگر قابل کاربرد باشد، بهتر است مسائلی را در نظر گیرد مانند:

الف- تضمین این که TOE توسط مصرف‌کننده مطابق با همین نسخه ارزشیابی شده TOE، دریافت می‌شود.
ب- اجتناب یا تشخیص هر مداخله با نسخه واقعی TOE.

پ- جلوگیری از ارائه نسخه کاذب از TOE

ت- اجتناب از دانش ناخواسته توزیع TOE به مشتری: ممکن است مواردی وجود داشته باشد که در آن حمله‌بر بالقوه نباید نداند چه موقع و چگونه آن را تحویل دهند.

ث- اجتناب یا تشخیص هر چیزی که مانع تحویل TOE می‌شود.

ج) اجتناب از تأخیر یا توقف TOE در حین توزیع.

روش‌های تحویل باید شامل اقدامات گیرنده تلویحی توسط این مسائل باشد. توضیحات سازگار از این اقدامات تلویحی در خانواده مراحل مقدماتی (AGD_PRE)، در صورت وجود بررسی می‌شود.

۱۳-۳-۴ ALC_DEL.1 روش‌های تحویل

وابسته‌ها: هیچ وابسته‌ای وجود ندارد.

۱۳-۳-۴-۱ عناصر عمل توسعه‌دهنده

۱۳-۳-۴-۱-۱ ALC_DEL.1.1D

توسعه‌دهنده باید روش‌های تحویل TOE به مشتری یا تحویل قسمت‌هایی از آن را، مستندسازی کند.

۱۳-۳-۴-۲ ALC_DEL.1.2D

توسعه‌دهنده باید از روش‌های تحویل استفاده کند.

۱۳-۳-۴ عناصر ارائه و محتوی

۱۳-۳-۴-۱ ALC_DEL.1.1C

اسناد تحویل باید تمام روش‌های لازم برای حفظ امنیت در هنگام توزیع نسخه‌های TOE به مشتری را شرح دهد.

۱۳-۳-۴ عناصر عمل ارزیاب

۱۳-۳-۴-۲ ALC_DEL.1.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۴ امنیت توسعه (ALC_DVS)

۱۳-۴-۱ اهداف

امنیت توسعه با فیزیک، رویه‌ها، کارکنان و سایر سنجه‌های امنیت سر و کار دارد که ممکن است در محیط توسعه برای حفظ TOE و قسمت‌های آن استفاده شود. و شامل امنیت فیزیکی از محل توسعه و روش‌هایی که برای انتخاب هیات توسعه استفاده می‌شود، می‌باشد.

۱۳-۴-۲ رتبه‌بندی مؤلفه

مؤلفه در این خانواده مبتنی بر این که چه توجیهی از قابلیت سنجه‌های امنیتی مورد نیاز است، سطح‌بندی می‌شود.

۱۳-۴-۳ نکات کاربردی

این خانواده با سنجه‌هایی که برای حذف یا کاهش تهدیدات موجود در سایت توسعه‌دهنده به کار می‌روند، سر و کار دارد.

ارزیاب به منظور ارزشیابی مدارک برای امنیت توسعه باید به سایت(های) مراجعه کند. ممکن است شامل سایت‌های پیمانکار درگیر در توسعه و تولید TOE باشد. هرگونه تصمیمی که مشاهده نشود باید با سند ارزشیابی موافق باشد.

اگرچه امنیت توسعه با حفظ TOE سر و کار دارد و از این رو با جنبه‌های که پس از تکمیل ارزشیابی مربوط می‌شوند، الزامات امنیت توسعه (ALC_DVS) فقط مشخص می‌کند که سنجه‌های امنیت توسعه در زمان ارزشیابی در محل می‌باشد. به علاوه، امنیت توسعه (ALC_DVS) شامل الزامات مربوط به آنهایی که قصد بکارگیری سنجه‌های امنیت توسعه در آینده پس از اتمام ارزشیابی هستند، نمی‌شود.

این مسئله به رسمیت شناخته شده است که اطلاعات محرمانه نمی‌تواند همیشه یک مسئله برای حفاظت از TOE در محیط توسعه آن باشد. استفاده از کلمه "لازم" مجموعه‌ای از حفاظت‌های مناسب را مجاز می‌دارد.

۱۳-۴-۴ ALC_DVS.1 شناسایی سنجه‌های امنیتی

وابسته‌ها: هیچ وابسته‌ای وجود ندارد.

۱۳-۴-۴-۱ عناصر عمل توسعه‌دهنده

۱۳-۴-۴-۱-۱ ALC_DVS.1.1D

توسعه‌دهنده باید مستندات امنیت توسعه را ایجاد کند.

۱۳-۴-۴-۲ عناصر ارائه و محتوی

۱۳-۴-۴-۲-۱ ALC_DVS.1.1C

مستندات امنیت توسعه باید تمام فیزیک، رویه‌ای، کارکنان و سنجه‌های امنیتی دیگر را شرح دهد که برای محافظت از محرمانه‌بودن و درستی طراحی TOE و پیاده‌سازی در محیط توسعه خود ضروری می‌باشد.

۱۳-۴-۴-۳ عناصر عمل ارزیاب

۱۳-۴-۴-۳-۱ ALC_DVS.1.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۴-۴-۳-۲ ALC_DVS.1.2E

ارزیاب باید تأیید کند که سنجه‌های امنیتی به‌کار گرفته می‌شوند.

۱۳-۴-۵ ALC_DVS.2 مقدار کافی از سنجه‌های امنیتی

وابسته‌ها: هیچ وابسته‌ای وجود ندارد.

۱۳-۴-۵-۱ عناصر عمل توسعه‌دهنده

۱۳-۴-۵-۱-۱ ALC_DVS.2.1D

توسعه‌دهنده باید مستندات امنیتی توسعه را ایجاد کند.

۱۳-۴-۵-۲ عناصر ارائه و محتوی

۱۳-۴-۵-۲-۱ ALC_DVS.2.1C

مستندات امنیت توسعه باید کلیه فیزیکی، رویه‌ای، پرسنل و سنجه‌های دیگر امنیت را شرح دهد که برای حفظ محرمانه‌بودن و درستی طراحی TOE و پیاده‌سازی در محیط توسعه ضروری می‌باشد.

۱۳-۴-۵-۲-۲ ALC_DVS.2.2C

مستندات امنیت توسعه باید توجیه کند که سنجه‌های امنیتی سطح لازم از حفاظت برای نگهداری محرمانه‌بودن و درستی TOE را ارائه می‌کند.

۱۳-۴-۵-۳ عناصر عمل ارزیاب

۱۳-۴-۵-۳ ALC_DVS.2.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۴-۵-۲ ALC_DVS.2.2E

ارزیاب باید تأیید کند که سنجه‌های امنیتی بکار گرفته می‌شوند.

۱۳-۵ تصحیح نقص (ALC_FLR)

۱۳-۵-۱ اهداف

برای تصحیح نقص باید معایب امنیت توسط توسعه‌دهنده ردیابی و تصحیح شود. اگرچه روش‌های تصحیح نقص نمی‌تواند در زمان ارزشیابی TOE مشخص شود، اما می‌توان خط‌مشی‌ها و رویه‌ها را ارزشیابی کرد و توسعه‌دهنده باید در محل نقایص را پیگیری و تصحیح کند و اطلاعات نقص و اصلاحات را توزیع کند.

۱۳-۵-۲ رتبه‌بندی مؤلفه

مؤلفه‌ها در این خانواده براساس میزان افزایش محدوده دامنه کاربرد رویه‌های تصحیح نقص و سختی خط‌مشی‌های بازسازی نقص رتبه‌بندی می‌شود.

۱۳-۵-۳ نکات کاربردی

این خانواده تضمین می‌کند که TOE حفظ می‌شود و در آتی پشتیبانی می‌شود، توسعه‌دهنده TOE مستلزم پیگیری و بازسازی معایب در TOE می‌باشد. به علاوه، نیازمندیها شامل توزیع اصلاحات نقص هم می‌باشد. اگرچه، این خانواده الزامات ارزشیابی فراتر از ارزشیابی فعلی اعمال نمی‌کند.

کاربر TOE نقطه قانونی در سازمان کاربرد نظر گرفته می‌شود که مسئول دریافت و پیاده‌سازی رفع معایب امنیتی می‌باشد. لزوماً این کاربر شخصی نیست، اما ممکن است نماینده به رسمیت می‌شناسد که سازمان‌های مختلف، روش‌های مختلفی برای رسیدگی گزارشات نقص دارند، که توسط کاربر شخصی و یا توسط قسمت اداری مرکزی انجام می‌شود.

روش‌های اصلاح نقص باید روش‌هایی را برای مقابله با انواع نقص‌هایی که مواجه می‌شویم شرح دهد. این نقص‌ها ممکن است توسط توسعه‌دهنده یا توسط قسمت‌های دیگر که آشنا با TOE هستند، گزارش شود. برخی نقص‌ها به سرعت قابل اصلاح نیستند. ممکن است بعضی مواقع که نقص را نمی‌توان درست نمی‌شود (مانند: رویه‌ای) و باید از سنجه‌ها استفاده کرد. اسناد ارائه شده بهتر است روش‌هایی برای سایت‌های عملیاتی با رفع، پوشش دهد و نیز اطلاعاتی در مورد معایبی که تأخیر در رفع آنها افتاده (موقتاً چه کاری انجام داد) یا وقتی که رفع آنها امکان پذیر نباشد، ارائه می‌کند.

تغییرات اعمال شده در TOE بعد از انتشار آن به صورت ارزشیابی نشده تحویل داده می‌شود؛ هر چند برخی اطلاعات از ارزشیابی اولیه ممکن است هنوز اعمال شود. عبارت "انتشار TOE" که در این خانواده به کار گرفته می‌شود به نسخه‌ای از محصول که از گواهی TOE منتشر می‌شود و تغییراتی که در آن اعمال شده است، اشاره دارد.

۱۳-۵-۴ ALC_FLR.1 بازسازی نقص اولیه

وابسته‌ها: هیچ وابسته‌ای وجود ندارد.

۱۳-۵-۴-۱ عناصر عمل توسعه‌دهنده

۱۳-۵-۴-۱-۱ ALC_FLR.1.1D

توسعه‌دهنده باید روش‌های اصلاح نقص خطاب به توسعه‌دهنده‌های TOE را مستندسازی کند.

۱۳-۵-۴-۲ عناصر ارائه و محتوی

۱۳-۵-۴-۲-۱ ALC_FLR.1.1C

در اسناد روش‌های اصلاح نقص باید روش‌های مورد استفاده برای ردیابی تمام معایب امنیت در هر انتشار TOE، نشان داده شود.

۱۳-۵-۴-۲-۲ ALC_FLR.1.2C

روش‌های اصلاح نقص نیاز دارند که ماهیت هر نقص امنیتی و اثر هر یک از معایب امنیتی و همچنین بیانیه‌ای از یافتن اصلاحات آن نقص ارائه کنند.

۱۳-۵-۴-۲-۳ ALC_FLR.1.3C

روش‌های اصلاح نقص مستلزم شناسایی اقدامات اصلاح‌کننده برای هر نقص امنیتی می‌باشند.

۱۳-۵-۴-۲-۴ ALC_FLR.1.4C

مستندات روش‌های اصلاح نقص باید روش‌های مورد استفاده برای تهیه اطلاعات مربوط به نقص، اصلاحات و راهنما در مورد اقدامات اصلاح‌کننده به کاربران TOE شرح دهد.

۱۳-۵-۴-۳ عناصر عمل ارزیاب

۱۳-۵-۴-۳-۱ ALC_FLR.1.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای ارائه مدارک و محتوی را برآورده می‌کند.

۱۳-۵-۵ ALC_FLR.2 روش‌های گزارش نقص

وابسته‌ها: هیچ وابسته‌ای وجود ندارد.

۱۳-۵-۵-۱ اهداف

به منظور این که توسعه‌دهنده قادر به انجام عمل مناسب در مورد گزارش نقص امنیتی از سوی کاربران TOE باشند، و دانستن آن که ارسال رفع اصلاحی به چه کسی باشد، کاربران TOE نیاز به درک نحوه ارائه گزارش نقص امنیتی به توسعه‌دهنده را دارند. راهنمای اصلاحات نقص از طرف توسعه‌دهنده به کاربر TOE اطمینان می‌دهد که کاربران از این اطلاعات مهم آگاه هستند.

۱۳-۵-۵-۲ عناصر عمل توسعه‌دهنده

ALC_FLR.2.1D ۱-۲-۵-۵-۱۳

توسعه‌دهنده باید روش‌های اصلاح نقص خطاب به توسعه‌دهنده‌های TOE را مستندسازی کند.

ALC_FLR.2.2D ۲-۲-۵-۵-۱۳

توسعه‌دهنده باید رویه‌ای برای پذیرش و اقدام برای تمام گزارشات معایب امنیتی و درخواست برای اصلاحات آن مقرر کند.

ALC_FLR.2.3D ۳-۲-۵-۵-۱۳

توسعه‌دهنده باید راهنمای اصلاح نقص خطاب به کاربران TOE را مقرر کند.

۱۳-۵-۵-۳ عناصر ارائه و محتوا

ALC_FLR.2.1C ۱-۳-۵-۵-۱۳

مستندات روش‌های اصلاح نقص باید روش‌های مورد استفاده برای ردیابی تمام نقص امنیتی گزارش شده در TOE را شرح دهد.

ALC_FLR.2.2C ۲-۳-۵-۵-۱۳

روش‌های اصلاح نقص مستلزم آن است که ماهیت هر نقص امنیتی و تاثیر آن را شرح دهد، همچنین بیانیه‌ای برای یافتن اصلاحات آن نقص ارائه کند.

ALC_FLR.2.3C ۳-۳-۵-۵-۱۳

روش‌های اصلاح نقص نیاز دارند که اقدامات اصلاح‌کننده برای هر نقص امنیتی را شناسایی کنند.

ALC_FLR.2.4C ۴-۳-۵-۵-۱۳

مستندات روش‌های اصلاح نقص باید روش‌های مورد استفاده برای تهیه اطلاعات مربوط به نقص، اصلاحات و راهنما درمورد اقدامات اصلاح‌کننده به کاربران TOE را شرح دهد.

ALC_FLR.2.5C ۵-۳-۵-۵-۱۳

در روش‌های اصلاح نقص باید رویه‌هایی که توسط توسعه‌دهنده از گزارشات کاربر TOE دریافت می‌شود و نیز پرس و جو در مورد نقص امنیت مشکوک در TOE، شرح داده شود.

ALC_FLR.2.6C ۶-۳-۵-۵-۱۳

روش‌های پردازش نقص امنیتی گزارش شده باید تضمین کند که تمام معایب گزارش شده اصلاح می‌شوند و روش‌های اصلاح برای کاربران TOE صادر می‌شود.

ALC_FLR.2.7C ۷-۳-۵-۵-۱۳

روش‌های پردازش نقص امنیتی گزارش شده باید حفاظی ارائه کند که بازسازی این معایب امنیتی، نقص امنیتی جدیدی را معرفی نکند.

ALC_FLR.2.8C ۸-۳-۵-۵-۱۳

راهنمای اصلاح نقص باید روش‌های گزارش دادن کاربران TOE به توسعه‌دهنده در مورد هر نقص امنیتی مظنون را شرح دهد.

۱۳-۵-۴ عناصر عمل ارزیاب

ALC_FLR.2.1E ۱-۳-۴-۵-۱۳

ارزیاب باید تأیید کند که اطلاعات ارائه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۵-۶ ALC_FLR.3 اصلاح نقص اصولی

وابسته‌ها: هیچ وابسته‌ای وجود ندارد.

۱۳-۵-۶ اهداف

به‌منظور این که توسعه‌دهنده قادر به انجام عمل مناسب در مورد گزارش نقص امنیتی ازسوی کاربران TOE باشد، و دانستن آن که ارسال رفع اصلاحی به چه کسی باشد، کاربران TOE نیاز به درک نحوه ارائه گزارش نقص امنیتی به توسعه‌دهنده را دارند. راهنمای اصلاحات نقص از طرف توسعه‌دهنده به کاربر TOE اطمینان می‌دهد که کاربران از این اطلاعات مهم آگاه هستند.

۱۳-۵-۶-۲ عناصر عمل توسعه‌دهنده

ALC_FLR.2.1D ۱-۲-۵-۵-۱۳

توسعه‌دهنده روش‌های بازسازی نقص خطاب به توسعه‌دهنده TOE را مستندسازی می‌کند.

۱۳-۵-۶-۲ ALC_FLR.3.2D

توسعه‌دهنده باید رویه‌ای برای پذیرش و رفتار کردن در مورد تمام گزارشات نقص امنیتی و درخواست برای اصلاحات آن نقص‌ها ارائه کند.

۱۳-۵-۶-۳ ALC_FLR.3.3D

توسعه‌دهنده باید راهنمای اصلاح نقص که به کاربران TOE اشاره می‌کند، را تهیه کند.

۱۳-۵-۶-۳-۱ عناصر ارائه و محتوا

ALC_FLR.3.1C ۱-۳-۶-۵-۱۳

مستندات روش‌های اصلاح نقص باید روش‌های مورد استفاده برای پیگیری تمام نقص امنیتی گزارش شده در هر یک از آزادی TOE را شرح دهد.

۱۳-۵-۶-۳-۲ ALC_FLR.3.2C

روش‌های اصلاح نقص باید توضیحاتی از ماهیت و اثر هر یک از نقص‌های امنیتی را ارائه کند، و همچنین بیانیه‌ای برای یافتن اصلاحات آن نقص ارائه کند.

۱۳-۵-۶-۳-۲ ALC_FLR.3.3C

روش‌های اصلاح نقص نیاز به شناسایی عمل‌های شناخته شده برای هر نقص امنیتی دارد.

۱۳-۵-۶-۳-۴ ALC_FLR.3.4C

در مستندات روش‌های اصلاح نقص باید روش‌های مورد استفاده برای تهیه اطلاعات نقص، اصلاحات و راهنما درمورد اقدامات اصلاحی به کاربران TOE شرح داده شود.

۱۳-۵-۶-۳-۵ ALC_FLR.3.5C

روش‌های اصلاح نقص باید روش‌هایی که توسعه‌دهنده از گزارشات کاربر TOE دریافت می‌کند و همچنین پرسش‌های معایب امنیتی مشکوک در TOE را شرح دهد.

۱۳-۵-۶-۳-۶ ALC_FLR.3.6C

روش‌های بازسازی نقص از جمله روشی است که نیاز به واکنش به موقع و توزیع خودکار گزارش نقص امنیتی و اصلاحات مربوط به کاربران ثبت شده که ممکن است توسط نقص امنیتی آسیب دیده شود.

۱۳-۵-۶-۳-۷ ALC_FLR.3.7C

روش‌هایی برای پردازش معایب امنیتی گزارش شده، که باید تضمین کند که هر گونه معایب گزارش شده اصلاح می‌شوند و روند بازسازی برای کاربران TOE صادر شده است.

۱۳-۵-۶-۳-۸ ALC_FLR.3.8C

روش‌هایی برای پردازش معایب امنیتی گزارش شده است که باید تدابیر امنیتی فراهم کند به‌طوری که هر گونه اصلاح معایب امنیتی، هیچ نقص جدیدی را معرفی نکند.

۱۳-۵-۶-۳-۹ ALC_FLR.3.9C

راهنمای اصلاح نقص باید واسطه‌هایی که که کاربران TOE هر نقص امنیتی مظنون در TOE را به توسعه‌دهنده گزارش می‌دهد، را شرح دهد.

۱۳-۵-۶-۳-۱۰ ALC_FLR.3.10C

راهنمای بازسازی نقص باید واسطه‌های کاربر TOE که با توسعه‌دهنده ثبت‌نام می‌کنند و برای دریافت گزارشات نقص امنیتی و اصلاحات واجد شرایط باشد را شرح می‌دهد.

۱۳-۵-۶-۳-۱۱ ALC_FLR.3.11C

راهنمای بازسازی نقص باید نقاط خاص تماس برای همه گزارشات و پرسش در مورد مسائل امنیتی از جمله TOE را شناسایی کند.

۱۳-۵-۶-۴ عناصر عمل ارزیاب

۱۳-۵-۶-۴-۱ ALC_FLR. 3.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳- ۶ تعریف چرخه حیات

۱۳- ۶- ۱ اهداف

کنترل ضعیف توسعه و نگهداشت از TOE می‌تواند به TOE منتج شود که همه SFRهای آن را برآورده نکند. بنابراین، مهم است که یک مدل برای توسعه و نگهداشت TOE در چرخه حیات TOE هر چه زودتر مقرر شود. با استفاده از یک مدل توسعه و نگهداشت TOE اطمینان حاصل نمی‌شود که TOE، SFRها را برآورده می‌کند. ممکن است مدل انتخاب شده ناکافی یا نارسا باشد و در نتیجه هیچ منافع در کیفیت TOE نمی‌توان مشاهده کرد. با استفاده از مدل چرخه حیات که توسط گروهی از کارشناسان تأیید شده است (به عنوان مثال: کارشناسان دانشگاهی، متن‌های استانداردها) تغییرات را بهبود می‌قسمتد به طوری که توسعه و نگهداشت مدل‌ها کمک می‌کند که TOE SFRهای آن را برآورده کند. و با استفاده از مدل چرخه حیات از جمله برخی ارزشیابی کیفی، اطمینان بیشتری در کیفیت کلی فرایند توسعه TOE حاصل می‌شود.

۱۳- ۶- ۲ رتبه‌بندی مؤلفه‌ها

مؤلفه در این خانواده بر اساس افزایش الزامات قابلیت سنجش مدل چرخه حیات و انطباق با آن مدل رتبه‌بندی می‌شود.

۱۳- ۶- ۳ نکات کاربردی

مدل چرخه حیات شامل مراحل، ابزارها و اصول فنی مورد استفاده برای توسعه و حفظ TOE می‌باشد. جنبه‌های این فرایند ممکن است با یک مدلی که شامل روش‌های طراحی، مراحل بازنگری، کنترل مدیریت پروژه، مراحل کنترل تغییر، روشهای تست و مراحل پذیرش باشد، پوشش داده شده باشد. یک چرخه حیات موثر به این جنبه‌های فرایند توسعه و فرایند نگهداشت اشاره می‌کند و مطابق با ساختار مدیریت کلی به مسئولیت‌ها و پیشرفت نظارت‌ها اختصاص می‌دهیم.

انواع مختلف شرایط پذیرش وجود دارد که در مکان‌های مختلف در معیار رسیدگی می‌شود: پذیرش قسمت‌ها توسط پیمانکارها (یکپارچگی) تحویل داده می‌شود بهتر است تعریف چرخه حیات در خانواده (ALC_DVS) انجام شود، پذیرش بعدی انتقال‌های درونی در امنیت توسعه (ALC_DVS)، پذیرش قسمت‌ها به طرف سیستم CM در توانمندی‌های CM (ALC_CMC)، و پذیرش TOE تحویل داده شده توسط مصرف‌کننده در تحویل (ALC_DEL). سه نوع اول ممکن است روی هم افتد.

همچنانکه تعریف چرخه حیات با نگهداشت TOE سر و کار دارد از این رو با جنبه‌هایی که بعد از تکمیل ارزشیابی مربوط می‌شوند، با ارزشیابی آنها اطمینان را از طریق تجزیه و تحلیل اطلاعات چرخه حیات برای TOE ارائه شده، در زمان ارزشیابی، می‌افزاید.

یک مدل چرخه حیات، کنترل لازم در توسعه و نگهداشت TOE، فراهم می‌کند، در صورتی که این مدل قادر باشد، خطری که باعث می‌شود TOE الزامات امنیتی را برآورده نکند به قدر کافی کم کند.

یک مدل چرخه حیات قابل سنجش مدلی است که با استفاده از ارزشیابی کمی (پارامترهای محاسباتی و یا معیارها) از محصول موفق، خواص توسعه از محصول، سنجش می‌شود. معیارهای معمولی، معیارهای پیچیده کد منبع، درجه نقص‌ها (خطاها در هر اندازه کد) یا زمان متوسط شکست هستند. برای ارزشیابی امنیت همه

معیارهای مربوطه به کار گرفته می شود که با کاهش احتمال خرابی کیفیت افزایش می یابد و در نتیجه به نوبه خود اطمینان از امنیت TOE افزایش می یابد.
بهتر است یکی را که وجود دارد در نظر بگیرید:

- مدل های چرخه حیات استاندارد شده در یک طرف (مانند مدل آبشار)
- معیارهای استاندارد شده از سوی دیگر (مانند انبوه خطا) که ممکن است ترکیب شده باشند. در ایزو ۱۵۴۰۸ نیاز ندارد که چرخه حیات، دقیقاً از استاندارد می کند پیروی کند.

۱۳-۶-۴ ALC_LCD.1 تعریف مدل چرخه حیات توسعه دهنده

وابسته ها: هیچ وابسته ای وجود ندارد.

۱۳-۶-۴-۱ عناصر عمل توسعه دهنده

۱۳-۶-۴-۱-۱ ALC_LCD.1.1D

توسعه دهنده باید مدل چرخه حیات که در توسعه و نگهداشت TOE به کار می رود را برقرار کند.

۱۳-۶-۴-۱-۲ ALC_LCD.1.2D

توسعه دهنده باید مستنداتی برای تعریف چرخه حیات ارائه کند.

۱۳-۶-۴-۲ عناصر ارائه و محتوی

۱۳-۶-۴-۲-۱ ALC_LCD.1.1C

مستندات تعریف چرخه حیات باید مدل مورد استفاده برای توسعه و نگهداشت TOE را شرح دهد.

۱۳-۶-۴-۲-۲ ALC_LCD.1.2C

مدل چرخه حیات باید کنترل های لازم برای توسعه و نگهداشت TOE را ارائه کند.

۱۳-۶-۴-۳ عناصر عمل ارزیاب

۱۳-۶-۴-۳-۱ ALC_LCD.1.1E

ارزیاب باید تأیید کند که اطلاعات ارائه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می کند.

۱۳-۶-۵ ALC_LCD.2 مدل چرخه حیات قابل سنجش

وابسته ها: هیچ وابسته ای ندارد.

۱۳-۶-۵-۱ عناصر عمل توسعه دهنده

۱۳-۶-۵-۱-۱ ALC_LCD. 2.1D

توسعه دهنده باید مدل چرخه حیات مورد استفاده در توسعه و نگهداشت را مقرر کند که مبتنی بر مدل چرخه حیات قابل سنجش می باشد.

۱۳-۶-۵-۱-۲ ALC_LCD.2.2D

توسعه دهنده باید مستندات تعریف چرخه حیات را فراهم کند.

۱۳-۶-۵-۱-۳ ALC_LCD.2.3D

توسعه‌دهنده باید با استفاده از مدل چرخه‌حیات قابل سنجش توسعه TOE را سنجش کند.

۱۳-۶-۵-۱-۴ ALC_LCD.2.4D

توسعه‌دهنده باید مستندات خروجی چرخه‌حیات را فراهم کند.

۱۳-۶-۵-۲ عناصر ارائه و محتوی

۱۳-۶-۵-۲-۱ ALC_LCD.2.1C

اسناد تعریف چرخه‌حیات مدل مورد استفاده برای توسعه و نگهداشت TOE را شرح می‌دهد، که شامل جزئیات پارامترهای حسابی و/یا معیارهای مورد استفاده برای سنجش کیفیت TOE و یا توسعه آن، می‌باشد.

۱۳-۶-۵-۲-۲ ALC_LCD.2.2C

مدل چرخه‌حیات برای کنترل لازم بر توسعه و نگهداشت TOE را فراهم می‌کند.

۱۳-۶-۵-۲-۳ ALC_LCD.2.3C

مستندات خروجی چرخه‌حیات باید نتایج سنجش‌هایی از توسعه TOE را با استفاده از مدل چرخه‌حیات قابل سنجش، مقرر کنند.

۱۳-۶-۵-۳ عناصر عمل ارزیاب

۱۳-۶-۵-۳-۱ ALC_LCD.2.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۷ ابزار و فنون

۱۳-۷-۱ اهداف

ابزار و فنون نمود انتخاب ابزاری است که به‌منظور توسعه، تحلیل و پیاده‌سازی TOE استفاده می‌شود. که شامل الزاماتی برای جلوگیری از بد شناخته شدن، نامتناقض بودن یا نادرست بودن ابزار توسعه برای توسعه TOE مورد استفاده قرار می‌گیرد. این شامل، زبان برنامه نویسی، مستندسازی، استانداردهای پیاده‌سازی و سایر قسمت‌های TOE از جمله حمایت از کتابخانه‌های زمان اجرا می‌شود اما نه محدود به آنها.

۱۳-۷-۲ رتبه‌بندی مؤلفه‌ها

مؤلفه‌ها در این خانواده براساس افزایش الزامات مورد نیاز برای شرح و هدف پیاده‌سازی استانداردها و مستندسازی گزینه‌های وابسته پیاده‌سازی رتبه‌بندی می‌شود.

۱۳-۷-۳ نکات کاربردی

الزامات مورد نیاز برای ابزار توسعه خوب شناخته شده، وجود دارد. اینها ابزاری هستند که به طور صریح و کامل شرح داده شده‌اند. برای مثال، زبان برنامه‌نویسی و سیستم‌های طراحی حمایت‌های کامپیوتر که بر اساس استانداردهایی که توسط متن استانداردها تصویب شده بر این باور است که به خوبی شناخته شوند. ابزار خودساخته نیاز به تجسس بیشتری دارد که آنها به وضوح و روشنی مشخص شوند.

الزامات ALC_TAT.1.2C مخصوص زبانهای برنامه‌نویسی قابل کاربرد است چنانکه تضمین می‌کند که کلیه بیانیه‌های کد منبع دارای مفهوم نامبهم هستند.

در ALC_TAT.2 و ALC_TAT.3، ممکن است راهنماهای پیاده‌سازی به عنوان استاندارد پیاده‌سازی پذیرش شود، اگر آنها توسط گروهی خبره تصویب شده باشند (مانند: خبره‌های دانشگاهی، متن استنادها). استانداردهای پیاده‌سازی معمولاً عمومی، کاملاً مورد قبول و عملی مشترک در یک صنعت مشخص هستند، اما همچنین ممکن است راهنماهای پیاده‌سازی توسعه‌دهنده_مشخص به عنوان استاندارد پذیرش شود؛ تأکید بر مهارت می‌شود.

ابزار و فنون بین استانداردهای پیاده‌سازی که توسط توسعه‌دهنده به کار گرفته می‌شود، تمیز داده می‌شوند (ALC_TAT.2.3D) و استانداردهای پیاده‌سازی برای "تمام قسمت‌های TOE" (ALC_TAT.3.3D) که شامل قسمت سوم نرم‌افزار، سخت‌افزار یا میان‌افزار هستند، می‌باشد. فهرست تنظیمات در محدوده CM معرفی می‌شوند (ALC_CMS) مستلزم این است که برای قسمت تنظیمات مربوطه TSF نشان داده شود، اگر توسط توسعه‌دهنده TOE یا توسعه‌دهنده‌های قسمت سوم ایجاد شده باشد.

۱۳-۷-۴ ALC_TAT.1 ابزار توسعه خوب شناخته شده

وابسته‌ها: ADV_IMP.1 ارائه پیاده‌سازی TSF

۱۳-۷-۴-۱ عناصر عمل توسعه‌دهنده

۱۳-۷-۴-۱-۱ ALC_TAT.1.1D

توسعه‌دهنده باید هر ابزار توسعه که برای TOE استفاده می‌شود را شناسایی کند.

۱۳-۷-۴-۲ ALC_TAT.1.2D

توسعه‌دهنده باید گزینه وابسته پیاده‌سازی انتخاب شده از هر ابزار توسعه را مستندسازی کند.

۱۳-۷-۴-۲ عناصر ارائه و محتوی

۱۳-۷-۴-۲-۱ ALC_TAT.1.1C

تمام ابزار توسعه که برای پیاده‌سازی استفاده می‌شوند باید خوب شناخته شده باشد.

۱۳-۷-۴-۲-۲ ALC_TAT.1.2C

مستندات ابزار توسعه باید مفهوم تمام بیانیه‌ها و قراردادها و دستوالعمل‌های پیاده‌سازی را بدون ابهام تعریف کند.

۱۳-۷-۴-۳ ALC_TAT.1.3C

مستندات ابزار توسعه باید مفهوم تمام گزینه‌های وابسته پیاده‌سازی را بدون ابهام تعریف کند.

۱۳-۷-۴-۳ عناصر عمل ارزیاب

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۷-۵ ALC_TAT.2 مطابق با استانداردهای پیاده‌سازی

وابسته‌ها: ADV_IMP.1 ارائه پیاده‌سازی TSF

۱۳-۷-۵-۱ عناصر عمل توسعه‌دهنده

۱۳-۷-۵-۱-۱ ALC_TAT.2.1D

توسعه‌دهنده باید هر ابزار توسعه که برای TOE استفاده می‌شود را شناسایی کند.

۱۳-۷-۵-۱-۲ ALC_TAT.2.2D

توسعه‌دهنده باید گزینه‌های وابسته پیاده‌سازی انتخاب شده از هر ابزار توسعه را مستندسازی کند.

۱۳-۷-۵-۱-۳ ALC_TAT.2.3D

توسعه‌دهنده باید پیاده‌سازی استانداردهایی که توسط توسعه‌دهنده به کار گرفته می‌شود را شرح دهد.

۱۳-۷-۵-۲ عناصر ارائه و محتوی

۱۳-۷-۵-۲-۱ ALC_TAT.2.1C

تمام ابزار توسعه که برای پیاده‌سازی استفاده می‌شوند باید خوب شناخته شده باشد.

۱۳-۷-۵-۲-۲ ALC_TAT.2.2C

مستندات ابزار توسعه باید مفهوم تمام بیانیه‌ها و قراردادها و دستوالعمل‌های پیاده‌سازی را بدون ابهام تعریف کند.

۱۳-۷-۵-۲-۳ ALC_TAT.2.3C

اسناد ابزار توسعه باید مفهوم تمام گزینه‌های وابسته پیاده‌سازی را بدون ابهام تعریف کند.

۱۳-۷-۵-۳ عناصر عمل ارزیاب

۱۳-۷-۵-۳-۱ ALC_TAT.2.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۳-۷-۵-۳-۲ ALC_TAT.2.2E

استانداردهای پیاده‌سازی که به کار گرفته می‌شوند باید توسط ارزیاب تأیید شود.

۱۳-۷-۶ ALC_TAT.3 برآوردن و پیاده‌سازی استانداردها - تمام قسمت‌ها

وابسته‌ها: ADV_IMP.1 ارائه پیاده‌سازی TSF

۱۳-۷-۶ عناصر عمل توسعه‌دهنده

ALC_TAT. 3.1D ۱-۱-۵-۷-۱۳

توسعه‌دهنده باید هر ابزار توسعه مورد استفاده برای TOE را شناسایی کند.

ALC_TAT.3.2D ۲-۱-۶-۷-۱۳

توسعه‌دهنده باید گزینه‌های وابسته پیاده‌سازی انتخاب شده از هر ابزار توسعه را مستندسازی کند.

ALC_TAT.3.3D ۳-۱-۶-۷-۱۳

توسعه‌دهنده باید استانداردهای پیاده‌سازی شده که توسط توسعه‌دهنده به کار گرفته می‌شود را تشریح کند.

۱۳-۷-۶-۲ عناصر ارائه و محتوی

ALC_TAT. 6.1C ۱-۲-۵-۷-۱۳

هر ابزار توسعه مورد استفاده برای پیاده‌سازی باید به‌خوبی تعریف شود.

ALC_TAT.3.2C ۲-۲-۶-۷-۱۳

مستندات هر ابزار توسعه باید معنی همه بیانیه‌ها و قراردادهای و دستوالعمل‌های پیاده‌سازی را بدون ابهام تعریف کند.

ALC_TAT.3.3C ۳-۲-۶-۷-۱۳

مستندات هر ابزار توسعه باید معنی همه گزینه‌های وابسته پیاده‌سازی را بدون ابهام تعریف کند.

۱۳-۷-۶-۳ عناصر عمل ارزیاب

ALC_TAT. 3.1E ۱-۳-۶-۷-۱۳

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

ALC_TAT.3.2E ۲-۳-۶-۷-۱۳

ارزیاب باید تأیید کند که استانداردهای پیاده‌سازی شده به کار گرفته شده‌اند.

۱۴دسته ATE: آزمون‌ها

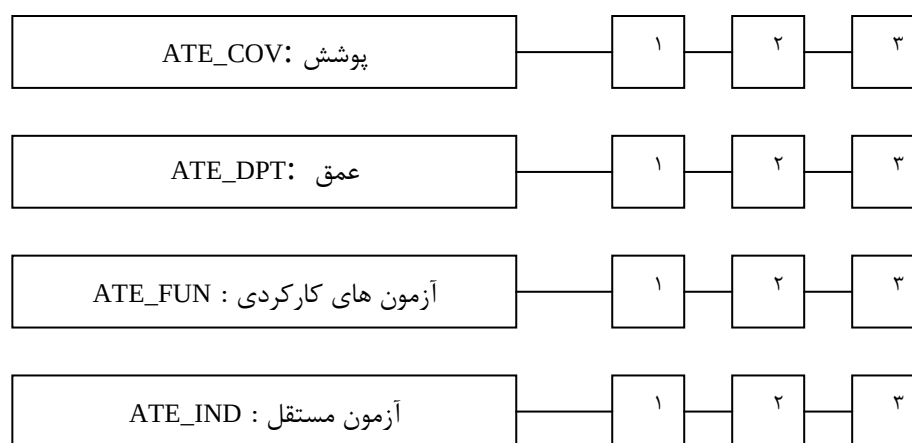
دسته "آزمون‌ها" از چهار خانواده تشکیل شده است. پوشش (ATE_COV)، عمق (ATE_DPT)، آزمون مستقل (ATE_IND) (مانند: آزمون کارکردی توسط ارزیاب انجام می‌شود)، و آزمون‌های کارکردی (ATE_FUN). انجام آزمون تضمین می‌کند که TSF همان‌طوری که شرح داده شده رفتار می‌کند. (در مشخصات کارکردی، طراحی TOE، و ارائه پیاده‌سازی).

در این دسته بر تأیید این که TSF مطابق با شرح طرح آن عمل می‌کند تأکید می‌شود. این دسته به آزمون نفوذ که مبتنی بر تجزیه و تحلیل TSF است اشاره نمی‌کند، که به‌طور ویژه به دنبال شناسایی آسیب‌پذیری‌ها در طراحی و پیاده‌سازی TSF شده است. تست نفوذ به‌طور جداگانه به عنوان جنبه‌ای از ارزشیابی آسیب‌پذیری در AVA، اشاره می‌شود: کلاس ارزشیابی آسیب‌پذیری.

ATE: دسته آزمون‌ها به آزمون توسط توسعه‌دهنده و آزمون توسط ارزیاب تفکیک می‌شود. خانواده‌های پوشش (ATE_COV)، عمق (ATE_DPT) به تکمیل انجام آزمون توسط توسعه‌دهنده اشاره می‌کند. پوشش (ATE_COV) به سختی آزمونی که بر روی مشخصات کارکردی انجام می‌شود، اشاره می‌کند. در عمق (ATE_DPT) اشاره می‌کند به این که آیا آزمون در برابر شرح طرح دیگر (معماری امنیت، طرح TOE، و ارائه پیاده‌سازی) مورد نیاز انجام می‌شود.

آزمون‌های عملیات (ATE_FUN) به انجام آزمون توسط توسعه‌دهنده و چگونگی مستندسازی آزمون اشاره می‌کند. در نهایت، آزمون مستقل (ATE_IND) به آزمون ارزیاب اشاره می‌کند: چه بسا ارزیاب باید قسمتی یا تمامی آزمون توسعه‌دهنده را تکرار کند و این که ارزیاب چه مقدار آزمون مستقل باید انجام دهد.

شکل ۱۴- خانواده‌های این دسته و سلسله مراتب مؤلفه‌های این خانواده را نشان می‌دهد.



شکل ۱۴- ATE: تحلیل دسته آزمون‌ها

۱-۱۴ (ATE_COV) پوشش (ATE_COV)

۱-۱۴ اهداف

این خانواده تاسیس می‌کند که TSF در برابر مشخصات کارکردی خود آزمایش شده است. این را از طریق بررسی مدارک توسعه‌دهنده از مطابقت انجام شدنی است.

۱-۱۴ ۲ رتبه‌بندی مؤلفه

مؤلفه‌ها در این خانواده مبتنی بر مشخصات رتبه‌بندی می‌شوند.

۱-۱۴ ۳ نکات کاربردی

۱-۱۴ ۴ ATE_COV.1 مدارک پوشش

وابسته‌ها: ADV_FSP.2 مشخصات کارکردی اجرایی امنیت

ATE_FUN.1 آزمون کارکردی.

۱-۱۴ ۱-۴ اهداف

هدف از این مؤلفه تأسیس کردن برخی از TSFI ها که آزمایش شده‌اند.

۱۴-۱-۴ نکات کاربردی

در این مؤلفه توسعه‌دهنده نشان می‌دهد که چگونه آزمون‌ها در مستندات آزمون مطابق با TSFI ها در مشخصات کارکردی انجام می‌شود. و این توسط بیانیه‌ای از مکاتبات، و شاید با استفاده از جدول انجام شدنی است.

۱۴-۱-۴ عناصر عمل توسعه‌دهنده

ATE_COV.1.1D ۱-۳-۴-۱-۱۴

توسعه‌دهنده باید مدارکی از پوشش آزمون ارائه کند.

۱۴-۱-۴ عناصر ارائه و محتوی

ATE_COV.1.1C ۱-۴-۴-۱-۴

مدارک پوشش آزمون باید مطابقت بین آزمون‌ها در مستندات آزمون و TSFI ها در مشخصات کارکردی را نشان دهد.

۱۴-۱-۴ عناصر عمل ارزیاب

ATE_COV.1.1E ۱-۵-۴-۱-۱۴

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات محتوی و ارائه مدارک را برآورده می‌کند.

۱۴-۱-۵ ATE_COV.2 تجزیه و تحلیل پوشش

وابسته‌ها: ADV_FSP.2 مشخصات کارکردی اجرای امنیت

ATE_FUN.1 آزمون کارکردی

۱۴-۱-۵ اهداف

هدف از این مؤلفه این است که تأیید کند تمام TSFI ها آزمایش شده است.

۱۴-۱-۵ نکات کاربردی

در این مؤلفه توسعه‌دهنده تأیید می‌کند که آزمون‌ها در مستندات آزمون مطابق با تمام TSFI ها در مشخصات کارکردی است. و این توسط بیانیه مکاتبات، و شاید با استفاده از جدول انجام شدنی است، فقط توسعه‌دهنده نیز تجزیه و تحلیل پوشش آزمون را ارائه می‌کند.

۱۴-۱-۵ عناصر عمل توسعه‌دهنده

ATE_COV.2.1D ۱-۳-۵-۱-۱۴

توسعه‌دهنده باید تجزیه و تحلیل پوشش آزمون را تهیه کند.

۱۴-۱-۵ عناصر ارائه و محتوی

ATE_COV.2.1C ۱-۴-۵-۱-۴

تجزیه و تحلیل پوشش آزمون باید مطابقت بین آزمون‌ها در مستندات آزمون و TSFI ها در مشخصات عملیات را نشان دهد.

ATE_COV.2.2C ۲-۴-۵-۱-۱۴

تجزیه و تحلیل پوشش آزمون باید نشان دهد که تمامی TSFI ها در مشخصات کارکردی آزمون شده‌اند.

۱۴-۱-۵-۵ عناصر عمل ارزیاب

ATE_COV.2.1E ۱-۵-۵-۴

ارزیاب باید تایید کند که اطلاعات تهیه شده تمام الزامات محتوا و ارائه مدارک را برآورده می‌کند.

۱۴-۱-۶ ATE_COV.3 تجزیه و تحلیل دقیق پوشش

وابسته‌ها: ADV_FSP.2 مشخصات کارکردی اجرای امنیت

ATE_FUN.1 آزمون کارکردی.

۱۴-۱-۶-۱ اهداف

در این مؤلفه هدف این است که تایید کند، توسعه‌دهنده تست‌های جامع از تمام واسطه‌ها در مشخصات کارکردی انجام می‌دهد. و همچنین تأیید کند که تمام پارامترها از تمامی TSFI آزمایش شده‌اند.

۱۴-۱-۶-۲ نکات کاربردی

در این مؤلفه توسعه‌دهنده تایید می‌کند که آزمون‌ها در مستندات آزمون مطابق با تمام TSFI ها در مشخصات کارکردی است. و این توسط بیانیه مکاتبات، و شاید با استفاده از جدول انجام شدنی است، اما علاوه بر این توسعه‌دهنده لازم است نشان دهد که آزمون‌ها از تمام پارامترهای TSFI ها استفاده می‌کنند. این الزامات اضافی شامل آزمون محدوده (به‌عنوان مثال: تأیید این که خطا بوجود آمده زمانی که از محدودیت اعلامی تجاوز کند). و آزمون‌های منفی (به‌عنوان مثال در مواقعی که دسترسی به کاربر الف داده شده است، تأیید کاربر A، نه تنها کاربر الف دسترسی دارد بلکه کاربر B نمی‌تواند به‌طور ناگهانی دسترسی داشته باشد). این نوع آزمون، نه صرفاً حرف‌زدن، جامع نیست زیرا ممکن نیست هر مقدار از پارامترهای پیش‌بینی بررسی شود.

۱۴-۱-۶-۳ عناصر عمل توسعه‌دهنده

ATE_COV.3.1D ۱-۳-۶-۱۴

توسعه‌دهنده باید تجزیه و تحلیل پوشش آزمون را تهیه کند.

ATE_COV.3.1C ۱-۴-۶-۱۴

تجزیه و تحلیل پوشش آزمون باید مطابقت بین آزمون‌ها در مستندات آزمون و TSFI ها در مشخصات کارکردی را نشان دهد.

ATE_COV.3.2C ۲-۴-۶-۱۴

تجزیه و تحلیل پوشش آزمون باید تمام TSFI ها در مشخصات کارکردی که به طور کامل آزمون شده‌اند را نشان دهد.

۱۴-۱-۶-۵ عناصر عمل ارزیاب

ATE_COV.3.1E ۱-۵-۶-۱۴

ارزیاب باید تأیید کند اطلاعات تهیه شده تمام الزامات محتوی و ارائه مدارک را برآورده می‌کند.

۱۴-۲ عمق (ATE_DPT)

۱۴-۲-۱ اهداف

مؤلفه در این خانواده با سطح جزئیات TSF که توسط توسعه‌دهنده آزمون می‌شود سرو کار دارد. آزمون TSF مبتنی بر افزایش عمق اطلاعات است حاصل از بازنمودهای طراحی اضافی و توضیحات (طراحی TOE، ارائه پیاده‌سازی، و شرح معماری امنیت) بنا شده است.

هدف مقابله با خطر از دست‌دادن خطا در توسعه TOE می‌باشد. برای آزمون آن از واسطه‌های درونی خاص استفاده می‌کند که می‌تواند ضمانت کند که نه تنها TSF رفتار امنیتی بیرونی مورد نظر را به‌نمایش می‌گذارد، بلکه این رفتار از عملکرد صحیح قابلیت درونی ناشی می‌شود.

۱۴-۲-۲ رتبه‌بندی مؤلفه

مؤلفه‌ها در این خانواده، از طراحی TOE به‌نمایش پیاده‌سازی بر اساس افزایش جزئیات ارائه شده در نمایش TSF رتبه‌بندی می‌شوند. این رتبه‌بندی نمایش TSF موجود در دسته ADV را منعکس می‌کند.

۱۴-۲-۳ نکات کاربردی

طراحی TOE مؤلفه‌های درونی (به‌عنوان مثال: زیر سیستم‌ها) و، شاید، پیمانه‌های TSF، همراه با توضیحات از واسطه‌های در بین این مؤلفه‌ها و پیمانه‌ها را شرح می‌دهد. مدارک آزمون از طراحی TOE باید نشان دهد که واسطه‌های درونی به‌کار گرفته شده‌اند و همان‌طور که شرح داده شده رفتار می‌کنند.

این ممکن است از طریق آزمون از طریق واسطه‌های بیرونی TSF، یا توسط آزمون زیر سیستم TOE یا تفکیک واسطه‌ای پیمانه، و شاید بکارگیری کنترل آزمون به‌دست آید. در مواردی که برخی از جنبه‌های واسطه درونی نمی‌توانند از طریق واسطه‌های بیرونی آزمایش شوند، یا باید توجیهی وجود داشته باشد که این جنبه‌های گوناگون آزمایش نشوند یا واسطه درونی باید به‌طور مستقیم آزمایش شود. در مورد دوم به منظور تسهیل آزمون مستقیم طرح TOE باید به اندازه کافی دقیق شرح داده شود.

در مواردی که شرح صحت طراحی TSF (در معماری امنیت (ADV_ARC)) به مکانیزم‌های خاص، آزمایشات انجام شده اشاره کند آزمون‌های انجام شده توسط توسعه‌دهنده باید نشان دهد که مکانیزم‌ها به‌کار گرفته شده و همان‌طور که شرح داده شده عمل می‌کند.

در عالی‌ترین مؤلفه از این خانواده، نه تنها در برابر طراحی TOE بلکه در برابر ارائه پیاده‌سازی آزمون انجام می‌شود.

۱۴-۲-۴ ATE_DPT.1 آزمون: طراحی ابتدایی

وابسته‌ها: ADV_ARC.1 شرح معماری امنیت

ADV_TDS.2 طراحی معماری

ATE_FUN.1 آزمون کارکردی

۱۴-۲-۴-۱ اهداف

شرح زیرسیستم از TSF توضیحات سطح-بالا از فعالیت‌های داخلی TSF ارائه می‌کند. آزمون در سطح زیر سیستم‌های TOE تضمین می‌کند که زیرسیستم‌های TSF همان‌طور که در طراحی TOE و شرح معماری امنیتی بیان شده رفتار می‌کنند و تعامل دارند.

۱۴-۲-۴ عناصر عمل توسعه‌دهنده

ATE_DPT.1.1D ۱-۲-۴-۲-۱۴

توسعه‌دهنده باید تجزیه و تحلیل عمق آزمون را تهیه کند.

۱۴-۲-۴ عناصر ارائه و محتوی

ATE_COV.3.1C ۱-۳-۴-۲-۴

تجزیه و تحلیل عمق آزمون باید مطابقت بین آزمون‌ها در مستندات آزمون و زیرسیستم‌های TSF در طراحی TOE را نشان دهد.

ATE_DPT.1.2C ۲-۳-۴-۲-۱۴

تجزیه و تحلیل عمق آزمون باید نشان دهد که تمام زیرسیستم‌های TSF در طرح TOE به‌طور کامل آزمون شده‌اند.

۱۴-۲-۴ عناصر عمل ارزیاب

ATE_DPT.1.1E ۱-۴-۴-۲-۱۴

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات محتوی و ارائه مدارک را برآورده می‌کند.

۱۴-۲-۵ ATE_DPT.2 آزمون: پیمانه‌های اجرای امنیت

وابسته‌ها: ADV_ARC.1 شرح معماری امنیت

ADV_TDS.3 طراحی پیمانه‌ای پایه

ATE_FUN.1 آزمون کارکردی

۱۴-۲-۵ اهداف

شرح زیرسیستم از TSF توضیحات سطح-بالا از فعالیت‌های داخلی TSF ارائه می‌کند. آزمون در سطح زیر سیستم‌های TOE تضمین می‌کند که زیر سیستم‌های TSF همان‌طور که در طراحی TOE و شرح معماری امنیتی بیان شده رفتار می‌کنند و تعامل دارند.

۱۴-۲-۵ عناصر عمل توسعه‌دهنده

ATE_DPT.2.1D ۱-۲-۵-۲-۱۴

توسعه‌دهنده باید تجزیه و تحلیل عمق آزمون را تهیه کند.

۱۴-۲-۵ عناصر ارائه و محتوی

ATE_COV.2.1C ۱-۳-۵-۲-۴

تجزیه و تحلیل عمق آزمون باید نشان دهد که بین آزمون‌ها در مستندات آزمون و زیرسیستم‌های TSF و پیمانه‌های اجرای SFR در طراحی TOE مطابقت وجود دارد.

ATE_DPT.2.2C ۲-۳-۵-۲-۱۴

تجزیه و تحلیل عمق آزمون باید تمام زیرسیستم‌های TSF در طراحی TOE که به‌طور کامل آزمون شده‌اند را نشان دهد.

ATE_DPT.2.3C ۳-۳-۵-۲-۱۴

تجزیه و تحلیل عمق آزمون باید پیمانه‌های اجرای-SFR در طراحی TOE که به‌طور کامل آزمون شده‌اند را نشان دهد.

۱۴-۲-۵-۴ عناصر عمل ارزیاب

ATE_DPT.2.1E ۱-۴-۵-۲-۱۴

ارزیاب باید تایید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۴-۲-۶ آزمون ATE_DPT.3: طراحی پیمانه

وابسته‌ها: ADV_ARC.1 شرح معماری امنیت

ADV_TDS.3 طراحی پیمانه نیمه‌رسمی

ATE_FUN.1 آزمون کارکردی

۱۴-۲-۶-۱ اهداف

شرح زیرسیستم از TSF توضیحات سطح-بالا از فعالیت‌های داخلی TSF ارائه می‌کند. آزمون در سطح زیر سیستم‌های TOE تضمین می‌کند که زیر سیستم‌های TSF همان‌طور که در طراحی TOE و شرح معماری امنیتی بیان شده رفتار می‌کنند و تعامل دارند.

۱۴-۲-۶-۲ عناصر عمل توسعه‌دهنده

ATE_DPT.3.1D ۱-۲-۵-۲-۱۴

توسعه‌دهنده باید تجزیه و تحلیل عمق آزمون را تهیه کند.

۱۴-۲-۶-۳ عناصر ارائه و محتوی

ATE_COV.3.1C ۱-۳-۶-۲-۱۴

تجزیه و تحلیل عمق آزمون باید نشان دهد که بین آزمون‌ها در مستندات آزمون و زیرسیستم‌های TSF و پیمانه‌ها در طراحی TOE مطابقت وجود دارد.

ATE_DPT.3.2C ۲-۳-۶-۲-۱۴

تجزیه و تحلیل عمق آزمون باید تمام زیرسیستم‌های TSF در طراحی TOE که به‌طور کامل آزمون شده‌اند را نشان دهد.

ATE_DPT.3.3C ۳-۳-۶-۲-۱۴

تجزیه و تحلیل عمق آزمون باید تمام پیمانه‌های TSF در طراحی TOE که به‌طور کامل آزمون شده‌اند را نشان دهد.

۱۴-۲-۶-۴ عناصر عمل ارزیاب

ATE_DPT.3.1E ۱-۴-۶-۲-۱۴

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۴-۲-۷ ATE_DPT.4 آزمون: ارائه پیاده‌سازی

وابسته‌ها: 1.ADV_ARC شرح معماری امنیت

4.ADV_TDS ارائه پیاده‌سازی TSF

1.ATE_FUN آزمون کارکردی

۱۴-۲-۷-۱ اهداف

شرح زیرسیستم از TSF توضیحات سطح-بالا از فعالیت‌های داخلی TSF ارائه می‌کند. آزمون در سطح زیرسیستم‌های TOE تضمین می‌کند که زیرسیستم‌های TSF همان‌طور که در طراحی TOE و شرح معماری امنیتی بیان شده رفتار می‌کنند و تعامل دارند.

۱۴-۲-۷-۲ عناصر عمل توسعه‌دهنده

۱۴-۲-۵-۱ ATE_DPT.4.1D

توسعه‌دهنده باید تجزیه و تحلیل عمق آزمون را تهیه کند.

۱۴-۲-۷-۳ عناصر ارائه و محتوی

۱۴-۲-۷-۳-۱ ATE_COV.4.1C

تجزیه و تحلیل عمق آزمون باید مطابقت بین آزمونها در مستندات آزمون و زیرسیستم‌های TSF و پیمانه‌ها در طراحی TOE را نشان دهد.

۱۴-۲-۷-۳-۲ ATE_DPT.4.2C

تجزیه و تحلیل عمق آزمون باید تمام زیرسیستم‌های TSF در طراحی TOE که به‌طور کامل آزمون شده‌اند را نشان دهد.

۱۴-۲-۷-۳-۳ ATE_DPT.4.3C

تجزیه و تحلیل عمق آزمون باید تمام پیمانه‌های TSF در طراحی TOE که به‌طور کامل آزمون شده‌اند را نشان دهد.

۱۴-۲-۷-۳-۴ ATE_DPT.4.4C

تجزیه و تحلیل عمق آزمون باید نشان دهد که TSF مطابق با ارائه پیاده‌سازی عمل می‌کند.

۱۴-۲-۷-۴ عناصر عمل ارزیاب

۱۴-۲-۷-۴-۱ ATE_DPT.4.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۴-۳ آزمون‌های کارکردی (ATE_FUN)

۱۴-۳-۱ اهداف

آزمون کارکردی توسط توسعه‌دهنده انجام می‌شود که تضمین کند آزمون‌ها در مستندات آزمون انجام می‌شود و به‌طور صحیح مستندسازی می‌شود. مطابق با این آزمون‌ها، شرح طراحی TSF از طریق خانواده‌های پوشش (ATE_COV) و عمق (ATE_DPT) انجام شدنی است.

این خانواده کمک به فراهم آوردن اطمینان از این که احتمال معایب کشف نشده نسبتاً کم است. خانواده‌های پوشش (ATE_COV)، عمق (ATE_DPT) و آزمون‌های کارکردی (ATE_FUN) در ترکیب برای تعریف مدارک آزمون که توسط توسعه‌دهنده استفاده می‌شود، به کار می‌رود. توسعه‌دهنده آزمون کارکردی مستقل را توسط آزمون مستقل (ATE_IND) مشخص می‌کند.

۱۴-۳-۲ رتبه‌بندی مؤلفه‌ها

این خانواده دارای دو مؤلفه است، نیاز مؤلفه بالاتر، ترتیب دادن وابسته‌هایی که تجزیه و تحلیل می‌شوند، می‌باشد.

۱۴-۳-۳ نکات کاربردی

روش‌هایی برای انجام آزمایشات وجود دارد که انتظار می‌رود دستورالعمل برای استفاد از برنامه آزمون و همراه آن آزمون ارائه کند از جمله محیط آزمون، شرایط آزمون، پارامترهای داده آزمون و مقادیر می‌باشد. روش‌های آزمون همچنین باید نشان‌دهد که چگونه نتایج آزمون از ورودی‌های آزمون مشتق شده‌اند. ترتیب وابسته‌ها قابل کاربرد است هنگامی که انجام موفق آزمون خاص به شرح ویژه موجود بستگی داشته باشد. برای نمونه ممکن است نیاز به اجرای سریع آزمون الف پیش از اجرای موفق آزمون ب باشد، چون بیان نتیجه اجرای موفق آزمون الف پیش‌نیاز اجرای موفق آزمون می‌باشد. بنابراین عدم موفقیت آزمون در مورد ترتیب وابسته‌ها به مشکل مواجه می‌شود. در مثال بالا، آزمون ب با عدم موفقیت مواجه می‌شود به دلیل این که آزمون پ (سریع‌تر از آزمون الف) سریع قبل از آن اجرا می‌شود، یا ممکن است شکست آزمون ب به دلیل عدم موفقیت آزمون الف باشد.

۱۴-۳-۴ ATE_FUN.1 آزمون کارکردی

وابسته‌ها: ATE_COV.1 مدارک پوشش

۱۴-۳-۴-۱ اهداف

هدف این است که توسعه‌دهنده نشان‌دهد آزمون‌ها در مستندات آزمون انجام می‌شود و به‌طور صحیح مستندسازی می‌شود.

۱۴-۳-۴-۲ عناصر عمل توسعه‌دهنده

۱۴-۳-۴-۲-۱ ATE_FUN.1.1D

توسعه‌دهنده باید TSF را آزمون کند و نتایج را مستندسازی کند.

۱۴-۳-۴-۲-۲ ATE_FUN.1.2D

توسعه‌دهنده باید مستندات آزمون را تهیه کند.

۱۴-۳-۴-۳ عناصر ارائه و محتوی

ATE_FUN.1.1C ۱-۳-۴-۳-۱۴

مستندات آزمون باید شامل طرح آزمون، نتایج مورد نظر آزمون و نتایج واقعی آزمون باشد.

ATE_FUN.1.2C ۲-۳-۴-۳-۱۴

طرح آزمون باید آزمون‌هایی که انجام می‌شود را معرفی کند و سناریو انجام هر تست را توضیح دهد. این سناریوها باید شامل ترتیب وابسته‌های نتایج آزمون‌ها باشد.

ATE_FUN.1.3C ۳-۳-۴-۳-۱۴

نتایج مورد نظر آزمون باید خروجی پیش‌بینی انجام موفق آزمون را نشان دهد.

ATE_FUN.1.4C ۴-۳-۴-۳-۱۴

نتایج واقعی آزمون باید با نتایج مورد نظر آزمون نامتناقض نباشد.

۱۴-۳-۴-۴ عناصر عمل ارزیاب

ATE_FUN.1.1E ۱-۴-۴-۳-۱۴

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

ATE_FUN.2 ۵-۳-۱۴ سفارش آزمون کارکردی

وابسته‌ها: ATE_COV.1 مدارک ضمانت

۱۴-۳-۵-۱ اهداف

اهداف توسعه‌دهنده شرح‌دادن اجرای آزمون‌ها در مستندات آزمون و مستندسازی به‌طور صحیح می‌باشد و دارای ساخت آزمون را تضمین می‌کند مانند ممانعت کردن قسمتنامه متغیرها درباره صحت واسطه‌هایی که آزمون می‌شوند.

۱۴-۳-۵-۲ نکات کاربردی

اگرچه روش‌های آزمون ممکن است پیش‌نیاز اولیه شرایط آزمون را برحسب ترتیب آزمون‌ها بیان می‌کند، اما ممکن است توضیح اصول ترتیب را ارائه نکند.

۱۴-۳-۵-۳ عناصر عمل توسعه‌دهنده

ATE_FUN.2.1D ۱-۳-۵-۳-۱۴

توسعه‌دهنده باید TSF را آزمایش کند و نتایج را مستند کند.

ATE_FUN.2.2D ۲-۳-۵-۳-۱۴

توسعه‌دهنده باید مستندات آزمون را مقرر کند.

۱۴-۳-۵-۴ عناصر ارائه و محتوی

ATE_FUN.2.1C ۱-۴-۵-۳-۱۴

مستندات آزمون باید از طرح آزمون، نتایج مورد نظر آزمون و نتایج واقعی آزمون تشکیل شده باشد.

ATE_FUN.2.2C ۲-۴-۵-۳-۱۴

اجرای آزمون و شرح انجام هر تست باید در طرح آزمون معرفی شود. این طرح باید شامل ترتیب وابسته‌های نتایج دیگر آزمون‌ها باشد.

۱۴-۳-۵-۴-۳ ATE_FUN.2.3C

نتایج مورد نظر آزمون باید خروجی پیش‌بینی اجرای موفق آزمون را نشان دهد.

۱۴-۳-۵-۴-۴ ATE_FUN.2.4C

نتایج مورد نظر آزمون با نتایج واقعی آزمون باید سازگار باشد.

۱۴-۳-۵-۴-۵ ATE_FUN.2.5C

مستندات آزمون باید شامل تحلیل رویه آزمون ترتیب وابستگی‌ها می‌باشد.

۱۴-۳-۵-۵ عناصر عمل ارزیاب

۱۴-۳-۵-۱ ATE_FUN.2.1E

اطلاعات ارائه شده‌ای که تمام الزامات نمایش و محتوای گواهینامه را برآورده کند باید ارزیاب تأیید کند.

۱۴-۴ آزمون مستقل (ATE_IND)

۱۴-۴-۱ اهداف

اهداف این خانواده براساس ضمانت به‌دست آمده در خانواده‌های ATE_FUN، ATE_COV و ATE_DPT ایجاد شده و با تأیید آزمون توسعه‌دهنده و انجام آزمون‌های اضافی توسط ارزیاب به‌دست می‌آید.

۱۴-۴-۲ رتبه‌بندی مؤلفه‌ها

رتبه‌بندی مبتنی بر مقدار مستندات آزمون توسعه‌دهنده و حمایت از آزمون و میزان آزمون ارزیاب می‌باشد.

۱۴-۴-۳ نکات کارردی

این خانواده با درجه‌ای سروکار دارد که آزمون کارکردی مستقل TSF وجود داشته باشد. آزمون کارکردی مستقل ممکن است آزمون‌های کارکردی توسعه‌دهنده (کامل یا قسمتی) را تکرار کند یا دامنه کاربرد را منبسط کند یا آزمون‌های توسعه‌دهنده را عمق دهد. این فعالیت‌ها تکمیل کننده هستند و باید مجموع مناسبی برای هر TOE طرح‌ریزی شود که در دسترس بودن و ضمانت نتایج آزمون و پیچیدگی عملیات TSF را در نظر گیرد. همچنین ایجاد دامنه برای آزمون اضافی در نظر نیاز است، و نفع نسبی که ممکن است از تلاش در این دو حوزه به‌دست آورد باشد.

نمونه‌گیری از آزمون‌ها به‌منظور تأیید این مسئله که برنامه آزمون طرح‌ریزی شده TSF توسط توسعه‌دهنده انجام شده و به‌طور صحیح نتایج را ضبط کرده است. مقدار نمونه انتخاب شده بر جزئیات و کیفیت نتایج آزمون کارکردی توسعه‌دهنده تأثیر می‌گذارد. همچنین ارزیاب باید هدف آزمون‌های اضافی را برای طراحی آزمون‌های اضافی در نظر گیرد و منفعت‌های مربوطه از عملیات در این دو ناحیه به‌دست می‌آید.

ممکن است در برخی وضعیت‌ها تکرار تمام آزمون‌های توسعه‌دهنده امکان‌پذیر و مطلوب باشد، اما در برخی دیگر دشوار و تولید کمتر می‌باشد. عالی‌ترین مؤلفه در این خانواده بهتر است که با هوشیاری انجام شود. نمونه‌برداری به‌کل نتایج آزمون در دسترس اشاره می‌کند، و آن‌هایی که الزامات ضمانت و عمق را برآورده می‌کنند را هم دربر دارد.

حجم نمونه انتخاب خواهد شد تحت تأثیر جزئیات و کیفیت پاسخ نتایج آزمون عملکردی است.

همچنین باید تنظیمات مختلفی از TOE مطابق با ارزیابی در نظر گرفته شود. ارزیاب باید نتایج ارائه شده قابل کاربرد را ارزیابی کند و آزمون مطابق با آن را طرح‌ریزی کند.

مناسب بودن TOE برای آزمون مبتنی بر دسترس داشتن به TOE و حمایت از مستندات و اطلاعات مورد نیاز (شامل هر نرم‌افزار یا ابزار برای آزمون) برای انجام آزمون‌ها می‌باشد.

علاوه بر این ممکن است مناسب بودن TOE برای آزمون مبتنی بر دیگر ملاحظات باشد. برای نمونه، نسخه TOE که توسط توسعه‌دهنده ارائه می‌شود ممکن است نسخه نهایی نباشد.

به واسطه‌های شرح داده شده در مشخصات کارکردی و طراحی TOE و پارامترهای تصویب از طریق فراخوانی‌های شناسایی شده در ارائه پیاده‌سازی، اصطلاح "واسط" اشاره می‌شود.

اشاره به یک زیرمجموعه از واسطه‌ها به منظور این که ارزیابان را مجاز دارند مجموعه‌ای مناسب از آزمون را طراحی کنند به صورتی که با هدف ارزشیابی‌هایی که انجام می‌شود سازگار باشد.

۱۴-۴-۴ آزمون مستقل – مطابقت

وابسته‌ها: ADV_FSP.1 مشخصات کارکردی پایه

AGD_OPE.1 راهنمای کاربر عملیاتی

AGD_PRE.1 روش‌های مقدماتی

۱۴-۴-۴ اهداف

در این مؤلفه هدف این است که نشان دهد که TOE مطابق با بازنمودهای طراحی خود و راهنمای اسناد عمل می‌کند.

۱۴-۴-۴ نکات کاربردی

این مؤلفه به کاربرد نتایج آزمون توسعه‌دهنده اشاره نمی‌کند، و جایی که نتایج در دسترس نباشند و همچنین در مواردی که آزمون توسعه‌دهنده بدون تأیید مورد قبول باشد قابل کاربرد می‌باشد. ارزیاب باید آزمون‌ها را درک و با در نظر گرفتن این که TOE مطابق با طراحی آن عمل می‌کند هدایت کند اما محدود به مشخصات کارکردی نمی‌باشد. روش این است که از عملکرد صحیح نماینده آزمون به جای رفتار هر آزمون ممکن اطمینان حاصل کند. سطح آزمونی که برای این هدف طرح‌ریزی شده یک موضوع اصولی است و باید در زمینه خاص TOE در نظر گرفته شود و در سایر ارزشیابی‌ها متوازن باشد.

۱۴-۴-۴ عناصر عمل توسعه‌دهنده

ATE_IND.1.1D ۱-۳-۴-۴-۱۴

توسعه‌دهنده باید TOE را برای آزمون مقرر کند.

۱۴-۴-۴ عناصر ارائه و محتوی

ATE_IND.1.1C ۱-۴-۴-۴-۱۴

TOE برای آزمون باید مناسب باشد.

۱۴-۴-۴ عناصر عمل ارزیاب

ATE_IND.1.1E ۱-۵-۴-۴-۱۴

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

ATE_IND.1.2E ۲-۵-۴-۴-۱۴

ارزیاب باید یک زیرمجموعه‌ای از TSF، برای تأیید این‌که TSF همان‌طور که مشخص شده عمل می‌کند را تست کند.

ATE_IND.2 14.4.5.1 Objectives ۵-۴-۱۴ آزمون مستقل - نمونه

وابسته‌ها: مشخصات کارکردی اجرای امنیت - امنیت

AGD_OPE.1 راهنمای کاربر کارکردی

AGD_PRE.1 روش‌های مقدماتی

ATE_COV.1 مدارک پوشش

ATE_FUN.1 آزمون کارکردی

۲-۵-۴-۴-۱۴ اهداف

هدف از این مؤلفه نشان دادن TOE که مطابق با طراحی مورد نظر و راهنمای مستندات عمل می‌کند. ارزیاب با انجام آزمون تأیید می‌کند که توسعه‌دهنده برخی آزمون‌های واسطه‌ها با مشخص کردن عملیات انجام می‌دهد.

۲-۵-۴-۴-۱۴ نکات کاربردی

توسعه‌دهنده بهتر است ارزیاب با مواد لازم برای تکثیر مؤثر آزمون‌های توسعه‌دهنده را مقرر کند. این ممکن است شامل چیزهایی مانند مستندات آزمون ماشین_قابل خواندن، برنامه‌های آزمون و غیره باشد.

الزامات این مؤلفه شامل در دسترس بودن نتایج تست توسعه‌دهنده برای ارزیاب در جهت تکمیل کردن برنامه تست می‌باشد. ارزیاب نمونه آزمون‌های توسعه‌دهنده را تکرار می‌کند تا از نتایج به دست آمده اطمینان حاصل کند. برای تأیید این اطمینان، ارزیاب توسط آزمون‌های اضافی که TOE با روش‌های مختلف را عمل می‌کند، به آزمون‌های توسعه‌دهنده اضافه می‌کند. با استفاده از پایگاه نتایج تست توسعه‌دهنده معتبر، ارزیاب می‌تواند این اطمینان را حاصل کند که TOE به‌طور صحیح در حوزه وسیع‌ای از شرایط بیشتر از خالص که با استفاده از تلاش‌های خود توسعه‌دهنده در سطح منبع ثابت معین می‌تواند عمل کند.

با اطمینان حاصل کردن از این‌که در جای مناسب توسعه‌دهنده TOE را تست کرده، همچنین ارزیاب آزادی بیشتری دارد، برای تمرکز کردن آزمون در رسیدگی مستندات یا در دانش متخصص که نگرانی‌های ویژه بالا رفته است.

۲-۵-۴-۴-۱۴ عناصر عمل توسعه‌دهنده

ATE_IND.2.1D ۱-۳-۵-۴-۴-۱۴

توسعه‌دهنده باید TOE را برای آزمون مقرر کند.

۴-۵-۴-۴-۱۴ عناصر ارائه و محتوی

ATE_IND.2.1C ۴-۱-۵-۴-۴-۱۴

TOE برای آزمون باید مناسب باشد.

ATE_IND.2.2C ۲-۴-۵-۴-۴-۱۴

توسعه‌دهنده باید یک مجموعه از منابع متناظر که برای آزمون کارکردی TSF توسعه‌دهنده به کار می‌رود، مقرر کند.

۱۴-۴-۵-۵ عناصر عمل ارزیاب

ATE_IND.2.1E ۱-۵-۵-۴-۱۴

اطلاعات ارائه شده‌ای که تمام الزامات مضمون گواهینامه را برآورده کند و گواهینامه را نشان‌دهد باید ارزیاب تأیید کند.

ATE_IND.2.2E ۲-۵-۵-۴-۱۴

برای تأیید نتایج آزمون توسعه‌دهنده، ارزیاب باید نمونه آزمون مستندات آزمون را انجام دهد.

ATE_IND.2.3E ۳-۵-۵-۴-۱۴

برای تأیید این که TSF مطابق با تعیین شده عمل می‌کند، ارزیاب باید زیر مجموعه‌ای از TSF را تست کند.

۱۴-۴-۶-۶ ATE_IND.3 تست کردن به صورت مستقل - کامل

وابسته‌ها: مشخصات کارکردی کامل

AGD_OPE.1 راهنمای کاربر عملیاتی

AGD_PRE.1 روش‌های مقدماتی

ATE_COV.1 مدارک پوشش

ATE_FUN.1 تست کارکردی

۱۴-۴-۶-۱ اهداف

هدف از این مؤلفه نشان‌دادن TOE که مطابق با طراحی موردنظر و راهنمای مستندات عمل می‌کند. آزمون‌های ارزیاب شامل کلیه آزمون‌های توسعه‌دهنده که آن‌ها را تکرار می‌کند، می‌باشد.

۱۴-۴-۶-۲ نکات کاربردی

توسعه‌دهنده بهتر است ارزیاب با مواد لازم برای تکثیر موثر آزمون‌های توسعه‌دهنده را مقرر کند. این ممکن است شامل چیزهایی مانند مستندات آزمون ماشین_قابل خواندن، برنامه‌های آزمون و غیره باشد.

در این مؤلفه ارزیاب باید کلیه آزمون‌های توسعه‌دهنده به‌عنوان قسمتی از برنامه آزمون، تکرار کند. همان‌طور که در مؤلفه پیشین ارزیاب همچنین آزمون‌هایی که هدف‌شان به‌کارگیری TSF به‌روش‌های مختلفی که توسط توسعه‌دهنده به‌دست آمده است، هدایت می‌کند. در مواردی که آزمون توسعه‌دهنده جامع باشد، ممکن است که حیطة کمی از آن بماند.

۱۴-۴-۶-۳ عناصر عمل توسعه‌دهنده

ATE_IND.3.1D ۱-۳-۶-۴-۱۴

توسعه‌دهنده باید TOE را برای آزمون مقرر کند.

۱۴-۴-۶-۴ عناصر ارائه و محتوی

ATE_IND.3.1C ۱-۴-۶-۴-۱۴

TOE باید برای آزمون مناسب باشد.

ATE_IND.3.2C ۲-۴-۶-۴-۱۴

توسعه‌دهنده باید یک مجموعه از منابع متناظر که برای آزمون کارکردی TSF توسعه‌دهنده به کار می‌رود، مقرر کند.

ATE_IND.3.1E ۱-۵-۶-۴-۱۴

اطلاعات ارائه شده‌ای که تمام الزامات مضمون گواهینامه را برآورده کند و گواهینامه را نشان‌دهد باید ارزیاب تأیید کند.

ATE_IND.3.2E ۲-۵-۶-۴-۱۴

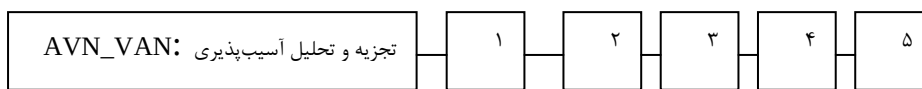
برای تأیید نتایج آزمون توسعه‌دهنده، ارزیاب باید تمام آزمون مستندات آزمون را اجرا کند.

ATE_IND.3.3E ۳-۵-۶-۴-۱۴

برای تأیید این که کل TSF مطابق با تعیین شده عمل می‌کند، ارزیاب باید زیرمجموعه‌ای از TSF را تست کند.

۱۵ گروه AVA ارزیابی آسیب‌پذیری

AVA: دسته ارزیابی آسیب‌پذیری به آسیب‌پذیری‌های قابل بهره‌برداری احتمالی معرفی شده در توسعه یا عملیات TOE، اشاره می‌کند.



شکل ۱۵- تجزیه دسته ارزیابی آسیب‌پذیری

۱۵-۱ نکات کاربردی

معمولاً، فعالیت ارزیابی آسیب‌پذیری شامل آسیب‌پذیری‌های مختلف در توسعه و عملیات TOE می‌باشد. آسیب‌پذیری‌های توسعه از برخی خواص متعلق به TOE که در حین توسعه مطرح شد، سوء استفاده می‌کنند. به‌عنوان مثال شکست‌دادن حفاظت TSF از خود در مداخله، حمله مستقیم یا نظارت بر TSF یا شکست‌دادن جدایی حوزه TSF از طریق نظارت و یا حمله مستقیم TSF یا شکست‌دادن غیر قابل bypass از طریق دورزدن TSF. آسیب‌پذیری‌های عملیاتی از نقاط ضعف در مقابله غیرفنی به نقض TOE SFR سوءاستفاده می‌کنند، به‌عنوان مثال بد استفاده کردن یا نادرست بودن تنظیمات. بد استفاده کردن، چه TOE بتواند بد تنظیم شود چه به شیوه‌ای ناامن به کار گرفته شود معنی می‌دهد، اما مدیر یا کاربر TOE بر این باور است که ایمن باشد.

ارزیابی آسیب‌پذیری‌ها توسط خانواده اطمینان AVA_VAN بیمه شده است. تمام آسیب‌پذیری‌های توسعه در متن AVA_VAN در نظر گرفته شده است. با توجه به واقعیت، این خانواده مجاز می‌دارد که کاربرد طیف وسیعی از روش‌های ارزیابی برای انواع سناریوی حمله غیرمشخص می‌باشد. این روش‌های ارزیابی غیرمشخص را دربر می‌گیرد، درمیان دیگر، و نیز روش‌های خاصی برای آن دسته از TSF‌هایی که در آن کانال‌های مخفیانه نظر گرفته می‌شود (برآورد ظرفیت کانال می‌تواند با استفاده از اندازه‌گیری‌های مهندسی غیررسمی، و نیز اندازه‌گیری‌های آزمون واقعی انجام شود) یا با استفاده از منابع کافی در صورت حمله مستقیم می‌تواند غلبه

کند(مفهوم اصلی فنی TSF مبتنی بر مکانیزم احتمالی یا مکانیزم‌های بی‌ثبات می‌باشد؛ صلاحیت رفتار امنیتی خود و تلاش لازم برای غلبه آنها می‌تواند با استفاده از تجزیه و تحلیل کمی و یا آماری صورت گیرد. اگر اهداف امنیتی مشخص شده در ST برای جلوگیری از یک کاربر از TOE از فعالیت‌های نظارتی در ارتباط با کاربر دیگری از TOE شود یا اطمینان حاصل کند که جریان اطلاعات را نمی‌توان برای دستیابی سیگنال‌های غیر قانونی داده لازم استفاده کرد، تجزیه و تحلیل کانال‌های مخفیانه بهتر است در حین انجام تجزیه و تحلیل آسیب‌پذیری در نظر گرفته شود. این اغلب با گنجاندن ISO/IEC 15408-2 غیر مشاهده‌پذیری (FPR_UNO) منعکس می‌شود و خط‌مشی‌های کنترل دسترسی چند سطحی از طریق ISO/IEC 15408-2 خط‌مشی‌های کنترل دسترسی (FDP_ACC) و یا ایزو ISO/IEC 15408-2 خط‌مشی‌های کنترل جریان اطلاعات (FDP_IFC) در ST مشخص می‌شود.

۱۵-۲ تحلیل آسیب‌پذیری (AVA_VAN)

۱۵-۲-۱ اهداف

تجزیه و تحلیل آسیب‌پذیری از یک ارزیابی برای تعیین اینکه چه آسیب‌پذیری‌های بالقوه در طول ارزیابی توسعه و عملیات پیش‌بینی شده از TOE شناسایی شده، و یا با روش‌های دیگر (به‌عنوان مثال از طریق نقص فرضیه‌ها یا کمی یا تجزیه و تحلیل آماری از رفتار امنیتی از مکانیسم‌های اصلی امنیتی)، می‌تواند به حمله‌کنندگان اجازه می‌دهد که SFRها را نقض کند.

تجزیه و تحلیل آسیب‌پذیری با تهدیدهایی سرو کار دارد که حمله‌کننده قادر به کشف معایبی خواهد بود که اجازه می‌دهد به صورت غیر مجاز به داده‌ها دسترسی داشته باشد و قابلیت‌ها، قادر به مداخله یا تغییر TSF یا مداخله یا توانمندی‌های مجاز کاربران دیگر را مجاز می‌دارد.

۱۵-۲-۲ رتبه‌بندی مؤلفه

رتبه‌بندی مبتنی برافزایش سختی تجزیه و تحلیل آسیب‌پذیری توسط ارزیاب می‌باشد. و سطوح افزایش پتانسیل حمله لازم توسط حمله‌کننده شناسایی می‌شود و از آسیب‌پذیری‌های بالقوه بهره‌برداری می‌شود.

۱۵-۲-۳ AVA_VAN.1 بررسی آسیب‌پذیری‌ها

وابسته‌ها: ADV_FSP.1 مشخصات کارکردی پایه

AGD_OPE.1 راهنمای کاربر عملیاتی

AGD_PRE.1 روش‌های مقدماتی

۱۵-۲-۳-۱ اهداف

بررسی آسیب‌پذیری از اطلاعات موجود در حوزه عمومی توسط ارزیاب برای تعیین آسیب‌پذیری‌های بالقوه‌ای که به راحتی توسط حمله‌کننده کشف می‌شود، انجام می‌شود.

ارزیاب آزمون نفوذ را برای تأیید این که آسیب‌پذیری‌های بالقوه نمی‌تواند در محیط‌های عملیاتی برای TOE بهره‌برداری کند، انجام می‌دهد. تست نفوذ توسط ارزیاب با فرض پتانسیل حمله انجام می‌شود.

۱۵-۲-۳-۲ عناصر عمل توسعه‌دهنده

۱۵-۲-۳-۲-۱ AVA_VAN.1.1D

توسعه‌دهنده باید TOE را برای آزمون تهیه کند.

۱۵-۲-۳-۳ عناصر ارائه و محتوی

AVA_VAN.1.1C ۱-۳-۳-۲-۱۵

TOE باید برای آزمون مناسب باشد.

۱۵-۲-۳-۴ عناصر عمل ارزیاب

AVA_VAN.1.1E ۱-۴-۳-۲-۱۵

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدرک را برآورده می‌کند.

AVA_VAN.1.2E ۲-۴-۳-۲-۱۵

ارزیاب باید جستجو از منابع حوزه عمومی برای شناسایی آسیب‌پذیری‌های بالقوه در TOE انجام دهد.

AVA_VAN.1.3E ۳-۴-۳-۲-۱۵

ارزیاب باید آزمون نفوذ را، مبتنی بر آسیب‌پذیری‌های بالقوه شناسایی شده انجام دهد، برای تعیین این که TOE به حملات انجام‌شده توسط حمله‌کننده با در اختیار داشتن پتانسیل اولیه حمله مقاوم است.

۱۵-۲-۴-۴ تحلیل آسیب‌پذیری

وابسته‌ها: ADV_ARC.1 شرح معماری امنیت

ADV_FSP.1 مشخصات کارکردی پایه

ADV_TDS.1 طراحی اولیه

AGD_PRE.1 راهنمای کاربر عملیاتی

AGD_PRE.1 روش‌های مقدماتی

۱۵-۲-۴-۱ اهداف

تجزیه و تحلیل آسیب‌پذیری توسط ارزیاب، برای تأیید وجود آسیب‌پذیری‌های بالقوه انجام می‌شود.

ارزیاب آزمون نفوذ را برای تأیید این که آسیب‌پذیری‌های بالقوه نمی‌تواند در محیط‌های عملیاتی برای TOE بهره‌برداری کند، انجام می‌دهد. تست نفوذ توسط ارزیاب با فرض پتانسیل حمله انجام می‌شود.

۱۵-۲-۴-۲ عناصر عمل توسعه‌دهنده

AVA_VAN.2.1D ۱-۲-۴-۲-۱۵

توسعه‌دهنده باید TOE را برای آزمون برقرار کند.

۱۵-۲-۴-۳ عناصر ارائه و محتوی

AVA_VAN.2.1C ۱-۳-۴-۲-۱۵

TOE باید برای آزمون مناسب باشد.

۱۵-۲-۴-۴ عناصر عمل ارزیاب

AVA_VAN.2.1E ۱-۴-۴-۲-۱۵

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات لازم برای محتوی و ارائه مدرک را برآورده می‌کند.

۱۵-۲-۴-۴-۲ AVA_VAN.2.2E

ارزیاب باید جستجو در مورد منابع حوزه عمومی برای شناسایی آسیب‌پذیری‌های بالقوه در TOE انجام دهد.

۱۵-۲-۴-۳ AVA_VAN.2.3E

ارزیاب باید تجزیه و تحلیل آسیب‌پذیری مستقل از TOE با استفاده از مستندات راهنما، مشخصات کارکردی، طراحی TOE و شرح معماری امنیت برای شناسایی آسیب‌پذیری بالقوه در TOE را انجام دهد.

۱۵-۲-۴-۴ AVA_VAN.2.4E

ارزیاب باید آزمون نفوذ را، مبتنی بر آسیب‌پذیری‌های بالقوه شناسایی شده انجام دهد، برای تعیین این که TOE به حملات انجام‌شده توسط حمله‌کننده با در اختیار داشتن پتانسیل اولیه حمله مقاوم است.

۱۵-۲-۵ AVA_VAN.3 تجزیه و تحلیل آسیب‌پذیری‌های مورد توجه

وابسته‌ها: ADV_ARC.1 شرح معماری امنیتی

ADV_FSP.2: مشخصات کارکردی اجرای امنیتی

ADV_TDS.3 طرح پیمان‌های پایه

ADV_IMP.1 پیاده‌سازی ارائه TSF

AGD_OPE.1 راهنمای کاربر عملیاتی

AGD_PRE.1 روش‌های مقدماتی

۱۵-۲-۵-۱ تجزیه و تحلیل آسیب‌پذیری توسط ارزیاب، برای تأیید وجود آسیب‌پذیری‌های بالقوه انجام می‌شود. ارزیاب آزمون نفوذ را برای تأیید این که آسیب‌پذیری‌های بالقوه نمی‌تواند در محیط‌های عملیاتی برای TOE بهره‌برداری کند، انجام می‌دهد. تست نفوذ توسط ارزیاب با فرض پتانسیل حمله انجام می‌شود.

۱۵-۲-۵-۲ موارد عمل توسعه‌دهنده

۱۵-۲-۵-۱ AVA_VAN.3.1D

ارزیاب باید TOE را برای آزمون ارائه کند.

۱۵-۲-۵-۳ عناصر ارائه و محتوی

۱۵-۲-۵-۱ TOE باید برای آزمون مناسب باشد.

۱۵-۲-۵-۴ عناصر عمل ارزیاب

ارزیاب باید آزمون نفوذ را، مبتنی بر آسیب‌پذیری‌های بالقوه شناسایی شده انجام دهد، برای تعیین این که TOE به حملات انجام‌شده توسط حمله‌کننده با در اختیار داشتن پتانسیل اولیه حمله مقاوم است.

۱۵-۲-۵-۴ AVA_VAN.3.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات لازم برای محتوی و ارائه مدرک را برآورده می‌کند.

۱۵-۲-۵-۲ AVA_VAN.3.2E

ارزیاب باید جستجو در مورد منابع حوزه عمومی برای شناسایی آسیب‌پذیری‌های بالقوه در TOE انجام دهد.

۱۵-۲-۵-۳ AVA_VAN.3.3E

ارزیاب باید تجزیه و تحلیل آسیب‌پذیری مستقل از TOE با استفاده از مستندات راهنما، مشخصات کارکردی، طراحی TOE و شرح معماری امنیت برای شناسایی آسیب‌پذیری بالقوه در TOE را انجام دهد.

۱۵-۲-۵-۴-۴ AVA_VAN.3.4E

ارزیاب باید آزمون نفوذ را، مبتنی بر آسیب‌پذیری‌های بالقوه شناسایی شده انجام دهد، برای تعیین این که TOE به حملات انجام‌شده توسط حمله‌کننده با در اختیار داشتن پتانسیل اولیه حمله پیشرفته مقاوم است.

۱۵-۲-۶ تجزیه و تحلیل آسیب‌پذیری‌های منظم

وابسته‌ها: ADV_ARC.1 شرح معماری امنیتی

ADV_FSP.2: مشخصات کارکردی اجرای - امنیتی

ADV_TDS.3 طرح پیمان‌های پایه

ADV_IMP.1 ارائه پیاده‌سازی TSF

AGD_OPE.1 راهنمای کاربر عملیاتی

AGD_PRE.1 روش‌های مقدماتی

۱۵-۲-۶-۱ اهداف

تجزیه و تحلیل آسیب‌پذیری توسط ارزیاب، برای تأیید وجود آسیب‌پذیری‌های بالقوه انجام می‌شود. ارزیاب آزمون نفوذ را برای تأیید این که آسیب‌پذیری‌های بالقوه نمی‌تواند در محیط‌های عملیاتی برای TOE بهره‌برداری کند، انجام می‌دهد. تست نفوذ توسط ارزیاب با فرض پتانسیل حمله متوسط انجام می‌شود.

۱۵-۲-۶-۲ عناصر عمل توسعه‌دهنده

۱۵-۲-۶-۲-۱ AVA_VAN.4.1D

ارزیاب باید TOE را برای آزمون برقرار کند.

۱۵-۲-۶-۳ عناصر ارائه و محتوی

۱۵-۲-۶-۳-۱ TOE باید برای آزمون مناسب باشد.

۱۵-۲-۶-۴ عناصر عمل ارزیاب

۱۵-۲-۶-۴-۱ AVA_VAN.4.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمامی الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۵-۲-۶-۴-۲ ارزیاب باید جستجو در مورد منابع حوزه عمومی برای شناسایی آسیب‌پذیری‌های بالقوه در TOE را انجام دهد.

۱۵-۲-۶-۴-۳ AVA_VAN.4.3E

ارزیاب باید تجزیه و تحلیل آسیب‌پذیری‌های منظم و مستقل از TOE با استفاده از مستندات راهنما، مشخصات کارکردی، طراحی TOE و شرح معماری امنیت برای شناسایی آسیب‌پذیری بالقوه در TOE را انجام دهد.

۱۵-۲-۶-۴-۴ AVA_VAN.4.4E

ارزیاب باید آزمون نفوذ را، مبتنی بر آسیب‌پذیری‌های بالقوه شناسایی شده انجام دهد، برای تعیین این که TOE به حملات انجام‌شده توسط حمله‌کننده با در اختیار داشتن پتانسیل متوسط حمله مقاوم است.

۱۵-۲-۷ AVA_VAN.5 تجزیه و تحلیل آسیب پذیری منظم پیشرفته

وابسته‌ها: ADV_ARC.1 شرح طراحی امنیتی

ADV_FSP.2: مشخصات کارکردی اجرای - امنیتی

ADV_TDS.3 طرح پیمان پایه

ADV_IMP.1 پیاده‌سازی ارائه TSF

AGD_OPE.1 راهنمای کاربر عملیاتی

AGD_PRE.1 روش‌های مقدماتی

۱۵-۲-۷ اهداف

تجزیه و تحلیل آسیب‌پذیری توسط ارزیاب، برای تأیید وجود آسیب‌پذیری‌های بالقوه انجام می‌شود. ارزیاب آزمون نفوذ را برای تأیید این‌که آسیب‌پذیری‌های بالقوه نمی‌تواند در محیط‌های عملیاتی برای TOE بهره‌برداری کند، انجام می‌دهد. تست نفوذ توسط ارزیاب با فرض پتانسیل حمله بالا انجام می‌شود.

۱۵-۲-۷-۱ عناصر عمل توسعه‌دهنده

AVA_VAN.5.1D ۱-۲-۷-۲-۱۵

ارزیاب باید TOE را برای آزمون تهیه کند.

۱۵-۲-۷-۳ عناصر ارائه و محتوی

AVA_VAN.5.1C ۱-۳-۷-۲-۱۵

TOE باید برای آزمون مناسب باشد.

۱۵-۲-۷-۴ عناصر عمل ارزیاب

AVA_VAN.5.1E ۱-۴-۷-۲-۱۵

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدرک را برآورده می‌کند.

AVA_VAN.5.2E ۲-۴-۷-۲-۱۵

ارزیاب باید جستجو در مورد منابع حوزه عمومی برای شناسایی آسیب‌پذیری‌های بالقوه در TOE را انجام دهد.

AVA_VAN.5.3E ۳-۴-۷-۲-۱۵

ارزیاب باید تجزیه و تحلیل آسیب‌پذیری‌های منظم و مستقل منظم از TOE با استفاده از مستندات راهنما، مشخصات کارکردی، طراحی TOE و شرح معماری امنیت برای شناسایی آسیب‌پذیری بالقوه در TOE را انجام دهد.

AVA_VAN.5.4E ۴-۴-۷-۲-۱۵

ارزیاب باید آزمون نفوذ را، مبتنی بر آسیب‌پذیری‌های بالقوه شناسایی شده انجام دهد، برای تعیین این‌که TOE به حملات انجام شده توسط حمله‌کننده با در اختیار داشتن پتانسیل بالای حمله مقاوم، است.

۱۶- گروه ACO: ترکیب

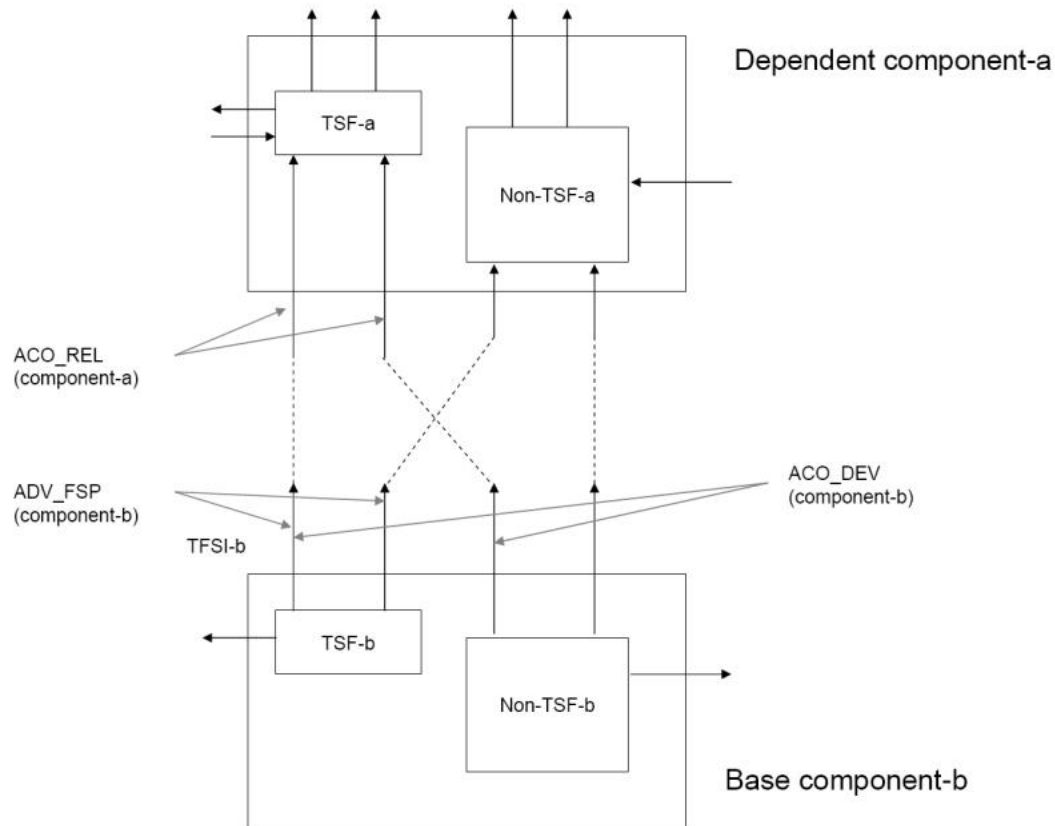
گروه ACO: ترکیب شامل پنج خانواده است. این خانواده‌ها الزامات اطمینان را مشخص می‌کنند و آن‌ها طوری طراحی شده‌اند که این اطمینان را می‌دهند که TOE ترکیبی با تکیه به قابلیت‌های امنیتی ارائه شده توسط نرم‌افزار قبلاً ارزیابی، میان‌ابزار یا مؤلفه‌های سخت‌افزاری، به‌طور ایمن عمل خواهد کرد.

ترکیب شامل انتخاب دو یا چند سازمان فناوری اطلاعات می‌شود و با موفقیت در برابر الزامات اطمینان امنیت ISO/IEC 15408 ارزشیابی می‌شود (مؤلفه‌های پایه و مؤلفه‌های وابسته، به ضمیمه ب مراجعه کنید) و آن‌ها را برای استفاده بدون توسعه بیشتر فناوری اطلاعات ترکیب می‌کنند. توسعه سازمان‌های فناوری اطلاعات اضافی را در بر نمی‌گیرد (سازمان‌هایی که قبلاً موضوع ارزشیابی مؤلفه نبوده است). TOE ترکیبی به شکل یک محصول جدید است که می‌تواند نصب شود و با هر نمونه محیط خاص یکپارچه شود به طوری که اهداف محیط را برآورده کند. این رویکرد هیچ رویکرد جایگزینی را برای ارزشیابی مؤلفه‌ها فراهم نمی‌کند.

ترکیب تحت گروه ACO با انتگرال‌گیری TOE ترکیبی یک روشی فراهم می‌کند که می‌تواند به جای سطح‌های مشخص تضمین مجموعه استاندارد ملی ایران-ایزو-آی‌ای‌سی ۱۵۴۰۸ به کار گرفته شود، این اطمینان در TOE به دست می‌آید که دو مؤلفه یا بیشتر که به‌طور موفقیت‌آمیز ارزشیابی شدند ترکیب می‌شوند بدون این که نیاز به ارزشیابی مجدد ترکیب TSF باشد.

(TOE ترکیبی انتگرال‌گیر در تمام گروه ACO به عنوان "توسعه‌دهنده" اشاره می‌شود که با هر اشاره به توسعه‌دهنده مؤلفه پایه یا مؤلفه‌های وابسته روشن شده است). بسته‌های اطمینان ترکیبی همان‌طور که در بندهای ۸ و ۶-۳ تعریف شده‌اند، معیار ضمانت TOE‌های ترکیبی است. این معیار ضمانت همچنین EALها، مورد نیاز است به دلیل این که برای ترکیب کردن مؤلفه‌های ارزشیابی شده در برابر EALها و به دست آوردن نتایج ضمانت EAL، کل SARهای موجود در EAL باید در TOE ترکیبی به کار گرفته شود.

اگرچه استفاده مجدد از نتایج ارزشیابی TOE مؤلفه امکان‌پذیر است، اغلب جنبه‌های اضافی مؤلفه‌ها وجود دارند که باید در TOE ترکیبی در نظر گرفته شوند همان‌طور که در ضمیمه ب ۳ شرح داده شده است. با توجه به قسمت‌های مختلفی که با فعالیت ارزشیابی TOE ترکیبی سر و کار دارد، به دست آوردن تمام مدارک لازم در مورد این جنبه‌های اضافی مؤلفه‌ها برای به کارگیری EAL مناسب امکان‌پذیر نمی‌باشد. بنابراین، CAPها، برای رسیدگی به مسئله ترکیب مؤلفه‌های ارزشیابی و به دست آوردن نتایج صحیح تعریف شده‌اند. این بیشتر در ضمیمه ب مورد بحث قرار می‌گیرد.



شکل ۱۶- رابطه بین خانواده ACO و تعامل بین مؤلفه‌ها

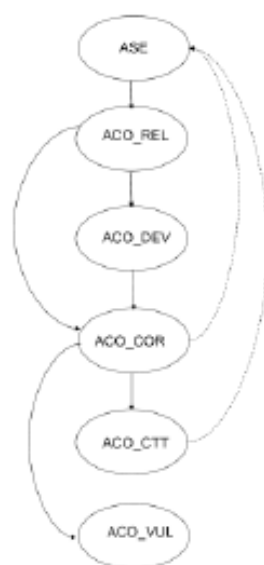
به‌طورکلی در TOE ترکیبی یک قالب است که یک مؤلفه متکی به خدمات ارائه شده توسط دیگر مؤلفه‌هاست. مؤلفه‌ای که نیاز به خدمات دارد مؤلفه وابسته می‌نامیم و مؤلفه‌ای که خدمات ارائه می‌کند مؤلفه پایه می‌نامیم. این تعامل و جدایی بیشتر در ضمیمه ب مورد بحث قرار گرفته است. فرض می‌شود قالبی وجود دارد که توسعه‌دهنده مؤلفه وابسته، ارزشیابی TOE ترکیبی را در برخی روش‌ها پشتیبانی می‌کند (به‌عنوان توسعه‌دهنده، حمایت‌کننده، یا فقط همکاری و ارائه شواهد و مدارک لازم از ارزشیابی مؤلفه وابسته) مؤلفه‌های ACO موجود در بسته‌های اطمینان CAP به‌عنوان تقویت برای ارزشیابی TOE مؤلفه بهتر است استفاده نشود، این به هیچ عنوان ضمانت قابل توجهی برای مؤلفه‌ها فراهم نمی‌کند.

خانواده‌ها در درون گروه ACO در ارزشیابی TOE مؤلفه ترکیب به شیوه‌ای شبیه به گروه‌های ADV، ATE و AVA تعامل دارند، از این‌رو مشخصات الزامات از آن گروه‌ها در جایی که قابل اجرا باشد، حمایت می‌کند. اگر چه چند مورد خاص برای ارزشیابی TOE ترکیبی وجود دارد.

به‌منظور تشخیص این‌که چگونه مؤلفه‌ها تعامل دارند و شناسایی هرگونه خطای ارزشیابی مؤلفه‌ها، وابسته‌ها، مؤلفه وابسته با تکیه به اصول مؤلفه پایه، شناسایی می‌شوند (ACO_REL).

این تکیه به مؤلفه اولیه برحسب واسطه‌ها که از طریق آن مؤلفه وابسته خواستار خدماتی برای حمایت از SFRهای مؤلفه وابسته است، مشخص می‌شود. واسطه‌ها، در سطوح بالاتر رفتار حمایتی، توسط مؤلفه پایه در پاسخ به درخواست خدماتی که ارائه می‌شود در ACO_DEV تجزیه و تحلیل می‌شوند. خانواده ACO_DEV مبتنی بر

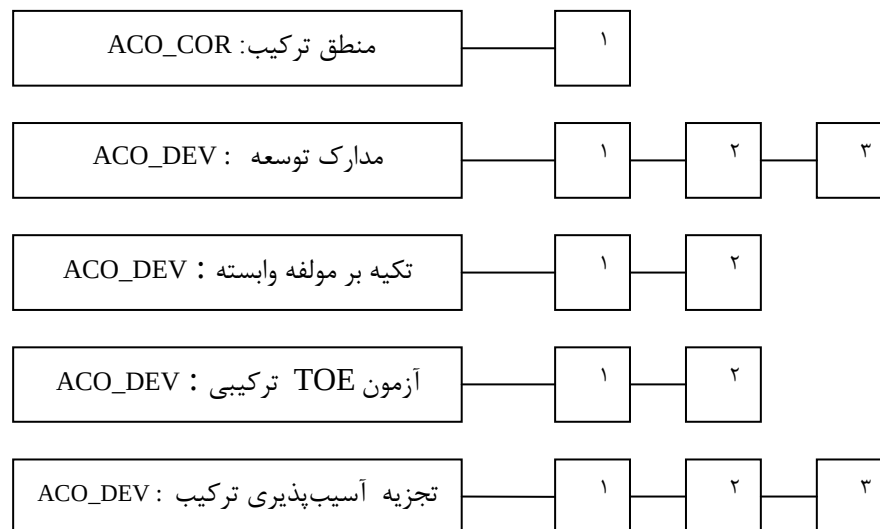
خانواده ADV_TDS می‌باشد، همان‌طور که در ساده‌ترین سطح، TSF هر مؤلفه می‌تواند به‌عنوان یک زیرسیستم TOE ترکیبی نگاه شود، با قسمت‌های اضافی از هر مؤلفه را به‌عنوان زیرسیستم‌های اضافی دیده می‌شود. بنابراین تعامل بین مؤلفه‌ها مانند تعامل میان زیرسیستم‌ها در ارزشیابی TOE مؤلفه در نظر می‌گیریم. ممکن است واسطه‌ها و شرح رفتار حمایتی ارائه شده برای ACO_DEV ناقص باشد. این در طول رفتار ACO_COR تعیین می‌شود. خانواده ACO_COR خروجی‌های ACO_DEV و ACO_COR را دربر دارد و تعیین می‌کند چه مؤلفه‌هایی در تنظیمات ارزشیابی به‌کار گرفته می‌شود و نشان می‌دهد جایی که مشخصات ناقص هستند و سپس به‌عنوان ورودی به آزمون (ACO_CTT) و فعالیت‌های تجزیه و تحلیل آسیب‌پذیری (ACO_VUL) TOE ترکیبی شناسایی می‌شود. آزمون TOE ترکیبی برای تعیین این‌که TOE ترکیبی رفتارمورد نظر را ارائه کند، انجام می‌شود. همان‌طور که توسط TOE SFRهای ترکیبی معین می‌شود و در سطوح بالاتر مقایسه واسطه‌ها بین مؤلفه‌های TOE ترکیبی را نشان می‌دهد. تجزیه و تحلیل آسیب‌پذیری‌های TOE ترکیبی از خروجی‌های تجزیه و تحلیل آسیب‌پذیری حمایت می‌کند. تجزیه و تحلیل آسیب‌پذیری TOE ترکیبی، هرگونه آسیب‌پذیری‌های باقیمانده از ارزشیابی‌های مؤلفه برای تعیین آسیب‌پذیری‌های باقیمانده برای TOE ترکیبی که قابل‌کاربرد نباشد را در نظر می‌گیرد. جستجو از اطلاعات قابل‌دسترس برای عموم در رابطه با مؤلفه‌ها نیز برای شناسایی هرگونه مسائل گزارش شده در مؤلفه‌ها بعد از تکمیل ارزشیابی‌های مربوطه، انجام می‌شود. تعامل بین خانواده‌های ACO در شکل ۱۷ در زیر به‌تصویر کشیده شده است. در جایی که شواهد و فهم به‌دست آمده در یک خانواده فعالیت بعدی را تغذیه می‌کند با پیکان‌های توپر نشان می‌دهد و جایی که فعالیت به‌طور آشکار SFRهای TOE ترکیبی را پیدا می‌کند با پیکان‌های نقطه چین نشان می‌دهد همان‌طور که در بالا توصیف کرد.



شکل ۱۷ - ارتباط بین خانواده‌های ACO

بحث دیگری در مورد تعریف و تعاملات در درون TOE ترکیبی در ضمیمه ب ارائه شده است.

شکل ۱۸ خانواده‌ها در درون این گروه و سلسله مراتب مؤلفه‌ها در درون خانواده‌ها را نشان می‌دهد.



شکل ۱۸ - ACO تجزیه دسته ترکیب

۱۶-۱-۱ اهداف

این خانواده به الزاماتی اشاره می‌کند که نشان‌دهنده مؤلفه پایه می‌تواند سطح مناسبی از اطمینان را برای استفاده در ترکیب ارائه کند.

۱۶-۱-۲ سطح‌بندی مؤلفه‌ها

فقط یک مؤلفه واحد در این خانواده وجود دارد.

۱۶-۱-۳ منطق ترکیب

وابسته‌ها: شرح عملیات ACO_DEV.1

ALC_CMC.1 رتبه‌بندی TOE

ACO_REL.1 اطلاعات تکیه پایه

توسعه‌دهنده باید منطق ترکیب را برای مؤلفه پایه ارائه کند.

۱۶-۱-۳-۲ عناصر ارائه و محتوی

منطق ترکیب باید نشان دهد که سطح اطمینان برای قابلیت پشتیبانی از مؤلفه پایه زمانی که مؤلفه پایه پیکره‌بندی شده است حداقل به اندازه مؤلفه وابسته باشد، چنان‌که برای پشتیبانی از TSF مؤلفه وابسته مورد نیاز است.

۱۶-۱-۳-۳ عناصر عمل ارزیاب

۱۶-۱-۳-۳-۱ ACO_COR.1.1E

ارزیاب باید تأیید کند که اطلاعات تمام الزامات مورد نظر برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۶ مدارک توسعه (ACO_DEV)

۱۶-۲-۱ اهداف

این خانواده الزامات مورد نیاز برای خصوصیات مؤلفه پایه در افزایش سطح جزئیات تعیین می‌کند. این اطلاعات برای به‌دست‌آوردن اطمینان از این‌که قابلیت امنیت مناسب برای حمایت از الزامات مورد نیاز برای مؤلفه پایه فراهم شده است، نیاز می‌باشد (مانند اطلاعات تکیه شناسایی شده)

۱۶-۲-۲ رتبه‌بندی مؤلفه

مؤلفه‌ها مبتنی بر مقادیر فزاینده‌ای از جزئیات، درمورد واسطه‌های ارائه‌شده و چگونگی پیاده‌سازی آنها رتبه‌بندی می‌شوند.

۱۶-۲-۳ نکات کاربرد

اغلب TSF مؤلفه پایه بدون اطلاع از مسئله وابسته‌های کاربردهای ممکن که با آن ممکن است ترکیب شود، تعریف می‌شود. TSF مؤلفه پایه که شامل تمام قسمت‌های مؤلفه پایه که برای اجرای SFRهای مؤلفه پایه باید به آن استناد کرد، تعریف می‌شود. این شامل تمام قسمت‌های مؤلفه پایه مورد نیاز برای پیاده‌سازی SFRهای مؤلفه پایه می‌باشد.

مشخصات کارکردی مؤلفه پایه TSFI را برحسب واسطه‌هایی که مؤلفه پایه فراهم کند شرح داده خواهد شد که اجازه می‌دهد موجودیت بیرونی عملیات TSF را احضار کند. این شامل واسطه‌هایی برای کاربر که مجاز می‌دارد تعامل با عمل TSF، SFRها را احضار کند و همچنین واسطه‌هایی که اجازه می‌دهد که TSF موجودیت فن‌آوری اطلاعات بیرونی را بخواهد.

خصوصیات کارکردی شرحی ارائه می‌کند از آنچه TSF در واسط خود فراهم می‌کند و این‌که کدام قابلیت TSF احضار می‌شود.

بنابراین مشخصات کارکردی لزوماً مشخصات واسط کامل از تمام واسطه‌های ممکن موجود بین موجودیت بیرونی و مؤلفه پایه را مقرر نمی‌کند، و آن شامل آن‌چه که TSF از محیط عملیاتی انتظار / نیاز دارد، نمی‌شود. شرح آن‌چه که TSF مؤلفه وابسته به مؤلفه پایه متکی است تکیه مؤلفه وابسته در نظر می‌گیرد (ACO_REL) و مدارک اطلاعات توسعه به واسطه‌های مشخص شده پاسخ می‌دهد. مدارک اطلاعات توسعه شامل مشخصات مؤلفه پایه می‌باشد.

این ممکن است مدارک مورد استفاده برای ارزشیابی مؤلفه پایه برای برآورده کردن الزامات مورد نیاز ADV باشد، یا ممکن است فرم دیگری از مدرک باشد که توسط توسعه‌دهنده مؤلفه پایه یا توسط توسعه‌دهنده TOE ترکیبی ایجاد شده است. مشخصات مؤلفه پایه برای مدرک توسعه (ACO_DEV) برای به‌دست‌آوردن اطمینان از این‌که قابلیت امنیتی مناسب برای حمایت از الزامات مورد نیاز برای مؤلفه وابسته ارائه می‌شود، به کار گرفته می‌شود.

سطح جزئیات مورد نیاز از این مدارک برای منعکس کردن سطح اطمینان مورد نیاز در TOE ترکیبی افزایش می‌یابد. این انتظار می‌رود که افزایش اطمینان حاصل از کاربرد بسته‌های اطمینان مؤلفه‌ها، بازتاب وسیعی دارد. ارزیاب تعیین می‌کند که این شرح از مؤلفه پایه با اطلاعات متکی ارائه شده برای مؤلفه وابسته سازگار است.

۱۶-۲-۴ شرح کارکردی ACO_DEV.1

وابسته‌ها: اطلاعات تکیه اساسی ACO_REL.1

۱۶-۲-۴-۱ اهداف

شرح واسط در مؤلفه پایه که مؤلفه وابسته به آن متکی است، مورد نیاز است. این آزمون برای تعیین این که آیا با شرح واسط‌هایی که مؤلفه وابسته به آن‌ها متکی است سازگار است یا نه، همان‌طور که در اطلاعات قابل اطمینان ارائه شده است.

۱۶-۲-۴-۲ عناصر عمل توسعه‌دهنده

۱۶-۲-۴-۲-۱ ACO_DEV.1.1D

توسعه دهنده باید اطلاعات توسعه را برای مؤلفه پایه ارائه دهد.

۱۶-۲-۴-۳ عناصر ارائه و محتوی

۱۶-۲-۴-۳-۱ ACO_DEV.1.1C

اطلاعات توسعه باید هدف از هر واسط مؤلفه پایه مورد استفاده در TOE ترکیبی را توضیح دهد.

۱۶-۲-۴-۳-۲ ACO_DEV.1.2C

اطلاعات توسعه باید ارتباط بین واسط‌ها، در TOE ترکیبی مورد استفاده در مؤلفه پایه و مؤلفه وابسته برای حمایت از TSF مؤلفه وابسته را نشان دهد.

۱۶-۲-۴-۴ عناصر عمل ارزیاب

۱۶-۲-۴-۴-۱ ACO_DEV.1.1E

ارزیاب باید تأیید کند که اطلاعات تمام الزامات مورد نیاز برای محتوی و ارائه مدرک را برآورده می‌کند.

۱۶-۲-۴-۴-۲ ACO_DEV.1.2E

ارزیاب باید تعیین کند که شرح واسط تهیه شده با اطلاعات تکیه ارائه شده برای مؤلفه وابسته سازگار است.

۱۶-۲-۵ ACO_DEV.2 طراحی سند اولیه

وابسته‌ها: ACO_REL.1 اطلاعات تکیه پایه

۱۶-۲-۵-۱ اهداف

شرح واسط در مؤلفه پایه که مؤلفه وابسته به آن متکی است، مورد نیاز است. این آزمون برای تعیین این که آیا با شرح واسط‌هایی که مؤلفه وابسته به آن‌ها متکی است سازگار است یا نه، همان‌طور که در اطلاعات قابل اطمینان ارائه شده است.

همچنین رفتار امنیتی مؤلفه پایه که از مؤلفه وابسته TSF حمایت می‌کند را شرح می‌دهد.

۱۶-۲-۵-۲ عناصر عمل توسعه‌دهنده

۱۶-۲-۵-۲-۱ توسعه‌دهنده باید اطلاعات توسعه برای مؤلفه پایه را ارائه دهد.

۱۶-۲-۵-۳ عناصر ارائه و محتوی

۱۶-۲-۵-۳-۱ ACO_DEV.2.1C

اطلاعات توسعه باید هدف و نحوه‌ی استفاده از هر یک از واسط مؤلفه پایه مورد استفاده در TOE ترکیبی را توصیف کند.

۱۶-۲-۵-۳-۲ ACO_DEV.2.2C

اطلاعات توسعه باید یک توضیح سطح بالا از رفتار مؤلفه پایه، که از اجرای مؤلفه وابسته SFRها حمایت می‌کند را فراهم کند.

۱۶-۲-۵-۳-۳ ACO_DEV.2.3C

اطلاعات توسعه باید ارتباط بین واسطه‌های مورد استفاده در TOE ترکیبی از مؤلفه پایه و مؤلفه وابسته برای حمایت TSF از مؤلفه وابسته را نشان دهد.

۱۶-۲-۵-۴-۱ عناصر عمل ارزیاب

۱۶-۲-۵-۴ ACO_DEV.2.1E

توسعه دهنده باید تأیید کند که اطلاعات تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۶-۲-۵-۴-۲ ACO_DEV.2.2E

ارزیاب باید تعیین کند که شرح واسط تهیه شده با اطلاعات قابل اطمینان ارائه شده برای مؤلفه وابسته سازگار است.

۱۶-۲-۶ ACO_DEV.3 مدارک تفصیلی طرح

وابسته‌ها: اطلاعات تکیه ACO_REL.2

۱۶-۲-۶-۱ اهداف

شرح واسط در مؤلفه پایه که مؤلفه وابسته به آن متکی است، مورد نیاز است. این آزمون برای تعیین این که آیا با شرح واسطه‌هایی که مؤلفه وابسته به آن‌ها متکی است سازگار است یا نه، همان‌طور که در اطلاعات قابل اطمینان ارائه شده است.

شرح واسط معماری مؤلفه پایه برای فعال کردن ارزیاب برای تعیین این که آیا واسط قسمتی از TSF تشکیل شده است یا نه، ارائه شده است.

۱۶-۲-۶-۲ عناصر عمل توسعه‌دهنده

۱۶-۲-۶-۲-۱ ACO_DEV.3.1D

توسعه دهنده باید اطلاعات توسعه را برای مؤلفه پایه تهیه کند.

۱۶-۲-۶-۳ عناصر ارائه و محتوی

۱۶-۲-۶-۳-۱ ACO_DEV.3.1C

اطلاعات توسعه باید هدف و روش استفاده از هر واسط مؤلفه پایه مورد استفاده در TOE ترکیبی را شرح دهد.

۱۶-۲-۳-۲ ACO_DEV.3.2C

اطلاعات توسعه باید زیرسیستم‌های مؤلفه پایه که واسطه‌های مؤلفه پایه مورد استفاده در TOE ترکیبی را ارائه می‌کند، را شناسایی کند.

۱۶-۲-۳-۴ ACO_DEV.3.4C

اطلاعات توسعه باید یک توضیح سطح بالا از رفتار زیرسیستم‌های مؤلفه پایه که حمایت از اجرای مؤلفه وابسته SFRها می‌کند را فراهم کند.

۱۶-۲-۶-۳-۴ ACO_DEV.3.4C

اطلاعات توسعه باید مسيردهی از واسطه‌ها به زیرسیستم‌های مؤلفه پایه را ارائه کند.

۱۶-۲-۶-۳-۵ ACO_DEV.3.5C

اطلاعات توسعه باید ارتباط بین واسطه‌های، مورد استفاده در TOE ترکیبی، مؤلفه پایه و مؤلفه وابسته برای حمایت از مؤلفه وابسته TSF را نشان دهد.

۱۶-۲-۶-۴ عناصر عمل ارزیاب

۱۶-۲-۶-۴-۱ ارزیاب باید تأیید کند که اطلاعات تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۶-۲-۶-۴-۲ ACO_DEV.3.2E

ارزیاب باید تعیین کند که شرح واسطه تهیه شده با اطلاعات تکیه ارائه شده برای مؤلفه وابسته سازگار است.

۱۶-۳ اتکای مؤلفه وابسته (ACO_REL)

۱۶-۳-۱ اهداف

هدف از این خانواده ارائه کردن مدرک، استندهایی که مؤلفه وابسته به مؤلفه پایه دارد را نشان می‌دهد. این اطلاعات برای افرادی که مسئول یکپارچه کردن مؤلفه‌ها با دیگر مؤلفه‌های فن‌آوری اطلاعات ارزشیابی شده برای تشکیل TOE ترکیبی است، و همچنین برای تأمین بینش خواص امنیتی که منجر به ترکیب شده، مفید می‌باشد. این شرحی از واسطه بین مؤلفه وابسته و مؤلفه‌های پایه TOE ترکیبی که ممکن است در حین ارزشیابی مؤلفه‌های منحصربه‌فرد مورد تجزیه و تحلیل واقع نشده باشد، چنان‌که واسطه‌ها، TSFI‌های مؤلفه منحصربه‌فرد TOE نباشد، را ارائه می‌کند.

۱۶-۳-۲ رتبه‌بندی مؤلفه

مؤلفه در این خانواده با توجه به میزان جزئیات ارائه شده در شرح تکیه مؤلفه وابسته به مؤلفه پایه رتبه‌بندی می‌شود.

۱۶-۳-۳ نکات کاربردی

تکیه مؤلفه وابسته از خانواده (ACO_REL) تعامل‌های بین مؤلفه‌ها را در نظر می‌گیرد در جایی که مؤلفه وابسته متکی به خدمات مؤلفه پایه برای حمایت از عملکرد قابلیت امنیتی مؤلفه وابسته باشد.

واسطه‌های این خدمات به مؤلفه پایه در طول ارزشیابی مؤلفه پایه ممکن است در نظر گرفته نشود به دلیل خدمات در مؤلفه پایه نه مربوط امنیت در ارزشیابی مؤلفه در نظر گرفته نمی‌شود، یا به دلیل هدف ذاتی از این خدمت (به عنوان مثال: نوع تنظیم قلم) یا به دلیل این که استاندارد ملی ایران- ایزو-آی ای سی ۱۵۴۰۸ مرتبط خواستار SFRها در ST مؤلفه پایه نمی‌شود. (به عنوان مثال: ورود واسطه زمانی که هیچ ISO/IEC 15408-2 استاندارد نباشد: شناسایی و تأیید SFRهای مدعی)

این واسطه‌ها به مؤلفه پایه، اغلب به عنوان واسطه‌های کارکردی در ارزشیابی مؤلفه پایه مشاهده می‌شود، و به علاوه واسطه‌های امنیتی (TSFI) در مشخصات کارکردی در نظر گرفته می‌شود.

به طور خلاصه، TSFIها در خصوصیات کارکردی تنها درخواست‌هایی که به سوی TSF توسط موجودیت‌های بیرونی انجام می‌شود و به آن درخواست‌ها پاسخ داده می‌شود را توصیف کرده است. درخواست‌هایی که توسط

TSF انجام می‌شود، به صراحت در طی ارزشیابی مؤلفه‌ها در نظر گرفته نمی‌شود، توسط اطلاعات تکیه تهیه شده برای برآورده کردن تکیه مؤلفه وابسته (ACO_REL) شرح داده شده است.

۱۶-۳-۴ اطلاعات تکیه پایه

وابسته‌ها: هیچ وابسته‌ای وجود ندارد.

۱۶-۳-۴-۱ عناصر عمل توسعه‌دهنده

۱۶-۳-۴-۱-۱ ACO_REL.1.1D

توسعه دهنده باید اطلاعات تکیه از مؤلفه وابسته را تهیه کند.

۱۶-۳-۴-۲ عناصر ارائه و محتوی

۱۶-۳-۴-۲-۱ ACO_REL.1.1C

اطلاعات تکیه باید قابلیت مؤلفه پایه سخت‌افزار، میان‌افزار و یا نرم‌افزار که توسط مؤلفه وابسته TSF به آنها تکیه می‌شود را شرح دهد.

۱۶-۳-۴-۲-۲ ACO_REL.1.2C

اطلاعات تکیه باید تمام تعامل‌های که از طریق آن مؤلفه وابسته TSF خدماتی از مؤلفه پایه TSF می‌خواهد را شرح دهد.

۱۶-۳-۴-۲-۳ ACO_REL.1.3C

اطلاعات تکیه باید شرح دهد که چگونه TSF وابسته از خود از دخالت و مداخله توسط مؤلفه پایه محافظت می‌کند.

۱۶-۳-۴-۱ عناصر عمل ارزیاب

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

۱۶-۳-۵ ACO_REL.2 اطلاعات تکیه

وابسته‌ها: هیچ وابسته‌ای وجود ندارد.

۱۶-۳-۵-۱ عناصر عمل توسعه‌دهنده

۱۶-۳-۵-۱-۱ توسعه دهنده باید اطلاعات تکیه مربوط به مؤلفه وابسته را تهیه کند.

۱۶-۳-۵-۲ عناصر ارائه و محتوی

۱۶-۳-۵-۲-۱ ACO_REL.2.1C

اطلاعات تکیه باید قابلیت مؤلفه پایه سخت‌افزار، میان‌افزار و یا نرم‌افزار که مؤلفه وابسته TSF به آنها وابسته است را شرح دهد.

۱۶-۳-۵-۲-۲ ACO_REL.2.2C

اطلاعات قابل اطمینان باید تمام تعامل‌هایی که از طریق آن مؤلفه وابسته TSF خدماتی از مؤلفه پایه TSF درخواست می‌کند، را شرح دهد.

۱۶-۳-۵-۲-۳ ACO_REL.2.3C

اطلاعات قابل اطمینان باید هر تعاملی را برحسب واسط استفاده شده و مقادیر بازگشتی از آن وسطها، توصیف کند.

۱۶-۳-۵-۲-۴ ACO_REL.2.4C

اطلاعات قابل اطمینان باید شرح دهد که چگونه TSF وابسته در برابر دخالت و مداخله توسط مؤلفه پایه از خود محافظت می کند.

۱۶-۳-۵-۳ عناصر عمل ارزیاب

۱۶-۳-۵-۱ ACO_REL.2.1E

ارزیاب باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می کند.

۱۶-۴ آزمون TOE ترکیبی (ACO_CTT)

۱۶-۴-۱ اهداف

این خانواده ملزم به انجام آزمون TOE ترکیبی و آزمون مؤلفه پایه، همان طور که در TOE ترکیبی به کارگرفته می شود، می باشد.

۱۶-۴-۲ رتبه بندی مؤلفه

مؤلفه در این خانواده براساس افزایش سخت گیری آزمون واسط و افزایش سخت گیری تجزیه و تحلیل مقدار کافی از آزمایشات نشان می دهد که TSF ترکیبی مطابق با اطلاعات قابل اطمینان و TOE SFR های ترکیبی رتبه بندی می شود.

۱۶-۴-۳ نکات کاربردی

دو جنبه متفاوت از آزمون در ارتباط با این خانواده وجود دارد.

الف) آزمون واسطها بین مؤلفه پایه و مؤلفه وابسته که مؤلفه وابسته برای اجرای قابلیت امنیت، که سازگاری آنها را نشان دهد، به آنها متکی است.

ب) آزمون TOE ترکیبی نشان می دهد که TOE مطابق با SFR های TOE ترکیبی رفتار می کند.

اگر تنظیمات آزمون مورد استفاده در طول ارزشیابی مؤلفه وابسته شامل استفاده از مؤلفه پایه به عنوان یک "پایگاه" و تجزیه و تحلیل آزمون به اندازه کافی باشد، نشان می دهد که TSF مطابق با SFR ها رفتار می کند، و توسعه دهنده نیاز به آزمون بیشتری از قابلیت TOE ترکیبی ندارد. با این حال، اگر مؤلفه پایه در تست مؤلفه وابسته مورد استفاده قرار نمی گرفت یا تنظیمات هر کدام از مؤلفه ها متفاوت باشد، پس توسعه دهنده آزمون TOE ترکیبی را انجام می دهد.

این ممکن است به صورت تکرار آزمون مؤلفه وابسته توسعه دهنده از مؤلفه وابسته باشد مشروط به این که به اندازه کافی نشان دهد که TSF TOE ترکیبی مطابق با SFR ها رفتار می کند.

توسعه دهنده باید مدارک آزمون مربوط به واسطهای مؤلفه پایه مورد استفاده در ترکیب را ارائه کند. عملکرد مؤلفه پایه TSF ها به عنوان قسمتی از ATE آزمون شده اند: این فعالیت های آزمون در حین ارزشیابی مؤلفه پایه می باشد.

بنابراین، ارائه واسطه‌های مناسب در داخل نمونه آزمون از ارزشیابی مؤلفه پایه قرار گرفته‌اند و آن در منطق ترکیب (ACO_COR) تعیین شده است که مؤلفه پایه مطابق با تنظیمات مؤلفه پایه ارزشیابی شده، با تمام قابلیت‌های امنیتی مورد نیاز توسط مؤلفه وابسته موجود در TSF عمل می‌کند، ارزیاب ممکن است با اقدام ACO_CTT.1.1E از طریق استفاده مجدد از مؤلفه پایه ATE با آن آشنا شود: احکام آزمایش

اگر این مورد وجود نداشته باشد، واسطه‌های مؤلفه پایه مربوط به ترکیب استفاده می‌شود که توسط هرگونه تغییرات در تنظیمات ارزشیابی تأثیرگذار است و هرگونه قابلیت امنیتی اضافی آزمایش می‌شود که مطمئن شوند آنها رفتار مورد انتظار را نشان می‌دهند. رفتار مورد انتظاری که آزمون می‌شود، اطلاعات قابل اطمینان (با تکیه به مدرک مؤلفه وابسته (ACO_REL)) را شرح می‌دهد.

۱۶-۴-۴ ACO_CTT.1.۴ آزمون واسط

وابسته‌ها: ACO_REL.1 اطلاعات تکیه پایه

ACO_DEV.1 شرح کارکرد

۱۶-۴-۴-۱ اهداف

هدف از این مؤلفه این است که مطمئن شود هر واسط مؤلفه پایه‌ای که مؤلفه وابسته به آن متکی است، آزمون می‌شود.

۱۶-۴-۴-۲ عناصر عمل توسعه‌دهنده

توسعه‌دهنده باید مستندات آزمون TOE ترکیبی را تهیه کند.

۱۶-۴-۴-۲ ACO_CTT.1.2D

توسعه‌دهنده باید مستندات آزمون واسط مؤلفه پایه را تهیه کند.

۱۶-۴-۴-۳ ACO_CTT.1.3D

توسعه‌دهنده باید TOE ترکیبی را برای آزمون تهیه کند.

۱۶-۴-۴-۴ ACO_CTT.1.4D

توسعه‌دهنده باید مجموعه‌ای معادل مجموعه منابع به آنهایی که در آزمون قابلیت توسعه‌دهنده مؤلفه پایه از مؤلفه پایه مورد استفاده قرار گرفته‌اند، ارائه کند.

۱۶-۴-۴-۳ عناصر ارائه و محتوی

۱۶-۴-۴-۱ ACO_CTT.1.1C

مستندات آزمون واسط مؤلفه پایه و TOE ترکیبی باید شامل طرح آزمون، نتایج مورد نظر آزمون و نتایج واقعی آزمون باشد.

۱۶-۴-۴-۳ ACO_CTT.1.2C

مستندات آزمون از اجرای آزمون‌های TOE ترکیبی توسعه‌دهنده تشکیل شده است و باید ثابت کند که TSF همان‌طور که مشخص شده، رفتار می‌کند.

۱۶-۴-۴-۳ ACO_CTT.1.3C

مستندات آزمون از اجرای آزمون‌های واسط مؤلفه پایه توسعه‌دهنده تشکیل شده است و باید نشان دهد که مؤلفه پایه با تکیه به آن توسط مؤلفه وابسته، به همان صورت که مشخص شده، رفتار می‌کند.

ACO_CTT.1.4C ۴-۳-۴-۴-۱۶

مؤلفه پایه باید برای آزمون مناسب باشد.

ACO_CTT.1.4C ۴-۴-۴-۱۶ عناصر عمل ارزیاب

ارزیاب باید تأیید کند که اطلاعات تهیه شده، تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

ACO_CTT.1.2E ۲-۴-۴-۴-۱۶

ارزیاب باید نمونه‌ای از آزمون در مستندات آزمون را برای تأیید نتایج آزمون توسعه‌دهنده، انجام دهد.

ACO_CTT.1.3E ۳-۴-۴-۴-۱۶

ارزیاب باید آزمونی از زیر مجموعه واسطه‌های TSF از TOE ترکیبی را انجام دهد برای تأیید این که TSF ترکیبی همان‌طور که مشخص شده عمل می‌کند.

ACO_CTT.2 ۵-۴-۱۶ آزمون واسط دقیق

وابسته‌ها: اطلاعات تکیه

ACO_DEV.2 مدرک پایه طراحی

۱-۵-۴-۱۶ اهداف

هدف از این مؤلفه این است که اطمینان حاصل شود که هر یک از واسط مؤلفه پایه که مؤلفه وابسته به آن متکی است، آزمایش شود.

۲-۵-۴-۱۶ عناصر عمل توسعه‌دهنده

ACO_CTT.2.1D ۱-۲-۵-۴-۱۶

توسعه‌دهنده باید مستندات آزمون TOE ترکیبی را تهیه کند.

ACO_CTT.2.2D ۲-۲-۵-۴-۱۶

توسعه‌دهنده باید مستندات آزمون واسط مؤلفه پایه را تهیه کند.

ACO_CTT.2.3D ۳-۲-۵-۴-۱۶

توسعه‌دهنده باید TOE ترکیبی را برای آزمون ارائه کند.

ACO_CTT.2.4D ۴-۲-۵-۴-۱۶

توسعه‌دهنده باید مجموعه‌ای معادل مجموعه منابع به آنهایی که در آزمون قابلیت توسعه‌دهنده مؤلفه پایه از مؤلفه پایه مورد استفاده قرار گرفته‌اند، ارائه کند.

۳-۵-۴-۱۶ عناصر ارائه و محتوی

ACO_CTT.2.1C ۱-۳-۵-۴-۱۶

مستندات آزمون واسط مؤلفه پایه و TOE ترکیبی باید شامل طرح آزمون، نتایج مورد نظر آزمون و نتایج واقعی آزمون باشد.

ACO_CTT.2.2C ۲-۳-۵-۴-۱۶

مستندات آزمون از اجرای آزمون‌های TOE ترکیبی توسعه‌دهنده تشکیل شده است و باید نشان دهد که TSF همان‌طور که مشخص شده رفتار می‌کند و کامل است.

۱۶-۴-۵-۳ ACO_CTT.2.3C

مستندات آزمون از اجرای آزمون‌های واسطه مؤلفه پایه تشکیل شده است و باید نشان دهد که واسطه مؤلفه پایه با تکیه به مؤلفه وابسته همان‌طور که مشخص شده رفتار می‌کند و کامل است.

۱۶-۴-۵-۴ ACO_CTT.2.4C

مؤلفه پایه باید برای آزمون مناسب باشد.

۱۶-۴-۵-۴ عناصر عمل ارزیاب

۱۶-۴-۵-۴ ACO_CTT.2.1E

توسعه‌دهنده باید تأیید کند که اطلاعات تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدرک را برآورده می‌کند.

۱۶-۴-۵-۲ ACO_CTT.2.2E

ارزیاب باید نمونه‌ای از آزمون در مستندات آزمون را برای تأیید نتایج آزمون توسعه‌دهنده، انجام دهد.

۱۶-۴-۵-۳ ACO_CTT.2.3E

ارزیاب باید آزمونی از زیر مجموعه واسطه‌های TSF از TOE ترکیبی انجام دهد برای تأیید این که TSF ترکیبی همان‌طور که تعیین شده عمل می‌کند.

۱۶-۵ تجزیه و تحلیل آسیب‌پذیری ترکیب (ACO_VUL)

۱۶-۵-۱ اهداف

این خانواده خواستار تجزیه و تحلیل اطلاعات آسیب‌پذیری موجود در حوزه عمومی و آسیب‌پذیری‌هایی که ممکن است به‌عنوان نتایج ترکیب معرفی گردد.

۱۶-۵-۲ رتبه‌بندی مؤلفه

مؤلفه این خانواده براساس افزایش امنیت اطلاعات آسیب‌پذیری در حوزه عمومی و تحلیل آسیب‌پذیری مستقل رتبه‌بندی می‌شود.

۱۶-۵-۳ نکات کاربردی

ارزیاب باید جزئیات مربوط به هرگونه آسیب‌پذیری‌های مانده گزارش شده در حین ارزشیابی مؤلفه‌ها را ارائه کند. این ممکن است از توسعه‌دهنده‌های مؤلفه یا گزارش‌های ارزشیابی مؤلفه‌ها به‌دست آورده شود. این به‌عنوان ورودی برای تجزیه و تحلیل آسیب‌پذیری ارزیاب TOE ترکیبی در محیط عملیاتی استفاده می‌شود.

محیط عملیاتی TOE ترکیبی، برای اطمینان از این که فرضیات و اهداف برای محیط عملیاتی مؤلفه‌ها (مشخص شده در هر ST مؤلفه) در TOE ترکیبی برآورده می‌شوند، بررسی می‌شود.

تجزیه و تحلیل‌های اولیه در مورد سازگاری فرضیه‌ها و اهداف بین مؤلفه‌ها و ST TOE ترکیبی، در حین انجام فعالیت‌های ASE برای TOE ترکیبی انجام شده است.

با این حال، این تحلیل با دانش‌های به‌دست‌آورده از فعالیت‌های ACO_REL، ACO_DEV و ACO_COR انجام می‌شود تا اطمینان حاصل شود، به‌عنوان مثال، مفروضات مؤلفه وابسته که توسط محیط در ST مؤلفه

وابسته اشاره می‌شود که به‌عنوان یک نتیجه از ترکیب دوباره معرفی نمی‌شوند (به‌عنوان مثال: مؤلفه پایه به اندازه کافی به فرضیه‌های مؤلفه وابسته در TOE ترکیبی اشاره می‌کند).
با تجسس توسط ارزیاب برای مسائل مربوط به مؤلفه، آسیب‌پذیری‌های بالقوه گزارش شده در حوزه عمومی، بعد از تکمیل ارزشیابی مؤلفه‌ها شناسایی می‌شوند. هرگونه آسیب‌پذیری‌های بالقوه سپس موضوع تست می‌شود.
اگر مؤلفه پایه مورد استفاده در TOE ترکیبی موضوع اطمینان از تداوم فعالیت‌های ممیزی شده باشد، ارزیاب در طول فعالیت‌های تجزیه و تحلیل آسیب‌پذیری TOE ترکیبی، تغییراتی در مؤلفه پایه صورت گرفته است که آنها را در نظر خواهد گرفت.

۱۶-۵-۴ ACO_VUL.1 مرور آسیب‌پذیری ترکیب

وابسته‌ها، ACO_DEV.1 شرح کارکردی

۱۶-۵-۴-۱ عناصر عمل توسعه‌دهنده

۱۶-۵-۴-۱-۱ ACO_VUL.1.1D

توسعه‌دهنده TOE ترکیبی برای آزمون فراهم می‌نماید.

۱۶-۵-۴-۲ عناصر ارائه و محتوی

۱۶-۵-۴-۲-۱ ACO_VUL.1.1C

TOE ترکیبی باید برای آزمون مناسب باشد.

۱۶-۵-۴-۳ عناصر عمل ارزیاب

۱۶-۵-۴-۳-۱ ACO_VUL.1.1E

ارزیاب باید تأیید کند که اطلاعات فراهم شده، تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند باید توسط ارزیاب تأیید شود.

۱۶-۵-۴-۳-۲ ACO_VUL.1.2E

ارزیاب باید تجزیه و تحلیل برای تعیین هرگونه آسیب‌پذیری‌های باقی‌مانده شناسایی شده، برای مؤلفه‌های پایه و مؤلفه وابسته در TOE ترکیبی که در محیط‌های عملیاتی خود قابل بهره‌برداری نیست را انجام دهد.

۱۶-۵-۴-۳-۳ ACO_VUL.1.3E

ارزیاب باید جستجو از منابع حوزه عمومی برای شناسایی آسیب‌پذیری‌های احتمالی ناشی از استفاده مؤلفه‌های وابسته و پایه در محیط عملیاتی TOE ترکیبی را انجام دهد.

۱۶-۵-۴-۳-۴ ACO_VUL.1.4E

ارزیاب با آزمون نفوذ مبتنی بر آسیب‌پذیری‌های شناسایی شده باید نشان دهد که TOE ترکیبی به حمله‌ها، توسط حمله‌کننده با پتانسیل اولیه حمله، مقاوم است.

۱۶-۵-۵ ACO_VUL.2 تحلیل آسیب‌پذیری ترکیب

وابسته‌ها: ACO_DEV.2 مدرک پایه طرح

۱۶-۵-۵-۱ عناصر عمل توسعه‌دهنده

۱۶-۵-۵-۱-۱ ACO_VUL.2.1D

توسعه‌دهنده باید TOE ترکیبی برای آزمون فراهم نماید.

۱۶-۵-۵-۲ عناصر ارائه و محتوی

ACO_VUL.2.1C ۱-۲-۵-۵-۱۶

TOE ترکیبی باید برای آزمون مناسب باشد.

۱۶-۵-۵-۳ عناصر عمل ارزیاب

ACO_VUL.2.1E ۱-۳-۵-۵-۱۶

توسعه‌دهنده باید تأیید کند که اطلاعات تهیه شده تمام الزامات محتوی و ارائه مدرک را برآورده می‌کند.

ACO_VUL.2.2E ۲-۳-۵-۵-۱۶

ارزیاب باید تجزیه و تحلیل برای تعیین هرگونه آسیب‌پذیری‌های باقی‌مانده شناسایی شده، برای مؤلفه‌های پایه و مؤلفه وابسته در TOE ترکیبی که در محیط‌های عملیاتی خود قابل بهره‌برداری نیست را انجام دهد.

ACO_VUL.2.3E ۳-۳-۵-۵-۱۶

ارزیاب باید جستجو از منابع حوزه عمومی برای شناسایی آسیب‌پذیری‌های احتمالی ناشی از استفاده مؤلفه‌های وابسته و پایه در محیط عملیاتی TOE ترکیبی را انجام دهد.

ACO_VUL.2.4E ۴-۳-۵-۵-۱۶

ارزیاب باید تجزیه و تحلیل آسیب‌پذیری‌های مستقل TOE ترکیبی، با استفاده از مستندات راهنما و اطلاعات تکیه و منطق ترکیب برای شناسایی آسیب‌پذیری‌های TOE ترکیب را انجام دهد.

ACO_VUL.2.5E ۵-۳-۵-۵-۱۶

ارزیاب با آزمون نفوذ مبتنی بر آسیب‌پذیری‌های شناسایی شده باید نشان دهد که TOE ترکیبی به حمله‌ها، توسط حمله‌کننده با پتانسیل حمله اولیه، مقاوم است.

۱۶-۵-۶-۳ ACO_VUL.3 تجزیه و تحلیل آسیب‌پذیری ترکیب اولیه - پیشرفته

۱۶-۵-۶-۱ ACO_VUL.3.1D عناصر عمل توسعه‌دهنده

ACO_VUL.3.1D ۱-۶-۵-۵-۱۶

توسعه‌دهنده باید TOE ترکیبی را برای آزمون فراهم نماید.

۱۶-۵-۶-۲ عناصر ارائه و محتوی

ACO_VUL.3.1C ۱-۲-۶-۵-۱۶

ترکیب TOE باید برای آزمون مناسب باشد.

۱۶-۵-۶-۳ عناصر عمل ارزیاب

ACO_VUL.3.1E ۱-۳-۶-۵-۱۶

ارزیاب باید تأیید کند که اطلاعاتی تهیه شده تمام الزامات مورد نیاز برای محتوی و ارائه مدارک را برآورده می‌کند.

ACO_VUL.3.2E ۲-۳-۶-۵-۱۶

ارزیاب باید تجزیه و تحلیل برای تعیین هرگونه آسیب‌پذیری‌های باقی‌مانده شناسایی شده، برای مؤلفه‌های پایه و مؤلفه وابسته در TOE ترکیبی که در محیط‌های عملیاتی خود قابل بهره‌برداری نیست را انجام دهد.

ACO_VUL.3.3E ۳-۳-۶-۵-۱۶

ارزیاب باید جستجو از منابع حوزه عمومی برای شناسایی آسیب‌پذیری‌های احتمالی ناشی از استفاده مؤلفه‌های وابسته و پایه در محیط عملیاتی TOE ترکیبی را انجام دهد.

ACO_VUL.3.4E ۴-۳-۶-۵-۱۶

ارزیاب باید تجزیه و تحلیل آسیب‌پذیری‌های مستقل TOE ترکیبی، با استفاده از مستندات راهنما و اطلاعات تکیه و منطق ترکیب برای شناسایی آسیب‌پذیری‌های TOE ترکیب را انجام دهد.

ACO_VUL.3.5E ۵-۳-۶-۵-۱۶

ارزیاب با آزمون نفوذ مبتنی بر آسیب‌پذیری‌های شناسایی شده باید نشان‌دهد که TOE ترکیبی به حمله‌ها، توسط حمله‌کننده با پتانسیل حمله اولیه، پیشرفته است.

پیوست الف

(اطلاعاتی)

توسعه (ADV)

این پیوست شامل مواد فرعی برای توضیحات بیشتر و فراهم نمودن مثالهای افزوده برای موضوعاتی که در خانواده ADV: دسته توسعه، بحث شد، می‌شود.

الف-۱ ADV_ARC: کالاهای تکمیلی ۱ در معماری امنیتی

یک معماری امنیتی مجموعه‌ای از خصوصیات است که TSF نشان می‌دهد. این خصوصیات شامل حفاظت از خود^۱، جداسازی دامنه^۲ و عدم توانایی bypass می‌شوند. داشتن این خصوصیات باعث ایجاد اطمینان از این موضوع می‌شود که TSF سرویس‌های امنیتی را فراهم می‌کند. این ضمیمه علاوه بر بحث روی سرفصل‌های توصیف معماری امنیتی، موضوعات اضافی را در رابطه به این خصوصیات فراهم می‌کند. بقیه این بندهای فرعی در ابتدا این خصوصیات را توضیح می‌دهند، سپس در رابطه با انواع اطلاعاتی که برای تشریح این که چگونه TSF این خصوصیات را نمایش می‌دهد، نیاز است، بحث می‌کند.

الف-۱-۱ خصوصیات معماری امنیتی

حفاظت از خود، به توانایی از TSF اشاره می‌کند که از خود در برابر دستکاری موجودیت‌های خارجی که ممکن است نتیجه‌اش ایجاد تغییرات در TSF باشد محافظت می‌کند. بدون این خصوصیات، TSF ممکن است در انجام سرویس‌های امنیتی خود دچار عدم توانایی شود.

این حالت اغلب در مواردی رخ می‌دهد که یک TOE از سرویس‌ها یا منابعی استفاده کنند که به‌وسیله موجودیت‌های دیگر به‌منظور انجام کارکردهای آن، پشتیبانی می‌کند. (برای مثال یک برنامه کاربردی که بر سیستم عامل اصولی تکیه می‌کند) در این حالت‌ها، TSF کاملاً از خودش محافظت نمی‌کند، به این علت که برای محافظت از سرویس‌هایی که استفاده می‌کند به دیگر موجودیت‌های فناوری اطلاعات نیز وابسته است.

جداسازی دامنه خصوصیتی است که به موجب آن TSF دامنه‌های امنیتی مجزایی برای هر یک موجودیت‌های فعال غیرقابل اطمینان^۴ بر روی هر یک از منابع‌اش ایجاد می‌کند، و سپس آن دامنه‌ها را جدا از یک‌دیگر نگه می‌دارد به این منظور که هیچ موجودیتی نتواند در دامنه موجودیت دیگر اجرا شود یا شروع به کار کند. برای مثال، یک سیستم عامل TOE یک دامنه را (فضای آدرس، متغیرهای محیطی براساس فرآیند^۵) برای هر یک از فرآیندهایی که با موجودیت‌های غیرقابل اطمینان شریک هستند، تأمین می‌کند.

1 - Supplementary material

2 - Self-protection

3- Domain separation

4 - Untrusted

5- Per-process environment variables

برای برخی از TOE ها این گونه دامنه ها وجود ندارند زیرا کلیه فعالیت های موجودیت های غیرقابل اطمینان توسط TSF از بین رفته اند. یک دیوار آتش بر مبنای فیلترکردن بسته^۱ مثالی از این نوع TOE می باشد، در جایی که هیچ دامنه موجودیت غیرقابل اطمینانی وجود ندارد، فقط ساختارهای داده توسط TSF نگه داری می شوند. وجود دامنه ها، سپس، وابسته است به ۱ نوع TOE و ۲ SFRs موجود در TOE. در حالت هایی که TOE دامنه را برای موجودیت های غیرقابل اطمینان آماده و فراهم می کند، این خانواده نیاز دارد به آن دامنه هایی که از دامنه های دیگر کاملاً مجزا شده اند از قبیل موجودیت های غیرقابل اطمینان در یک دامنه که از دخالت دیگر دامنه های موجودیت های غیرقابل اطمینان در امان هستند.

الف - ۲ مواد تکمیلی درباره TSFI ها: ADV_FSP

هدف از تعیین ویژگی های TSFI، تهیه اطلاعات لازم برای نتیجه گیری از آزمون است، بدون دانستن معنای واکنش با TSF، نمی توان به خوبی رفتار TSF را مورد آزمون قرار داد.

دو قسمت برای مشخص نمودن ویژگی های TSFI ها وجود دارد: شناسایی آن ها و شرح آن ها.

به دلیل تنوع TOE های ممکن، و تنوع TSF های مختلف درون آن، هیچ مجموعه استاندارد از واسطه هایی که TSFI ها را تشکیل می دهند وجود ندارد. این پیوست، راهنمایی هایی را در مورد عامل های که تعیین می کنند کدام واسطه ها، TSFI هستند ارائه می دهد.

الف - ۲-۱ تعیین TSFI

به ترتیب شناسایی واسط نسبت به TSFI، قسمت هایی از TOE که TSF را شکل می دهند باید، اول، شناسایی شوند. این شناسایی، در واقع قسمتی از تحلیل طراحی TOE است، اما در ضمن توسط توسعه دهنده، در مواردی که طراحی TOE شامل بسته های تضمینی نمی شود، انجام می شود. (در حین شناسایی و شرح TSFI). در این تحلیل، چنان چه TOE در مطلوبیت SFR در ST، مشارکت می کند پس باید سهم TOE در TSF باید در نظر گرفته شود. (در تمام یا قسمتی از آن).

به عنوان مثال، این مسأله شامل هر چیزی در TOE است که در مقداردی زمان اجرایی TSF دخالت دارد، نظیر نرم افزاری که ابتدا اجرا می شود، تا TSF قادر باشد از خودش محافظت کند زیرا اجرای SFR ها هنوز شروع نشده است. (به عنوان مثال، تا زمانی که سیستم بالا بیاید). همچنین TSF شامل همه قسمت هایی از TOE می شود که در اصول معماری حفاظت TSF از خودش، جداسازی دامنه، و قابلیت عبور ندادن، مشارکت می کنند. (قسمت معماری امنیتی ADV_ARC را ببینید).

اولین بار که TSF تعریف می شود، TSFI مشخص می شود. TSFI شامل همه موضوعاتی است که کاربر برای درخواست سرویس از TSF به آن ها نیاز دارد (داده هایی را که باید توسط TSF پردازش شوند تهیه می کند).

همچنین شامل واکنش هایی منطبق با این احضارهای سرویس می باشد. در واقع احضارهای سرویس و واکنش ها، محدوده عبور TSF را مشخص می کنند. تا زمانی که بسیاری از آن ها آشکار هستند، ممکن است بقیه مبهم و ناآشکار باشند. سوالی که باید موقع تعیین TSFI ها پرسیده شود این است که: " چطور یک مهاجم بالقوه با به کارگیری TSF می تواند SFR ها را از کار بیندازد؟ " متون زیر برنامه تعریف TSFI را در زمینه های متفاوت نشان می دهند.

¹ Packet-filter firewall

الف - ۱-۲-۱ واسطه‌های الکتریکی

در TOE‌هایی نظیر کارت‌های هوشمند، که تنها ادعای دسترسی منطقی به TOE ندارد، بلکه دسترسی فیزیکی کامل به TOE دارد، محدوده TSF محدوده فیزیکی است. بنابراین، واسطه‌های الکتریکی نمایش، مورد توجه TSFI قرار می‌گیرند زیرا دست‌کاری آن‌ها می‌تواند بر روی رفتار TSF تأثیر داشته باشد. همچنین، همه واسطه‌ها (اتصالات الکتریکی) نیاز دارند که از نظر ولتاژهای مختلفی که ممکن است به کار گرفته شوند و غیره شرح داده شوند.

الف - ۱-۲-۲ پشته پروتکل شبکه

TSFI‌های TOE که پردازش پروتکل را انجام می‌دهند، ممکن است لایه‌های آن پروتکل باشند که یک مهاجم می‌تواند دسترسی مستقیم به آن داشته باشد. نیازی نیست که پشته پروتکل، حتماً این‌گونه باشد بلکه ممکن است به این نحو باشد.

به عنوان مثال، اگر TOE، ترتیبی از تجهیزات شبکه داشته باشد که اجازه دهد هر مهاجمی بر روی پشته پروتکل اثر بگذارد (به عنوان نمونه، سیگنال‌های دلخواه، ولتاژهای دلخواه، بسته‌های دلخواه، دیتاگرام‌های دلخواه و ... بفراستد). در نتیجه مرز TSF در هر لایه پشته وجود دارد. بنابراین، ویژگی‌های کارکردی، هر پروتکلی را در هر لایه‌ای از پشته، آدرس‌دهی می‌کنند.

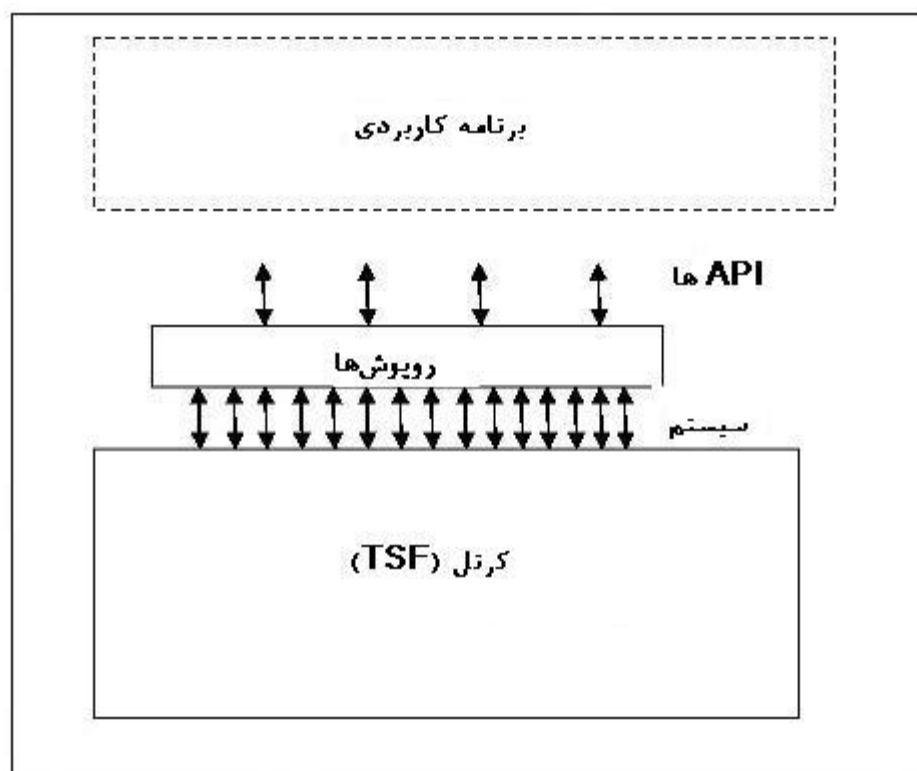
هر چند، اگر TOE دیوار آتشی باشد که شبکه داخلی را از اینترنت محافظت می‌کند، به معنی دست‌کاری مستقیم ولتاژهایی که وارد TOE می‌شوند توسط یک مهاجم بالقوه نیست، هرگونه ولتاژ اضافی به راحتی قابل عبور از اینترنت نیست. در نتیجه، مهاجم، تنها می‌تواند به پروتکل‌هایی در لایه اینترنت یا بالای آن دسترسی پیدا کند. این مرز TSF در هر لایه از پشته وجود دارد. بنابراین، ویژگی‌های کارکردی تنها در لایه اینترنت یا بالاتر از آن آدرس‌دهی می‌شوند: این مسأله شرح می‌دهد که در هر یک از لایه‌های ارتباطی مختلف، دیوار آتش برحسب این‌که چه ورودی خوش‌ساختی بر روی آن خط قرار گرفته است و با توجه به ورودی‌های خوش‌ساخت و بدساخت عمل می‌کند.

به عنوان مثال شرح لایه پروتکل اینترنت، شرح می‌دهد که چه بسته‌های IP خوش‌ساختی تشکیل می‌شوند و چه اتفاقی می‌افتد وقتی که هم بسته‌های درست ساخته شده و هم بسته‌های بدساخت دریافت می‌گردند. همچنین، شرح لایه TCP یک اتصال موفق TCP را شرح می‌دهد و این‌که چه اتفاقی می‌افتد وقتی که اتصالات موفق برقرار می‌شوند و چه موقع اتصالات موفق نمی‌توانند برقرار شوند یا سهواً اتصالات قطع می‌شوند.

هدف کلی دیوار آتش، تصفیه کردن دستورات برنامه کاربردی است (نظیر FTP یا Telnet)، شرح لایه برنامه کاربردی، دستورات برنامه کاربردی را شرح می‌دهد که این دستورات توسط دیوار آتش شناخته و تصفیه می‌شوند، همچنین نتایج مواجهه با دستورات ناشناخته توسط دیوار آتش بررسی می‌گردد.

شرح این لایه‌ها، همانند شرح آن‌ها در منابع استانداردهای ارتباطی منتشر شده‌ای است که مورد استفاده قرار گرفته‌اند. (نظیر Telnet, FTP, TCP و...) و با توجه به گزینه‌های تعریف شده برای کاربر انتخاب می‌شوند.

الف - ۱-۲-۳ رپوش‌ها



شکل الف-۱- روپوش ها

روپوش ها، سری های پیچیده ای از واکنش های درون سرویس های عمومی ساده شده هستند، مثلاً هنگامی که سیستم عامل، API ها را برای استفاده برنامه های کاربردی ایجاد می کند در واقع نوعی روپوش ایجاد کرده است (همان طور که در شکل A.1 نشان داده شده است).

چه TSFI ها، فراخوانی های سیستم باشند و چه API ها به برنامه های کاربردی موجود، وابسته باشند، اگر برنامه کاربردی بتواند، فراخوانی های سیستم را به طور مستقیم مورد استفاده قرار دهد، در نتیجه فراخوانی سیستم، TSFI است. هر چند، اگر چیزهایی وجود داشته باشند که استفاده مستقیم فراخوانی های سیستم را ممنوع کنند و نیاز داشته باشند که همه ارتباطات، از طریق API ها صورت گیرد، در نتیجه در این جا، API، TSFI است. مانند یک واسط کاربر گرافیکی: دستورات قابل فهم توسط ماشین را به صورت گرافیکی برای کاربر ترجمه می کند و بالعکس. این مثال نیز مشابه مثال قبلی است، مثلاً TSFI ها یا دستوراتی هستند که کاربران به آن ها دسترسی دارند و یا به شکل گرافیکی هستند (مانند منوهای پایین کشیدنی، چک باکس ها، جعبه های متنی) که برای استفاده کاربران قرار داده شده اند.

باید به این مسأله توجه داشته باشیم که در هر دوی این مثال ها، اگر استفاده از واسط های اولیه برای کاربران، ممنوع شده باشد (مثلاً استفاده از فراخوانی سیستم یا دستورات برای کاربران ممنوع شده باشد). شرح این محدودیت و اجرای آن در سند شرح معماری امنیتی آمده است (الف-۱ را ببینید). و همچنین شرح آن، قسمتی از TSF نیز می باشد.

الف - ۲-۱-۴ واسط های خارج از دسترس

گاهی برای یک TOE، برخی از واسطها ممکن است خارج از دسترس باشند. یعنی، اهداف امنیتی برای محیط عملیاتی (در هدف امنیتی) ممکن است به این واسطها اجازه دسترسی نداشته باشند یا به حدی دسترسی آنها به این واسطها محدود باشد که عملاً تفاوتی با دسترسی نداشتن آنها نداشته باشد.

این گونه واسطها مورد توجه TSFIها قرار نمی گیرند. به مثالهای زیر توجه نمایید:

الف) اگر اهداف امنیتی محیط عملیاتی برای یک دیوار آتش مستقل در وضعی باشند که آن دیوار آتش در محیط اتاق سرور باشد و فقط پرسنل مورد اعتماد و آموزش دیده به آن دسترسی داشته باشند و دارای تجهیزات منبع نیروی برق وقفه پذیر (در برابر خرابی منبع برق) باشند، واسطهای فیزیکی و نیرو تا زمانی که پرسنل مورد اعتماد و آموزش دیده، تلاش برای از کار انداختن و یا قطع منبع نیروی برق آن ننمایند، خارج از دسترس نخواهند بود. ب) اگر اهداف امنیتی محیط عملیاتی برای دیوار آتش نرم افزار، در وضعی باشند که "سیستم عامل و سخت افزار، محدوده امنی را برای مصون ماندن برنامه های آن از دخالت دیگر برنامه ها فراهم کنند"، واسطهای این نرم افزار از طریق دیوار آتشی که بتواند توسط دیگر برنامه ها به سیستم عامل دسترسی داشته باشد (به عنوان مثال، حذف یا تغییر قابلیت اجرایی دیوار آتش، خواندن یا نوشتن مستقیم بر روی فضای حافظه دیوار آتش)، تا زمانی که قسمتی از سیستم عامل یا سخت افزار محیط عملیاتی این واسطها را خارج از دسترس نکند، خارج از دسترس نخواهند بود.

پ) اگر اهداف امنیتی محیط عملیاتی برای دیوار آتش نرم افزار به صورت مازاد در وضعی باشند که سیستم عامل و سخت افزار به خوبی بتوانند دستورات TOE را اجرا کنند و هیچ گونه دخالتی در TOE نداشته باشند، آنگاه واسطی که از طریق دیوار آتش، کارکرد اولیه خود را از سیستم عامل و سخت افزار به دست می آورد (مانند اجرای دستورالعمل های کد ماشین، APIهای سیستم عامل، نظیر ایجاد، خواندن، نوشتن یا حذف فایل ها، APIهای گرافیکی،...) قابل دسترس نخواهد بود، زیرا سیستم عامل و سخت افزار، تنها چیزهایی هستند که می توانند به واسط دسترسی داشته باشند و کاملاً مورد اعتماد هستند.

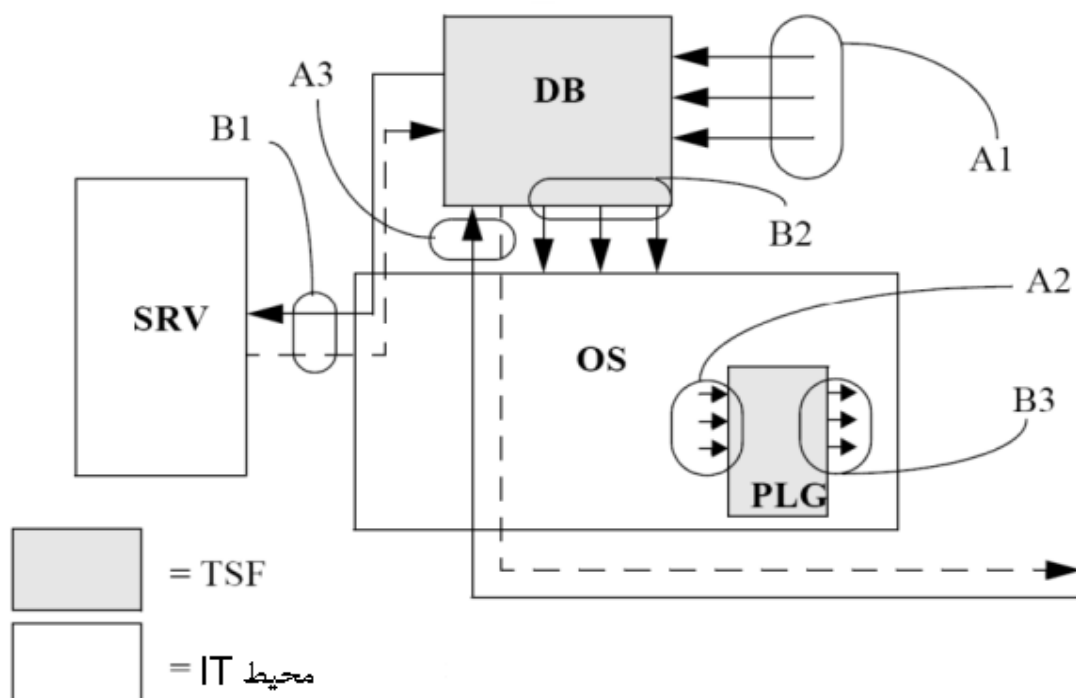
در همه این مثالها، این واسطهای غیرقابل دسترسی، TSFI نخواهند بود.

الف - ۲ - ۲ مثال: یک DBMS مختلط

شکل الف-۲ یک TOE مختلط را نشان می دهد: سیستم مدیریت پایگاه داده به سخت افزار و نرم افزاری تکیه دارد که خارج از محدوده TOE است. (به محیط فناوری اطلاعات در ادامه این بحث مراجعه کنید.) برای ساده سازی این مثال، TOE را عیناً مشابه TSF در نظر گرفته ایم. قسمت های سایه زده شده، TSF را نشان می دهند، و قسمت های بدون سایه موجودیت های فناوری اطلاعات را در محیط نشان می دهند. TSF، شامل این موارد است: موتور پایگاه داده و مدیریت GUIها (که توسط قسمت هایی با برچسب DB نشان داده شده اند) و پیمانه کرنلی که قسمتی از سیستم عامل را اداره می کند که این قسمت برخی کارکردهای امنیتی را اجرا می کند. (توسط قسمت هایی با برچسب PLG نشان داده شده است).

پیمانه کرنل TSF مواردی را که توسط ویژگی های OS تعریف می شود وارد کرده است که این ویژگی های OS تقاضای برخی کارکردها را می نمایند. (این کارکردها می توانند درایور یک وسیله، یا پیمانه احراز هویت و ... باشند).

نکته اصلی این است که این پیمانه کرنل دارای کلید اتصال، سرویس‌های امنیتی تعیین شده توسط الزامات کارکردی در ST را فراهم می‌کند.



شکل الف-۲- واسطها در سیستم DBMS

محیط فناوری اطلاعات، شامل خود سیستم عامل (قسمتهایی که با برچسب OS نشان داده شده است)، به‌علاوه یک سرور بیرونی است (که با برچسب SRV نشان داده شده است)، سرور بیرونی، همانند OS، سرویسی را آماده می‌کند که TSF به آن وابسته است، و در نتیجه نیاز دارد که در محیط فناوری اطلاعات باشد. در شکل، برای TSFI با برچسب AX نشان داده شده‌اند، و برچسب BX برای سایر واسطه‌هایی است که در ACO: (یعنی ترکیب) مستندسازی شده‌اند.

اکنون به بحث در مورد هر یک از این گروه‌های واسط می‌پردازیم:

واسط گروه A1، واضح‌ترین مجموعه TSFI را نشان می‌دهد. این واسطها، توسط کاربران برای دسترسی مستقیم به پایگاه داده و منابع و کارکردهای امنیتی آن، استفاده می‌شود.

واسط گروه A2، TSFI را نشان می‌دهد که OS این TSFI را درخواست می‌کند تا کارکردی را که پیمانه قابل اتصال فراهم کرده، بگیرد. این‌ها در مقابل واسط گروه B3 قرار می‌گیرند، واسط گروه B3 فراخوانی‌هایی را نشان می‌دهد که پیمانه قابل اتصال می‌سازد تا سرویس‌هایی را از محیط فناوری اطلاعات بگیرد.

واسط گروه A3، TSFI را نشان می‌دهد که از طریق محیط فناوری اطلاعات عبور می‌کند. در این مورد، DBMS بر روی شبکه با پروتکل برنامه_سطح اختصاصی ارتباط برقرار می‌کند. تا زمانی که محیط فناوری اطلاعات آمادگی فراهم نمودن پروتکل‌های پشتیبانی مختلف را دارد (به‌عنوان مثال: Ethernet, IP, TCP) پروتکل لایه برنامه‌ای که برای گرفتن سرویس‌ها از DBMS به‌کار می‌رود TSFI است و باید به همین شکل نیز مستند شود. خط نقطه‌گذاری شده سرویس‌ها/مقادیر بازگشتی از TSFI را بر روی اتصال شبکه نشان می‌دهد.

واسطه‌های برچسب‌گذاری‌شده با Bx واسطه‌هایی را با قابلیت کارکرد در محیط فناوری اطلاعات نشان می‌دهند. این واسطه‌ها TSFI نیستند و نیاز دارند که به تنهایی مورد بحث و بررسی قرار گیرند تا زمانی که TOE از آن‌ها در ارزشیابی ترکیبی به‌عنوان قسمتی از فعالیت‌های مرتبط با دسته ACO استفاده کند.

الف - ۲-۳ ویژگی‌های کارکردی Example

دیوار آتش Example بین شبکه ورودی و شبکه خروجی به‌کار می‌رود. این دیوار آتش، آدرس مبدأ داده دریافت‌شده را بررسی می‌کند (برای این‌که ضمانت کند که داده‌های خارجی تغییر ظاهر نداده و به‌جای داده‌های داخلی خود را نشان دهند)؛ اگر هرگونه تغییر ظاهری را کشف کرد از این تغییر log گرفته و آن را ذخیره می‌کند. مدیر از شبکه داخلی با استفاده از Telnet به دیوار آتش متصل می‌شود. کارهایی که مدیر انجام می‌دهد عبارتند از احراز هویت، تغییر رمز، بازبینی log، و قراردادن یا تغییر آدرس‌های شبکه‌های خارجی و داخلی.

دیوار آتش Example از قبل واسطه‌های زیر را بر روی شبکه داخلی قرار داده است:

الف) دیتاگرام‌های IP

ب) دستورات مدیریت

و واسطه‌های زیر را برای شبکه بیرونی قرار داده است:

الف) دیتاگرام‌های IP

توضیحات مربوط به واسطه‌ها: دیتاگرام‌های IP

دیتاگرام‌هایی که در قالب تعیین‌شده توسط RFC791 هستند.

- هدف - انتقال بلاک‌های داده (دیتاگرام‌ها) از hostهای مبدأ به hostهای مقصد که توسط آدرس‌هایی با اندازه ثابت مشخص شده‌اند. همچنین، اگر لازم باشد، جدا کردن و به‌هم چسباندن دیتاگرام‌های طولانی، برای این‌که انتقال از طریق شبکه‌هایی با بسته‌های کوچک انجام شود.
- روش استفاده: آن‌ها از پروتکل سطح پایین (به‌عنوان مثال، لایه پیوند داده) استفاده می‌کنند.
- پارامترها: فیلدهای header دیتاگرام IP، آدرس مبدأ، آدرس مقصد، flag قسمت قسمت نشده
- شرح پارامتر: (شرح داده شده توسط RFC 791، بند فرعی ۳.۱) قالب header اینترنت)
- فعالیت‌ها: دیتاگرام‌هایی را انتقال می‌دهد که در حال تغییر ظاهر نیستند، اگر لازم باشد دیتاگرام‌های بزرگ را قسمت‌قسمت می‌کند، و همین‌طور چسباندن این قطعه‌های قسمت‌قسمت شده به دیتاگرام‌ها
- پیغام‌های خطا (هیچکدام) هیچ ضمانت قابل اعتمادی وجود ندارد. (قابلیت اعتماد و اعتبار توسط پروتکل‌های لایه بالاتر فراهم می‌شود). دیتاگرام‌های غیرقابل حمل کنار گذاشته می‌شوند. (به‌عنوان مثال، باید قطعه قطعه شوند برای حمل و انتقال، اما flag قطعه قطعه شدن برایشان قرار داده نشده است).

شرح واسطه‌ها: دستورات مدیریت

دستورات مدیریت، به مدیر این توانایی را می‌دهد که با دیوار آتش تعامل داشته باشد. این دستورات و پاسخ‌ها از هر host از شبکه داخلی بر روی telnet قرار می‌گیرند. دستوراتی که در دسترس هستند به‌شرح زیر می‌باشند:

• Password

- هدف- قرار دادن رمز برای مدیر
- روش استفاده- < رمز > Password
- پارامترها- رمز
- شرح پارامتر- مقدار رمز جدید
- فعالیت‌ها- تغییر رمز به رمز جدید دیگر. هیچ محدودیتی در این زمینه وجود ندارد.
- پیغام‌های خطا- وجود ندارد.

• Readaudit

- هدف- ارائه logهای گرفته شده به مدیر
- روش استفاده- Readaudit
- پارامترها- وجود ندارد.
- شرح پارامتر- وجود ندارد.
- فعالیت‌ها- فراهم نمودن متن log
- پیغام‌های خطا- وجود ندارد.

• Setintaddr

- هدف- قراردادن آدرس مربوط به آدرس درونی
- روش استفاده- < آدرس > Setintaddr
- پارامترها- آدرس
- شرح پارامتر- سه فیلد اول آدرس IP (که در RFC 791 تعریف شده‌اند). به عنوان مثال: ۱۲۳.۱۲۳.۱۲۳
- فعالیت‌ها- تغییر مقدار درونی متغیر شبکه درونی؛ مقداری که قصد تغییر ظاهر دادن را دارد.
- پیغام‌های خطا- "آدرس در حال استفاده است." این پیغام نشان می‌دهد که شبکه درونی تعریف شده مشابه شبکه بیرونی است.

• Setextaddr

- هدف- قراردادن آدرس مربوط به آدرس بیرونی
- روش استفاده- < آدرس > Setextaddr
- پارامترها- آدرس
- شرح پارامتر- سه فیلد اول آدرس IP (که در RFC 791 تعریف شده‌اند). به عنوان مثال: ۱۲۳.۱۲۳.۱۲۳
- فعالیت‌ها- تغییر مقدار درونی متغیر شبکه بیرونی
- پیغام‌های خطا- "آدرس در حال استفاده است." این پیغام نشان می‌دهد که شبکه بیرونی تعریف شده مشابه شبکه درونی است.

الف-۳ مباحث تکمیلی برای درونی‌های ADV_INT: TSF

تنوع وسیع TOEها، صرفاً رمزگذاری در مورد TOEهای "خوش ساخت" یا "دارای حداقل پیچیدگی" را ممکن می‌سازد. قضاوت در مورد ساختار و پیچیدگی، براساس تکنولوژی‌های به کار رفته در TOE صورت

می‌گیرد. به عنوان مثال، نرم‌افزاری را خوش‌ساخت می‌گوییم که ویژگی‌های به کار رفته در مهندسی و طراحی آن نرم‌افزار، دارای هماهنگی و ترتیب باشند.

این پیوست، مباحث تکمیلی را درباره TSF، در مورد ساختار و پیچیدگی اجزای نرم‌افزار رویه-مبنا بیان می‌کند. این مباحث، بر پایه اطلاعات موجود در توضیحات طراحی نرم‌افزار است. برای دیگر انواع درونی‌ها (نظیر سخت افزار، نرم‌افزار غیررویه‌ای مانند کد شیء‌گرا، و...) باید براساس فعالیت‌ها و تمرینات مناسب، با کنکاش و همفکری، نوشته‌ای مناسب تهیه شود.

الف - ۳-۱ ساختار نرم‌افزار رویه‌ای

ساختار نرم‌افزار رویه‌ای، به شکل سنتی براساس پیمانه آن می‌باشد. نرم‌افزار نوشته شده با طراحی پیمانه‌ای به فهم مناسب ما کمک می‌کند به این صورت که یک پیمانه به چه پیمانه‌های دیگری متصل است (اتصال) و چه وظایف مرتبط با یکدیگر دارند (پیوستگی).

نرم‌افزاری که به صورت پیمانه‌ای طراحی شده است مشخص می‌کند که یک پیمانه چه وابستگی‌هایی به پیمانه‌های دیگر دارد (اتصال) و چه پیمانه‌هایی در آن نرم‌افزار قویاً با یکدیگر ارتباط دارند (پیوستگی). استفاده از طراحی پیمانه‌ای، باعث کاهش وابستگی بین عناصر TSF می‌شود و در نتیجه باعث کاهش خطر ناشی از تغییر یا خطا در یک پیمانه که روی تمام TOE اثر خواهد گذارد می‌شود.

استفاده از طراحی پیمانه‌ای باعث افزایش وضوح طراحی می‌شود و ضمانت این‌که اثرات غیر منتظره رخ ندهد را بالا می‌برد. ویژگی‌های دیگر تجزیه و تحلیل پیمانه‌ای، کاهش میزان افزونه یا کد ناخواسته است.

به حداقل رساندن میزان کارکرد در TSF، این اجازه را می‌دهد که هم ارزیاب و هم توسعه‌دهنده، تنها بر کارکردی که برای اجرای SFR لازم است تمرکز کنند، و همین‌طور فهم بهتری را سبب شده و خطای طراحی یا پیاده‌سازی را کاهش می‌دهد.

ترکیب تجزیه و تحلیل پیمانه‌ای، لایه‌بندی و به حداقل رسانی در فرایند طراحی و پیاده‌سازی، باید توأم با ملاحظات مهندسی نرم‌افزار به طور صحیح باشد.

یک سیستم کاربردی و مفید، معمولاً شامل اتصال‌های ناخواسته میان پیمانه‌ها است، شامل برخی پیمانه‌هایی است که کارکردهای آزاد دارند و همین‌طور شامل موشکافی و پیچیدگی در طراحی پیمانه است.

این انحراف از ایدآل‌های تجزیه و تحلیل، اغلب اوقات برای رسیدن به برخی اهداف یا محدوده‌ها، ضروری پنداشته می‌شوند، و به کارایی، سازگاری، یا کارکرد طراحی شده برای آینده، یا برخی معیارهای دیگر، که ممکن است براساس قضاوت توسعه‌دهنده قابل پذیرش باشند، ارتباط دارد.

در به کار بردن الزامات این دسته، بنابر ملاحظات، باید، اصول مهندسی نرم‌افزار به شکل صحیح داده شود، هر چند که باید همه اهداف قابل فهم، به انجام برسند.

الف - ۳-۱ پیوستگی

پیوستگی، روش و درجه‌ای است برای وظایفی که توسط پیمانه نرم‌افزار تک منظوره که مرتبط به یک پیمانه دیگر است، انجام می‌شود. انواع پیوستگی شامل تصادفی، ارتباطی، کارکردی، منطقی، ترتیبی و موقتی می‌باشد. ویژگی‌های انواع این پیوستگی‌ها در زیر آمده است و براساس کاهش مطلوب بودن، مرتب شده است:

الف) پیوستگی کارکردی: پیمانه‌ای با پیوستگی کارکردی، فعالیت‌های مرتبط به هدف تک منظوره را انجام می‌دهد. یک پیمانه کارکردی پیوسته، یک نوع تکی ورودی را به یک نوع تکی خروجی تبدیل می‌کند. مانند مدیر یک پشته یا مدیر یک صف.

ب) پیوستگی ترتیبی: پیمانه‌ای با پیوستگی ترتیبی، پیمانه‌ای است که هر خروجی یک تابع آن، ورودی تابع بعدی آن پیمانه می‌باشد. یک مثال برای پیوستگی ترتیبی عبارت است از توابعی که نوشته‌ها را ثبت می‌کنند و تعداد تخلفات در هر نوشتن را می‌شمارند.

پ) پیوستگی ارتباطی: پیمانه‌ای با پیوستگی ارتباطی، پیمانه‌ای است که خروجی‌هایی را برای استفاده دیگر توابع داخل پیمانه تولید می‌کند یا از خروجی‌های دیگر توابع داخل پیمانه استفاده می‌کند. یک مثال برای پیمانه ارتباطی پیمانه کنترل دسترسی است که شامل کنترل‌های الزامی، کنترل‌های احتیاطی و کنترل صلاحیت می‌باشد.

ت) پیوستگی موقتی: پیمانه‌ای با پیوستگی موقتی پیمانه‌ای است که توابع آن نیاز دارند همزمان اجرا شوند. پیمانه‌هایی نظیر پیمانه شروع کننده، پیمانه بازیافت و پیمانه خاموش کننده جزء چنین دسته‌ای هستند.

ث) پیوستگی منطقی (با روالی): پیمانه‌ای با پیوستگی منطقی کارهای مشابهی را بر روی ساختمان داده‌های متفاوت انجام می‌دهد. یک پیمانه، پیوستگی منطقی دارد اگر توابع آن، عملیات‌هایی متفاوت ولی مرتبط را بر روی ورودی‌های متفاوت انجام دهند.

ج) پیوستگی تصادفی: پیمانه‌ای با پیوستگی تصادفی، پیمانه‌ای است که فعالیت‌های غیرمرتبط با هم انجام می‌دهد.

الف-۳-۱-۲ جفت شدن

اتصال، چگونگی و درجه وابستگی بین پیمانه‌های نرم‌افزار می‌باشد. انواع مختلف اتصال وجود دارد، اتصالاتی نظیر اتصال فراخوانی، اتصال عمومی و اتصال محتوایی.

خصوصیات انواع این اتصالات به ترتیب کاهش مطلوبیت، به شرح زیر است:

الف) فراخوانی: دو پیمانه به صورت متصل فراخوانی می‌شوند اگر از طریق استفاده از فراخوانی کارکرد مستندات شان با یکدیگر ارتباط داشته باشند، مثال‌های این نوع اتصال عبارتند از داده، مُهر و کنترل، که در زیر توضیح داده می‌شوند.

۱- داده: دو پیمانه از طریق داده به یکدیگر متصل‌اند اگر از طریق استفاده از پارامترهای فراخوانی که آیتم‌های داده تکی را نشان می‌دهند با یکدیگر ارتباط داشته باشند.

۲- مُهر: دو پیمانه از طریق مُهر به یکدیگر اتصال داده می‌شوند اگر از طریق استفاده از پارامترهای فراخوانی که فیلدهای چندگانه دارند با یکدیگر در ارتباط باشند یا دارای ساختار درونی قابل ملاحظه‌ای باشند.

۳- کنترل: دو پیمانه از طریق کنترل به یکدیگر متصل می‌شوند اگر یکی از آن‌ها اطلاعاتی را عبور دهد که تاثیر قابل ملاحظه‌ای بر منطق درونی دیگری بگذارد.

ب) عمومی: دو پیمانه به شکل عمومی به یکدیگر متصل‌اند اگر آن‌ها داده‌های عمومی یا منابع سیستمی عمومی را با یکدیگر به اشتراک بگذارند. متغیرهای سراسری نشان می‌دهند که پیمانه‌هایی که از این متغیرها استفاده می‌کنند به شکل عمومی به هم متصل شده‌اند. اتصال عمومی از طریق متغیرهای سراسری، معمولاً مجاز است و

تنها به درجه، محدود می‌شود. به‌عنوان مثال، متغیرهایی که درون یک منطقه سراسری قرار می‌گیرند اما تنها توسط یک پیمان‌ه به‌کار گرفته می‌شوند، در واقع در جای مناسبی قرار نگرفته‌اند و باید از محیط سراسری برداشته شوند [و در یک محیط محلی قرار بگیرند]. عامل‌ها دیگری که برای ارزشیابی تناسب متغیرهای سراسری باید مورد توجه قرار داده شوند عبارتند از:

۱- تعداد پیمان‌ه‌هایی که متغیر سراسری را اصلاح می‌کنند: در حالت کلی، تنها یک پیمان‌ه باید برای کنترل محتواهای متغیر سراسری، عهده‌دار مسوولیت باشد، اما ممکن است پیمان‌ه دومی نیز در این مسوولیت سهیم باشد، در چنین مواردی، باید توجیهات لازم برای دخالت پیمان‌ه دیگر وجود داشته باشد. این مسأله که بیش از دو پیمان‌ه، عهده‌دار چنین مسوولیتی باشند غیرقابل پذیرش است. (به‌منظور ارزشیابی، باید دقت لازم در این‌که پیمان‌ه واقعاً مسوولیت محتوای متغیر را برعهده دارد به‌عمل آید، به‌عنوان مثال، اگر یک روال برای اصلاح متغیر به‌کار برده شود و آن روال به سادگی تغییر خواسته شده توسط فراخوانی کننده‌اش را انجام دهد، در نتیجه پیمان‌ه فراخوان، یک پیمان‌ه پاسخ‌گو و مسوولیت‌پذیر است و ممکن است بیش از یک پیمان‌ه، از چنین پیمان‌ه‌های مسوولیت‌پذیری داشته باشیم).

علاوه‌بر این، به‌عنوان قسمتی از تعیین پیچیدگی، اگر دو پیمان‌ه، مسوول محتوای متغیر سراسری باشند، باید این مسأله کاملاً مشخص باشد که چطور برای انجام اصلاحات، به‌همکاری با یکدیگر می‌پردازند.

۲- تعداد پیمان‌ه‌هایی که به متغیر سراسری ارجاع می‌دهند، اگر چه، هیچ محدودیتی در مورد تعدادشان وجود ندارد، باید مواردی از این پیمان‌ه‌ها که چینی ارجاعاتی می‌دهند از لحاظ ضرورت و اعتبار ارجاع، مورد آزمون قرار گیرند.

پ) محتوا: دوپیمان‌ه از نظر محتوای به یکدیگر متصل می‌شوند اگر یکی از آن‌ها به‌شکل مستقیم به درون دیگری ارجاع دهد. (به‌عنوان مثال، کد پیمان‌ه دیگر را تغییر دهد، یا درون برچسب‌های ارجاع را در پیمان‌ه دیگر تغییر دهد و ...). نتیجه این می‌شود که برخی یا همه محتوای یک پیمان‌ه بر دیگری اثر دارد. اتصال محتوای می‌تواند به‌عنوان واسط‌های پیمان‌ه منتشر نشده، استفاده شود. این مسائل برخلاف اتصال فراخوانی است که تنها از واسط‌های پیمان‌ه منتشر شده استفاده می‌کند.

الف- ۳- ۲- پیچیدگی نرم‌افزار رویه‌ای

پیچیدگی، میزان نقاط تصمیم و مسیرهای منطقی‌ای است که اجرای یک کد، به خود اختصاص می‌دهد. در ادبیات مهندسی نرم‌افزار، از پیچیدگی به‌عنوان یک ویژگی منفی نرم‌افزار، یاد می‌شود زیرا مانع از فهم منطق و جریان کد می‌شود. مانع دیگری که در راه فهم کد وجود دارد تکرار غیرضروری کد است که باعث افزونگی غیرضروری می‌شود.

استفاده از لایه‌بندی، علاوه بر جداسازی سطوح انتزاعی و به‌حداقل رساندن چرخه وابستگی‌ها، به فهم بهتر TSF کمک می‌کند و تضمین بیشتری را فراهم می‌کند که الزامات کارکردی امنیتی TOE به‌شکل دقیق و کامل در پیاده‌سازی، معرفی شده‌اند.

کم کردن پیچیدگی، شامل کم کردن یا از بین بردن وابستگی‌های دو طرفه نیز می‌شود، که این وابستگی‌ها، هم پیمان‌ه‌هایی در یک لایه و هم آن پیمان‌ه در لایه‌های جداگانه دیگر را شامل می‌شوند. پیمان‌ه‌هایی که دارای وابستگی دو طرفه هستند برای ایجاد یک نتیجه واحد، ممکن است به یک پیمان‌ه دیگر وابسته باشند که می‌تواند

در شرایط بن‌بست یا بدتر از آن در شرایطی که دور ایجاد شده است، مفید باشد، (به‌عنوان مثال زمان بررسی کردن در برابر زمان درگیر بودن)، جایی که نتیجه نهایی می‌تواند نامعین باشد و بر روی محیط محاسباتی در لحظه مورد نظر، اثر گذار باشد.

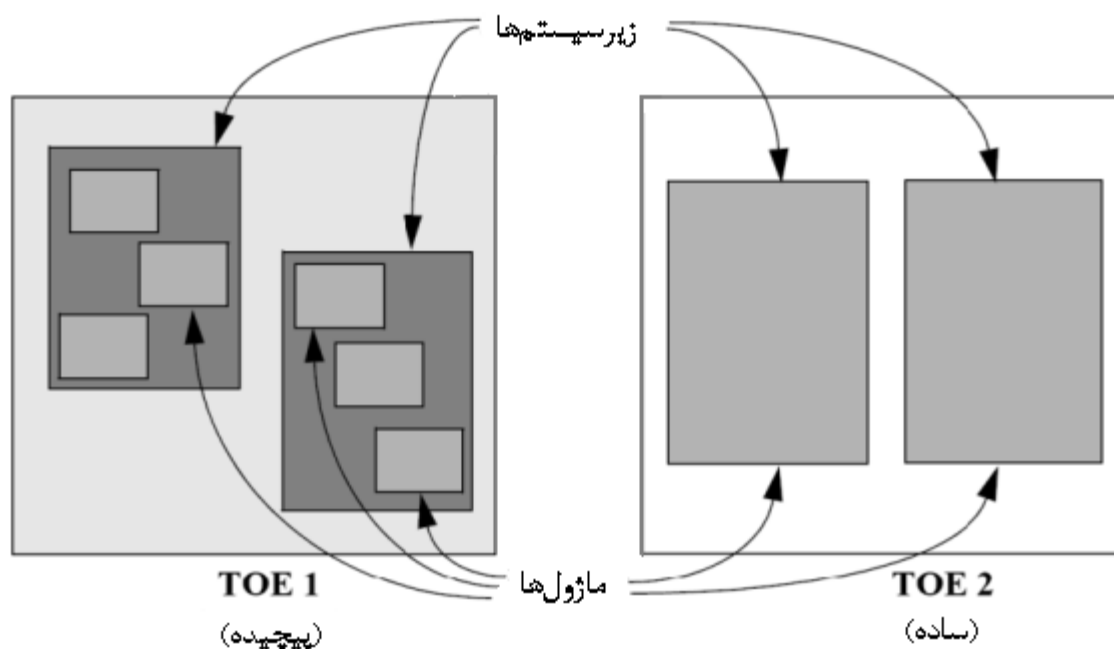
به‌حداقل رساندن پیچیدگی طراحی، ویژگی کلیدی مکانیسم اعتبار‌قسمتی مرجع است، و هدف از آن رسیدن به TSF است که به راحتی فهمیده می‌شود و به‌طور کامل بتوان آن را تحلیل کرد. (ویژگی‌های کلیدی مهم دیگری برای مکانیسم اعتبار قسمتی مرجع وجود دارند، ویژگی‌هایی نظیر خود-محافظ بودن TSF و منشعب نشدن آن، سایر ویژگی‌ها در الزامات خانواده ADV_ARC آمده است.

الف - ۴: ADV_TDS: زیرسیستم و پیمانه‌ها

این بند فرعی، راهنمایی بیشتری را در مورد خانواده TDS ارائه می‌دهد و کاربرد آن را در رابطه با زیرسیستم و پیمانه، بیان می‌دارد. در مورد چگونگی آن‌ها، همراه با جزئیات بیشتری که می‌آورد به بحث می‌پردازد، همین‌طور الزامات چیزهایی با جزئیات کمتر را کاهش می‌دهد.

الف - ۴: زیرسیستم‌ها

شکل الف-۳، بسته به پیچیدگی TSF، طراحی زیرسیستم‌ها و پیمانه‌ها را نشان می‌دهد. (که در آن، زیرسیستم‌ها در سطح بالاتری از انتزاع، نسبت به پیمانه‌ها هستند.) یا این‌که فقط شرح یک سطح از انتزاع است (به‌عنوان مثال، زیرسیستم‌هایی در سطوح تضمین پایین‌تر، پیمانه‌هایی در سطوح بالاتر)، در مواردی که سطح پایین‌تر انتزاع (یعنی پیمانه) ارائه می‌شود. الزامات، بر روی انتزاعات سطح بالاتر (یعنی زیرسیستم‌ها) بسته می‌شود. زیرا اساساً زیرسیستم‌ها به‌شکل پیش‌فرض دیده می‌شوند. این مسأله با جزئیات دقیق در بحث زیر در مورد زیرسیستم‌ها و پیمانه‌ها بیان شده است.



شکل الف-۳: زیرسیستم‌ها و ماژول‌ها

از توسعه‌دهنده، این انتظار می‌رود که طراحی TOE در مورد زیرسیستم‌ها را شرح دهد. اصطلاح " زیرسیستم " به شکلی مبهم انتخاب شده است و می‌تواند به قسمت‌های مختلف TOE ارجاع دهد. (به‌عنوان مثال، زیرسیستم‌ها، پیمانه‌ها). تا زمانی که الزامات برای شرح زیرسیستم‌ها بیان می‌شود زیرسیستم‌ها می‌توانند حتی به‌صورتی ناجور در یک دامنه وجود داشته باشند.

اولین کاربرد زیرسیستم‌ها، جداسازی محدوده TSF است، به عبارت دیگر، قسمت‌های TOE را که شامل TSF می‌شوند جدا می‌سازد. در حالت کلی، یک زیرسیستم، قسمتی از TSF است اگر ظرفیت تأثیرگذاری بر تصحیح عملکرد هر یک از SFRها را داشته باشد (چه به‌وسیله طراحی و چه توسط پیاده‌سازی). به‌عنوان مثال، برای نرم‌افزاری که وابسته به شیوه‌های اجرایی سخت‌افزاری متفاوت است، دامنه جداگانه‌ای (الف_۱ را ببینید). را فراهم می‌کند که کد SFR اجرایی در یک دامنه اجرا شود، سپس همه زیرسیستم‌هایی که در آن دامنه اجرا می‌شوند، به‌عنوان قسمتی از TSF در نظر گرفته می‌شوند. همچنین، اگر بیرون از سرور آن دامنه، یک SFR پیاده‌سازی شد، آن SFR نیز قسمتی از TSF به حساب می‌آید. (به‌عنوان مثال، اجرای یک خط‌مشیء کنترل دسترسی درباره اهدافی که مدیریت می‌کند).

دومین کاربرد زیرسیستم‌ها، فراهم نمودن ساختاری برای توضیح TSF در سطح شرحی است که آن شرح به‌نحوه چگونگی کار TSF می‌پردازد، لازم نیست جزئیات پیاده‌سازی سطح پایین در شرح پیمانه آورده شود. (در مورد آن بعداً صحبت می‌کنیم). زیرسیستم‌ها هم در سطح بالا شرح داده می‌شوند (کمبود فراوانی جزئیات پیاده‌سازی)، هم در سطح جزئیات (فراهم نمودن بینش بیشتری برای پیاده‌سازی).

سطح شرح فراهم شده برای زیرسیستم توسط درجه مسئولیت زیرسیستم در قبال پیاده‌سازی SFR، تعیین می‌شود.

یک زیرسیستم SFR اجرایی، زیرسیستمی است که مکانیسم‌هایی را برای اجرای عنصر هر SFR فراهم می‌کند، یا مستقیماً زیرسیستمی را که مسئولیت اجرای SFR را برعهده دارد پشتیبانی می‌کند. اگر یک زیرسیستم، یک TSFI SFR اجرایی را فراهم کند (پیاده‌سازی کند) آنگاه آن زیرسیستم، یک SFR اجرایی است.

زیرسیستم‌ها می‌توانند به‌عنوان SFR پشتیبان و SFR غیرمداخله‌گر نیز شناخته شوند. زیرسیستم SFR پشتیبان، زیرسیستمی است که توسط زیرسیستم SFR اجرایی به پیاده‌سازی SFR مرتبط می‌شود اما نقش مستقیم در زیرسیستم SFR اجرایی بازی نمی‌کند. یک زیرسیستم SFR غیرمداخله‌گر، زیرسیستمی است که برای اجرای یک SFR، نه به نقش اجرایی و نه پشتیبانی وابسته نمی‌باشد.

الف - ۴-۲ پیمانه‌ها

یک پیمانه، معمولاً یک واحد معماری کوچک نسبی است که می‌تواند در رابطه با ویژگی‌های مطرح در درون TSF مشخص شود (ADV_INT).

وقتی هم الزامات طراحی پیمانه‌ای پایه‌ای ADV_TDS.3 (یا بالاتر) و الزامات درون TSF (ADV_INT) در PP یا ST ارائه می‌شوند، یک پیمانه مرتبط با الزامات طراحی TOE (ADV_TDS) به موجودیت مشابهی به‌عنوان " پیمانه " برای الزامات درون TSF (ADV_INT) اشاره می‌کند. برخلاف زیرسیستم‌ها، پیمانه‌ها پیاده‌سازی را در سطح جزئیات شرح می‌دهند که می‌تواند به‌عنوان راهنمایی برای مرور پیاده‌سازی به کار گرفته شود.

به این نکته مهم باید توجه کنیم که ، بسته به TOE، پیمانه‌ها و زیرسیستم‌ها ممکن است به انتزاع مشابهی ارجاع دهند. برای طراحی پایه‌ای ADV_TDS.1 و طراحی معماری ADV_TDS.2 (که نیازی به شرح در سطح پیمانه ندارند). شرح زیرسیستم، جزئیات پایین‌ترین سطح موجود را در مورد TSF، فراهم می‌کند. این شرح‌ها برای طراحی پیمانه‌ای پایه‌ای ADV_TDS.3 (که نیاز به شرح پیمانه دارد). پایین‌ترین سطح جزئیات را فراهم می‌کنند، در صورتی که شرح زیرسیستم (اگر به صورت جدا وجود داشته باشد) صرفاً شرح‌های پیمانه را در متن قرار می‌دهد. به عبارت دیگر، اگر شرح‌های پیمانه وجود داشته باشد دیگر نیاز به تهیه جزئیات شرح‌های زیرسیستم نیست.

در TOE‌هایی که به اندازه کافی ساده هستند، نیازی به "شرح زیرسیستم" جدا نمی‌باشد. می‌توان از طریق مدارک فراهم‌شده توسط پیمانه‌ها به الزامات دسترسی پیدا کرد. برای TOE‌های پیچیده، هدف از شرح زیرسیستم (با توجه به TSF) تهیه یک متن خواندنی است که براساس آن بتوان TOE‌ها را به شکل مناسبی تحلیل کرد. این تفاوت در شکل A.3 نشان داده شده است.

پیمانه SFR اجرایی، پیمانه‌ای است که مستقیماً الزامات کارکردی امنیت (SFR) را در ST، اجرا می‌کند. این پیمانه‌ها، معمولاً TSFI SFR اجرایی را اجرا خواهند کرد، اما برخی کارکردهای بیان شده در SFR (مانند کارکرد استفاده مجدد هدف و ویرایش) ممکن است مستقیماً صرفاً به یک TSFI وابسته نباشند. همانند مورد زیرسیستم‌ها، پیمانه‌های SFR پشتیبان، پیمانه‌هایی هستند که توسط پیمانه SFR اجرایی به سیستم مربوط می‌شوند اما مسئولیت اجرای مستقیم SFR را ندارند.

پیمانه‌های SFR غیر مداخله‌گر، پیمانه‌هایی هستند که به صورت مستقیم و چه غیرمستقیم با اجرای SFR‌ها، ارتباط ندارند.

به این نکته مهم باید توجه کنیم که تعیین چیزی که "اجراهای مستقیم" می‌شود به این معنی است که این مسأله تا حدی شخصی است. در معنایی محدود، این مسأله می‌تواند یک یا دو خط از کد باشد که عملیات مقایسه را انجام می‌دهد یا عملیات صفرسازی را انجام می‌دهد و غیره، که این عملیات، الزامی را پیاده‌سازی می‌کند.

یک توصیف گسترده، عبارت از پیمانه‌ای است که برای پاسخ به TSFI یک SFR اجرایی خواسته می‌شود و همچنین همه پیمانه‌هایی که توسط این پیمانه درخواست می‌شوند. (تا زمانی که فراخوانی تمام شود). هیچ یک از این توصیفات، به طور خاص قانع کننده نیستند، به دلیل محدودیت اولین توصیف، ممکن است پیمانه‌های مهم به غلط به عنوان SFR پشتیبان طبقه‌بندی شوند در حالی که دومین توصیف به پیمانه‌هایی که به عنوان SFR اجرایی طبقه‌بندی نشده‌اند منجر می‌شود.

توصیف یک پیمانه، باید به گونه‌ای باشد که بتوان بر اساس توصیف آن، آن پیمانه را پیاده‌سازی کرد و نتایج پیاده‌سازی باید به این شکل باشد:

۱- یکسانی پیاده‌سازی TSF فعلی مرتبط با واسطه‌های ارائه شده و مرتبط با پیمانه‌ای که از آن TSF، استفاده کرده است.

۲- یکسانی الگوریتم، نسبت به پیمانه TSF. به عنوان مثال، RFC793 توصیف سطح بالایی از پروتکل TCP ارائه می‌دهد که لزوماً از نظر پیاده‌سازی، مستقل است. تا زمانی که، RFC793، جزئیات زیادی را ارائه می‌دهد

یک شرح طراحی مناسب نیست، زیرا صرفاً، مختص یک پیاده‌سازی نیست. یک پیاده‌سازی واقعی، می‌تواند پروتکل‌های خاص در RFC را اضافه کند، و انتخاب‌های پیاده‌سازی (نظیر استفاده از داده‌های سراسری در مقابل داده‌های محلی، در قسمت‌های مختلف پیاده‌سازی) ممکن است در تحلیلی که انجام می‌شود دارای فشرده‌گی و پیچیدگی تحلیل باشند.

شرح طراحی پیمانه TCP باید فهرست واسط‌های ارائه شده توسط پیاده‌سازی را فراهم کند (به‌جز آن‌هایی که در RFC793 تعریف شده‌اند)، و همچنین شرح الگوریتم پردازش مرتبط با پیمانه‌های پیاده‌سازی TCP را فراهم نماید (با فرض این‌که آن‌ها قسمتی از TSF هستند). در طراحی، پیمانه‌ها، با جزئیات کارکردی که ارائه می‌دهند (هدف)، شرح داده می‌شوند.

با واسط‌هایی که ارائه می‌دهند، مقادیر بازگشتی از آن واسط‌ها، واسط‌هایی (ارائه شده توسط دیگر پیمانه‌ها) که استفاده می‌کنند، و شرح این‌که چطور کارکرد آن‌ها را فراهم می‌کنند. (یک راه ممکن برای شرح کارکرد، شرح الگوریتم است.) شرح داده می‌شوند.

هدف پیمانه باید نشان‌دهنده که پیمانه در حال ارائه چه کارکردی است. و باید برای این‌که خواننده، یک ایده کلی از نحوه کارکرد پیمانه در معماری آن دریافت کند، کافی و رسا باشد.

واسط‌های ارائه شده توسط پیمانه، آن دسته از واسط‌هایی هستند که توسط دیگر پیمانه‌ها برای درخواست کارکردی، مورد استفاده قرار گرفته‌اند. واسط‌ها، هم شامل واسط‌های صریح و آشکار می‌شوند (نظیر فراخوانی درخواست‌شده توسط دیگر پیمانه‌ها) و هم شامل واسط‌های ضمنی و تلویحی می‌شوند (نظیر داده‌های سراسری دست‌کاری شده توسط پیمانه). واسط‌ها از نظر این‌که چطور خواسته می‌شوند و چطور هر مقداری بازگشت داده می‌شود، شرح داده می‌شوند. این شرح، شامل فهرستی از پارامترها، و شرح این پارامترها می‌باشد.

اگر این انتظار وجود دارد که پارامتری، مجموعه‌ای از مقادیر را بگیرد (مثلاً یک پارامتر پرچم)، یک مجموعه کامل از مقادیری که پارامتر می‌تواند بگیرد بر روی پردازش پیمانه مورد نظر اثر خواهند داشت.

همچنین، پارامترهای ارائه دهنده ساختارهای داده به‌گونه‌ای شرح داده می‌شوند که هر فیلد ساختمان داده، تعریف و شرح داده شود. برای داده‌های سراسری باید این شرح داده شود که توسط پیمانه قابل خواندن یا نوشتن یا هر دو هستند.

باید توجه داشته باشیم که زبان‌های برنامه‌نویسی متفاوت، ممکن است " واسط‌های اضافی داشته باشند که آشکار نباشند. یکی از مثال‌ها می‌تواند بار اضافی عملگر/تابع در C++ باشد.

همچنین این "واسط ضمنی" در شرح دسته، به‌عنوان قسمتی از طراحی پیمانه، شرح داده می‌شود. توجه کنید که یک پیمانه، تنها می‌تواند یک واسط را ارائه دهد، این حالت رایج‌تر است تا این‌که یک پیمانه بخواهد مجموعه کوچکی از واسط‌های مرتبط به‌هم را ارائه دهد.

در مقابل آن، واسط‌های به‌کار گرفته شده توسط یک پیمانه باید به‌گونه‌ای تعریف بشوند که بتوان تعیین کرد کدام پیمانه مورد درخواست، شرح داده شده است.

شرح طراحی باید یک دلیل الگوریتمی برای پیمانه‌ای که فراخوانی می‌شود مشخص کند. به‌عنوان مثال، اگر پیمانه A شرح داده شود و از روال حبابی پیمانه B استفاده کند، یک شرح الگوریتمی غیرکافی ممکن این باشد که پیمانه A، واسط double_bubble را در پیمانه B برای اجرای مرتب‌سازی حبابی، درخواست می‌کند.

یک شرح الگوریتمی کافی به این شکل است که "پیمانه A، روال double_bubble() ر همراه با لیست ورودی‌های کنترل دسترسی، درخواست می‌کند، double_bubble()، ابتدا ورودی‌های مرتب‌شده را به نام کاربر، بازگشت می‌دهد، سپس فیلد دسترسی اجازه، مطابق با قوانین..." شرح جزئیات پیمانه در طراحی، باید، جزئیات را به اندازه کافی فراهم کند، آن وقت واضح خواهد بود که چه تأثیراتی را پیمانه A از واسط مرتب‌سازی حبابی انتظار دارد.

توجه داشته باشید که یک روش ارائه این واسط‌های فراخوانی‌شده، از طریق درخت فراخوانی است، و در نتیجه شرحی که به شکل الگوریتمی است می‌تواند شامل شرح الگوریتمی پیمانه فراخوانی شده باشد.

همان‌طور که قبلاً اشاره کردیم، شرح الگوریتمی پیمانه، باید پیاده‌سازی پیمانه را به شکل الگوریتمی، شرح دهد. این عمل می‌تواند در pseudo_code، از طریق فلوچارت‌ها، یا (در طراحی پیمانه‌ای پایه‌ای ADV_TDS.3) متن غیررسمی انجام شود. در مورد این مسأله صحبت می‌کنیم که چطور ورودی‌ها و توابع فراخوانی پیمانه، برای انجام تابع پیمانه به کار گرفته می‌شوند. به این نکته توجه داشته باشیم که تغییرات، نسبت به داده‌های سراسری، وضعیت سیستم، و مقادیر بازگشتی تولید شده توسط پیمانه صورت می‌گیرد. این مسأله، در سطحی از جزئیات است که پیاده‌سازی را بتوان طراحی کرد که برای پیاده‌سازی واقعی TOE، بسیار ساده باشد.

باید توجه داشته باشیم که کد منبع، الزامات مستند پیمانه را نمی‌بیند. اگر چه، طراحی پیمانه، پیاده‌سازی را شرح می‌دهد اما این پیاده‌سازی نیست. توضیح در مورد منبع کد به اندازه کافی مستند است اگر توضیحاتی در مورد مفاد کد منبع کد ارائه دهد. توضیحات درون خطی که صرفاً، توضیح می‌دهند که هر خط کد، چه کاری انجام می‌دهد بی‌فایده هستند زیرا توضیحی در مورد این که پیمانه‌ها چه کاری انجام می‌دهند ارائه نمی‌کنند.

در عناصر زیر، برچسب‌ها (SFR اجرایی، SFR پشتیبان و SFR غیرمداخله‌گر) در زیرسیستم‌ها و پیمانه‌ها، برای شرح اندازه و نوع اطلاعاتی که توسط توسعه‌دهنده ساخته می‌شوند به کار می‌رود. عناصر، ساخت یافته هستند در نتیجه هیچ انتظاری وجود ندارد که توسعه‌دهنده تنها اطلاعات خاص را ارائه دهد.

یعنی، اگر مستند توسعه‌دهنده در مورد TSF، اطلاعات را در الزامات زیر فراهم کند، هیچ انتظاری وجود ندارد که توسعه‌دهنده مستندات آن‌ها، سیستم‌های برچسب و پیمانه‌های SFR اجرایی، SFR پشتیبان و SFR غیرمداخله‌گر را به روز کند. هدف اصلی از این برچسب زنی این است که به توسعه‌دهنده این اجازه را بدهد که با حداقل متدولوژی‌های توسعه رشد یافته (و محصولات مرتبط، نظیر واسط جزئی و مستند طراحی) شواهد لازم را بدون این که هزینه بی‌مورد مصرف شود، فراهم آورد.

الف - ۴ - ۳- راه کارهای سطح بندی

به دلیل وجود ذهنیت در تعیین این که چه چیزی SFR اجرایی است در برابر این که چه چیزی SFR پشتیبان است (و در مواردی، حتی تعیین این که چه چیزی SFR غیرمداخله‌گر است) نمونه‌ای که در پی می‌آید در این خانواده پذیرفته شده است.

در مؤلفه‌های اخیر این خانواده، توسعه‌دهنده، دسته‌بندی زیرسیستم‌ها را درون SFR اجرایی، و ... ایجاد می‌کند و اطلاعات مناسب را تدارک می‌بیند و شواهد اضافی کمی را که برای ارزیاب برای آزمودن این ادعا وجود دارد فراهم می‌کند.

همان‌طور که سطح تضمین مورد نظر، افزایش می‌یابد، تا وقتی که توسعه‌دهنده هنوز تعیین دسته‌بندی را انجام می‌دهد، ارزیاب، شواهد بیشتر و بیشتری که در تأیید دسته‌بندی توسعه‌دهنده به کار برد به دست می‌آورد. به ترتیب تمرکز بر تحلیل ارزیاب از قسمت‌های SFR مرتبط با TOE، به خصوص در سطوح پایین‌تر تضمین، مؤلفه‌های خانواده به گونه‌ای سطح‌بندی می‌شوند که اطلاعات جزئی درون آن‌ها تنها برای معماری موجودیت‌های SFR اجرایی مورد نیاز واقع می‌شوند.

به همان نسبت که سطح تضمین افزایش می‌یابد، اطلاعات بیشتری برای موجودیت‌های SFR پشتیبان و (نهایتاً) موجودیت‌های SFR غیرمداخله‌گر نیاز می‌شوند. باید توجه داشت که حتی وقتی که اطلاعات کامل، مورد نیاز است، نیازی نیست که همه این اطلاعات در سطح یکسانی از جزئیات، تحلیل شوند. تمرکز، باید بر روی مواردی باشد که نیاز به اطلاعات ضروری دارند و باید ببینیم که اطلاعات ضروری برای آن فراهم و تحلیل شده است یا نه.

جدول الف ۵ اطلاعات مورد نیاز مؤلفه‌های هر خانواده را برای معماری موجودیت‌هایی که شرح داده شده‌اند خلاصه می‌کند.

جدول الف ۱_ تشریح سطح بندی جزئیات

	پیمانه TSF			زیر سیستم TSF		
	SFR NI	SFR پشتیبان	SFR اجرایی	SFR NI	SFR پشتیبان	SFR اجرایی
ADV_TDS.1 طراحی پایه‌ای (ارائه غیر رسمی)				نقش پشتیبانی	نقش پشتیبانی	ساختار، خلاصه SFR-Enf.، رفتار، تعاملات
ADV_TDS.2 طراحی معماری (ارائه غیررسمی)				نقش پشتیبانی، تعاملات	ساختار، خلاصه SFR-Enf.، رفتار، خلاصه رفتار دیگر، تعاملات	ساختار، شرح جزئیات SFR-Enf.، رفتار، خلاصه رفتار دیگر، تعاملات
ADV_TDS.3 طراحی پیمانه‌ای پایه (ارائه غیررسمی)	تعاملات، هدف	تعاملات، هدف	هدف، واسطه‌های SFR	شرح، تعاملات	شرح، تعاملات	شرح، تعاملات
ADV_TDS.4 طراحی پیمانه‌ای نیمه رسمی (ارائه نیمه رسمی)	تعاملات، هدف	هدف، واسطه‌های SFR	هدف، واسطه‌های SFR	شرح، تعاملات	شرح، تعاملات	شرح، تعاملات
ADV_TDS.5 طراحی پیمانه‌ای نیمه رسمی	هدف، همه	هدف، همه	هدف، همه	شرح، تعاملات	شرح، تعاملات	شرح، تعاملات

همه واسطها	واسطها	واسطها	تعاملات	تعاملات	کامل (ارائه نیمه رسمی)
هدف، همه واسطها	هدف، همه واسطها	هدف، همه واسطها	شرح، تعاملات	شرح، تعاملات	ADV_TDS.6 طراحی پیمانهای نیمه رسمی کامل همراه با ارائه طراحی سطح بالای رسمی (ارائه نیمه رسمی، ارائه رسمی اضافی)

الف - ۵ موارد تکمیلی در مورد روش‌های رسمی

روش‌های رسمی، نمایش ریاضیاتی TSF و رفتارش را فراهم می‌کنند و مورد نیاز موارد زیر قرار می‌گیرند، ویژگی‌های کارکردی نیمه‌رسمی کامل ADV_FSP.6 همراه با ویژگی‌های رسمی اضافی، مدل خط‌مشیء امنیتی TOE رسمی ADV_SPM.1، و طراحی پیمانهای نیمه‌رسمی کامل ADV_TDS.6 همراه با مؤلفه‌های نمایش طراحی سطح بالای رسمی.

دو جنبه از روش‌های رسمی وجود دارد: زبان ویژگی‌ها که برای بیان رسمی به کار می‌رود، و اثبات‌کننده برهان که به‌صورت ریاضی، کامل بودن و درستی ویژگی‌های رسمی را اثبات می‌کند.

بیان رسمی، درون یک سیستم رسمی که مبتنی بر مفاهیم ریاضیاتی ثابت است بیان می‌شود. این مفاهیم ریاضیاتی برای تعریف قوانین، نحو و معنای مشخص واسط، به کار می‌روند. سیستم رسمی، یک سیستم انتزاعی موجودیت‌ها و ارتباطاتی است که می‌توانند توسط موارد زیر شرح داده شوند: ویژگی الفبای رسمی، زبان رسمی‌ای که آن الفبا بر پایه دستور آن زبان قرار گرفته است، و مجموعه‌ای از قوانین رسمی واسط برای استنتاج ساختن جمله‌ها در زبان رسمی.

ارزیاب باید سیستم‌های رسمی شناخته‌شده را امتحان کند تا از موارد زیر مطمئن شود:

۱- متن توضیحی، معانی تعریف شده اصطلاحات، اختصارات و ترکیباتی را که در متن به کار رفته‌اند به‌جزء آن‌هایی که کاربرد عادی دارند، فراهم می‌کند.

۲- استفاده از سیستم رسمی و نیمه‌رسمی در ارتباط با به‌کارگیری متن توضیحی پشتیبان به صورت رسمی برای معانی مبهم می‌باشد.

۳- سیستم رسمی قادر است قوانین و ویژگی‌های SFPهای کاربردی، کارکرد امنیتی و واسط‌های (فراهم نمودن جزئیات اثرات، پیام‌های خطا و استثناها) TSF، زیرسیستم‌های آن‌ها یا پیمان‌هایی که نشانه‌گذاری را، برای خانواده تضمین به کار می‌گیرند را بیان کند.

۴- نشانه‌گذاری، قوانینی را برای تعیین معنای ساختارهای معتبر نحوی فراهم می‌کند.

• هر سیستم رسمی یک نحو رسمی را به کار می‌گیرد که این نحو، قوانینی را برای شناخت ساختارهای مبهم فراهم می‌کند.

• هر سیستم رسمی قوانین اثباتی را فراهم می‌کند.

۵ - دلیل منطقی مفاهیم ریاضی بنا نهاده شده را پشتیبانی می‌کند.

۶ - از نتیجه‌گیری‌های متناقض جلوگیری می‌کند.

اگر توسعه دهنده، سیستم رسمی را به کار می‌گیرد که توسط مأخذ ارزشیابی پذیرفته شده است ارزیاب می‌تواند بر سطح رسمیت و قدرت سیستم تکیه کند و بر نصب سیستم رسمی با ویژگی‌های TOE و برهان‌های مطابقت تمرکز کند.

سبک رسمی، از اثبات‌های ریاضی ویژگی‌های امنیتی مبتنی بر خواص امنیتی، سازگاری پالایش و مطابقت ارائه‌ها، پشتیبانی می‌نماید. به نظر می‌رسد ابزار رسمی در جاهایی که دستورالعمل راهنما ناکارآمد و دور از فهم است کافی باشد. ابزارهای رسمی، همچنین برای کاهش خطای احتمالی در نتایج راهنما، مناسب هستند. مثال‌های سیستم‌های رسمی:

- زبان ویژگی‌های Z یک بیان‌کننده سطح بالا است، و از روش‌های متفاوتی یا سبک‌های ویژگی‌های رسمی متفاوتی پشتیبانی می‌کند. استفاده از Z برای ویژگی‌های مدل_گرا رایج است، استفاده از الگو برای عملیات‌های خاص رسمی رایج است. برای اطلاعات بیشتر به وبسایت <http://vl.zuser.org/> مراجعه کنید.
- ACL2 یک سیستم رسمی با کد باز است که شامل زبان ویژگی بر مبنای LISP و اثبات‌گر تئوری است. برای اطلاعات بیشتر وبسایت <http://www.cs.utexas.edu/users/moore/acl2/> را ببینید.
- Isabelle یک محیط رایج و عمومی برای اثبات نظریه است که اجازه می‌دهد فرمول‌های ریاضی به زبان رسمی بیان شوند و ابزارهایی را برای اثبات آن‌ها درون یک حساب منطقی فراهم می‌کند. (برای اطلاعات بیشتر به مثال وبسایت <http://www.cl.cam.ac.uk/Research/HVG/Isabelle/> مراجعه نمایید.)
- روش B یک سیستم رسمی مبتنی بر حساب گزاره‌ای است، اولین دستور، با استفاده از قوانین استنتاج و نظریه مجموعه‌ها، محاسبات را پیش‌بینی می‌کند. (برای اطلاعات بیشتر به مثال وبسایت <http://vl.fmnet.info/b/> مراجعه نمایید.)

پیوست ب

(اطلاعاتی)

ترکیب (ACO)

هدف از این پیوست توضیح در مورد مفهوم ارزشیابی‌های ترکیب و معیار ACO می‌باشد. این پیوست معیار ASE را مشخص نمی‌کند؛ می‌توان این تعریف را در بند ۱۰ پیدا کرد.

ب-۱ ضرورت ارزشیابی‌های TOE ترکیبی

بازار فن‌آوری اطلاعات^۱ در مجموع از فروشندگان ارائه نوع خاصی از محصول/فن‌آوری درست شده است. اگر چه مقداری هم‌پوشی^۲ وجود دارد، جایی که فروشنده سخت‌افزار کامپیوتر ممکن است پیشنهاد یک نرم‌افزار کاربردی و یا سامانه عامل را دهد و یا یک تولید کننده تراشه^۳ نیز ممکن است یک سامانه عامل اختصاص داده شده برای مجموعه تراشه‌های^۴ خود آن تولید کند، به‌طور معمول موردی است که :

۱- محلول^۵ فن‌آوری اطلاعات توسط فروشندگان جورواجور پیاده‌سازی می‌شود.

۲- علاوه بر اطمینان از مؤلفه‌های فردی گاهی اوقات نیاز به اطمینان از ترکیب (ترکیب) مؤلفه‌ها، می‌باشد. اگرچه این همکاری بین فروشندگان وجود دارد، در انتشار برخی از مواد مورد نیاز برای ادغام فنی مؤلفه‌ها، موافقت نامه به‌ندرت به این حد از ارائه اطلاعات طراحی دقیق و فرآیند توسعه / مدارک رویه‌ای وسعت می‌دهیم. این نبود اطلاعات جامع از توسعه دهنده مؤلفه‌ای که به مؤلفه دیگری وابسته است بدان معنی که توسعه‌دهنده مؤلفه وابسته دسترسی به نوع اطلاعات لازم که ارزشیابی هر دو مؤلفه وابسته و مؤلفه پایه در EAL2 یا بالاتر را انجام می‌دهد، ندارد.

بنابراین ، در حالی که ارزشیابی مؤلفه وابسته هنوز می‌تواند در هر سطح اطمینان انجام شود، که مؤلفه‌ها با اطمینان در EAL2 یا بالاتر ساخته می‌شوند و لازم است که از مدارک ارزشیابی و نتایج ارزشیابی انجام شده برای توسعه‌دهنده مؤلفه مجدداً استفاده شود.

قصد براین است که معیارهای ACO در وضعیتی که یک موجودیت فن‌آوری اطلاعات به دیگری وابسته است ، برای ارائه خدمات امنیتی قابل اجرا هستند.

موجودیتی که خدماتی ارائه می‌کند اصطلاح "مؤلفه پایه" نامیده می‌شوند و موجودیتی که خدمات دریافت می‌کند "مؤلفه وابسته" نامیده می‌شوند.

این رابطه ممکن است در تعدادی از مفاهیم وجود داشته باشد. به‌عنوان مثال، برنامه کاربردی (مؤلفه وابسته) ممکن است از خدماتی که توسط سامانه عامل (مؤلفه پایه) ارائه شده استفاده کند.

متناوباً، رابطه در دو برنامه کاربردی بهم وصل شده، یا اجرا شده در محیط سیستم عامل مشترک، یا در پایگاه‌های سخت‌افزار مجزا ممکن است به‌صورت نظیر به نظیر^۶ باشد.

1 - IT

2- overlap

3 - chip

4- chipset

5 - solution

6 -peer-to-peer

اگر جفت مافوق^۱ خدماتی به جفت پایین رتبه^۲ ارائه دهد، جفت مافوق، مؤلفه پایه و مؤلفه پایین رتبه، مؤلفه وابسته در نظر گرفته می‌شود.

اگر جفت‌ها به صورت متقابل به یکدیگر خدماتی ارائه کنند، هر جفتی که به عنوان مؤلفه پایه در نظر گرفته می‌شود برای ارائه خدمات است و مؤلفه وابسته برای دریافت خدمات مورد نیاز است.

با این کار نیاز به تکرار مؤلفه‌های ACO است که تمامی الزامات برای هر نوع جفت مؤلفه به کار گرفته می‌شود. معیار نیز در نظر دارد که به صورت گسترده‌تری قابل اجرا باشد، گام به گام (جایی که در آن TOE ترکیبی متشکل از مؤلفه وابسته و مؤلفه پایه است که خود مؤلفه پایه TOE ترکیبی دیگر می‌شود)، در روابط پیچیده‌تر، اما این ممکن است نیاز به شرح بیشتری داشته باشد.

هنوز برای ارزشیابی TOE ترکیبی نیاز است که مؤلفه‌های فردی به طور مستقل ارزشیابی شوند، همانطور که ارزشیابی‌های ترکیبی توسعه یافته از نتایج ارزشیابی‌های مؤلفه فردی مورد نیاز است. هنگامی که ارزشیابی TOE ترکیبی شروع می‌شود، ممکن است که ارزشیابی مؤلفه وابسته هنوز در حال پیش‌روی باشد.

با این حال، ارزشیابی مؤلفه وابسته باید قبل از کل ارزشیابی TOE تشکیل شده کامل شود. ممکن است فعالیت‌های ارزشیابی ترکیبی رخ دهد در آن واحد که ارزشیابی مؤلفه وابسته رخ می‌دهد. محرک^۳ اقتصادی / کسب و کار - توسعه دهنده مؤلفه وابسته یا ضامن فعالیت‌های ارزیابی ترکیبی خواهد بود یا حمایت از این فعالیت‌ها خواهد کرد مانند تحویل ارزیابی از ارزیابی مؤلفه وابسته که برای فعالیت‌های ارزیابی ترکیبی مورد نیاز است.

محرک‌های فنی - مؤلفه‌هایی را در نظر می‌گیرند که آیا اطمینان لازم توسط مؤلفه پایه ارائه شده است (به عنوان مثال بعد از تکمیل ارزشیابی مؤلفه تغییراتی را در مؤلفه پایه در نظر بگیریم) با درک این که مؤلفه وابسته اخیراً دست‌خوش (تحت) ارزشیابی مؤلفه است و همه تحویل ارزشیابی همراه با ارزشیابی موجود می‌باشند. بنابراین، هیچ فعالیتی در حین ترکیب وجود ندارد که مستلزم تأیید مجدد فعالیت‌های ارزشیابی مؤلفه وابسته باشد. همچنین قالب‌های مؤلفه پایه (یکی از) تنظیمات آزمون برای تست مؤلفه وابسته در حین ارزشیابی مؤلفه وابسته تأیید شود، و اجازه دهد که ACO_CTT مؤلفه پایه در این تنظیمات در نظر گرفته شود. مدارک ارزشیابی از ارزشیابی مؤلفه وابسته، ورودی مورد نیاز به فعالیت‌های ارزیابی TOE ترکیبی است. تنها ارزشیابی مواد از ارزشیابی مؤلفه پایه که مورد نیاز است به عنوان ورودی فعالیت‌های ارزشیابی TOE ترکیبی است:

آسیب‌پذیری‌های مانده در مؤلفه پایه، چنان که در حین ارزشیابی مؤلفه پایه گزارش می‌شود.

این برای فعالیت‌های ACO_VUL لازم است.

هیچ شواهد ارزشیابی دیگری از فعالیت‌های مؤلفه پایه برای ارزشیابی TOE ترکیبی لازم نیست، چنان که که نتایج ارزشیابی از ارزشیابی مؤلفه‌ای از مؤلفه پایه بهتر است مجدداً استفاده شود.

1- dominant

2 -minor

3- Driver

ممکن است اطلاعات اضافی در مورد مؤلفه پایه لازم باشد اگر TOE ترکیبی TSF شامل مؤلفه پایه بیشتر از آن چه در طول ارزشیابی مؤلفه‌ای از مؤلفه پایه در نظر گرفته شد.

ارزشیابی مؤلفه‌ای از مؤلفه پایه و مؤلفه‌های وابسته را به‌عهده گرفت تا زمان تصمیم نهایی برای مؤلفه‌های ACO اختصاص داده شده، کامل شود.

مؤلفه‌های ACO_VUL تنها مقاومت در برابر حمله کننده با حمله احتمالی تا پیشرفته - اساسی را در نظر می‌گیرند.

این به‌علت سطح اطلاعات طراحی است که می‌تواند برقرار کند که چگونه مؤلفه پایه بر روی مؤلفه وابسته‌ای که به آن تکیه دارد از طریق استفاده از فعالیت های ACO_DEV خدماتی ارائه کند.

بنابراین، اعتماد ناشی از ارزشیابی TOE ترکیبی با استفاده از CAP محدود به یک سطح مشابه به دست آمده از ارزشیابی‌های مؤلفه TOE EAL4 است.

اگرچه اطمینان در مؤلفه‌ها که TOE ترکیبی را در بر می‌گیرد که ممکن است بالاتر از EAL4 باشد.

ب- ۲ انجام ارزشیابی امنیت برای TOE ترکیبی

ST توسط توسعه‌دهنده برای ارزشیابی TOE ترکیبی (مؤلفه پایه + مؤلفه وابسته) ارائه خواهد شد.

این ST بسته اطمینان به‌کار گرفته شده برای TOE ترکیبی را شناسایی می‌کند، با استناد بر اطمینان به دست آمده از ارزشیابی مؤلفه، در موجودیت ترکیبی تضمین می‌کند.

هدف از در نظر گرفتن ترکیب مؤلفه‌ها مطابق با ST تأیید مناسب بودن مؤلفه‌ها از نقطه نظر محیط زیست و الزامات می‌باشد، و همچنین تعیین کردن این که TOE ST ترکیبی با ST‌های مؤلفه و خط‌مشی‌های امنیتی بیان شده آنها، سازگار است.

این شامل تعیین کردن این که ST‌های مؤلفه و خط‌مشی‌های امنیتی بیان شده سازگار است.

ST TOE ترکیبی ممکن است به محتوای ST‌های مؤلفه مراجعه کند، و یا نویسنده ST ممکن است تصمیم به تکرار مادی ST‌های مؤلفه در طول ST TOE ترکیبی که منطقی را برقرار کند که چگونه ST‌های مؤلفه در ST TOE ترکیبی نشان داده شوند. در طول اجرای فعالیت‌های ارزشیابی ASE_CCL برای ST TOE ترکیبی، ارزیاب تعیین می‌کند که ST‌های مؤلفه با دقت در ST TOE نشان داده شوند.

این از طریق تعیین کردن ST TOE ترکیبی قابل شرح که با مؤلفه ST TOE‌ها مطابقت دارد به‌دست می‌آید.

همچنین، ارزیاب لازم است تعیین کند که الزامات مؤلفه وابسته در محیط عملیاتی به اندازه کافی در TOE ترکیبی برآورده می‌شود.

شرح TOE ترکیبی راه‌حل ترکیبی را توصیف خواهد کرد.

محدوده منطقی و فیزیکی و رمز راه‌حل ترکیبی شرح داده خواهد شد، و رمز منطقی بین مؤلفه‌ها را نیز شناسایی می‌شود.

توضیحات، قابلیت‌های امنیتی که توسط هر یک از مؤلفه‌ها ارائه شده باشد را شناسایی می‌کند.

بیانیه‌ای از SFR‌ها برای TOE ترکیبی شناسایی می‌کند که کدام مؤلفه SFR را برآورده می‌کند.

اگر SFR با هر دو مؤلفه مواجه شود، سپس بیانیه‌ای شناسایی خواهد کرد که کدام مؤلفه جنبه‌های مختلف FR را برآورده می‌کند.

به‌همین ترتیب مشخصات خلاصه TOE ترکیبی شناسایی می‌کند که کدام مؤلفه قابلیت‌های امنیتی توصیف شده را فراهم می‌کند.

بسته آسه : امنیت مورد نیاز مقصد ارزشیابی شود تا پا متشکل خیابان باید با بسته آسه سازگار باشد :

الزامات ارزشیابی هدف امنیتی در ارزشیابی مؤلفه‌ها مورد استفاده قرار می‌گیرد.

استفاده مجدد از نتایج ارزشیابی ST‌های مؤلفه می‌تواند در نمونه‌های ساخته شود که TOE ST ترکیبی مستقیماً به ST‌های مؤلفه اشاره دارد.

مثال: اگر TOE ST ترکیبی به ST مؤلفه برای قسمتی از بیانیه خود SFR اشاره کند، ارزیاب می‌تواند درک کند که الزامات تمام واگذاری‌ها و عملیات انتخاب (مانند بیان شده در 3C. ASE_REQ.* ارزشیابی‌های مؤلفه) را برآورده کند .

ب- ۳ تعامل بین سازمان های فناوری اطلاعات ترکیبی

TSF مؤلفه پایه اغلب بدون دانش‌های وابسته به این برنامه‌ها تعریف می‌شود ممکن است از تعریف را با آن تشکیل شده است که ممکن است، تعریف TSF مؤلفه پایه، شامل تمام قسمت‌های مؤلفه پایه که برای اجرای SFR‌های مؤلفه پایه باید به آن استناد کرد.

و این تمام شامل نقاط قسمت‌های مؤلفه پایه مورد نیاز برای پیاده‌سازی SFR‌های مؤلفه پایه می‌باشد.

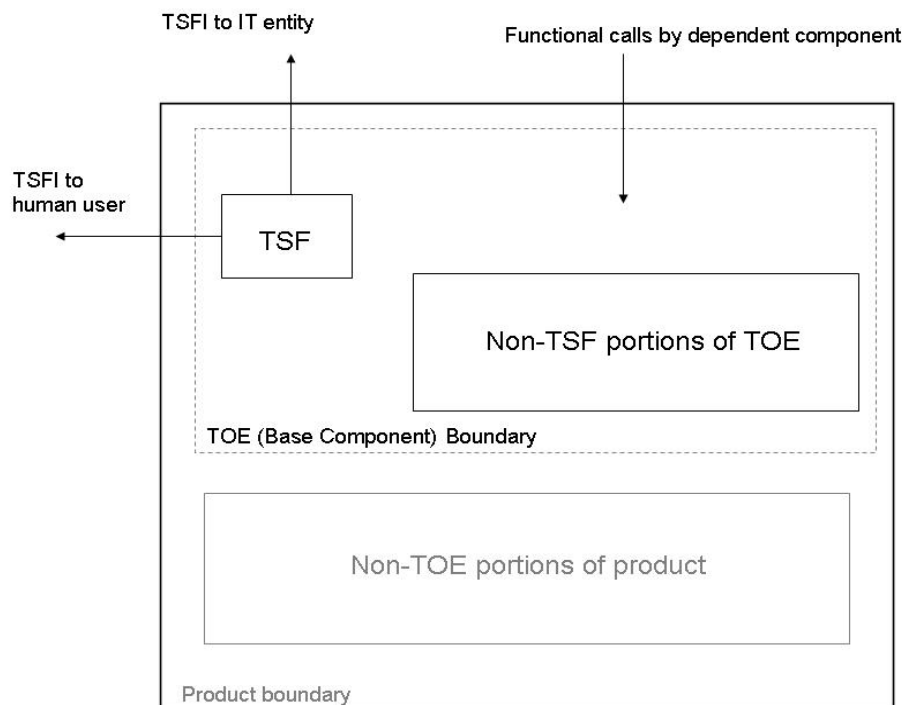
TSFI‌های مؤلفه پایه واسطه‌هایی را نشان می‌دهد که توسط TSF موجودیت‌های بیرونی مشخص شده در بیانیه‌ای از SFR که سرویسی از TSF را احضار می‌کند، ارائه شده است.

این شامل واسطه‌هایی به کاربر انسانی و همچنین واسطه‌های موجودیت‌های فناوری اطلاعات بیرونی می‌باشد. با این حال، TSFI تنها شامل آن واسطه‌های TSF است، و بنابراین لزوماً مشخصات واسطه جامع از همه واسطه‌های ممکن موجود بین موجودیت بیرونی و مؤلفه پایه نیست.

مؤلفه پایه ممکن است واسطه‌ها به خدماتی که مربوط امنیتی در نظر گرفته نمی‌شود، را نشان دهد یا به دلیل هدف ذاتی از این سرویس (به‌عنوان مثال نوع تنظیم قلم) و یا به دلیل ایزو ۱۵۴۰۸ مرتبط در ST مؤلفه پایه SFR‌ها ادعا می‌کند (به‌عنوان مثال، واسطه ورود به سامانه زمانی که هیچ ایزو ۱۵۴۰۸-۲ FIA نباشد: شناسایی و تأیید SFR‌ها خواسته می‌شود). واسطه‌های وظیفه‌مندی ارائه شده توسط مؤلفه پایه، علاوه بر واسطه‌های امنیتی (TSFIs) هستند، و نیازی نیست در طی ارزشیابی مؤلفه پایه در نظر گرفته شوند.

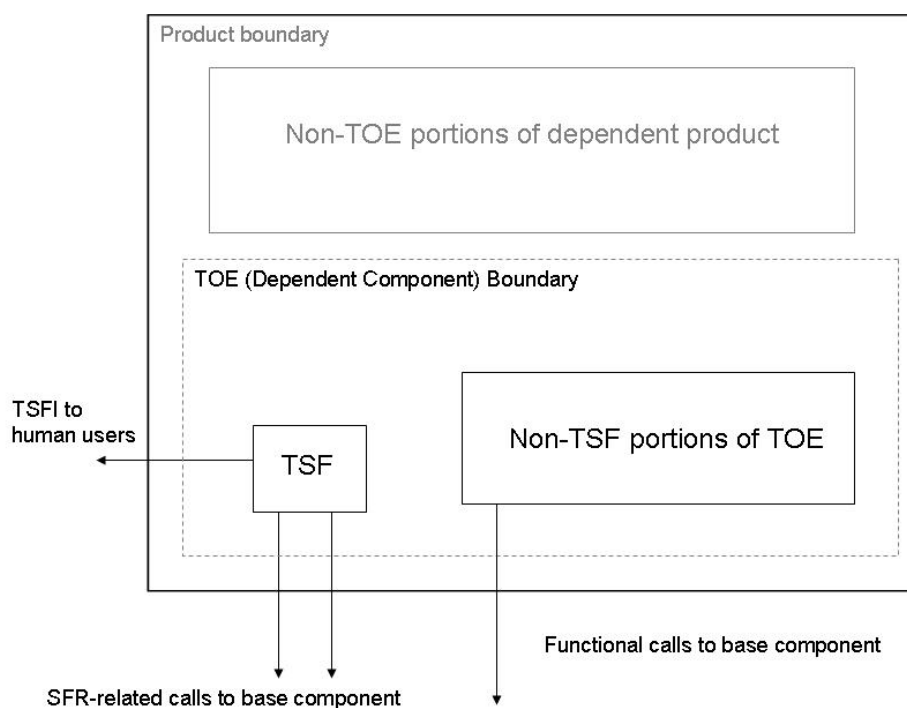
این اغلب شامل واسطه‌هایی است که توسط مؤلفه وابسته برای احضار خدمات که توسط مؤلفه پایه ارائه شده، استفاده می‌شود.

مؤلفه پایه ممکن است شامل برخی از واسطه‌های غیرمستقیم که از طریق آن ممکن است TSFI نامیده شود، به‌عنوان مثال عبارتند از API‌ها است که می‌تواند برای احضار یک سرویس از TSF، که در طول ارزشیابی مؤلفه پایه در نظر گرفته نشده است، مورد استفاده قرار گیرد.



شکل ب-۱- انتزاع مؤلفه پایه

مؤلفه وابسته، که متکی به مؤلفه پایه است، به طور مشابه تعریف می‌شود: واسطه‌های به موجودیت‌های بیرونی تعریف شده در SFRهای مؤلفه ST طبقه‌بندی شده است مانند TSFI و در ADV_FSP بررسی خواهد شد. هرگونه اعلام خطر از TSF وابسته به محیط زیست در حمایت از SFR نشان داده خواهد شد که TSF وابسته نیاز به برخی خدمات از محیط زیست برای اجرای SFRهای مؤلفه وابسته دارد. چنین سرویسی که خارج از مرز مؤلفه وابسته و مؤلفه پایه است بعید است که در ST وابسته به عنوان یک موجودیت بیرونی تعریف شود. از این رو، خواهان خدمات انجام شده توسط TSF وابسته به پایگاه عهده‌دار آن (مؤلفه پایه) مورد تجزیه و تحلیل به عنوان قسمتی از فعالیتهای خصوصیات کارکردی (ADV_FSP) نخواهد شد. وابستگی‌های مؤلفه پایه در مؤلفه وابسته ST با عنوان اهداف امنیت برای محیط زیست بیان می‌شوند. این انتزاع از مؤلفه وابسته و واسطه‌ها در شکل ب-۲ نشان داده شده است.



شکل ب- ۲ انتزاع مؤلفه وابسته

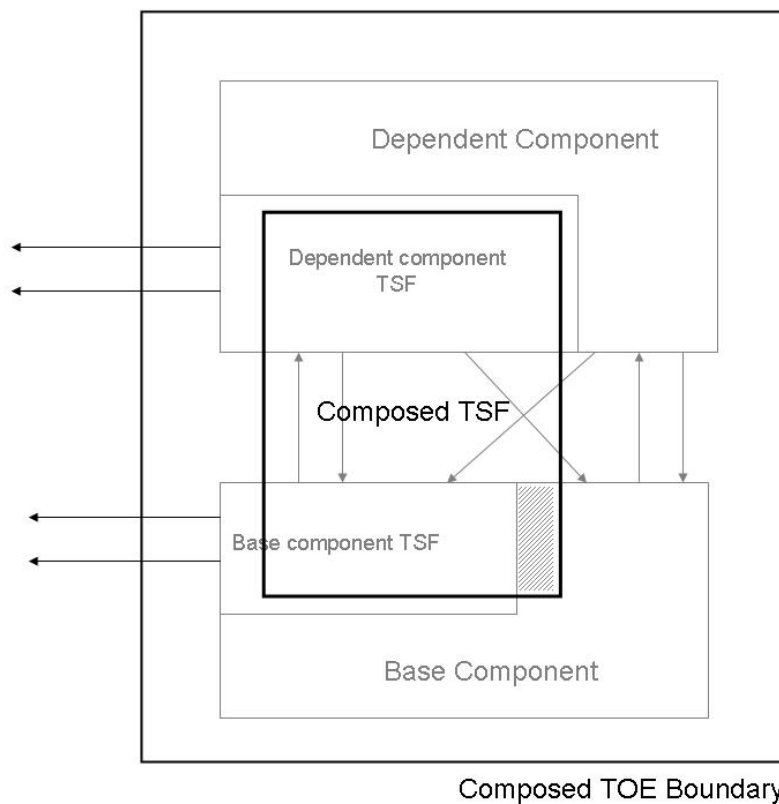
وقتی که ترکیب مؤلفه پایه و مؤلفه وابسته را در نظر می‌گیریم، اگر TSF مؤلفه وابسته نیاز به خدمات از مؤلفه پایه برای حمایت از اجرای SFR دارد، واسطه خدماتی باید تعریف شود.

اگر این خدمات از طریق TSF مؤلفه پایه ارائه شده است، و سپس آن واسطه توصیه می‌شود TSFI از مؤلفه پایه باشد و طبق مشخصات کارکردی مؤلفه پایه از قبل تعریف شده باشد. اگر با این حال، خدمات توسط TSF مؤلفه وابسته فراخوانده شود که توسط TSF مؤلفه پایه ارائه نشده است (به عنوان مثال پیاده‌سازی در غیر قسمت TSF مؤلفه پایه یا احتمالاً حتی در غیر قسمت TOE مؤلفه پایه) در شکل ب- ۳، نشان دهنده داده نشده است)، بعید است که TSFI مؤلفه پایه مربوط به خدمات وجود داشته باشد، مگر آن که خدمات توسط TSF مؤلفه پایه با واسطه است.

واسطه‌های خدمات از مؤلفه وابسته به محیط کارکردی در خانواده‌ای متکی به مؤلفه وابسته (ACO_REL) در نظر گرفته می‌شود.

غیر از قسمت TSF مؤلفه پایه به سوی TOE TSF ترکیبی به دلیل به وابستگی‌هایی که مؤلفه وابسته به مؤلفه پایه برای حمایت از SFRهای مؤلفه وابسته دارد، نزدیک می‌شود.

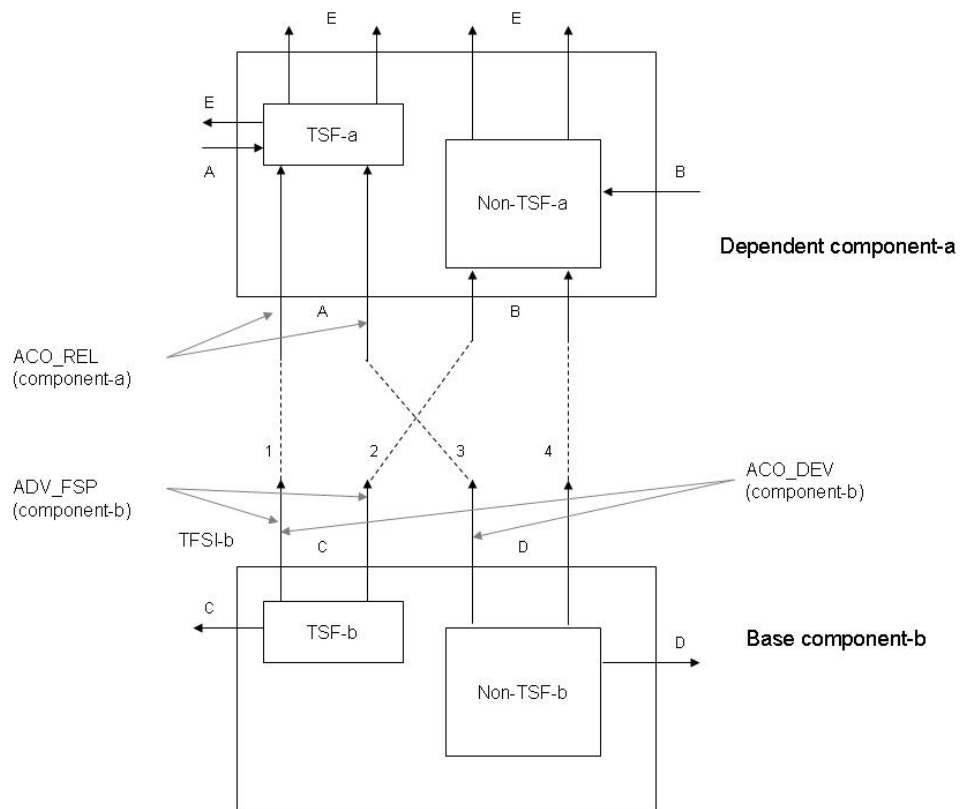
بنابراین، در چنین مواردی، TSF از TOE ترکیبی بزرگتر از مجموع TSFهای مؤلفه است.



شکل ب-۳-انتزاع هدف امنیتی ترکیب شده

ممکن است موردی باشد که مؤلفه پایه TSFI فراخوانده شود به یک طریقی که ارزشیابی مؤلفه پایه پیش‌بینی نشده است.

از این‌رو الزاماتی برای آزمون‌های بیشتری درمورد مؤلفه پایه TSFI خواهد بود. واسطه‌های احتمالی در نمودار زیر (شکل ب ۴) و متن شرح داده شده است.



شکل ب-۴- واسط مؤلفه ترکیب شده

الف- پیکان‌ها به سمت "مؤلفه وابسته - الف (الف و ب) می‌روند = جایی که مؤلفه انتظار دارد که محیط زیست به درخواست سرویس پاسخ دهد.

پیکان‌ها از "مؤلفه پایه - ب" (پ و ت) بیرون می‌آیند = واسط‌های خدماتی که به محیط زیست توسط مؤلفه پایه ارائه شده است.

پ) خط‌های منقطع بین مؤلفه‌ها = نوعی از ارتباطات بین جفت واسطه‌ها

پیکان دیگر (خاکستری) = واسط‌هایی که توسط معیار معین شرح داده می‌شود.

شرح ذیل مختصرسازی است، فقط ملاحظات که باید در نظر گرفته شود توضیح می‌دهد.

مؤلفه‌های الف ('مؤلفه وابسته- الف') و ب ('مؤلفه پایه - ب') وجود دارند: پیکان‌های بیرون آمده از TSF - الف خدمات ارائه شده توسط TSF - الف هستند و بنابراین TSFI‌های (الف) ؛

به‌همین ترتیب، پیکان‌های بیرون آمده از TSF - ب ('پ') TSFI‌ها هستند (ب).

این‌ها هر یک در مشخصات عملکرد مربوطه خود با جزئیات شرح داده شده است. مؤلفه - الف به گونه‌ای است که نیاز به خدمات از محیط زیست دارد:

افراد مورد نیاز توسط TSF (الف) هستند دارای برچسب ""؛ دیگر (و مرتبط به TSF -) خدمات دارای برچسب "ب".

زمانی که مؤلفه-الف و مؤلفه-ب ترکیب می‌شوند، امکان چهار ترکیب از (خدمات مورد نیاز توسط مؤلفه-الف) و (خدمات ارائه شده توسط مؤلفه-ب) وجود دارد که با خطوط منقطع نشان داده شده است (انواع ارتباطات بین جفت واسطه‌ها).

هر مجموعه از این ممکن است برای ترکیب خاص وجود داشته باشد:

الف - TSF - الف به خدماتی نیاز دارد که توسط TSF - ب فراهم می‌شود ("الف" به "ج متصل است") : این درست و سراسر است :

جزئیات بیشتر در مورد "ج" در FSP برای مؤلفه-ب هستند در این مورد بهتر است تمامی واسطه‌ها برای مؤلفه-ب در مشخصات کارکردی مشخص شود.

ب) به جز نیازهای TSF - الف آن خدماتی که توسط TSF - ب ارائه می‌شوند ("ب" متصل به "پ" است) : این سراسر است (دوباره، جزئیات در مورد "پ" در FSP برای مؤلفه-ب هستند)، اما بی‌اهمیت : راه و روش امنیتی.

به جز نیازهای TSF - الف آن خدماتی که توسط غیر از TSF - ب ارائه می‌شود ("ب" متصل به "ت" است. در حال حاضر هیچ جزئیاتی در مورد ت نداریم، لیکن هیچ مفهوم امنیتی در مورد استفاده از این واسطه‌ها وجود ندارد ، بنابراین نیازی نیست که آنها در این ارزشیابی در نظر گرفته شوند، اگر چه آنها به احتمال زیاد برای توسعه‌دهنده یک مسئله ادغام شده هستند.

ت) نیازهای TSF - الف این خدماتی که توسط غیر - TSF - ب ارائه می‌شوند ("الف" به "ت" متصل است): این زمانی رخ می‌دهد که مؤلفه - الف و مؤلفه - ب حواس مختلف دارند از آنچه "خدمات امنیتی" است. شاید مؤلفه-ب هیچ ادعایی در مورد I&A ندارد (FIA SFRها ندارد در ST آن)، اما قانوناً نیازهای مؤلفه-الف توسط محیط زیست ارائه شده است.

هیچ جزئیاتی در مورد واسطه‌های "ت" موجود وجود ندارد (آنها TSFI نیستند (ب) ، به طوری که آنها در FSP مؤلفه-ب نیست) .

توجه : اگر نوعی از تعامل شرح داده شده در وضعیت ت فوق به وجود بیاید، آنگاه TSF از TOE ترکیبی TSF - الف + TSF - ب + غیر TSF - ب خواهد بود.

در غیر این صورت، TOE TSF ترکیبی خواهد بود TSF - الف + TSF - ب.

انواع واسطه‌های ۲ و ۴ از شکل ب-۴ شکل به طور مستقیم مربوط به ارزشیابی TOE ترکیبی نمی‌شوند.

واسطه‌های ۱ و ۳ را در طول برنامه کاربردی خانواده‌های مختلف در نظر گرفته خواهد شود :

مشخصات کارکردی (ADV_FSP) (برای مؤلفه-ب) واسطه‌های پ را شرح می‌دهد.

ب) با تکیه بر مؤلفه وابسته (ACO_REL) واسطه‌های الف را توصیف می‌کند.

ج) مدارک توسعه (ACO_DEV) واسطه‌های پ برای اتصال نوع ۱ و واسطه‌های ت برای اتصال نوع ۳ را شرح می‌دهد.

نمونه نوعی که در آن ترکیب ممکن است به کار گرفته شود یک سامانه مدیریت پایگاه داده (¹DBMS) است که اصول سامانه عامل (سامانه عامل) به آن استناد می‌کند.

در طی ارزشیابی مؤلفه DBMS، ارزشیابی از خواص امنیتی DBMS (به هر درجه‌ای از دقت زیاد توسط مؤلفه‌های تضمین مورد استفاده در ارزشیابی املاء شده است) خواهد شد:

¹ - database management system

مرز TSF آن شناسایی خواهد شد، مشخصات کارکردی آن برای تعیین این که آیا آن واسطها به خدمات امنیتی ارائه شده توسط TSF توصیف می شود، ارزشیابی می شود، شاید اطلاعات بیشتری در مورد TSF (طراحی آن، معماری، ساختار داخلی) ارائه خواهد شد، TSF آزمایش خواهد شد، جنبه های چرخه حیات آن و اسناد راهنما ارزشیابی خواهد شد، و غیره.

با این حال، برای ارزشیابی DBMS هر مدرک مربوط به وابستگی DBMS بر روی سامانه عامل، خواسته نمی شود.

DBMS ST محتمل ترین فرضیه ها را در مورد سامانه عامل در فرضیات بند فرعی بیان خواهد کرد و اهداف امنیتی برای سامانه عامل در بند فرعی محیط زیست را بیان می کند.

DBMS ST حتی ممکن است آن اهداف را برای محیط زیست بر حسب SFR های سامانه عامل نمونه سازی کند. با این حال، خصوصیتی برای سامانه عامل وجود ندارد که جزئیات خصوصیات کارکردی، شرح معماری، و یا سایر مدارک ADV را برای DBMS منعکس کند.

با اتکاء به مؤلفه وابسته (ACO_REL) نیاز را برآورده خواهد کرد.

با اتکاء به مؤلفه وابسته (ACO_REL) واسطهای وابسته TOE که مؤلفه پایه را برای ارائه خدمات فرا می خواند. اینها واسطهایی هستند که مؤلفه پایه پاسخ می دهد.

شرح واسطه از نظر مؤلفه وابسته تأمین می شود.

مدرک توسعه (ACO_DEV) واسطهای ارائه شده توسط مؤلفه پایه را شرح می دهد، که به درخواستهای خدمات مؤلفه وابسته پاسخ می دهد.

این واسطها به واسطهای مؤلفه وابسته مربوطه مسپرد می شوند که با استناد به اطلاعات شناسایی می شوند. تمامیت این مسپرد می، چه مؤلفه مبنای واسطها شرح داده شده همه واسطهای مؤلفه وابسته، در اینجا تأیید نمی شود، فقط در منطق ترکیب (ACO_COR) نشان می دهند).

در سطوح بالاتر ACO_DEV سیستم فرعی واسطهای توصیف شده را ارائه می کند.

واسطهای مورد نیاز توسط مؤلفه وابسته که برای مؤلفه مبنا شرح داده نشده است در توضیحی برای منطق ترکیب (ACO_COR) گزارش شده است.

این توضیح همچنین گزارش می کند که چه واسطهایی از مؤلفه پایه که به مؤلفه وابسته استناد می کند در مدت ارزشیابی مؤلفه پایه در نظر گرفته شده است.

واسطهایی که در ارزشیابی مؤلفه پایه در نظر گرفته نشده بودند، منطقی از تأثیر استفاده از واسط بر روی مؤلفه پایه TSF ارائه می کند.

پیوست پ

(اطلاعاتی)

منابع متقاطع از وابستگی‌های مولفه تضمین

وابستگی‌هایی که در مولفه‌های بندهای ۹ و ۱۰-۱۶ مستند شده‌اند، وابستگی‌های مستقیم بین مولفه‌های تضمین هستند.

جدول‌های وابستگی زیر برای مولفه‌های تضمین، وابستگی‌های مستقیم، غیرمستقیم و انتخابی‌شان را نشان می‌دهند. هر مولفه که یک وابستگی از چند مولفه تضمین می‌باشد در یک ستون قرار گرفته است. هر مولفه تضمین در یک سطر قرار گرفته است. مقدار در هر سلول جدول نشان می‌دهد که آیا مولفه برچسب ستون به واسطه مولفه برچسب سطر، به طور مستقیم مورد نیاز است (مشخص شده به وسیله "×") یا به طور غیر مستقیم (مشخص شده به وسیله "-"). اگر هیچ کاراکتری نشان داده نشود، مولفه به مولفه دیگر وابستگی ندارد.

ALC_CMS.1	ALC_CMC.1	ACO_REL.2	ACO_REL.1	ACO_DEV.3	ACO_DEV.2	ACO_DEV.1	
-	X		X			X	ACO_COR.1
			X			X	ACO_CTT.1
		X	-		X		ACO_CTT.2
			X				ACO_DEV.1
			X				ACO_DEV.2
		X					ACO_DEV.3
							ACO_REL.1
							ACO_REL.2
			-			X	ACO_VUL.1
			-		X		ACO_VUL.2
		-		X			ACO_VUL.3

جدول پ-۱ جدول وابستگی برای رده ACO: تجزیه

[illegible]

جدول پ-۲ جدول وابستگی برای کلاس ADV: توسعه

ADV_FSP.1	
AGD_OPE.1	X
AGD_PRE.1	

جدول پ-۳ جدول وابستگی برای کلاس AGD: مستندات راهنما

	ALC_TAT.1	ALC_LCD.1	ALC_DVS.2	ALC_DVS.1	ALC_CMS.1	ADV_TDS.3	ADV_TDS.1	ADV_IMP.1	ADV_FSP.4	ADV_FSP.2	
ALC_CMC.1					X						
ALC_CMC.2					X						
ALC_CMC.3		X		X	X						
ALC_CMC.4		X		X	X						
ALC_CMC.5		X	X		X						
ALC_CMS.1											
ALC_CMS.2											
ALC_CMS.3											
ALC_CMS.4											
ALC_CMS.5											
ALC_DEL.1											
ALC_DVS.1											
ALC_DVS.2											
ALC_FLR.1											
ALC_FLR.2											
ALC_FLR.3											
ALC_LCD.1											
ALC_LCD.2											
ALC_TAT.1	-					-	-	X	-	-	

ALC_TAT.2	-	-	X	-	-					-
ALC_TAT.3	-	-	X	-	-					-

جدول پ-۴ جدول وابستگی برای رده ALC: پایه چرخه حیات

	APE_ECD.1	APE_INT.1			
APE_CCL.1	X	X			X
APE_ECD.1					
APE_INT.1					
APE_OBJ.1					
APE_OBJ.2					X
APE_REQ.1	X				
APE_REQ.2	X		X		
APE_SPD.1					

جدول پ-۵ جدول وابستگی برای کلاس APE: ارزیابی پروفایل محافظتی

	ADV_ARC.1	ADV_FSP.1	ADV_FSP.2	ADV_TDS.1	ASE_ECD.1	ASE_INT.1	ASE_OBJ.2	ASE_REQ.1	ASE_SPD.1
ASE_CCL.1					X	X		X	
ASE_ECD.1									
ASE_INT.1									
ASE_OBJ.1									
ASE_OBJ.2									X
ASE_REQ.1					X				
ASE_REQ.2					X		X		-
ASE_SPD.1									
ASE_TSS.1		X			-	X		X	
ASE_TSS.2	X	-	-	-	-	X		X	

جدول پ-۶ جدول وابستگی برای کلاس ASE: ارزیابی هدف امنیتی

ALC_TAT.1										
AGD_PRE.1	X	X								
AGD_OPE.1	X	X	X	X	X	X	X	X	X	
ADV_TDS.3			X	X	X	X	X	X	X	
ADV_TDS.1		X	-	-	-	-	-	-	-	
ADV_IMP.1			X	X	X	X	X	X	X	
ADV_FSP.4			-	-	-	-	-	-	-	
ADV_FSP.2		-	X	X	X	X	X	X	X	
ADV_FSP.1	X	X	-	-	-	-	-	-	-	
ADV_ARC.1		X	X	X	X	X	X	X	X	
	AVA_VAN.1									
	AVA_VAN.2	X								
	AVA_VAN.3	X								
	AVA_VAN.4	X								
	AVA_VAN.5	X								

جدول پ-۸ جدول وابستگی برای کلاس AVA: ارزیابی آسیب پذیری

پیوست ت

(اطلاعاتی)

منبع متقاطع از ppها و مولفه‌های تضمین

جدول ت-۱ ارتباط بین ppها و خانواده‌ها و مولفه‌ها از رده APE را تشریح می‌کند.

Assurance class	Assurance family	Assurance component	
		Low Assurance PP	PP
Protection Profile evaluation	APE_CCL	1	1
	APE_ECD	1	1
	APE_INT	1	1
	APE_OBJ	1	2
	APE_REQ	1	2
	APE_SPD		1

جدول ت-۱ خلاصه سطح تضمین pp

پیوست ث

(اطلاعاتی)

منبع متقاطع از مولفه‌های تضمین و EALها

جدول ث-۱ ارتباط بین سطوح تضمین ارزیابی و رده‌های تضمین، خانواده‌ها و مولفه‌ها را تشریح می‌کند.

Assurance class	Assurance Family	Assurance Components by Evaluation Assurance Level						
		EAL1	EAL2	EAL3	EAL4	EAL5	EAL6	EAL7
Development	ADV_ARC		1	1	1	1	1	1
	ADV_FSP	1	2	3	4	5	5	6
	ADV_IMP				1	1	2	2
	ADV_INT					2	3	3
	ADV_SPM						1	1
	ADV_TDS		1	2	3	4	5	6
Guidance documents	AGD_OPE	1	1	1	1	1	1	1
	AGD_PRE	1	1	1	1	1	1	1
Life-cycle support	ALC_CMC	1	2	3	4	4	5	5
	ALC_CMS	1	2	3	4	5	5	5
	ALC_DEL		1	1	1	1	1	1
	ALC_DVS			1	1	1	2	2
	ALC_FLR							
	ALC_LCD			1	1	1	1	2
	ALC_TAT				1	2	3	3
Security Target evaluation	ASE_CCL	1	1	1	1	1	1	1
	ASE_ECD	1	1	1	1	1	1	1
	ASE_INT	1	1	1	1	1	1	1
	ASE_OBJ	1	2	2	2	2	2	2
	ASE_REQ	1	2	2	2	2	2	2
	ASE_SPD		1	1	1	1	1	1
	ASE_TSS	1	1	1	1	1	1	1
Tests	ATE_COV		1	2	2	2	3	3
	ATE_DPT			1	2	3	3	4
	ATE_FUN		1	1	1	1	2	2
	ATE_IND	1	2	2	2	2	2	3
Vulnerability assessment	AVA_VAN	1	2	2	3	4	5	5

جدول ث-۱ خلاصه سطح تضمین ارزیابی

پیوست ج

(اطلاعاتی)

منبع متقاطع از CAPها و مولفه‌های تضمین

جدول ج-۱ ارتباط بین سطوح تضمین ترکیب و رده‌ها، خانواده‌ها و مولفه‌ها را نشان می‌دهد.

Assurance class	Assurance Family	Assurance Components by Composition Assurance Package		
		CAP-A	CAP-B	CAP-C
Composition	ACO_COR	1	1	1
	ACO_CTT	1	2	2
	ACO_DEV	1	2	3
	ACO_REL	1	1	2
	ACO_VUL	1	2	3
Guidance documents	AGD_OPE	1	1	1
	AGD_PRE	1	1	1
Life-cycle support	ALC_CMC	1	1	1
	ALC_CMS	2	2	2
	ALC_DEL			
	ALC_DVS			
	ALC_FLR			
	ALC_LCD			
	ALC_TAT			
Security Target evaluation	ASE_CCL	1	1	1
	ASE_ECD	1	1	1
	ASE_INT	1	1	1
	ASE_OBJ	1	2	2
	ASE_REQ	1	2	2
	ASE_SPD		1	1
	ASE_TSS	1	1	1

جدول ج-۱ خلاصه سطح تضمین ترکیب